

Kuan-Ching Li · Xiaofeng Chen
Willy Susilo *Editors*

Advances in Cyber Security: Principles, Techniques, and Applications



Springer

Advances in Cyber Security: Principles, Techniques, and Applications

Kuan-Ching Li · Xiaofeng Chen
Willy Susilo
Editors

Advances in Cyber Security: Principles, Techniques, and Applications

Editors

Kuan-Ching Li 

Department of Computer Science and
Information Engineering
Providence University
Taichung, Taiwan

Willy Susilo 

School of Computing and Information
Technology
University of Wollongong
Wollongong, NSW, Australia

Xiaofeng Chen 

School of Cyber Engineering
Xidian University
Xi'an, Shaanxi, China

ISBN 978-981-13-1482-7

ISBN 978-981-13-1483-4 (eBook)

<https://doi.org/10.1007/978-981-13-1483-4>

Library of Congress Control Number: 2018958348

© Springer Nature Singapore Pte Ltd. 2019

This work is subject to copyright. All rights are reserved by the Publisher, whether the whole or part of the material is concerned, specifically the rights of translation, reprinting, reuse of illustrations, recitation, broadcasting, reproduction on microfilms or in any other physical way, and transmission or information storage and retrieval, electronic adaptation, computer software, or by similar or dissimilar methodology now known or hereafter developed.

The use of general descriptive names, registered names, trademarks, service marks, etc. in this publication does not imply, even in the absence of a specific statement, that such names are exempt from the relevant protective laws and regulations and therefore free for general use.

The publisher, the authors, and the editors are safe to assume that the advice and information in this book are believed to be true and accurate at the date of publication. Neither the publisher nor the authors or the editors give a warranty, express or implied, with respect to the material contained herein or for any errors or omissions that may have been made. The publisher remains neutral with regard to jurisdictional claims in published maps and institutional affiliations.

This Springer imprint is published by the registered company Springer Nature Singapore Pte Ltd. The registered company address is: 152 Beach Road, #21-01/04 Gateway East, Singapore 189721, Singapore

Foreword I

With the rapid development of cyber technology, more and more users and organizations are willing to use cyber technology for work and daily life. All agree that cyber technology has great potential to transform the way human beings work, live, and behave. However, cybersecurity events ranging from data leakage to all kinds of ransomware happen with frequency higher than past years. The wanton outbreak of ransomware WannaCry caused great harm to the network users. The “Snowden event” exemplified the world that cybersecurity has a direct consequence on the national security. Currently, cybersecurity has received widespread attention in academic, industrial community, and government. On the other hand, the development of cloud computing, IoT, and big data makes the distributed networked systems more sophisticated, powerful and easy to use. In the meantime, these new technologies bring new challenges to cybersecurity. Therefore, one should seek solutions to build secure network and systems which are also more effective, intelligent, adaptive, and high performance for real-world applications.

The current book, *Advances in Cyber Security: Principles, Techniques, and Applications*, covers the recent advances in cybersecurity, which is true value to the individual, organization, and human society to understand the fundamental and realistic issue about cybersecurity. The field include: lightweight solutions for public key encryption in resource-constrained environments, nonintrusive load monitoring algorithms to mine consumer privacy in smart grid, accountable anonymous credentials, CAPTCHA design and security issues, ring signature, authenticated data redaction with privacy-preserving and flexible redaction control, a methodology for retrofitting privacy and its application to e-shopping transactions, pseudonymous signature schemes.

In the field of fundamental study, this book has included a survey of stateful public key encryption schemes. The idea of the stateful public encryption is to reuse some random parameters in the encryption algorithm by maintaining a state to save the current random variable, which is used to generate the concerned random parameters. The heavy computations like exponentiation operations can be reduced. This book also discussed possible applications of stateful encryption schemes for building up lightweight asymmetric encryption primitives for the IoT (Internet of Things) environment. On the other hand, the widespread use of CAPTCHAs these

days has made them an integral part of the Internet for providing online services, which are intended for humans, with some level of protection against automated abuse. This book gives an overview of research examining a wide range of issues that have been conducted on different types of CAPTCHAs.

In the field of practical application, this book has included the nonintrusive load monitoring algorithms to mine consumer privacy in the smart grid. This book covers the background and advantages of NILM method and the classification of NILM method, depicts the general and specific process of NILM method, and discusses examples of supervised and unsupervised NILM, and finally, examples of applications of NILM method are presented. In the cyber world, anonymous authentication is an important tool for privacy protection. However, users may misbehave under the cover of anonymity. Thus, accountability is crucial in any practical privacy-preserving authentication. This book reviews the concept of anonymous credentials and discusses various accountability mechanisms, discussing as well how recent development of blockchain and quantum computers have influenced the recent research advances in this area. Moreover, the way how anonymous credentials are applied in real-world applications in cryptocurrencies is also discussed. The huge growth of e-shopping has brought convenience to customers and increased revenue to merchants and financial entities. Nowadays, e-shopping has evolved to possess many functions, features, and requirements. However, customer privacy has been mostly ignored. This book introduces a methodology for privacy augmentation design namely “utility, privacy, and then utility again” paradigm, which is suitable for real-world engineering processes that need to adhere to the aforementioned constraints.

In the field of signature, this book introduces the basics of ring signature, including the security model and a simple construction based on discrete logarithm setting, covering also a variant called linkable ring signature that provides linkability in addition to the property of a normal ring signature. This book introduces a commercial application of (linkable) ring signature in blockchain called Ring Confidential Transaction (RingCT), which is the privacy-preserving protocol used in Monero, one of the largest cryptocurrencies in the world. Traditional data signatures are designed to protect signed messages from any changes in data integrity and authenticity verification properties. However, appropriate alteration of the signed message should be allowed for the purposes of privacy protection in scenarios as medical data sharing, outsourced databases, etc. Redactable signatures, a branch of homomorphic signatures for editing, allow any party to delete some sub-message blocks from a signed message and generate a valid signature on the remaining message without any help of the original signer. This book introduces the state-of-the-art redactable signature schemes. In addition, it depicts three integrated solutions, which hopefully offer more insights into this crucial problem.

This book also introduces the pseudonymous signature schemes. The pseudonymous signature schemes aim to provide a strong cryptographic evidence of the integrity of the signed data and origin of the signature, but at the same time have to hide the identity of the signatory. There are two crucial properties that are specific for pseudonymous signatures: ability to recover the real identity of the

signatory in certain circumstances and resilience to Sybil attacks. Despite using a single private key, the signatory can create a (single) unlinkable pseudonym for each domain or sector of activity and generate signatures corresponding to this pseudonym.

Overall, this book represents a solid research contribution to state-of-the-art studies and practical achievements in algorithms, analytics, and applications over cybersecurity, and puts the basis for further efforts in this challenging scientific field that will even more play a leading role in next-generation research. The Editors are confident that this book will significantly contribute towards the challenging field of cybersecurity.

West Lafayette, USA
June 2018

Elisa Bertino
Purdue University

Foreword II

Due to the rapid development of cyber technology in recent years, the protection of computing systems in institutions, organizations, and devices has been magnified against threats and attacks, and strengthened early vulnerable ones. Cybersecurity and privacy events ranging from data leakage to network collapse occur with higher frequency than past years, and these have become the grand challenges in today's society. The ability to perceive, discover, and prevent malicious actions or events within the cyberspace has attracted considerable interest in both academic and industrial communities.

It is important to the individuals, organizations, and human society hinging on understanding and solving fundamental and realistic issues about security and privacy in the cyberspace. These include lightweight cryptographic solutions in resource-constrained environments, privacy protection methods in smart grid monitoring, anonymous credentials and confidential transaction in crypto currency, security in reverse Turing tests design, privacy-preserving data redaction and privacy retrofitting solutions, and pseudonymous signature schemes. The current book, *Advances in Cyber Security: Principles, Techniques, and Applications* comes at the right time with the right purpose, containing herein the description of the following research ideas:

Chapter “[Stateful Public-Key Encryption: A Security Solution for Resource-Constrained Environment](#)” provides an extensive survey of original stateful public key encryption schemes and their extensions. It discusses also the possible applications of stateful encryption schemes for building up lightweight asymmetric encryption primitives for Internet of Things (IoT) environments.

Chapter “[Non-intrusive Load Monitoring Algorithms for Privacy Mining in Smart Grid](#)” introduces the background and advantages of nonintrusive load monitoring (NILM) method, as well as the classification of NILM method. It also depicts the general and specific process of NILM method, and discusses the examples of supervised and unsupervised NILM, and finally, examples of applications of NILM method are presented.

Chapter “[Accountable Anonymous Credentials](#)” reviews the concept of anonymous credentials and discusses various accountability mechanisms, as well as how recent development of blockchain and quantum computers have influenced the recent research advances in this area. Moreover, the way how anonymous credentials are applied in real-world applications in crypto-currencies is also discussed.

Chapter “[CAPTCHA Design and Security Issues](#)” examines and discusses a wide range of issues that have been conducted on different types of CAPTCHAs.

Chapter “[Ring Signature](#)” depicts the basics of ring signature and presents a commercial application of (linkable) ring signature in blockchain, which is the privacy-preserving protocol used in Monero, one of the largest cryptocurrencies in the world.

Chapter “[Data Authentication with Privacy Protection](#)” provides a basic introduction to the state-of-the-art redactable signature schemes, and it mainly considers the redaction control problem of redactable signature schemes in different applications. Moreover, three integrated solutions are depicted, which hopefully offer more insights into this crucial problem.

Chapter “[A Methodology for Retrofitting Privacy and Its Application to e-Shopping Transactions](#)” puts forward a methodology for privacy augmentation design namely “utility, privacy, and then utility again” paradigm, specially suitable for real-world engineering processes that need to adhere to the aforementioned constraints, which gives an e-shopping system with enhanced privacy features, presents a set of “utility-privacy tradeoffs”, and showcases a practical approach implementing the notion of “privacy by design” while maintaining as much compatibility as possible with current infrastructures.

Chapter “[Pseudonymous Signature Schemes](#)” aims to provide a strong cryptographic evidence of integrity of the signed data and origin of the signature, despite having to hide the identity of the signatory.

The editors have assembled an impressive book consisting of eight chapters, written by well-established authors from countries across America, European, Australia, and Asia. Notwithstanding authors come from different disciplines and subfields, their journey are the same: to discover and analyze cybersecurity and to create value for their organizations and society. The chapters are well written and organized by various authors who are active researchers or practical experts in the area related to or in cybersecurity. Advances in cybersecurity will contribute tremendously to the security and privacy protection process and help generate many new research fields and disciplines such as those in multi-functionality, lightweight, and privacy-preserving cryptographic protocol designing. On the other hand, it will stimulate technology innovation and possibly inspire entrepreneurship. In addition, it will have a great impact on Internet, IoT, cloud computing, big data, data mining, and electronic currency.

I would like to thank and congratulate the editors of this book: Kuan-Ching Li, Xiaofeng Chen, and Willy Susilo, for their tireless energy and dedication in putting together this significant volume. In the cyber era, countries, enterprises, and institutions have launched their cybersecurity strategy, and this book aims exactly at essential cybersecurity issues such as multi-functionality, lightweight,

privacy-preserving technologies, and their applications. This book has great potential to provide fundamental security and privacy to individuals, long-lasting value to organizations, and security and sustainability to both academic and industrial communities.

Xi'an, China
June 2018

Jianfeng Ma
Xidian University

Preface

The rapid development of cyber technology has been accompanied with serious security challenges nowadays. Cybersecurity events ranging from data leakage to network collapse happen with frequency higher than past years, and the most famous one is “Snowden event”, that exemplified the world that cybersecurity has a direct consequence on the national security. Currently, cybersecurity has attracted considerable interest in both academic and industrial community, especially techniques of Cloud Computing, IoT, and Big Data that make the distributed networked systems more sophisticated, powerful, easy to use. Nevertheless, security problems may be an Achilles’ heel. Based on these circumstances, one should seek solutions to build secure network and systems which are also more effective, intelligent, adaptive, and high performance for real-world applications.

One of the most problematic elements of cybersecurity is the quickly and constantly evolving nature of security risks and activities. The traditional approach has been targeted to focus most resources on the most crucial system components and protect against the largest known threats, necessitated leaving some less important system components undefended and some less dangerous risks not protected against. Nevertheless, such an approach is insufficient in the current environment.

Based on this methodological vision, this book is organized to provide the description of chapters as follows:

Chapter “[Stateful Public-Key Encryption: A Security Solution for Resource-Constrained Environment](#)”, Lightweight Solutions for Public Key Encryption in Resource-Constrained Environments: A Survey of Stateful Public Key Encryption Schemes, by Joonsang Baek, Willy Susilo, Khaled Salah, Jun Su Ha, Ernesto Damiani, and Ilsun You, considers that stateful public key encryption proposed by Bellare, Kohno, and Shoup (2006) significantly improves the efficiency of encryption portion of ElGamal-like public key encryption schemes. The idea of the stateful public key encryption is to reuse some random parameters in the encryption algorithm by maintaining a state to save the current random variable, which is used to generate the concerned random parameters. This turns out to be highly effective in reducing heavy computations like exponentiation operations in the encryption process. Since its invention, several variants and extensions have been proposed.

This chapter provides an extensive survey of original stateful public key encryption schemes and their extensions. Possible applications of stateful encryption schemes for building up lightweight asymmetric encryption primitives for the IoT (Internet of Things) environment are also discussed.

Chapter “[Non-intrusive Load Monitoring Algorithms for Privacy Mining in Smart Grid](#)”, by Zijian Zhang, Jialing He, Liehuang Zhu, and Kui Ren, moves the attention on nonintrusive load monitoring (NILM) method that is essentially artificial intelligence algorithms for energy conservation and privacy mining through decomposing aggregated meter readings of consumer energy consumption into the individual devices energy consumption. The authors introduce the background and advantages of NILM method and the classification of NILM method, depict the general and specific process of NILM method, and discuss examples of supervised and unsupervised NILM, and finally, examples of applications of NILM method are presented.

Chapter “[Accountable Anonymous Credentials](#)”, by Zuoxia Yu, Man Ho Au, and Rupeng Yang, focuses on the significance of anonymity, which refers to the absence of identifying information associated with an interaction. In the cyber world, anonymous authentication is an important tool for privacy protection. However, users may misbehave under the cover of anonymity. Thus, accountability is crucial in any practical privacy-preserving authentication. In this chapter, authors review the concept of anonymous credentials and discuss various accountability mechanisms, discussing as well how recent development of blockchain and quantum computers have influenced the recent research advances in this area. Moreover, the way how anonymous credentials are applied in real-world applications in cryptocurrencies is also discussed.

Chapter “[CAPTCHA Design and Security Issues](#)”, by Yang-Wai Chow, Willy Susilo, and Pairat Thorncharoensri, moves the attention to the concept of reverse Turing tests, commonly known as CAPTCHAs, for distinguishing between humans and computers has been around for many years. The widespread use of CAPTCHAs these days has made them an integral part of the Internet for providing online services, which are intended for humans, with some level of protection against automated abuse. Since their inception, much research has focused on investigating various issues surrounding the design and security of CAPTCHAs. A fundamental requirement of CAPTCHAs necessitates that they must be designed to be easy for humans but difficult for computers. However, it is well recognized that the tradeoff between usability and security is difficult to balance. In addition, numerous attacks have been developed to defeat CAPTCHAs. In response to this, many different CAPTCHA design variants have been proposed over the years. Despite the fact that CAPTCHAs have been around for more than two decades, the future of CAPTCHAs remains an open question. It is shown in this chapter an overview of research examining a wide range of issues that has been conducted on different types of CAPTCHAs.

Chapter “[Ring Signature](#)”, by Joseph K. Liu, discusses the basics of ring signature, including the security model and a simple construction based on discrete logarithm setting, covering also a variant called linkable ring signature that provides

linkability in addition to the property of a normal ring signature. In this chapter, he presents a commercial application of (linkable) ring signature in blockchain called Ring Confidential Transaction (RingCT), which is the privacy-preserving protocol used in Monero, one of the largest cryptocurrencies in the world.

Chapter “[Data Authentication with Privacy Protection](#)”, Authenticated Data Redaction with Privacy Preserving and Flexible Redaction Control, by Jianghua Liu, Yang Xiang, Wanlei Zhou, Xinyi Huang, and Jinhua Ma, puts emphasis on digital signatures, aimed at protecting a signed message from any alteration with the properties of data integrity and authenticity authentication. However, appropriate alteration of the signed message should be allowed for the purposes of privacy protection in scenarios as medical data sharing, outsourced databases, etc. Redactable signatures, a branch of homomorphic signatures for editing, allow any party to delete some sub-message blocks from a signed message and generate a valid signature on the remaining message without any help of the original signer. This chapter provides a basic introduction to the state-of-the-art redactable signature schemes, and authors mainly consider the redaction control problem of redactable signature schemes in different applications. In addition, it depicts three integrated solutions, which hopefully offer more insights into this crucial problem.

Chapter “[A Methodology for Retrofitting Privacy and Its Application to e-Shopping Transactions](#)”, by Jesus Diaz, Seung Geol Choi, David Arroyo, Angelos D. Keromytis, Francisco B. Rodriguez, and Moti Yung, addressed to the fact that huge growth of e-shopping has brought convenience to customers and increased revenue to merchants and financial entities. In addition, e-shopping has evolved to possess many functions, features, and requirements (e.g., regulatory ones). However, customer privacy has been mostly ignored, and while it is easy to add simple privacy to an existing system, this typically causes loss of functions. What is needed is enhanced privacy on one hand, while retaining the critical functions and features on the other hand. This is a dilemma which typifies the “privacy versus utility” paradigm, especially when it is applied to an established primitive with operational systems, where applying conventional privacy by design principles is not possible and completely altering information flows and system topologies is not an option. This dilemma is becoming more problematic with the advent of regulations such as the European GDPR, which requires companies to provide better privacy guarantees whenever and wherever personal information is involved. In this chapter, authors put forward a methodology for privacy augmentation design namely “utility, privacy, and then utility again” paradigm, specially suitable for real-world engineering processes that need to adhere to the aforementioned constraints, which gives an e-shopping system with enhanced privacy features, presents a set of “utility-privacy tradeoffs”, and showcases a practical approach implementing the notion of “privacy by design” while maintaining as much compatibility as possible with current infrastructures.

Chapter “[Pseudonymous Signature Schemes](#)”, by Przemysław Błażkiewicz, Lucjan Hanzlik, Kamil Kluczniak, Łukasz Krzywiecki, Mirosław Kutylowski, Marcin Słowik, and Marta Wszola, concerns cryptographic schemes enabling to sign digital data in a pseudonymized way. The schemes aim to provide a strong

cryptographic evidence of integrity of the signed data and origin of the signature, but at the same time have to hide the identity of the signatory. There are two crucial properties that are specific for pseudonymous signatures: ability to recover the real identity of the signatory in certain circumstances and resilience to Sybil attacks. Despite using a single private key, the signatory can create a (single) unlinkable pseudonym for each domain or sector of activity and generate signatures corresponding to this pseudonym.

Overall, this book represents a solid research contribution to state-of-the-art studies and practical achievements in algorithms, analytics, and applications over cybersecurity, and puts the basis for further efforts in this challenging scientific field that will even more play a leading role in next-generation research. The Editors are confident that this book will significantly contribute towards the challenging field of cybersecurity.

Taichung, Taiwan
Xi'an, China
Wollongong, Australia

Kuan-Ching Li
Xiaofeng Chen
Willy Susilo

Acknowledgements

First and foremost, we would like to thank and acknowledge the contributors to this book for their support, and the reviewers for their valuable and useful comments and suggestions that sought in improving the earlier outline and presentation of the book.

We extend our deepest thanks to editorial team from Springer Nature for their collaboration, guidance, and most importantly, patience in finalizing this book in highest standards. Additionally, we acknowledge the efforts of the team from Springer Nature's production department for their extensive efforts during the phases of this project and the timely fashion in which the book was produced by.

Finally, it is acknowledged the support in part by the 111 Center of Mobile Internet Security, Xidian University and China 111 project (No. B16037).

Contents

Stateful Public-Key Encryption: A Security Solution for Resource-Constrained Environment	1
Joonsang Baek, Willy Susilo, Khaled Salah, Jun Su Ha, Ernesto Damiani and Ilsun You	
Non-intrusive Load Monitoring Algorithms for Privacy Mining in Smart Grid	23
Zijian Zhang, Jialing He, Liehuang Zhu and Kui Ren	
Accountable Anonymous Credentials	49
Zuoxia Yu, Man Ho Au and Rupeng Yang	
CAPTCHA Design and Security Issues	69
Yang-Wai Chow, Willy Susilo and Pairat Thorncharoensri	
Ring Signature	93
Joseph K. Liu	
Data Authentication with Privacy Protection	115
Jianghua Liu, Yang Xiang, Wanlei Zhou, Xinyi Huang and Jinhua Ma	
A Methodology for Retrofitting Privacy and Its Application to e-Shopping Transactions	143
Jesus Diaz, Seung Geol Choi, David Arroyo, Angelos D. Keromytis, Francisco B. Rodriguez and Moti Yung	
Pseudonymous Signature Schemes	185
Przemysław Błażkiewicz, Lucjan Hanzlik, Kamil Klucznik, Łukasz Krzywiecki, Mirosław Kutylowski, Marcin Słowik and Marta Wszola	

Stateful Public-Key Encryption: A Security Solution for Resource-Constrained Environment



Joonsang Baek, Willy Susilo, Khaled Salah, Jun Su Ha,
Ernesto Damiani and Ilsun You

Abstract The stateful public-key encryption scheme proposed by Bellare, Kohno and Shoup in 2006 significantly improves the efficiency of the encryption operation of ElGamal-like public-key encryption schemes. The basic idea of the stateful public-key encryption scheme is to reuse some random parameters in the encryption algorithm by maintaining a state to save the current random variable, which is used to generate the random parameters. This turns out to be highly effective in reducing heavy computations like exponentiation operations in the encryption process. Since its invention, several variants and extensions of the stateful public key encryption scheme have been proposed. This chapter provides an extensive survey of original stateful public-key encryption scheme and their extensions. Also, possible applications of stateful encryption schemes for building up lightweight asymmetric encryption primitives for the Internet of things (IoT) environment are discussed.

1 Introduction

Compared with symmetric encryption, public-key encryption (PKE) significantly simplifies the process of key exchange/distribution as the confidential data can now be encrypted with public keys which do not have to be kept secret. The secure machine-to-machine communication in the Internet of things (IoT) environment can greatly

J. Baek (✉) · W. Susilo
Institute of Cybersecurity and Cryptology, University of Wollongong,
Wollongong, NSW, Australia
e-mail: baek@uow.edu.au

K. Salah · J. S. Ha · E. Damiani
Khalifa University of Science and Technology, Abu Dhabi,
United Arab Emirates

I. You
Soonchunhyang University, Asan, South Korea

be benefited from this feature of PKE but an issue of efficiency may arise since PKE schemes usually need heavier computational operations as compared with symmetric encryption schemes. Enhancing efficiency is an important issue of IoT security as devices used in the IoT environment are often resource-constrained. This chapter investigates the possibility of employing PKE in such environment by providing an extensive survey on stateful public-key encryption [16], a special type of PKE scheme that has potential to meet the high-efficiency requirement of the resource-constrained environment. We begin this chapter by revisiting the ElGamal encryption scheme [26].

The ElGamal encryption scheme is a well-known public-key encryption scheme based on the Diffie–Hellman key exchange protocol [25, 35]. It may be one of the most well-known public key schemes, together with the RSA encryption scheme [42], and has been focused by both academia and industry for many years. In terms of academic research, the ElGamal encryption scheme has affected the design of numerous cryptographic schemes and protocols. On the practical side, it has been implemented in a number of important security applications including PGP.

In order to perform encryption, the very original ElGamal encryption scheme needs to map a message to a member of the underlying group. This limitation can easily be resolved using a hybrid form of the ElGamal encryption scheme, in which a symmetric encryption scheme is employed to encrypt (longer) plaintext messages. For the easy exposition of the subject matters, we informally describe the hybrid ElGamal encryption scheme as follows. Let $y = g^x$ be the public key, where g is a generator of the underlying group of prime order p and $x \in \mathbb{Z}_q$ is the private key. Then, to encrypt a message m , the sender selects r uniformly at random from $\mathbb{Z}_p$ and computes a ciphertext $c = (g^r, E(k, m))$, where $k = G(g^r, y^r)$ for some key generation function G . By raising g^r to the power of x , the receiver can recover m , i.e., decrypt c . (We remark that for appropriate instantiations for G and E , this scheme provides strong security such as security against chosen ciphertext attack as discussed in [1].)

In 2006, Bellare, Kohno and Shoup (BKS) [16] had a very interesting idea on how to speed up the encryption operation of the hybrid ElGamal encryption scheme described above. Their idea is to *reuse* r and keep (r, g^r, y^r) as a *state* to encrypt multiple messages, which results in saving the expensive computations of g^r and y^r . Note that as a result of this construction, the encapsulated key y^r is no longer ephemeral and becomes a long-term key. As careful readers might suspect, this randomness reuse can make the encryption scheme insecure by violating semantic security [15]. This is the reason why one needs a strong symmetric encryption scheme in which fresh randomness is generated to provide indistinguishable encryption [15]. However, since the generation of the randomness via pseudorandom generator (PRG) is much cheaper than via number-theoretic operation like the modular exponentiation or the multiplication over elliptic curve, the computational gain can be achieved. BKS called the type of an encryption scheme described just now “*stateful public-key encryption* (stateful PKE)”.

In this chapter, we take a close look at the concept of stateful PKE scheme, its realization, and extensions. In particular, the contributions of this chapter are summarized as follows:

1. This chapter reviews the basic definitions and security notions for stateful PKE schemes.
2. This chapter provides an extensive survey of stateful PKE schemes available in the literature. For the sake of clarity, the stateful PKE scheme is classified depending on their functionality and generality.
3. This chapter also provides surveys of the existing implementations of stateful PKE schemes and discusses the possibility of using them to secure resource-constrained devices.

This chapter is organized as follows. In Sect. 2, we provide a comprehensive overview of the formal security notion of stateful PKE. We explain our classifications of stateful PKE schemes in Sect. 3. In Sect. 4, we review stateful PKE schemes available in the literature, which satisfy the basic property formulated by BKS [16]. The extended schemes that achieve various functionalities and properties including identity-based encryption are investigated in Sect. 5. We review the existing implementations of the stateful PKE schemes and discuss their possible applications for securing resource-constrained mobile devices in Sect. 6. Finally, we propose some open problems in Sect. 7.

2 Preliminaries

2.1 Notations

$s \xleftarrow{R} S$ denotes selecting an element s from a set S uniformly at random. By $z \leftarrow A(x, y, \dots)$, we denote an operation of assigning an output of the algorithm A which takes $x, y, \dots$ to z as input. $\|n\|$ denotes the number of bits in a binary representation of an integer n , that is, $\|n\| = \lfloor \log_2 n \rfloor + 1$. All adversarial algorithms are called “adversaries” in this chapter.

2.2 Formal Definitions of Stateful Public-Key Encryption and Its Security

The following definition of a generic stateful PKE scheme, formulated by BKS, captures the intuition of having public-key encryption maintain state [16].

Definition 1 A stateful PKE scheme StPKE consists of algorithms Setup, KG, PKCk, NwSt, Encrypt, and Decrypt, each of which is described as follows:

- $sp \leftarrow \text{Setup}(1^\lambda)$: Taking a security parameter $\lambda \in \mathbb{Z}^+$ as input, this algorithm generates a system parameter sp .
- $(sk, pk) \leftarrow \text{KG}(sp)$: Taking sp as input, this algorithm generates a private key sk and a public key pk .
- $0/1 \leftarrow \text{PKCk}(sp, pk)$: Taking (sk, pk) as input, this algorithm returns 1 if pk is valid and 0 otherwise.
- $st \leftarrow \text{NwSt}(sp)$: Taking sp as input, this algorithm generates a new state st .
- $(c, st) \leftarrow \text{Encrypt}(sp, pk, st, m)$: Taking (sp, pk, st, m) as input, where m is a message, this algorithm outputs a ciphertext c and a state st .
- $m/\perp \leftarrow \text{Decrypt}(sp, sk, c)$: Taking (sp, pk, st, m) as input, this algorithm decrypts c into m or returns a reject symbol $\perp$.

Note that in the above definition, the state st provided as input to the encryption algorithm can be updated by it. We assume that state is not an empty set. (If it is, the encryption becomes stateless.)

BKS formulated the indistinguishability security notion of stateful PKE against chosen ciphertext attack (IND-CCA) [16], which we review as follows.

Definition 2 (*IND-CCA of StPKE*) Let StPKE be a generic stateful PKE scheme and let $\mathcal{A}$ be an adversary. Consider the following adversarial game which takes a security parameter λ as input:

1. The game generates $sp \leftarrow \text{Setup}(1^\lambda)$, $(pk_1, sk_1) \leftarrow \text{KG}(sp)$ and $st \leftarrow \text{NwSt}(sp)$, where (sk_1, pk_1) is a pair of private and public keys of an honest receiver R_1 . Then, the game sends sp and pk_1 to $\mathcal{A}$.
2. $\mathcal{A}$ outputs $pk_2, \dots, pk_n$, which are public keys of $R_2, \dots, R_n$ respectively. (Note that $pk_i \in \{\text{KG}(sp)\}$ for $i = 1, \dots, n$. Note also that $\mathcal{A}$ may or may not possess the private keys of the public keys $pk_2, \dots, pk_n$ depending on the security model, which will be discussed in detail following this definition.)
3. $\mathcal{A}$ makes different kinds of queries; they are responded by the game as follows:
 - When a challenge query (m_0, m_1) , where $|m_0| = |m_1|$, is made, the game chooses $\beta \xleftarrow{\mathcal{R}} \{0, 1\}$, computes $(c^*, st) \leftarrow \text{Encrypt}(sp, pk_1, st, m_\beta)$, and returns c^* to $\mathcal{A}$.
 - When an encryption query (i, m) for some $i \in \{1, \dots, n\}$ is made, the game computes $(c, st) \leftarrow \text{Encrypt}(sp, pk_i, st, m)$ and returns c to $\mathcal{A}$.
 - When a decryption query $c \neq c^*$ is made, the game computes $\text{Decrypt}(sp, sk_1, c)$ and returns a result to $\mathcal{A}$.
4. $\mathcal{A}$ outputs β' , which is a guess on β .
5. The game returns 1 if $\beta' = \beta$, and 0 otherwise.

$\mathcal{A}$'s advantage is defined as follows:

$$\text{Adv}_{\text{StPKE}, \mathcal{A}}^{\text{ind-cca}}(\lambda) \stackrel{\text{def}}{=} |\Pr[\beta' = \beta] - 1/2|.$$

There are a few remarks on the definition presented above:

1. There are two models for the security of stateful PKE: One is “Known Secret Key (KSK)” and the other one is “Unknown Secret Key (USK)” [16]. In the KSK model, the adversary $\mathcal{A}$ is supposed to know the matching private keys $sk_2 \dots, sk_n$ of the public keys $pk_2 \dots, pk_n$, which $\mathcal{A}$ outputs in the second step of the above game. Meanwhile, in the USK model, $\mathcal{A}$ does not necessarily know the corresponding private keys. In other words, the KSK model implies that a trusted third party such as certificate authority checks whether a subject owns a private key of a given public key by running a proof of knowledge protocol. On the other hand, the USK model suggests that the proof of knowledge of a private key is not required but a minimal validity check for public key, e.g., checking whether various elements of the public key are in the right range. Note that the algorithm PKCk indeed provides such minimal check.
2. Although BKS mentioned that the simple public-key checking mechanisms like whether certain components of a given public key are elements of the underlying group are implicit in many public-key schemes, they did not state why the PKCk algorithm is explicitly presented in their definition of the generic stateful PKE scheme (i.e., StPKE). We deduce the reason as follows. In stateful PKE, the same state can be used to perform encryption under multiple public keys, which might be of assistance to an adversary to gain any (useful) information about a message. Hence, the security model of stateful PKE allows the adversary to create those public keys except for the target one. Thus, as the security model involves the generation of receivers’ public keys *by the adversary* unlike the security model of the regular PKE in which a single receiver’s public key is assumed to be generated correctly, there should be a mechanism that all the public keys concerned in the stateful PKE are at least valid.
3. Note that in the above game, $\mathcal{A}$ has access to an encryption oracle. This is different from a regular PKE scheme in which there is no need for adversary to have access to encryption oracle since the adversary can produce ciphertexts by himself. In contrast, a situation becomes different since the adversary, *not given state*, cannot generate ciphertexts by himself in the stateful PKE scheme.

2.3 Symmetric Encryption

As mentioned in earlier section, in order to construct a stateful PKE scheme which is IND-CCA secure, a strong symmetric encryption scheme is required. It seems that the CCA-secure data encapsulation mechanism (DEM) used in the KEM/DEM construction for hybrid encryption [23, 44] (KEM: key encapsulation mechanism) is enough for this purpose, it turns out that a stronger symmetric encryption scheme, which is CCA-secure even when an adversary is allowed to query an encryption oracle multiple times, is required.

Definition 3 (*IND-CCA of SYM*) Let SYM be a symmetric encryption scheme; it consists of E , an encryption algorithm, and D a decryption algorithm. Let $\mathcal{B}$ be an adversary. Consider the following game which takes a security parameter λ as input:

1. The game selects a key $k \xleftarrow{R} \{0, 1\}^\lambda$.
2. $\mathcal{B}$ makes encryption and decryption queries; they are responded by the game as follows:
 - When an encryption query m is made, the game computes $c \leftarrow E(k, m)$ and returns c to $\mathcal{B}$.
 - When a decryption query c is made, the game computes $m \leftarrow D(k, c)$ and returns m to $\mathcal{B}$. (Note that m can be $\perp$.)
3. When $\mathcal{B}$ makes a target encryption query (m_0, m_1) , where $|m_0| = |m_1|$, the game selects $\beta \xleftarrow{R} \{0, 1\}$, computes $c^* \leftarrow E(k, m_\beta)$, and returns c^* to $\mathcal{B}$. (Note that his query is made only at once.)
4. $\mathcal{B}$ continues to make encryption and decryption queries; they are responded by the game as follows:
 - When an encryption query m is made, the game computes $c \leftarrow E(k, m)$ and returns c to $\mathcal{B}$.
 - When a decryption query c such that $c \neq c^*$ is made, the game computes $m \leftarrow D(k, c)$ and returns c to $\mathcal{B}$. (Note that m can be $\perp$.)
5. $\mathcal{B}$ outputs β' , which is a guess on β .
6. The game outputs 1 if $\beta' = \beta$, and 0 otherwise.

We define $\mathcal{B}$'s advantage as follows:

$$\text{Adv}_{\text{SYM}, \mathcal{B}}^{\text{ind-cca}}(\lambda) \stackrel{\text{def}}{=} |\Pr[\beta' = \beta] - 1/2|.$$

Fortunately, it is easy to build up a symmetric encryption scheme which is IND-CCA secure [12, 14], say, using the encrypt-then-mac composition that employs AES with CBC-MAC or HMAC [13].

2.4 Computational Problems

We now review some computational problems that this chapter will refer to.

The first computational problem we review is the Gap Diffie–Hellman (GDH) problem. This problem is actually originated from Okamoto and Pointcheval's work [39]. However, the computational problem on which the stateful PKE schemes from [9, 16] are based on a slightly weaker form of the GDH problem in which one of decisional Diffie–Hellman oracles that an adversary has access to take two (not three) fixed group elements as defined below.

Definition 4 (GDH) Let $\mathbb{G}$ be a multiplicative group of prime order p such that $\|p\| = \lambda$ and let g be a generated of $\mathbb{G}$. The GDH problem for an adversary $\mathcal{B}$ is defined as follows:

Given $(g, g^a, g^b) \in \mathbb{G} \times \mathbb{G} \times \mathbb{G}$ for random $a, b \in \mathbb{Z}_p$, compute g^{ab} with the help of the restricted decisional Diffie–Hellman oracle $\text{DDH}_{g, g^a}(\cdot, \cdot)$, which on input (g^s, g^t) outputs 1 if and only if $as = t \bmod p$.

We define $\mathcal{B}$'s advantage $\text{Adv}_{\mathbb{G}, \mathcal{B}}^{\text{sdh}}(\lambda)$ as the probability that $\mathcal{B}$ succeeds in solving the GDH problem.

The next one is the usual decisional Diffie–Hellman (DDH) problem.

Definition 5 (DDH) Let $\mathbb{G}$ be as defined in Definition 4. The DDH problem for an adversary $\mathcal{B}$ is defined as follows:

Given $(g, g^a, g^b, g^c) \in \mathbb{G} \times \mathbb{G} \times \mathbb{G} \times \mathbb{G}$ for random $a, b, c \in \mathbb{Z}_p$, determine whether $c = ab$ or not.

We define $\mathcal{B}$'s advantage $\text{Adv}_{\mathbb{G}, \mathcal{B}}^{\text{ddh}}(\lambda)$ as the probability that $\mathcal{B}$ succeeds in solving the DDH problem.

We also review the following gap bilinear Diffie–Hellman (GBDH) problem defined in [41], which modifies the original bilinear Diffie–Hellman problem (BDH) that involves the bilinear pairing e . For the sake of simplicity, we assume that e is a symmetric pairing throughout this chapter; it satisfies the following properties [17, 20]: (1) Non-degeneracy: $e(g, g) \neq 1 \in \mathbb{G}_t$; (2) Bilinearity: For all $a, b \in \mathbb{Z}_p$, $e(g^a, g^b) = e(g, g)^{ab}$ [17]. We remark an asymmetric pairing, a more general form of pairing, does exist. (The extensive survey on pairing for cryptography can be found in [27].)

Definition 6 (GBDH) Let $\mathbb{G}$ be a multiplicative group of prime order p such that $\|p\| = \lambda$ and let g be a generated of $\mathbb{G}$. Let $e : \mathbb{G} \times \mathbb{G} \rightarrow \mathbb{G}_t$ be a bilinear pairing, where $\mathbb{G}_t$ has the same order p . The GBDH problem an adversary $\mathcal{B}$ is defined as follows:

Given $(g, g^a, g^b, g^c) \in \mathbb{G}^4$, compute $e(g, g)^{abc}$ with the help of the bilinear Decisional Diffie–Hellman oracle $\text{DDH}_{g, g^a, g^b, g^c}(\cdot)$, which on input $\tau \in \mathbb{G}_t$ outputs 1 if and only if $\tau = e(g, g)^{abc}$.

We define $\mathcal{B}$'s advantage $\text{Adv}_{\mathbb{G}, \mathbb{G}_t, \mathcal{B}}^{\text{gbdh}}(\lambda)$ as the probability that $\mathcal{B}$ succeeds in solving the GBDH problem.

2.5 Making Use of “Advantages”

The “advantages” described in the security definitions and computational problems can be used in a usual way. For example, if a given StPKE scheme is secure in the IND-CCA sense, the advantage $\text{Adv}_{\text{StPKE}, \mathcal{A}}^{\text{ind-cca}}(\lambda)$ of this notion is *negligible* in

λ . In a similar fashion, if, the DDH problem, for example, is hard (or intractable), the advantage $\text{Adv}_{\mathbb{G}, \mathcal{B}}^{\text{ddh}}(\lambda)$ is negligible in λ . The security of other schemes and the hardness of other computational problems can be described similarly.

Note that in the rest of the chapter, we do not explicitly mention the “advantages” defined in this section.

3 Taxonomy of Stateful Public-Key Encryption

In this chapter, we classify existing stateful PKE schemes based on *functionality* and *generality*. Under the category of functionality, stateful PKE schemes are classified as “basic” and “extended” schemes. Also, under the category of generality, they are classified as “generic” and “nongeneric” schemes.

“Basic” schemes are stateful PKE schemes that provide the basic functionality of BKS’ schemes [16]. “Extended” schemes are those that provide functionalities beyond the basic functionality of the BKS schemes.

After BKS’ schemes emerged, some generic constructions of basic and extended stateful PKE schemes have been proposed. In this regard, we classify stateful PKE schemes into “generic” and “nongeneric” schemes.

Figure 1 illustrates the taxonomy of the stateful PKE schemes surveyed in this chapter.

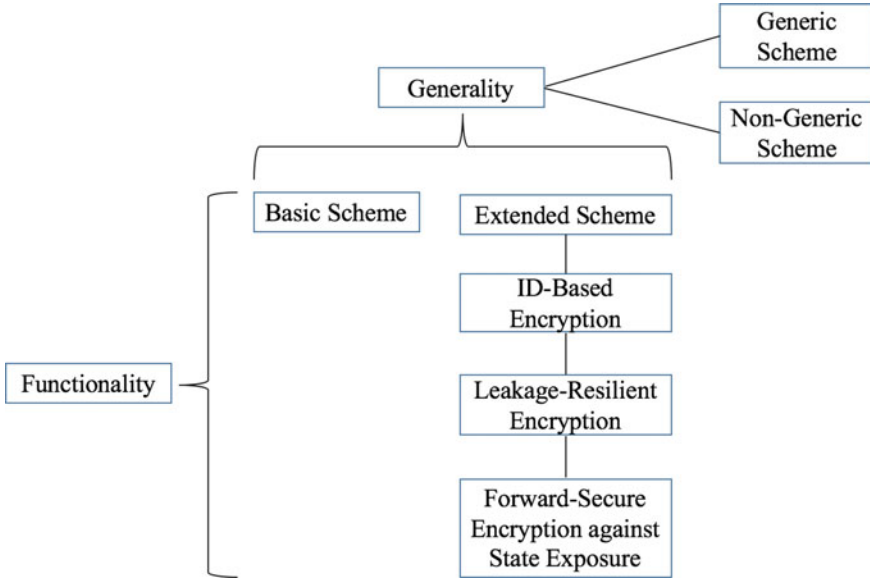


Fig. 1 Taxonomy of stateful PKE surveyed in this chapter

4 Basic Schemes

The first group of stateful PKE schemes that we describe in this section consists of schemes constructed according to Definition 1. We call these schemes “basic” in a sense that they provide the basic functionality that BKS envisioned [16].

4.1 Nongeneric Schemes

In this subsection, we review two constructions of stateful PKE, both of which make use of the Diffie–Hellman primitive. We call them “nongeneric” as there exists a generic construction, which will be treated in the next subsection.

Bellare–Kohno–Shoup This is the most-known scheme, proposed by BKS [16]. We denote this scheme by “BKS1”. (Note that in [16], this is denoted by “StDH”.) Its sub-algorithms are described in Fig. 2:

As mentioned earlier, the BKS1 scheme is a hybrid encryption scheme, where the key encapsulation mechanism (KEM) [23] involves computation of the Diffie–Hellman key y^r . But the ephemeral value r is *reused* until a new one is generated. This would make the KEM deterministic and the confidentiality of message would be lost since the indistinguishability of does not hold. However, BKS solved this problem by using a strong and *randomized* symmetric encryption scheme for the data encapsulation mechanism (DEM) [23] part. Indeed, the above scheme is proven to be IND-CCA secure (Definition 2) in the USK model assuming that the DEM part

Setup(1^λ): Construct a multiplicative group $\mathbb{G}$ of prime order p such that $\|\mathbb{G}\| = \lambda$; denote a generator of $\mathbb{G}$ by g ; construct a hash function $H : \mathbb{G} \times \mathbb{G} \times \mathbb{G} \rightarrow \{0, 1\}^l$ and a symmetric encryption scheme (E, D) ; return a system parameter $sp = (p, \mathbb{G}, g, H, E, D)$.

KG(sp): Pick $x \in \mathbb{Z}_p$ at random; compute $y = g^x$; return (x, y) (x is a private key and y is a public key.)

PKCk(sp, pk): Check whether y is a member of $\mathbb{G}$. If $y \in \mathbb{G}$, return 1. Else return 0.

NwSt(sp): Pick $r \in \mathbb{Z}_p^*$ uniformly at random; compute $u = g^r$; return $st = (r, u)$.

Encrypt(sp, pk, st, m): Parse st as (r, u) . Compute $\Psi = y^r$, $k = H(u, y, \Psi)$ and $v = E(k, m)$ for plaintext m ; return $c = (u, v)$.

Decrypt(sp, sk, c): Parse c into (u, v) ; compute $\Psi = u^x$ and $k = H(u, y, \Psi)$; return $D(k, v)$ (which is either m or $\perp$).

Fig. 2 Scheme BKS1

Setup(1^λ): Construct a multiplicative group $\mathbb{G}$ of prime order $\|\mathbb{G}\| = \lambda$, generated by g_1 and g_2 ; construct a hash function $H : \mathbb{G} \times \mathbb{G} \rightarrow \mathbb{Z}_p$, which is a collision-resistant, a key derivation function $G : \mathbb{G} \rightarrow \{0, 1\}^l$ and a symmetric encryption scheme (E, D) ; return a system parameter $sp = (\mathbb{G}, p, g_1, g_2, H, E, D)$.

KG(sp): Pick $x_1, x_2, y_1, y_2 \in \mathbb{Z}_p$ uniformly at random; compute $X = g_1^{x_1} g_2^{x_2}$ and $Y = g_1^{y_1} g_2^{y_2}$; return $pk = (X, Y)$ and $sk = (x_1, x_2, y_1, y_2)$.

PKCk(sp, pk): Return 1.

NwSt(sp): Pick $r \in \mathbb{Z}_p^*$ uniformly at random; compute $u_1 = g_1^r, u_2 = g_2^r$ and $\alpha = H(u_1, u_2)$; return state $st = (r, u_1, u_2, \alpha)$.

Encrypt(sp, pk, st, m): Parse st as (r, u_1, u_2, α) ; compute $\Psi = X^r Y^{r\alpha}$, $k = G(\Psi)$ and $v = E(k, m)$ for a plaintext m ; return a ciphertext $c = (u_1, u_2, v)$.

Decrypt(sp, sk, c): Parse c into (u, v) ; compute $\Psi = u_1^{x_1 + \alpha y_1} u_2^{x_2 + \alpha y_2}$ and $k = G(\Psi)$; return $D(k, v)$ (which is either m or $\perp$).

Fig. 3 Scheme BKS2

(E, D) is also IND-CCA secure (Definition 3) and the hash function H is a random oracle [11].

BKS constructed another scheme aiming to remove the random oracle. Their construction is based on the well-known Kurosawa and Desmedt's hybrid encryption scheme without random oracles [33]. We call this scheme “BKS2” and describe it in Fig. 3.

Note that the PKCk algorithm described above will return 1 since the BKS2 scheme works in the KSK model where the adversary is assumed to *possess* the matching private keys of the public keys. Note also that BKS recommends a universal (or equivalently target collision-resistant) hash function [36] to implement H , which is weaker than the collision-resistant hash function described above.

The BKS2 scheme is proven to be IND-CCA secure in the KSK model provided that the DEM part (E, D) is IND-CCA secure (Definition 3) and the DDH problem (Definition 5) is hard.

Baek–Chu–Zhou In 2011, Baek, Chu and Zhou (BCZ) [9] proposed another basic scheme that focuses on improving communication efficiency by providing short ciphertext. Their scheme, which we denote by “BCZ”, is described in Fig. 4.

One of the benefits of the BCZ scheme is to provide short ciphertext with the same level of security, i.e., security against CCA. As mentioned earlier, a randomized symmetric encryption scheme is required to achieve data confidentiality, which, however, usually causes ciphertext to be expanded due to an extra random string output as a part of DEM. On the other hand, in the BCZ scheme, the session key (k in the above description) is randomized even if the same state is used again and it is XOR-ed with the hash function H 's output to make the size of the whole ciphertext smaller, different from the BKS1 scheme described previously.

Setup(1^λ): Generate a multiplicative group $\mathbb{G}$ whose order is prime p such that $\|p\| = 2\lambda$; denote a generator of $\mathbb{G}$ by g ; choose hash functions $G : \mathbb{G} \times \{0, 1\}^{\lambda_k} \rightarrow \{0, 1\}^l$, where $\lambda_k = 2\lambda$ and $l \geq 1$, and $H : \mathbb{G} \times \mathbb{G} \times \{0, 1\}^* \times \mathbb{G} \rightarrow \{0, 1\}^{\lambda_l}$; return a system parameter $sp = (\mathbb{G}, p, g, G, H)$.

KG(sp): Select $x \in \mathbb{Z}_p$ uniformly at random, compute $y = g^x$ and return a public key $pk = y$ and a private key $sk = x$.

PKCk(sp, pk): Check if y is an element of $\mathbb{G}$. If $y \in \mathbb{G}$, return 1. Else return 0.

NwSt(sp): Select $r \in \mathbb{Z}_p^*$ uniformly at random, compute $u = g^r$ and return a state $st = (r, u)$.

Encrypt(sp, pk, st, m): Parse st into (r, u) . compute $\Psi = y^r$ and choose $s \in \{0, 1\}^\lambda$ uniformly at random; compute $k = G(u, s)$, $v = k \oplus m$ for a plaintext $m \in \{0, 1\}^l$, where $l \geq 1$, and $W = H(y, u, v, \Psi) \oplus s$; return a ciphertext $c = (u, v, w)$.

Decrypt(sp, sk, c): Parse c into (u, v, w) ; compute $\Psi = u^x$ and $s = w \oplus H(y, u, v, \Psi)$; return $m = v \oplus k$, where $k = G(u, s)$.

Fig. 4 Scheme BCZ

The BCZ scheme was proven to be IND-CCA secure in the random oracle model under the assumption that the GDH problem (Definition 4) is intractable.

4.2 Generic Schemes

Notice that BKS1, BKS2, and BCZ schemes are based on the specific Diffie–Hellman primitive (especially realized over elliptic curve as mentioned in [16]). In the literature, there are two generic schemes that realize the original concept of stateful PKE. We review those schemes in this section.

Baek–Zhou–Bao: Generic Construction of Stateful Public-Key Encryption

Baek, Zhou and Bao (BZB) proposed generic constructions of stateful PKE [8], which we denote by “BZB1” and “BZB2”. Their constructions are based on a new cryptographic primitive termed as “partitioned key encapsulation mechanism (PKEM)”. In the PKEM scheme, a ciphertext portion depending on a system parameter can be “partitioned” from other portion of ciphertext. (Note that the system parameter here is different from a public key, which is explicitly used for encryption.) More precisely, PKEM has two sub-algorithms, Encap1 and Encap2. The former will generate the portion of the ciphertext taking the system parameter as input while the latter will generate the other portion of the ciphertext taking the public key and the portion of ciphertext generated by Encap1 as input. A detailed description of the BZB1 scheme is given in Fig. 5.

At first sight, the security of the BZB1 scheme can be analyzed in a similar way as the security of hybrid encryption schemes based on the KEM/DEM framework

Setup(1^λ): This algorithm simply returns the system parameter sp output by the Setup algorithm of the PKEM scheme.

KG(sp): This algorithm simply returns the private and public key pair (sk, pk) output by the KG algorithm of the PKEM scheme.

PKCk(sp, pk): This algorithm returns 1 without doing anything else since in the KSK model, any public keys are generated accurately according to the specification of the KG algorithm. (In other words, a party that has created a public key must know its corresponding private key.)

NwSt(sp): Compute $(\omega, \psi) \leftarrow \text{Encap1}(sp)$, set $st = (\omega, \psi)$ and return st .

Encrypt(sp, pk, st, m): If $st = (\omega, \psi)$ or $st = (\omega, \psi, pk', \sigma', k')$ with $pk' \neq pk$, compute $(\sigma, k) \leftarrow \text{Encap2}(sp, pk, \omega, \psi)$. Else parse st into $(\omega, \psi, pk, \sigma, k)$. Then, perform the following: Compute $e \xleftarrow{R} \text{SEnc}(k, m)$, set $c = (\psi, \sigma, e)$ and $st = (\omega, \psi, pk, \sigma, k)$, and return (c, st) .

Decrypt(sp, sk, c): Parse c into (ψ, σ, e) and compute $k \leftarrow \text{Decap}(sp, sk, \psi, \sigma)$. If $k = \perp$, return $\perp$. Else return $\text{SDec}(k, e)$.

Fig. 5 Scheme BZB1

is analyzed [23]. This is partially true as the BZB1 scheme basically follows the KEM/DEM framework. However, the security notion of stateful public key encryption requires more in that an adversary has a capability to produce receivers' public key except for the target receiver (i.e., R_1 , as described in Definition 2) and come up with ciphertexts that correspond to these public keys and a (given) state. For this reason, BZB defined a new notion called “reproducibility of PKEM” meaning that in the KSK model, an adversary can produce ciphertexts associated with the public keys that he has created and the given state. Note that this notion makes sense only in the KSK model, because the adversary is supposed to know corresponding private keys of other receivers' public keys except for the target receiver's one. In the USK model, we may not need this property.

Indeed, BZB showed that in the KSK model, the above BZB1 scheme is IND-CCA secure without random oracles [11], provided that the underlying PKEM is reproducible. However, with respect to the USK model, BZB proposed another construction based on the random oracle, which we denote by BZB2. Note that this scheme does not require the reproducibility of PKEM. In Fig. 6, we describe the scheme BZB2.

The above scheme is shown to be IND-CCA secure, provided that H is a *random oracle* and the PKEM scheme satisfies OW-ECKA, meaning “one-wayness (OW) under extended key checking attack (EKCA)”. (Note that in KCA [2], an adversary queries a key and ciphertext pair to a key checking oracle, which verifies whether the given ciphertext encapsulates the given key. BZB strengthens this notion so that an adversary can select a public key at will and include this in the key and ciphertext query.)

Setup(1^λ): This algorithm simply returns the system parameter sp output by the Setup algorithm of the PKEM scheme.

KG(sp): This algorithm returns the pair of private and public keys (sk, pk) returned by the KG algorithm of the PKEM scheme.

PKCk(sp, pk): Run the algorithm PKV which checks if a given key pk is in the range of outputs of the KG algorithm.

NwSt(sp): Compute $(\omega, \psi) \leftarrow \text{Encap1}(sp)$, set $st = (\omega, \psi)$ and return st .

Encrypt(sp, pk, st, m): If $st = (\omega, \psi)$ or $st = (\omega, \psi, pk', \sigma', \tilde{k}')$ with $pk' \neq pk$, compute $(\sigma, k) \leftarrow \text{Encap2}(sp, pk, \omega, \psi)$ and $\tilde{k} \leftarrow H(\phi, pk, \sigma, k)$. Else parse st into $(\omega, \psi, pk, \sigma, k)$. Then, perform the following: Compute $e \xleftarrow{R} \text{SEnc}(\tilde{k}, m)$, set $c = (\psi, \sigma, e)$ and $st = (\omega, \psi, pk, \sigma, \tilde{k})$, and return (c, st) .

Decrypt(sp, sk, c): Parse c into (ψ, σ, e) and compute $k \leftarrow \text{Decap}(sp, sk, \psi, \sigma)$. If $k = \perp$, return $\perp$. Else compute $\tilde{k} \leftarrow H(\psi, pk, \sigma, k)$ and return $\text{SDec}(\tilde{k}, e)$.

Fig. 6 Scheme BZB2

The benefit of the generic construction is clear: BZB was able to construct several new stateful PKE schemes based on public-key encryption schemes of Boneh and Katz [19], Kiltz [32], and Boyen, Mei and Waters [21].

5 Extended Schemes

It would be natural to ask whether stateful PKE schemes can be extended to have other functionalities. The answer is positive. In this section, we review stateful PKE schemes with additional features, which we call “extended schemes”.

5.1 Nongeneric Schemes

Phong–Matsuoka–Ogata: Stateful Identity-Based Encryption Scheme Phong, Matsuoka and Ogata (PMO) [41] proposed the concept of stateful identity-based encryption (IBE) and constructed a scheme that realizes it using Boneh and Franklin’s IBE scheme based on pairing [17]. In IBE, public keys are represented by arbitrary strings, called “identities”, not by numbers that verified using digital certificates. Any party in possession of the identities can send confidential messages by encrypting their messages using those identities. However, identity-based encryption has been regarded as an inefficient cryptographic primitive as the relatively expensive *pairing operation* is inevitable. Hence, it is imperative to improve computational efficiency of IBE schemes and PMO tackled this problem through the randomness reuse technique

Setup(1^λ): Generate two groups $\mathbb{G}$ and $\mathbb{G}_t$ of prime order p such that $||p|| = \lambda$ and a pairing $e : \mathbb{G} \times \mathbb{G} \rightarrow \mathbb{G}_t$; denote a generator of $\mathbb{G}$ by g ; construct two hash functions $H_1 : \{0, 1\}^n \rightarrow \mathbb{G}^*$, where n is the length of an identity (an identifier string), and $H_2 : \mathbb{G} \times \mathbb{G} \times \mathbb{G}_t \rightarrow \{0, 1\}^k$, where k is the length of the key of symmetric encryption; choose master key $x \in \mathbb{Z}_p$ uniformly at random and compute $y = g^x$; construct a symmetric encryption scheme (E, D) ; return a system parameter $sp = (\mathbb{G}, \mathbb{G}_t, e, p, g, H_1, H_2, y, E, D)$ while keep $mk = x$ as secret.

Extract(sp, ID): Compute $d_{ID} = H_1(ID)^x$ for an identity ID ; return $sk_{ID} = d_{ID}$ as a private key for ID .

NwSt(sp): Choose $r \in \mathbb{Z}_p^*$ uniformly at random; compute $u = g^r$ and $\psi = y^r$; return a state $st = (u, \psi)$.

Encrypt(sp, pk, st, m): Parse st into (u, ψ) ; compute $q_{ID} = H_1(ID)$, $\omega = e(q_{ID}, y)$, $k = H_2(u, q_{ID}, \omega)$ and $v = E(k, m)$ for a plaintext m ; return a ciphertext $c = (u, v)$.

Decrypt(sp, sk_{ID}, c): Parse sk_{ID} into d_{ID} and c into (u, v) ; compute $q_{ID} = H_1(ID)$, $\omega = e(d_{ID}, y)$ and $k = H_2(u, q_{ID}, \omega)$; return $D(k, v)$ (which is either m or $\perp$).

Fig. 7 Scheme PMO

employees in stateful PKE schemes. Their scheme, which we denote by “PMO”, is described in Fig. 7.

Note that in the above scheme, ω^r can be saved in st (the current state) so that the pairing operation will be bypassed until a new state is created.

PMO showed that the above scheme is “IND-ID-CCA” secure under the assumption that the GBDH problem (Definition 6) is intractable in the random oracle model. Note that PMO’s IND-ID-CCA definition refers to a security notion similar to that of the stateful PKE except that an adversary has full power to obtain private keys associated with any identities other than a target identity [41]. Note also that since the adversary has access to private keys that correspond to the identities of his choice, the distinction between the USK and KSK models is no longer necessary. (That is, their security analysis holds in the KSK model.)

Baek et al.: Forward-Secure Stateful Public-Key Encryption Scheme Note that the ephemeral exponent r stored in the state variable st should be protected; otherwise, ciphertexts created under the same r can be decrypted by an adversary who has acquired it. Baek et al. [10] addressed this issue of so-called “state exposure” by making state evolving over time: Despite exposure of a current state, all the ciphertexts created under the states *before* the current exposure do not lose security. In other words, their scheme is “forward-secure”. In Fig. 8, we describe their scheme denoted by “BVSJW”.

GenSP(λ): Generate a multiplicative group $\mathbb{G}$ of prime order $\|\mathbb{G}\| = \lambda$; denote a generator of $\mathbb{G}$ by g ; construct a hash function $H : \mathbb{G}^3 \rightarrow \{0, 1\}^v$ such that $v = v_L + v_R$ where $v_L > 0$ and $v_R > 0$. (Note that the value of v is determined by the value of λ), a pseudorandom generator $G : \{0, 1\}^{v_R} \rightarrow \{0, 1\}^v$ and a symmetric encryption scheme (E, D) ; return a system parameter $sp = (\mathbb{G}, p, g, H, G, E, D)$.

GenKey(sp): Choose $x \in \mathbb{Z}_p^*$ uniformly at random; compute $y = g^x$; return a public key $pk = y$ and a private key $sk = x$.

PKCk(sp, pk): Check if y is an element of $\mathbb{G}$. If $y \in \mathbb{G}$, return 1. Else return 0.

NwSt(sp, pk): Choose $r \in \mathbb{Z}_p^*$ uniformly at random; compute $u = g^r$ and $\kappa = y^r$; compute $(k_0, h_0) \leftarrow H(u, y, \kappa)$, where $k_0 \in \{0, 1\}^{v_L}$ and $h_0 \in \{0, 1\}^{v_R}$; delete r and κ ; return an initial state $st_0 = (u, k_0, h_0)$.

StUpdate(sp, i, st_i) for $0 \leq i < T$: Parse st_i into (u, k_i, h_i) ; compute $(k_{i+1}, h_{i+1}) \leftarrow G(h_i)$, where $k_{i+1} \in \{0, 1\}^{v_L}$ and $h_{i+1} \in \{0, 1\}^{v_R}$; set $st_{i+1} = (u, k_{i+1}, h_{i+1})$; return $(i + 1, st_{i+1})$ and delete st_i .

Enc(sp, pk, i, st_i, m) for $1 \leq i \leq T$: Parse st_i into (u, k_i, h_i) ; compute $v = E(k_i, m)$; set $\psi = (u, v)$; return (i, ψ) .

Dec(sp, sk, i, ψ): Parse ψ into (u, v) . If $u \notin \mathbb{G}$, return $\perp$ (reject). Else compute $\kappa = u^x$, $(k_0, h_0) \leftarrow H(u, y, \kappa)$ and $(k_i, h_i) \leftarrow G^i(h_0)$; return $m = D(k_i, v)$.

Fig. 8 Scheme BVSJW

Baek et al. showed that in the KSK model, the BVSJW scheme is “IND-FS-CCA” secure assuming that the DDH problem is intractable; the pseudorandom generator G is forward-secure; and the symmetric encryption scheme (E, D) is IND-CCA secure. (Note that the IND-FS-CCA is an extended notion of the usual IND-CCA to the setting of forward security (FS) amid state exposure.)

5.2 Generic Schemes

Nguyen–Tanaka–Yasunaga: Generic Construction of Leakage Resilient Stateful Public-Key Encryption Nguyen, Tanaka and Yasunaga (NTY) [38] proposed a generic construction of a PKE scheme which is secure against a posteriori chosen ciphertext and key-leakage attacks; we denote this notion of security by “IND-LR-CCA”. Their construction is based on the universal hash proofs that Cramer and Shoup [22, 23] proposed to provide PKE with chosen ciphertext security to generalize Naor and Segev’s scheme to construct a PKE scheme secure against key-leakage attacks [37]. In the same paper, NTY modified their scheme to provide efficient encryption through stateful PKE technique.

Setup(1^λ): Compute $sp_1 \leftarrow \text{Param}_1(1^\lambda)$ and $sp_2 \leftarrow \text{Param}_2(1^\lambda)$; set $sp = (sp_1, sp_2)$; return sp .

KGen(sp): Parse sp into (sp_1, sp_2) ; compute $(sk_1, pk_1) \leftarrow \text{KGen}_1(sp_1)$ and $(sk_2, pk_2) \leftarrow \text{KGen}_2(sp_2)$; set $sk = (sk_1, sk_2)$ and $pk = (pk_1, pk_2)$; return (sk, pk) .

PKCk(sp, pk): Return 1.

NwSt(sp): Sample $(x, w) \xleftarrow{R} \mathcal{R}_L$ and set $st = (x, w)$; return st .

Encrypt(sp, pk, st, m): If $st = (x, w)$ then compute $\pi_1 \leftarrow \text{Pub}_1(pk_1, x, w)$. Else parse st into (x, w, pk, π_1) . Then, perform the following: Compute $e \xleftarrow{R} \text{E}(\pi_1, m)$ and $\pi_2 \leftarrow \text{Pub}_2(pk_2, x, w, e)$; return $c = (x, e, \pi_2)$ and a new state $st = (x, w, pk, \pi_1)$.

Decrypt(sp, sk, c): Parse sk into (sk_1, sk_2) and c into (x, e, π_2) ; compute $\pi'_2 \leftarrow \text{Priv}_2(sk_2, x, e)$. If $\pi'_2 \neq \pi_2$, return $\perp$. Else compute $\pi_1 \leftarrow \text{Priv}_1(sk_1, x)$; return $\text{D}(\pi_1, e)$.

Fig. 9 Scheme NTY

First, we provide some preliminaries to describe NTY's scheme. Let X , W , and L be non-empty sets, where $L \subset X$. Let $\mathcal{R}_L \subset X \times W$ be a binary relation. For $x \in X$ and $w \in W$ satisfying $(x, w) \in \mathcal{R}_L$, w is said to be a witness for x . Let $\text{HPS}_1 = (\text{Param}_1, \text{KGen}_1, \text{Pub}_1, \text{Priv}_1)$ be an 1-universal λ -key-leakage extractor hash proof system for a language L ; let $\text{HPS}_2 = (\text{Param}_2, \text{KGen}_2, \text{Pub}_2, \text{Priv}_2)$ be an extended 2-universal hash proof system for the same language L . Let (E, D) be a symmetric encryption scheme. By $(x, w) \xleftarrow{R} \mathcal{R}_L$, we denote an instance sampling algorithm of L , which chooses a random pair (x, w) satisfying $x \in X$, $w \in W$ and $(x, w) \in \mathcal{R}_L$. Now, in Fig. 9, we describe NTY's scheme, denoted by "NTY".

Note that NTY provided an instance of their generic construction using Cramer and Shoup's famous hash proof system [23]; its security is proven under the assumption that the DDH problem (Definition 5) is intractable.

Yang–Zhang–Matsuura–Imai: Generic Construction of Stateful Identity-Based Encryption Yang, Zheng, Matsuura and Imai (YZMI) generalized the result of PMO to propose a generic construction of stateful IBE [47], which we denote by "YZMI". The basic idea of their construction is to design a stateful identity-based key encapsulation mechanism (SIBKEM) scheme and combine it with the symmetric encryption (i.e., DEM) to construct a full stateful PKE scheme following the KEM/DEM framework [23]. Note that YZMI's SIBKEM scheme uses the identity-based noninteractive key exchange scheme IBNIKE that consists of Setup, Ext, Sample, Shr, Shr', and Shr'': Setup and Ext algorithms are usual ones that generate system parameters sp and a private key sk_{ID} associated with a given identity ID , respectively. Sample gen-

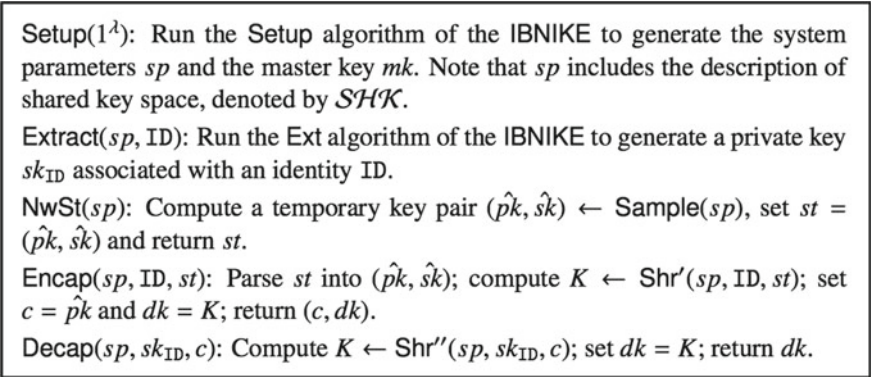


Fig. 10 Scheme YMZI

erates a temporary pair of public and private keys $(\hat{pk}, \hat{sk})$. On input $sp, \hat{sk}$, and ID , Shr generates a shared (common) key K . On input $sp, \hat{pk}$, and sk_{ID} , Shr generates a shared key K . A requirement here is that Shr' and Shr'' will generate the same key K .

Now, we describe YMZI’s SIBKEM scheme, which we denote by YMZI in Fig. 10. In Table 1, we summarize all the schemes discussed in this chapter.

Table 1 Summary of stateful public-key encryption schemes and extensions: below, “RO” means the security analysis is provided in the random oracle model and “NRO” means the security analysis is provided in the standard model (i.e., without random oracle). Other abbreviations are explained throughout this chapter

Functionality	Generality	Name	Security	Described in
Basic	Nongeneric	BKS1 [16]	IND-CCA, USK/GDH/RO	Sect. 4.1
		BKS2 [16]	IND-CCA, KSK/DDH/NRO	Sect. 4.1
		BCZ [9]	IND-CCA, USK/GDH/RO	Sect. 4.1
	Generic	BZB1 [8]	IND-CCA, KSK/NRO	Sect. 4.2
		BZB2 [8]	IND-CCA, USK/RO	Sect. 4.2
Extended	Nongeneric	PMO [41]	IND-ID-CCA, KSK/GBDH/RO	Sect. 5.1
		BVSJW [10]	IND-FS-CCA, USK/GDH/RO	Sect. 5.1
	Generic	NTY [38]	IND-LR-CCA, KSK/NRO	Sect. 5.2
		YZMI [47]	IND-ID-CCA, KSK/NRO	Sect. 5.2

6 Implementations and Applications

It is rather interesting if not surprising that despite the simplicity, efficiency, and proven security, stateful PKE schemes have not been used in practice actively. To our knowledge, the only implementation of a stateful PKE scheme reported in the literature is Baek et al. [7] stateful ElGamal scheme implemented on a micaZ wireless sensor [48]. This work shows that randomness reuse technique used in the stateful PKE results in significant energy saving: According to [7], an (non-stateful) ElGamal scheme consumes nearly 8.5 times more energy than its stateful counterpart. Also, their implementation shows that it is feasible to realize public-key cryptography for resource-constrained devices like sensors.

Very recently, a stateful IBE scheme has been applied to secure smart home application [4].—Readers are referred to Fig. 11. Their implementation also shows that the randomness reuse technique also leads to significant reduction in encryption operation.

We argue that due to the efficiency gains, stateful PKE schemes can serve as good asymmetric encryption primitives for securing devices that have limited power and communication capacity such as wireless sensors and other similar devices [3]. So far, symmetric encryption schemes have been preferred to provide security for the resource-constrained environments because almost all symmetric encryption schemes are efficient in general and hence consume less energy, compared with asymmetric ones [29, 31]. However, the old key management problem still remains: How can the keys among devices be shared efficiently? Although it is computationally more expensive, PKE is still useful to solve the problem. But the implementation/simulation results mentioned in the beginning of this section show that stateful PKE schemes provide the efficiency level comparable to symmetric encryption.

We envision that a very potential area where stateful PKE schemes can play an important role in security is the Internet of Things (IoT) [5, 34, 46]. Note that as IoT involves a number of low-powered mobile devices, it is imperative to provide *lightweight* cryptographic solutions for it.

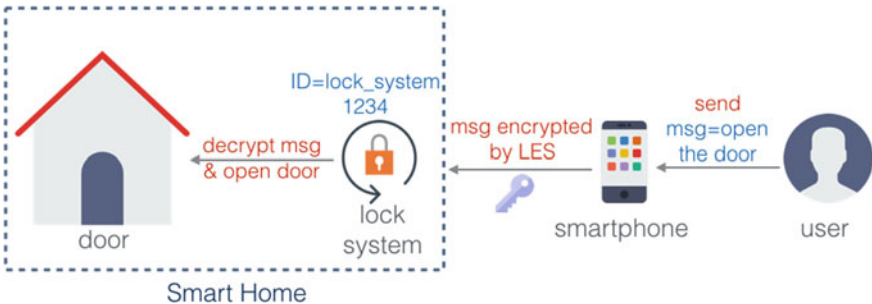


Fig. 11 Stateful identity-based encryption for smart home

One possible scenario is a nuclear power plant where sensors (IoT devices) are placed in various locations [30, 45]. These sensors often need to transmit sensitive information such as radiation level and control commands to base station. One can use symmetric encryption to provide such data with confidentiality but it would be difficult to manage multiple (symmetric) keys for numerous sensors. To alleviate this, one can employ a PKE scheme to have sensors encrypt their data using the base station's public key. However, if a regular PKE scheme is used, computational overheads will have impact the battery life of sensors. In this case, one may employ a stateful PKE scheme to provide efficient encryption for sensors.

In fact, in the area of IoT, there has been some endeavors to realize public-key cryptography in the resource-constrained devices. Ayuso et al. demonstrated that ECC can be optimized for devices of IPv6 over Low-power Wireless Personal Area Networks (6LoWPAN) [6]. Later, Shafagh implemented the standard certificate-based cipher suite of the Datagram Transport Layer Security (DTLS) protocol on a resource-constrained device [43]. On the one hand, both works present the feasibility of employing public-key cryptography in the area of IoT, but on the other hand, they pose the problem of optimizing further to enhance performance.

7 Open Problems

In this chapter, we closely investigated the concept and security notion of stateful PKE schemes. We then surveyed a number of stateful PKE schemes in the literature after classifying them through their functionality and generality. We also investigated existing implementations of stateful PKE schemes and discussed their efficiency implication toward *lightweight public-key cryptography*.

The purpose of this survey is to provide practitioners of security engineering with an overview and a directive for stateful PKE, which, we envision, can serve as a good asymmetric primitive for securing devices which are power-constrained.

In terms of future research on stateful PKE, we envision that the following two directions are interesting to pursue.

1. Searching for more applications: As discussed throughout this chapter, the randomness reuse technique of stateful PKE schemes leads to a very efficient public-key encryption process. This could be useful in many applications where entities that need to perform public-key encryption operations are lack of power resources and hence, it is important for them to have lightweight encryption algorithm. One immediate application is the asymmetric environment of Wireless Sensor Network (WSN), in which numerous sensors need to send confidential messages to more powerful base stations. However, we envision that not only WSN but also other mobile network systems with public-key cryptography capacity [24, 28] would be benefitted from stateful PKE. For instance, stateful PKE implementation could be considered in the DTLS protocol with the mode of *RawPublicKey* and/or *Certificate* mode to secure the constrained application protocol (CoAP)

messages for IoT communications [29]. Applying stateful PKE to various platform settings and protocols would introduce a number of challenges.

2. Searching for alternative computational primitives related to stateful PKE: So far dominant computational problems used in various stateful public-key encryptions are all related to the Diffie–Hellman problems as reviewed in Sect. 2.4. Even if there exist generic constructions of stateful PKE, a challenging problem is to construct stateful PKE schemes based on computational problems other than Diffie–Hellman ones. Constructing such schemes in the USK model with the help of random oracles would not be very difficult but constructing such schemes in the KSK model without random oracles would be much harder. For example, can we construct a stateful public-key encryption scheme using Paillier’s encryption [40] in the KSK model without random oracles? Another question is how to extend PMO’s result [41] to construct a stateful IBE scheme with a different structure, for example, following the structure of Boneh and Boyen’s IBE scheme [18].

References

1. Abdalla, M., Bellare, M., & Rogaway, P. (2001). The oracle Diffie–Hellman assumptions and an analysis of DHIES. In *Proceedings of CT-RSA '01* (Vol. 2020, pp. 143–158). LNCS. Berlin: Springer.
2. Abe, M. (2004). Combining encryption and proof of knowledge in the random oracle model. *The Computer Journal*, 47(1), 58–70.
3. Akyildiz, I., & Kasimoglu, I. (2004). Wireless sensor and actor networks: Research challenges. *Ad Hoc Networks*, 2(4), 351–367.
4. Al Salami, S., Baek, J., Salah, K., & Damiani, E. (2016). Lightweight encryption for smart home. In *ARES '16* (pp. 382–388).
5. Atzori, L., Iera, A., & Morabito, G. (2010). The internet of things: A survey. *Computer Networks* 2787–2805. Elsevier.
6. Ayuso, J., Marin, L., Jara, A., & Skarmeta, A. (2010). Optimization of public key cryptography (RSA and ECC) for 16-bits devices based on 6LoWPAN. In *1st International Workshop on the Security of the Internet of Things*.
7. Baek, J., Tan, H., Zhou, J., & Wong, J. (2008). Realizing stateful public key encryption in wireless sensor network. In *Proceedings of the IFIP TC 11 23rd International Information Security Conference* (pp. 95–107). Berlin: Springer.
8. Baek, J., Zhou, J., & Bao, F. (2008). Generic constructions of stateful public key encryption and their applications. In *Proceedings of ACNS 2008* (Vol. 5037, pp. 75–93). LNCS. Berlin: Springer.
9. Baek, J., Chu, C., & Zhou, J. (2011). On shortening ciphertexts: New constructions for compact public key and stateful encryption schemes. In *Proceedings of CT-RSA* (Vol. 6558, pp. 302–318). LNCS. Berlin: Springer.
10. Baek, J., Vu, Q., Shoufan, A., Jones, A., & Wong, D. S. (2013). Stateful public-key encryption schemes forward-secure against state exposure. *The Computer Journal*, 56(4), 497–507.
11. Bellare, M., & Rogaway, P. (1993). Random oracles are practical: A paradigm for designing efficient protocols. In *Proceedings of ACM-CCS '93* (pp. 62–73). ACM.
12. Bellare, M., & Namprepre, C. (2000). Authenticated encryption: Relations among notions and analysis of the generic composition paradigm. In *Asiacrypt '00* (Vol. 1976, pp. 531–545). LNCS. Berlin: Springer.

13. Bellare, M., Canetti, R., & Krawczyk, H. (1996). Keying hash functions for message authentication. In *Crypto '96* (Vol. 1109, pp. 1–15). LNCS. Berlin: Springer.
14. Bellare, M., Desai, A., Jorikpi, E., & Rogaway, P. (1997). A concrete security treatment of symmetric encryption. In *Proceedings of FOCS '97* (pp. 394–403).
15. Bellare, M., Desai, A., Pointcheval, D., & Rogaway, P. (1998). Relations among notions of security for public-key encryption schemes. In *Crypto '98* (Vol. 1462, pp. 26–45). LNCS. Berlin: Springer.
16. Bellare, M., Kohno, T., & Shoup, V. (2006). Stateful public-key cryptosystems: How to encrypt with one 160-bit exponentiation. In *Proceedings of ACM-CCS '06* (pp. 380–389). ACM Press.
17. Boneh, D., & Franklin, M. (2003). Identity based encryption from the Weil pairing. *SIAM Journal of Computing* 32(3), 586–615. (Extended abstract in *Crypto '01* (Vol. 2139, pp. 213–229). LNCS. Berlin: Springer (2001)).
18. Boneh, D., & Boyen, X. (2004). Efficient selective-ID secure identity-based encryption without random oracles. In *Proceedings of Eurocrypt '04* (Vol. 3027, pp. 223–238). LNCS. Berlin: Springer.
19. Boneh, D., & Katz, J. (2005). Improved efficiency for CCA-secure cryptosystems built using identity-based encryption. In *CT-RSA '05* (Vol. 3376, pp. 87–103). LNCS. Berlin: Springer.
20. Boyen, X. (2008). A tapestry of identity-based encryption: Practical frameworks compared. *International Journal of Applied Cryptography*, 3–21. Inderscience.
21. Boyen, X., Mei, Q., & Waters, B. (2005). Direct chosen ciphertext security from identity-based techniques. In *ACM-CCS 2005* (pp. 320–329). New York: ACM Press.
22. Cramer, R., & Shoup, V. (2002). Universal hash proofs and a paradigm for adaptive chosen ciphertext secure public-key encryption. In *Eurocrypt '02* (Vol. 2332, pp. 45–64). LNCS. Berlin: Springer.
23. Cramer, R., & Shoup, V. (2003). Design and analysis of practical public-key encryption schemes secure against adaptive chosen ciphertext attack. *SIAM Journal of Computing*, 33, 167–226.
24. Dankers, J., Garefalakis, T., Schaffelhofer, R., & Wright, T. (2002). Public key infrastructure in mobile systems. *Electronics & Communication Engineering Journal*, 14(5), 180–190. IEE.
25. Diffie, W., & Hellman, M. (1976). New directions in cryptography. *IEEE Transactions on Information Theory*, 22(6), 644–654.
26. ElGamal, T. (1985). A public key cryptosystem and a signature scheme based on discrete logarithms. *IEEE Transactions on Information Theory*, 31, 469–472.
27. Galbraith, S., Paterson, K., & Smart, N. (2008). Pairings for cryptographers. *Discrete Applied Mathematics*, 156, 3113–3121.
28. Gaubatz, G., Kaps, J.-P., & Sunar, B. (2004). Public key cryptography in sensor networks revisited. In *1st European Workshop on Security in Ad-Hoc and Sensor Networks (ESAS 04)*.
29. Granjal, J., Monteiro, E., & Silva, J. S. (2015). Security for the internet of things: A survey of existing protocols and open research issues. *IEEE Communication Surveys & Tutorials*, 17(3), 1294–1312.
30. Hashemian, H. M. (2005). *Sensor Performance and Reliability*. Research Triangle Park, North Carolina: ISA (Instrumentation Systems, and Automation Society).
31. Katagi, M., & Moriai, S. (2011). *Lightweight cryptography for the internet of things*. Technical report, Sony Corporation.
32. Kiltz, E. (2007). Chosen-ciphertext secure key-encapsulation based on gap hashed Diffie–Hellman. In *PKC '07* (Vol. 4450, pp. 282–297). LNCS. Berlin: Springer.
33. Kurosawa, K., & Desmedt, Y. (2004). A new paradigm of hybrid encryption scheme. In *Crypto '04* (Vol. 3152, pp. 426–442). LNCS. Berlin: Springer.
34. Mattern, F., & Floerkemeier, C. (2010). From the internet of computers to the internet of things. *From Active Data Management to Event-Based Systems and More* (pp. 242–259). Berlin: Springer.
35. Merkle, M. (1978). Secure communications over insecure channels. *Communications of the ACM*, 21(4), 294–299.
36. Naor, M., & Yung, M. (1989). Universal one-way hash functions and their cryptographic applications. In *STOC '89* (pp. 33–43). ACM.

37. Naor, M., & Segev, G. (2009). Public-key cryptosystems resilient to key leakage. In *Crypto '09* (Vol. 5677, pp. 18–35). LNCS. Berlin: Springer.
38. Nguyen, M., Yasunaga, K., & Tanaka, K. (2013). Leakage-resilience of stateless/stateful public-key encryption from hash proofs. *IEICE Transactions*, 96-A(6), 1100–1111.
39. Okamoto, T., & Pointcheval, P. (2001). REACT: Rapid enhanced-security asymmetric cryptosystem transform. In *Proceedings of CT-RSA '01* (Vol. 2020, pp. 159–175). LNCS. Berlin: Springer.
40. Paillier, P. (1999). Public-key cryptosystems based on composite degree residuosity classes. In *Eurocrypt '99* (Vol. 1592, pp. 223–238). LNCS. Berlin: Springer.
41. Phong, L., Matsuoka, H., & Ogata, W. (2008). Stateful identity-based encryption scheme: Faster encryption and decryption. In *Proceedings of ASIACCS '08* (pp. 381–388). ACM.
42. Rivest, R., Shamir, A., & Adleman, L. (1978). A method for obtaining digital signatures and public key cryptosystems. *Communications of the ACM*, 21(2), 120–126.
43. Shafagh, H. (2013). *Leveraging public-key-based authentication for the internet of things*. Master thesis, RWTH Aachen University, Germany.
44. Shoup, V. (2001). A proposal for an ISO standard for public key encryption (version 2.1). In *ISO/IEC JTC 1/SC 27*.
45. US Nuclear Regulatory Commission. (1998). Advanced instrumentation and maintenance technologies for nuclear power plants. In *NUREG/CR-5501*, Washington DC.
46. Yan, Z., Zhang, P., & Vasilakos, A. V. (2014). A survey on trust management for internet of things. *Journal of Network and Computer Applications*, 42, 120–134.
47. Yang, P., Zhang, R., Matsuura, K., & Imai, H. (2009). Generic construction of stateful identity based encryption. In *Proceedings of ISC '09* (Vol. 5735, pp. 338–346). LNCS. Berlin: Springer.
48. ZigBee Alliance. (2016). MICAz, Wireless measurement system. Retrieved June 2016, from http://www.memsic.com/userfiles/files/Datasheets/WSN/micaz_datasheet-t.pdf.

Non-intrusive Load Monitoring Algorithms for Privacy Mining in Smart Grid



Zijian Zhang, Jialing He, Liehuang Zhu and Kui Ren

Abstract Non-intrusive load monitoring (NILM) method is essentially artificial intelligence algorithms for energy conservation and privacy mining. It obtains consumers' privacy data by decomposing aggregated meter readings of consumer energy consumption into the individual devices energy consumption. In this chapter, we first introduce the background and the advantage of the NILM method, and the classification of NILM method. Secondly, we demonstrate the general process of NILM method. The specific process contains data preprocess, event detection and feature extraction, and energy consumption learning and appliance inference. Furthermore, we introduce a supervised NILM example and an unsupervised example. We describe their processes, and discuss their characteristics and performances. In addition, the applications of NILM method are depicted. Lastly, we conclude this chapter and give the future work.

1 Introduction

Nowadays, Smart grid [62] is usually equipped with smart meters to allow utility companies to monitor the grid more granularly, which allows them to predict changes in demand more accurately, detect failures more quickly and adapt pricing and electricity generation more dynamically. It is common knowledge that utility companies all over the world are very willing to be bringing in time-of-day usage data. This

Z. Zhang · J. He (✉) · L. Zhu

School of Computer Science and Technology, Beijing Institute of Technology, Beijing 100081, People's Republic of China

e-mail: hejialing@bit.edu.cn

Z. Zhang

e-mail: zhangzijian@bit.edu.cn

L. Zhu

e-mail: liehuangz@bit.edu.cn

K. Ren

Institute of Cyber Security Research and School of Computer Science and Engineering, Zhejiang University, Hangzhou 310058, China

© Springer Nature Singapore Pte Ltd. 2019

K.-C. Li et al. (eds.), *Advances in Cyber Security: Principles,*

Techniques, and Applications, https://doi.org/10.1007/978-981-13-1483-4_2

data tries to discourage electricity consumption among the peak hours and defers these consumptions to off-peak time (a.k.a. peak shaving). When the tariffs are flexibly adjusted due to peak shaving, smart meters are crucial to monitor customers' electricity consumption data at a high time resolution, in order to remind customers' uneconomical usages of electricity appliances in real time. Smart meters also benefits customers as they can monitor and adapt their energy consumption in real time to reduce costs.

Apart from the benefits to the utility companies and customers, smart meters are also favored by the electricity manufacturers, advertisement companies and insurance companies because meter readings can uncover the customers' activities in houses by Appliance Load Monitoring (ALM) methods. Generally, the usage of a certain electrical device, e.g. a computer or an air conditioner etc., can be identified via monitoring of the meter readings. In a special case, even the program on TV can be identified based on its corresponding electricity usage. The in-house activities and when they occur have highly commercial value for habit and preference perception, personalized advertisement push, insurance and risk evaluation.

There are two major approaches to monitor the energy consumption of appliances, normally are called Intrusive Load Monitoring (ILM) and Non-Intrusive Load Monitoring (NILM) [1–3]. The ILM approach requires to install multiple meters in houses. These meters take responsibility for recording the energy consumption of all the appliances incessantly. Although the results of ILM approach are usually accurate, it is impractical because of its high demanding costs, multiple meter configurations and the process for installation is very complicated as well [4–6]. On the contrary, the NILM approach is convenient to be implemented as it merely needs to install a single meter outside houses [7–10]. The non-intrusive load monitoring system diagram is depicted in Fig. 1. However, since no special hardware or software is assumed to be installed or run in the customer residences, the working status of each appliance is a completely black box. The only way to analyze the customers' activities has to disaggregate the high resolution meter readings directly. Therefore, the precision of the detection and the largest number of the electricity appliances are both limited. Table 1 compares the advantage and disadvantage of the ILM and NILM methods. From the viewpoint of the practicability and cost, the NILM methods outperform ILM methods because the NILM methods do not intrude the customers' residences and they require only one smart meter. Therefore, this chapter mainly focuses on introducing the NILM approach, and the effort to increase the number of the appliances and to improve the accuracy of the result.

2 General Process of the NILM Approach

The task of the NILM approach aims to disaggregate a aggregated electricity signal that often means the power consumption into the involved individual devices' contributions [3]. Formally, for the total aggregation consumption $Y (Y \in Y_1, Y_2, \dots, Y_T)$ of all the appliances in the house at the time $t (t \in 1, 2, \dots, T)$, the purpose of the

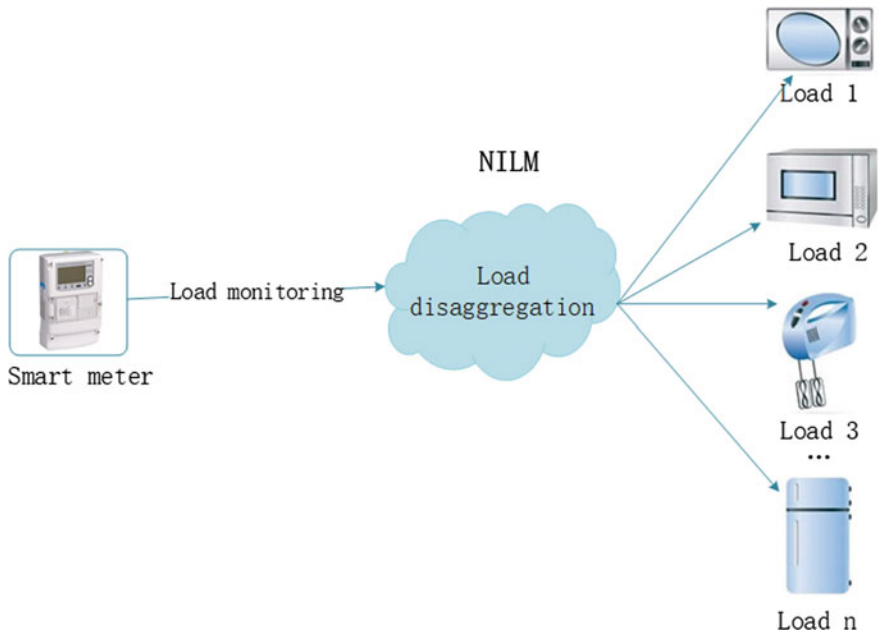


Fig. 1 The non-intrusive load monitoring system diagram

Table 1 The advantage and disadvantage of the ILM and NILM approaches

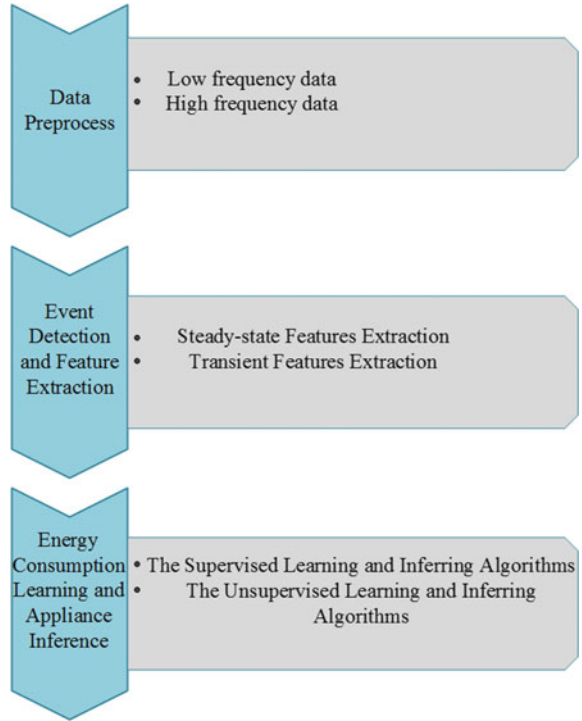
Parameters	ILM	NILM
Indoors installation	Necessary	Not necessary
Numbers of smart meter	Large	Only one
Numbers of electricity appliances	Small	Large
Accuracy	Relatively high	Relatively low

NILM approach is to recover the consumption y_t^i of the $i - th$ device at time t . If there are N appliances in total, and $i \in 1, 2, \dots, N$, we have $Y_t = \sum_1^N y_t^i$.

The general process of the NILM approach often requires three steps, as shown in Fig. 2. First is data acquisition. This step processes the raw smart meter readings, mostly for the missing consumption or outliers. Next is event detection. In this step, the task is to capture the major change of the power consumption through the smart readings. These major changes of the power consumption often can identify the related appliance because the changes usually happen when the appliance turned on or off. Finally, the specific NILM algorithms are designed to infer the usage of the electric appliances due to the feature of their energy consumption.

According to the operation mode of the appliance, all the appliances can be divided into four types [13].

Fig. 2 The general process of the NILM approach



Type 1: ON/OFF Appliances belong to this category only has two states of operations (ON/OFF). Most of the appliances like TV and toaster are belonged to this category.

Type 2: Finite State Machines (FSM) These appliances own two or more operating states (the number is finite). And whole switching cycle is repeated frequently among these states. Examples of such devices include refrigerator (OFF/ON/Defrost) and dryer (OFF/Heater + Motor/Motor only).

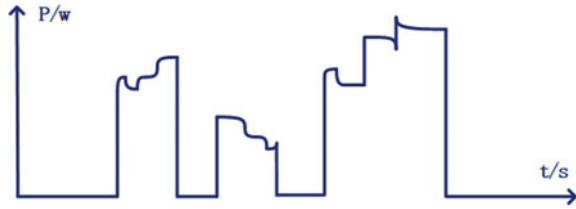
Type 3: Continuously Variable Consumer Device Appliances belong to this category with variable power draw but without fixed number of states. The regular rules of these appliances' power consumption is hard to capture because there is no repeatability. It causes the difficulty for NILM algorithm to disaggregate them from the aggregated load. Devices like power drill and dimmer lights are in this category.

Type 4: Permanent Consumer Device Devices like smoke detector belong to this category because the rate they consuming energy remains active and constant through days, weeks or even months.

2.1 Data Preprocess

In the NILM approach, data preprocess is the first step to deal with the raw aggregated consumption that is generated by a smart meter at a regular rate. According to the

Fig. 3 The power monitored of appliances



size of the sampling frequency, the aggregated consumption data can be divided into two types. One is low frequency data and the other is high frequency data [11, 12, 61].

From the viewpoint of low frequency, it is usually no more than 1 Hz. The sampling time interval is about 1/60 second. The cost of low frequency meters is inexpensive, but only major power changes can be captured from low frequency data [1]. From the viewpoint of high frequency, it varies from 10 KHz to 100 MHz. The cost of high frequency meters is expensive, but more information like outliers can be obtained from high frequency data [13].

Several benchmark datasets, such as BLUED [14] and REDD [15] are currently available to be downloaded. These datasets contain both the low-frequency data and the high-frequency data. For instance, the REDD dataset provides the low-frequency data with 1 Hz and high-frequency data with 15 KHz. This dataset collects energy consumption data in 6 houses for more than one month. As a benchmark dataset, it not only has the aggregated meter readings but also has the energy consumption of each individual appliance. If a dataset misses part of energy consumption data, the average of the neighboring data could be filled to achieve data integrity.

2.2 Event Detection and Feature Extraction

In the NILM approach, the event detection is critical for disaggregation as it helps to recognize the working states of the appliances. Here we define an event as a major change of the meter readings. The event detection has a complex process because of the multiple kinds and working states of the electricity appliances. In fact, two states, finite state, continuously variable states and constant states are four kinds of states according to the pattern of their energy consumption [16, 60].

Event detection algorithms concentrate on analyzing all the events in the consumption data. Roughly, when an event occurs, some operations must be run for some electricity appliances. For instance, for a two-state appliance, the operations could be switching the appliance on or off. Almost all the event detection algorithms rely on the fact that the meter readings are fluctuate from time to time, as shown in Fig. 3. Hence, the events can be found in terms of transient changes and steady-state changes, accordingly.

There exists some feature extraction algorithms for characterizing the detected events of the appliances. Steady-state event detection algorithms mainly watch the power change of appliances. For example, when the energy consumption changes from a higher value to a lower value, some corresponding appliance is identified to be turned off. The steady-state event detection algorithms are mainly applied to analyze the low frequency data. The transient event detection algorithms view the state transitions as a signature to identify the appliances because the transitions are unique for the appliances. The features of the state transitions include but not limited to the duration, shape, size and harmonics of the waveforms [2]. However, these signatures cannot be well extracted unless the sampling frequency is higher than 1 KHz. The transient event detection algorithms are common used for analyzing high frequency data.

After the steady-state and transient events are detected, the NILM approach starts to extract the features of the electricity appliances. The electricity appliances have steady-state features and transient features in accordance with the two kinds of events.

Steady-State Features Extraction

We also take a two-state appliance as the example. The steady-state features [16] consist of the real power and the reactive power. The real power represents the total amount of the energy consumption of each electricity appliance. For the pure resistor circuit, since the current and voltage waveforms have the same phase, there is no reactive energy. For inductor and capacitor circuit, the current and voltage, the current and voltage waveforms have different phases. Thus, the real power and the reactive power both exists. The real power can distinguish the higher-power appliances like water pumps because their power draw characteristics are distinct [17–19, 59]. But multiple states transform simultaneously will lead to erroneous result. Furthermore, the steady-state features are not proper for the appliances when the feature space of the real power and reactive power exist a considerable overlap, typically for the appliances with low-power as depicted in the Fig. 4.

Apart from the real power and the reactive power, the peak power, the root mean square of the voltage and current values, the phase difference and the information of power factor are also common features to disaggregate the meter readings. For example, the power factor information is a ratio between the real power and the apparent power. This feature has good performance for disaggregating the two-state electricity appliances in the kitchen [20].

Besides the traditional features, a novel disaggregation algorithm that uses voltage and current trajectory to differentiate a group of appliances has been proposed [21, 22]. The voltage and current trajectory differentiate the class of appliances into different groups with high accuracy, giving further sub-division with each individual group. The result shows that this algorithm is more effective than the existing algorithms because of a taxonomy of the electrical appliances according to the dedicated voltage and current curves. Gupta et al. [23] also explored that the steady-state voltage noise can characterize the appliances if they equip with a Switch Mode Power Supply.

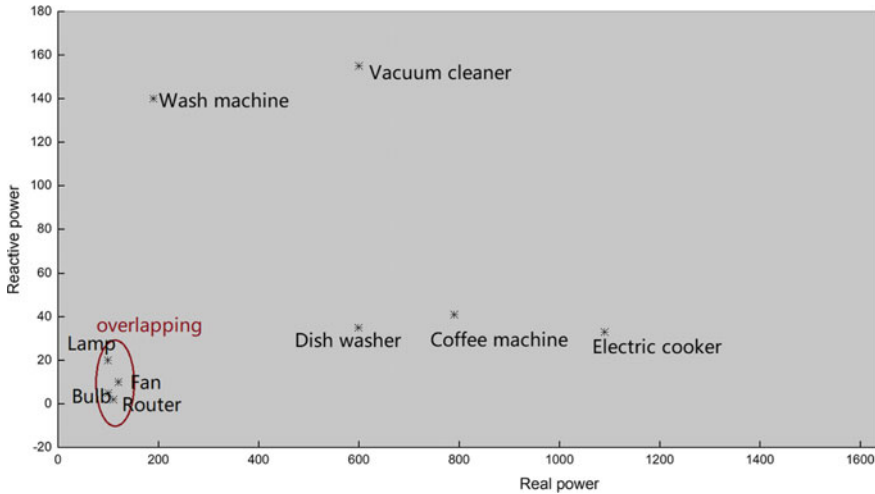


Fig. 4 The power monitored of appliances

Although several efforts are made in the steady-state feature extraction algorithms, these algorithms have often two disadvantages. One is to require additional hardware for measurement. The other is that the algorithms are quite sensitive when monitoring to the wiring architecture.

We provide a introduction of the existing steady-state feature extraction algorithms in Table 2.

Transient Features Extraction The Transient features extraction algorithms reduce the overlaps of the steady-state features, thereby improving the accuracy of disaggregation. Correspondingly, these algorithms need higher frequency data.

One classic transient features extraction algorithm analyzes the spectral envelope of the waveform based on Short-Time Fourier Transform (STFT) which has been proven to be useful in detecting the appliances with variable-state. Unfortunately, this algorithm can just detect whether the appliances are turned on or not in a certain time period, but not determine the specific time point when the appliances are turned on. To solve this problem, the revised algorithm that applies the correlate spectral envelopes with real power and reactive power components is proposed [45, 46]. However, the revised algorithm often suffers from the excessive training.

Comparing with Short-Time Fourier Transform, the wavelet transform has also been used to identify all the transient features of appliances. The transient response features and transient time of a transient features extraction algorithm are proven to be less than those of a steady-state features extraction algorithm [47, 57].

Several recent works [11, 13, 58] show good results via sampling the voltage noise that happens with the transient events frequently (like turning from off to on). The idea is based on the fact that all of the appliances would emit voltage noises.

Table 2 Summary of steady-state methods

Features type	Extraction methods	Advantages	Disadvantages
Real and reactive power [7, 17–19, 24]	Calculation of change	Simple Intuitive	Overlap (P-Q plane); Poor performance for Type 2, 3 and Type 4 loads
V-I waveforms [20, 25–31]	Calculation of a series of index $I_{\{RMS\}}$, $I_{\{avg\}}$, $I_{\{peak\}}$, $V_{\{RMS\}}$	Devices can easily be categorized into resistive, inductive and electronic loads	High sampling Low accuracy for Type 3 loads, overlapping features for Type 1 and 2 category, unable to distinguish between overlapping activation events
V-I trajectory [32, 33]	Shape features of V-I trajectory	Detail taxonomy of electrical appliances can be formed due to distinctive V-I curves	Difficult to distinguish smaller loads
Voltage noise [23, 34]	Fast Fourier Transform (FFT)	Those with SMPS can be recognized with high accuracy	The ability of anti-interference is very poor; Poor generality

Table 3 Summary of transient-based methods

Features type	Extraction methods	Advantages	Disadvantages
Transient power [30, 35–37]	FFT; Power spectrum envelope estimation; Calculation of waveform vector	Appliances with same power draw characteristics can be easily differentiated. Recognition of Type 1, 2, 3 loads	Continuous monitoring, high sampling rate not suitable for Type 4 loads
Start up current transients [17, 36, 38]	Calculation of a series of index current spikes, size, duration...	Works well for Type 1, 2 loads, distinct transient behavior in multiple load operation scenario	Poor detection of Simultaneous activation deactivation of sequences, unable to characterize Type 3 and 4 loads, sensitive to wiring architecture, appliance specific
Voltage noise [34, 39]	Spectrum analysis	Able to distinguish similar loads	There is a certain error in identifying simultaneous activation

Specifically, all of the noises are normally divided into three categories: steady-state continuous noise, on-off transient noise and steady-state line voltage noise. Table 3 demonstrates some typical transient-based NILM approaches.

2.3 *Energy Consumption Learning and Appliance Inference*

In this process, the specific states of all the appliances at each time point are classified or clustered via the features detected before. The whole process contains two types of algorithms. One is energy consumption learning algorithms and the other is appliance inference algorithms. The energy consumption learning algorithms are used to train the appropriate parameters, while the appliance inference algorithms are used to infer the specific states of appliances at all the time points. These algorithms can be categorized into two kinds, the supervised learning and inferring algorithms and unsupervised learning and inferring algorithms [54–56].

The Supervised Learning and Inferring Algorithms

The supervised learning and inferring algorithms first train parts of the meter readings due to the energy consumption of each appliance, in order to infer the states of the appliances. Then they test the other of the meter readings to evaluate the accuracy of the inference. Since installing the meter readings to monitor all the appliances is an expensive and time-consuming process, the scalability of these algorithms are limited.

Some may argue that these algorithms belong to ILM approach, because they need to install smart meters in houses. But they are traditionally viewed as NILM approach as the test process does not require to intrude the houses and intruding behavior is only once during in the training phase.

The Unsupervised Learning and Inferring Algorithms

Unlike the supervised learning and inferring algorithms, the unsupervised learning and inferring algorithms neither require to train data for each appliance, nor need to monitor the energy consumption of each appliance. The parameters are adjusted only through the meter readings themselves [40].

The unsupervised learning and inferring algorithms can further be divided into three subgroups as suggested by [41]. First is to require unlabeled the training data to build the appliance model or to populate appliances database. The appliance model is either generated manually [42] or produced automatically [43] during training the meter readings. The appliances in houses are assumed to be known before.

The second uses the labelled data from an unknown house to build appliances models This algorithm is then used to disaggregate a brand new house. Most deep learning based NILM methods fall in this category.

The third neither requires to train before disaggregation, nor requires to monitor the energy consumption of each appliance. In other words, this algorithm has not any prior knowledge [44, 45].

Generally speaking, NILM algorithms based on supervised learning emerge in an endless stream, but there are not many kinds of load involved, and the scene of processing is relatively simple. Compared with supervised algorithms, the unsupervised ones have low accuracy, but they have the advantage of reducing manual intervention

Table 4 Summary of learning and inferring algorithms

Methods type	Algorithm types	Features type	Application scenarios	Accuracy (%)
Supervised NILM	SVM	Steady transient	Common appliances; The accuracy is low when type 4 appliance is not considered; Not much type of load;	66–100
	Nearest neighbour (KNN)	Transient	Non concurrent events; Linear load; Single load and multi load operation scenes;	78–100
	Adaboost	Steady	Some common appliances; Consideration of complex conditions such as noise interference;	98–99
Unsupervised NILM	HMM	Steady	Not contain much appliances; No type 4 appliances;	52–98
	Motif mining	Steady	Appliances' number is known; Low accuracy for Type 2 appliances;	15–98
	Deep learning	Steady transient	Concurrent events; Similar load features;	50–100

and have good prospects for development. The improved and integrated algorithms can cope with complex scene, which are worth continuing to study. Table 4 depicts the comparison of some of the supervised and unsupervised algorithms.

3 Examples

In this section, we take two examples to further explain the two kinds of learning and inferring Algorithms.

3.1 A Supervised Learning and Inferring Example

In this section, we will introduce Wang's scheme [52] which is based on sparse coding. The scheme proposed a new clustering algorithm—Probability Based Double Clustering(PDBC), which can promote the efficiency of clustering the device consumption features. Real experiments based on data set—REDD showed the average disaggregation accuracy of this scheme could reach 77%.

There are total n appliances in a house. Each device is modeled based on sparse coding. As to each device $i = 1, 2, \dots, n$, the feature matrix of the device is learned at the frequency of q HZ. Once obtaining enough features for the $i - th$ involved appliance, the following approximation would be utilized:

$$T_w(x_i(t)) \approx X_i a_i(t), T_w(x_i(t)) = (x_i(t), x_i(t + \frac{1}{q}), x_i(t + 2 \times \frac{1}{q}), \dots, x_i(t + T_w)) \quad (1)$$

In Eq. 1, T_w was the time of a sliding window, which denoted a lasting period of time during the training process and $T_w \ll T_{tr}$ where T_{tr} means the whole training time. m_i denoted the features that captured from the $i - th$ device. $X_i \in R^{m_i \times T_w}$. $a_i(t)$ demonstrated the activations of feature matrix X_i . $a_i(t)$ was sparse that contained mostly zero atoms and only one none-zero element that is 1. Then the scheme utilized a matching algorithm to get the $a_i(t)$ so that they could calculate $X_i a_i(t)$ to obtain an approximate solution of all involved individual device. There were mainly two stages in this scheme, which are learning the feature and power consumption matching.

3.1.1 Learning the Feature

In this stage, the PBSC algorithm was proposed to learn each device feature matrix. In the scheme, it assumed that the training process consumes T_{tr} time and the sampling frequency is q HZ, so there were $(T_{tr} - T_w + 1) \times q$ sliding windows, as to a sliding window, $T_w \times q$ elements are included.

Assumed that each sliding window was regarded as a data point in the algorithm. The data point was defined as $P_i \in (1, (T_{tr} - T_w + 1) \times q)$, therefore there were total k unique points P_{uniq} after removing the repeated points. The vector $R = (r_1, r_2, r_3, \dots, r_k)$ denoted the repeat times for each data point. $d_{ij} = \|P_i - P_j\|_2$ was defined as the distance of two data points, the distance matrix D was a $k \times k$ scale symmetric matrix with a diagonal of 0, $D = \{d_{ij}, i, j \in \{1, 2, 3, \dots, k\}\}$.

Then the PDBC algorithm is utilized to perform the cluster task, specifically, m is a upper limit that could represent the number of clustering centers. Then in the clustering process, it just repeatedly compare the number of the actual clustering centers and m . Therefore, they could make the clustering efficient with the number of clustering centers stabilized at a certain controllable value.

After this first clustering process, the center point represented the point with the larger distance from the other data points, here the result was just evaluated by the difference of the data values. The result is not fair enough because some of the data points that with small value have a high probability for being buried in large. So a second clustering was further performed to promote the efficiency.

In the second clustering, all the clusters got from the first clustering were further clustered. The number of clusters was set through the probability set C . The C_i in the set means the probability of each individual cluster. As to all repeated points, C_i was computed through Eqs. 2 and 3.

$$C_i = \frac{\text{num}(\text{Cluster}_i)}{\sum_{i=1}^k r_i} \quad (2)$$

$$\text{num}(\text{Cluster}_i) = \sum r_i, r_i \in \{\text{Cluster}_i\} \quad (3)$$

The Algorithm 1 in [52] described the details.

Algorithm 1 Learning Feature Matrix [52]

Input: Device training data set D_{tr} ,

Sliding window size w ,

The number of feature vector m .

Output: Device feature matrix X .

1. Compute P_{uniq} and R from D_{tr}
 2. Compute distance matrix D :
 3. **for** $i = 1, \dots, \text{size}(R)$ **do**
 4. **for** $j = i, \dots, \text{size}(R)$ **do**
 5. $d_{ij} = \|P_i - P_j\|_2$
 6. **end for**
 7. **end for**
 8. First Clustering: improved FSFDP($D, m/10$)
 9. Second Clustering:
 10. **for** $k = 1, \dots, \text{size}(\text{clusters})$ **do**
 11. $C_i = \text{num}(\text{cluster}_i) / \|R\|_1$
 12. improved FSFDP($D_i, m * C_i$)
 13. clustering result is collected to X
 14. **end for**
 15. **retrun** X
-

3.1.2 Power Consumption Matching

In the leaning feature matrix stage, the feature matrix for each individual device X_i has been obtained. In the power consumption matching stage, the main task was to getting $a_i(t)$. The Max-Min pruning Matching (MMPM) algorithm was proposed to commit the task. The main contribution of MMPM was to performing the pruning optimization for shorting the decomposing time while obtaining the global optimum solution. The optimization process was consisted of two processes which were minimum pruning process and maximum pruning. It assumed arg_{max} denoted the maximum pruning parameters, μ represented the threshold of pruning.

The contribution of maximum pruning was to obtain the global optimal result and cease the matching loop when they got the global optimal result. To perform this matching process, getting the order j that represents the maximum element of $T_w(y(t))$. Then sorted each feature matrix $X_i, i \in \{1, 2, 3 \dots, n\}$ according to the $j - th$ element as the descending order, they regarded the element in the X_i in the $j - th$ column as the maximum. Then the maximum pruning parameters were calculated:

$$arg_{max} = y(t + (j - 1)q) - \sum_{i=n-i}^n max_i \quad (4)$$

When $arg_{max} > \mu$, it depicted that the arg_{max} in the remaining loops would be larger than the given pruning threshold, so all the remaining loops would be cut off.

The contribution of minimum pruning process was to cut a invalid loop once the value of the vectors is found too small. For each loop, they obtained a remainder power $T_w(r(t))$ which denoted the difference between the aggregated power $T_w(y(t))$ and the value of upper loop, the minimum pruning judgement regulation was defined:

$$\min(T_w(r(t))) + \mu < 0 \quad (5)$$

If this judgement regular was set up, then the remaining loop would make the $\min(T_w(r(t)))$ smaller, so cutted off all the remaining invalid loops. All the details were described in Algorithm 2 in [52].

Algorithm 2 MMPM algorithm [52]

Input: Device feature matrixs $X_1 X_2 \dots X_n$

Test data Y .

Pruning threshold u

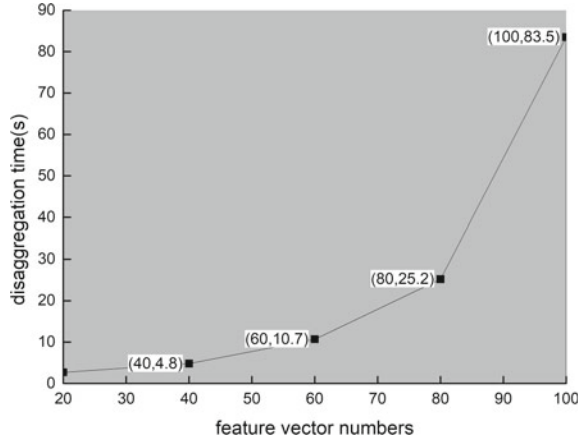
Output: Disaggregation result $\tilde{Y}_1 \tilde{Y}_2 \dots \tilde{Y}_n$

1. get the windows size w and each device feature numbers m_i
 2. **while** $X_1 \neq NULL$
 3. get one feature vector form X_1
 4. compute the remainder energy $T_w(y(t))$ and arg_{max}
 5. **if** ($arg_{max} > \mu || min(T_w(y(t))) + \mu < 0$)
 6. break;
 7. **end if**
 8. overlay record the feature vector into $\tilde{Y}_1$
 9. **while** $X_2 \neq NULL$
 10. get one feature vector form X_2
 11. compute the remainder energy $T_w(y(t))$ and arg_{max}
 12. **if** ($arg_{max} > \mu || min(T_w(y(t))) + \mu < 0$)
 13. break;
 14. **end if**
 15. overlay record the feature vector into $\tilde{Y}_2$
 16. ...
 17. **while** $X_n \neq NULL$
 18. get one feature vector form X_n
 19. compute the remainder energy $T_w(y(t))$ and arg_{max}
 20. **if** ($arg_{max} > \mu || min(T_w(y(t))) + \mu < 0$)
 21. break;
 22. **end if**
 23. overlay record the feature vector into $\tilde{Y}_n$
 24. **end while**
 25. ...
 26. **end while**
 27. **end while**
-

3.1.3 Experiment Analysis

All the experiments in the paper [52] is executed through the REDD data set [15] which is a public data set constructed for electricity disaggregation. REDD contained six different houses' power consumption signals. For each individual house, about 20 kinds of devices were measured and the aggregated power was recorded in the

Fig. 5 The time with different feature vector numbers for the algorithm [52]



same time. The measuring time lasted about two weeks and the sampling rate is 1/3 HZ which is a low frequency. The data of the House 5 was excluded because the data in this house is lack of enough fluctuations, which were not proper for feature extractions.

In the experiment, Wang's scheme utilized a month of recorded data with 5 usual household appliances. They used one week data for learning the features and all the rest of the data for power consumption matching. The size of learned feature matrix was set as $20 \times m$ which represented that there are m feature vectors and the length of the vector is 20.

In the last, they got five feature matrixes, the time of the power consumption matching process is about 10s for a sliding window's power readings. The disaggregation accuracy was denoted as follows:

$$acc_{\text{energy matching}} = 1 - \frac{\sum_{t \in \psi} \sum_{i=1}^M \|T_w(x_i(t)) - \tilde{T}_w(x_i(t))\|_1}{2 \sum_{t \in \psi} \|T_w(x_i(t))\|_1} \quad (6)$$

In Eq. 6, $\psi = \{1, T_w + 1, 2T_w + 1, \dots\}$. They compared their scheme with the PED algorithm [53], supervised FHMM algorithm [8] and the simple mean prediction method.

Figure 5 showed the time with different feature vector numbers for the algorithm. Table 5 showed the disaggregation accuracy of all the five houses that the REDD data set recorded. Their algorithm performed better than all the other schemes, promoted the accuracy about 5.4% higher.

Table 5 Energy disaggregation accuracies (%) [52]

	House 1 (%)	House 2 (%)	House 3 (%)	House 4 (%)	House 6 (%)	Average (%)
Simple	41.4	39.0	46.7	52.7	33.7	42.7
FHMM	71.5	59.6	59.6	69.0	62.9	64.5
PED	81.6	79.0	61.8	58.5	79.1	72.0
EPSC	84.3	82.7	70.2	71.0	78.9	77.4

3.2 An Unsupervised Learning and Inferring Example

An unsupervised learning and inferring example based on deep learning algorithms is illustrated here. We first recall the usage of the deep learning algorithms [46–48] for energy disaggregation. Next, we introduce a deep neural network architecture that is a form of recurrent neural network referred to as Long Short-Term Memory (LSTM) through the data training, neural network architecture, disaggregation, and results analysis procedures [63].

3.2.1 Data Training

During data training process, deep neural networks take a tremendous number of training data just because they own a lot of trainable parameters. So it is critical to acquire large training datasets. For energy disaggregation, tremendous amounts of aggregated data can be effectively created by combing real appliances' activations randomly (the activation denotes the power of an appliance in a complete operating cycle).

The data set of UK-DALE [49] was used as source data in this example. UK-DALE contains the load data of 6 houses, and the data of house 1, 2, 3, 5, 6 is used in the experiment. The experiment contains five appliances which are washing machine, kettle, microwave, dish washer and fridge.

In this experiment, they trained the networks on both synthetic aggregated data and the real aggregated data in 50:50 ratios. Each individual appliance was trained by one network. The input for each network is a window of aggregated power consumption, the desired output of the network is the target appliance's power consumption. In their experiment, the size of the window varied for different appliances, like 1536 samples for the dish washer and 128 samples for the kettle. They reserved the last week of data for training and the rest of the data for testing. Table 6 depicted the number of appliance training activations. Table 7 depicted the number of testing activations. Table 8 depicted the specific houses used for training and testing.

Appliances activations can be extracted by *Electric.get_activations()* function In the NILMTK tool [50].

The arguments passed to this method are shown in Table 9. For simple applications like toasters, they extracted activations through analysing consecutive samples

Table 6 Number of training activations per house [63]

Appliance	House 1	House 2	House 3	House 5	House 6
Kettle	2836	543	44	716	176
Fridge	16336	3526	0	4681	1488
Washing machine	530	53	0	0	51
Microwave	3266	387	0	0	28
Dish washer	197	98	0	23	0

Table 7 Number of testing activations per house [63]

Appliance	House 1	House 2	House 3	House 6	House 6
Kettle	54	29	40	50	18
Fridge	168	277	0	145	140
Washing machine	10	4	0	0	2
Microwave	90	9	0	0	4
Dish washer	3	7	0	3	0

Table 8 Houses used for training and testing [63]

Appliance	Training	Testing
Kettle	1, 2, 3, 4	5
Fridge	1, 2, 4	5
Washing machine	1,5	2
Microwave	1, 2	5
Dish washer	1, 2	5

Table 9 Arguments passed to *get_activations()* [63]

Appliance	Max power (W)	On power threshold (W)	Min. on duration (s)	Min. off duration (s)
Kettle	3100	2000	12	0
Fridge	300	50	60	12
Washing machine	2500	20	12	30
Microwave	3000	200	12	30
Dish washer	2500	10	1800	1800

that were above a predefined power threshold. If the activations were shorter than the threshold duration, then they were thrown. As to some more complicated appliances like washing machine whose power consumption might drop below for short periods of time during a operating cycle, NILMTK ignored these sub-threshold power consumption.

Locate the activations in the house's meter readings for the target appliance. The code could decide to whether to include the target appliance's activations with the probability of 50% for each training example. If the code decided not to include the target appliance, it would choose a random window of aggregated data without any activations of the target appliance. Otherwise, activations of a target appliance would be included and randomly positioned in a window. In the same time, the time window of the real aggregated data was loaded and loaded together as the input of the network.

Synthetic aggregate data: In order to create the synthetic aggregated data, they extracted the five target appliances' activations from all of the training data. Firstly, two vectors with zero elements were defined, one was the input of the network and the other was the output. The length of the vector was the size of the window related to the network. All the five appliances' activations were scanned through and were decided whether to be included in the training sequence. The probability of appearing in the sequence is 50%, and the probability of being 'distractor' of other appliance was 25%. Specifically, for a target appliance, the activation of the appliance was randomly chose to added in a random position of the input vector. Distractor appliances' activations could appear any positions of the sequence.

3.2.2 Neural Network Architecture

The LSTM was utilized in this example. Specifically, the feed forward neural network that mapped from a solo input vector to a solo output vector was utilized. If a new input vector was cast into the network, then the net would lost the memory about the previous input. In their experiment, RNNS was trained by backpropagation through time (BPTT) [51]. Bidirectional layers were added to enhance the effect of RNNS. Bidirectional RNN, in which there were two parallel RNNS. One of the RNN was utilized to read the input sequence forwards and the other RNN was used to read the sequence backwards. The output of the network was constituted by concatenating the outputs of the above two parallel RNNS.

The architecture is depicted as follows:

1. Input (The length of the input vector is related with the duration of an appliance)
2. 1D conv (filter stride is set as 1, size is 4, number of filters is set as 16, border mode is same and activation function is set as linear)
3. Fully connected (N is set as 1, activation function is set as linear)
4. Fully connected (N is set as 128, activation function is set as TanH)
5. bidirectional LSTM (N is set as 256 with peepholes)
6. bidirectional LSTM (N is set as 128 with peepholes)

For each time window, the network dealt with a sample of aggregated data and obtained a solo sample of the related target appliance.

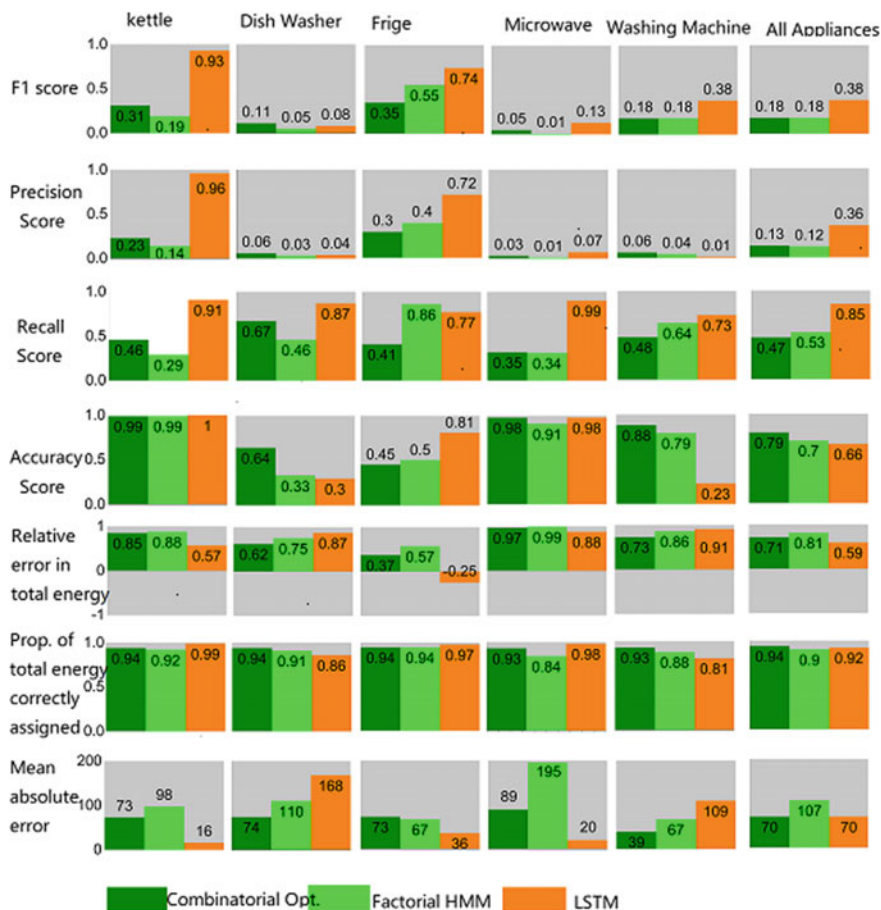


Fig. 6 The general process of the NILM approach

3.2.3 Disaggregation

They would preprocess the input data with zeros element in the beginning and the end of the input vector. The net was slide along the input sequence to cope with the complicated situation in which the input time window of a net was at most up to few hours.

3.2.4 Results

The disaggregation result on an unseen house of this experiment is shown in Fig. 6. We use the following metrics in this experiment:

TP means how many true positives exist

FN means how many false negatives exist

FP means how many false positives exist

N means how many negatives in ground truth exist

P means how many positives in ground truth exist

E means aggregated actual energy

$\hat{E}$ means aggregated predicted energy

$y_t^{(i)}$ means the i - th appliance's actual power consumption at time t

$\hat{y}_t^{(i)}$ means the i - th appliance's estimated power at time t

$\bar{y}_t^{(i)}$ means the aggregate real power at time t

Precision is set as $\frac{TP}{TP+FP}$

Recall is set as $\frac{TP}{TP+FN}$

$F1$ is set as $2 \times \frac{\text{precision} \times \text{recall}}{\text{precision} + \text{recall}}$

Accuracy is set as $\frac{TP+TN}{P+N}$

Mean absolute error is set as $\frac{1}{T} \sum_1^T |\hat{y}_t - y_t|$

Relative error of whole energy is set as $\frac{|\hat{E} - E|}{\max(E, \hat{E})}$

Proportion of total energy correctly assigned is set as $1 - \frac{\sum_{t=1}^T \sum_{i=1}^n |\hat{y}_t^i - y_t^i|}{\sum_{t=1}^T \bar{y}_t}$.

4 Applications of NILM

NILM is a promising technology in practical application. It can bring various benefits to users and power companies. For example, it can help users to save electricity power and help power companies to arrange power transmission rationally [64]. In this section we will depict some practical applications of NILM.

4.1 Optimization of Power Use Strategy

Based on the detection data of users' appliances through NILM system, we can analyze users' electricity power usage habits, energy consumption of appliances and other information. If these information can be fed back to users, so that users can take targeted energy-saving measures. If the electricity power usage information of other users is combined, it can provide effective energy saving suggestions for the users. At present, there have been NILM applications like automatic management system for commercial users [65].

4.2 *Fault Detection and Diagnosis*

Through the data collected by the NILM system, we can get the current, power and other waveform data of the appliances. For many appliances, when some of their components' physical characteristics have been changed, the current and power waveform would appear distorted, and the transient, steady-state features extracted and some other estimation parameters got from the power waveform may change. So, we can carry out fault diagnosis according to the situation. For example, [66] shows that those refrigeration controllers whose regulating performance are bad may appear big swings for their power signals. Based on the envelop analysis of power signals, the corresponding relationship between diagnostic parameters and equipment health is further established, and a non-intrusive fault diagnosis for motor load is achieved [67–69].

4.3 *Demand Response*

Load disaggregation enables electric power companies to understand the working characteristics, power consumption rules of different load classes and even single electric equipment and current electric power and controllable capacity. Those information can help power companies to formulate dynamic price and demand response incentive policies more scientifically. In addition, the analysis and processing of the power consumption detail monitoring results can be used to adjust, improve and scientifically evaluate the energy efficiency projects in power companies.

Under normal circumstances, the dynamic price or the demand response can motivate the user's friendly interaction with power companies, which can achieve load peak shifting and shaving, improve the load coefficient, thereby improving the economic efficiency of the power system operation, (such as energy saving, prolonging the service life and reducing the operating and maintenance costs of power equipment.) improving the utilization rate of short-term power assets, and postponing long-term infrastructure investment. In case of emergency, if the power grid is under overload or low voltage, emergency load rejection can be realized through demand response protocol, thereby improving system stability, preventing system collapse, and ensuring the safe operation of the power system.

And like electric water heater, air conditioner, heater, refrigerator, washing machine, vacuum cleaner and electric kettle etc. with load can be shifted in the power system, which not only can quickly respond to the peak load demand of the power grid, but also have little influence on the users with power supply interruption in a short time. So they are the main force when the users interacting with the power grid and responding the demand of power grid, and the power system implementing demand management.

5 Conclusions and Future Work

Smart meters today can record the power consumption of the related house at a high time resolution and deliver these recorded data to a utility company or institution. This is very good for monitoring the smart grid and then control the power grid better. It is also helpful for users' electricity conservation by adjusting electricity usage time.

Not only are smart meters conducive for the management of the power grid, but also the high resolution of meter readings can be utilized for exposing customers' activities in house. Therefore, this chapter mainly introduced a NILM approach for mining customers' privacy without intruding into customer residence, i.e. install no device or embed no Trojan virus in the house. Specifically, the core idea was to disaggregate the incessant readings for indicating the consumption of every electricity appliance by designing the energy consumption learning and appliance inference algorithms, thereby exposing customers' daily activities. The existing energy consumption learning and appliance inference algorithms were often divided into two categories which are the supervised and unsupervised algorithms. These algorithms aimed to classify or cluster the working states of the electricity appliances, in order to predict customers' activities.

As discussed before, since no special hardware or software is assumed to be installed or run in the customer residences, the working state of each appliance at each time point is a completely black box. So the only way to analyze the customers' activities has to disaggregate the meter readings directly. This makes the result of the NILM approach not accurate when the number of the appliances are large. Hence, how to improve the precision of the inference and enlarge the number of the electricity appliances are two research directions for the NILM approach from the viewpoint of privacy mining.

From the viewpoint of privacy preserving, consumption patterns can be identified through the high-frequency data, creating considerable risks in customers' privacy, especially in the United States and European countries. Several cities like Capitola and Ross in California, have already begun to refuse the installation of smart meters, and the European Commission's Article 29 Working Party also strongly advocates privacy enhancing technologies in smart grid. The need and urgency for such technologies is exacerbated by the fact that more than 8 million smart meters have already been installed in the United States. Similarly, European Parliament's directive requires 80% smart meter adoption in all European households by 2020, and 100% by 2022. Worse, the electricity energy is not abstract data. Therefore, adversaries could secretly install their own smart meters outside the residences to record the energy consumption. This type of attacks cannot be resisted against by the traditional cryptographic primitives. Hence, developing new technologies for preserving customers' privacy without having bad impact on the management of the smart grid is a potential research direction.

References

1. Esa, N. F., Abdullah, M. P., & Hassan, M. Y. (2016). A review disaggregation method in non-intrusive appliance load monitoring. *Renewable and Sustainable Energy Reviews*, 66, 163–173.
2. Faustine, A., Mvungi, N. H., Kaijage, S., et al. (2017). A survey on non-intrusive load monitoring methodologies and techniques for energy disaggregation problem[J].
3. Zoha, A., Gluhak, A., Imran, M. A., et al. (2012). Non-intrusive load monitoring approaches for disaggregated energy sensing: A survey[J]. *Sensors*, 12(12), 16838.
4. Jiang, X., Dawson-Haggerty, S., Dutta, P., et al. (2009). Design and implementation of a high-fidelity AC metering network. In *International Conference on Information Processing in Sensor Networks* (pp. 253–264). IEEE.
5. Suzuki, K., Inagaki, S., Suzuki, T., et al. (2008). Nonintrusive appliance load monitoring based on integer programming. In *Sice Conference* (pp. 2742–2747). IEEE.
6. Ridi, A., Gisler, C., & Hennebert, J. (2014). A survey on intrusive load monitoring for appliance recognition. In *International Conference on Pattern Recognition* (pp. 3702–3707). IEEE Computer Society.
7. Hart, G. W. (1992). Nonintrusive appliance load monitoring. *Proceedings of the IEEE*, 80(12), 1870–1891.
8. Kolter, J. Z. (2011). Recent advances in algorithms for energy disaggregation. In *BECC Conference*.
9. Tsai, M. S., & Lin, Y. H. (2012). *Development of a non-intrusive monitoring technique for appliance' identification in electricity energy* (pp. 108–113). IEEE.
10. Adabi, A., Mantey, P., Holmegaard, E., et al. (2015). Status and challenges of residential and industrial non-intrusive load monitoring. In *Technologies for Sustainability* (pp. 181–188). IEEE.
11. Zeifman, M., & Roth, K. (2011). Nonintrusive appliance load monitoring: Review and outlook. *IEEE Transactions on Consumer Electronics*, 57(1), 76–84.
12. Belley, C., Gaboury, S., Bouchard, B., et al. (2014). An efficient and inexpensive method for activity recognition within a smart home based on load signatures of appliances. *Pervasive and Mobile Computing*, 12(3), 58–78.
13. Zoha, A., Gluhak, A., Imran, M. A., et al. (2012). Non-intrusive load monitoring approaches for disaggregated energy sensing: A survey. *Sensors*, 12(12), 16838–16866.
14. Anderson, K., Ocneanu, A., Benitez, D., et al. (2012). BLUED: A fully labeled public dataset for event-based non-intrusive load monitoring research.
15. Kolter, J. Z., & Johnson, M. J. (2011). REDD: A public data set for energy disaggregation research. In *Workshop on data mining applications in sustainability (SIGKDD)* (Vol. 25, pp. 59–62). San Diego, Citeseer.
16. Hart, G. W. (1992). Nonintrusive appliance load monitoring. *Proceedings of the IEEE*, 80(12), 1870–1891.
17. Norford, L. K., & Leeb, S. B. (1995). Non-intrusive electrical load monitoring in commercial buildings based on steady-state and transient load-detection algorithms. *Energy and Buildings*, 24(1), 51–64.
18. Farinaccio, L., & Zmeureanu, R. (1999). Using a pattern recognition approach to disaggregate the total electricity consumption in a house into the major end-uses. *Energy and Buildings*, 30, 245–259.
19. Marceau, M. L., & Zmeureanu, R. (2000). Nonintrusive load disaggregation computer program to estimate the energy consumption of major end uses in residential buildings. *Energy Conversion and Management*, 41, 1389–1403.
20. Lee, W. K., Fung, G. S. K., Lam, H. Y., Chan, F. H. Y., & Lucente, M. (2004). Exploration on load signatures. In *Proceedings of International Conference on Electrical Engineering (ICEE), Sapporo, Japan, 4–6 July 2004* (pp. 1–5).
21. Lam, H., Fung, G., & Lee, W. (2007). A novel method to construct taxonomy electrical appliances based on load signaturesof. *IEEE Transactions on Consumer Electronics*, 53(2), 653–660.

22. Madden, S., Franklin, M. J., Hellerstein, J. M., et al. (2002). TAG: A Tiny AGgregation service for ad-hoc sensor networks. *Acm Sigops Operating Systems Review*, 36(SI), 131–146.
23. Gupta, S., Reynolds, M. S., & Patel, S. N. (2010). ElectriSense: Single-point sensing using EMI for electrical event detection and classification in the home. In *Proceedings of the 12th ACM International Conference on Ubiquitous Computing, Copenhagen, Denmark, 26–29 September 2010* (pp. 139–148).
24. Marchiori, A., Hakkarinen, D., Han, Q., et al. (2011). Circuit-level load monitoring for household energy management. *IEEE Pervasive Computing*, 10(1), 40–48.
25. Liang, J., Ng, S. K. K., Kendall, G., et al. (2010). Load signature study-part I: Basic concept, structure, and methodology. *IEEE Transactions on Power Delivery*, 25(2), 551–560.
26. Najmeddine, H., Drissi, K. E. K., Pasquier, C., Faure, C., Kerroum, K., Diop, A., et al. (2008). State of art on load monitoring methods. In *Proceedings of the 2nd IEEE International Conference on Power and Energy Conference, Johor Bahru, Malaysia, 1–3 December 2008* (pp. 1256–1258).
27. Kato, T., Cho, H. S., & Lee, D. (2009). Appliance Recognition from Electric Current Signals for Information-Energy Integrated Network in Home Environments. In *Proceedings of the 7th International Conference on Smart Homes and Health Telematics, Tours, France, 1–3 July 2009* (Vol. 5597, pp. 150–157).
28. Cole, A., & Albicki, A. (2000). Nonintrusive identification of electrical loads in a three-phase environment based on harmonic content. In *Proceedings of Instrumentation and Measurement Technology Conference, Baltimore, MD, USA, 1–4 May 2000* (Vol. 716, pp. 24–29).
29. Suzuki, K., Inagaki, S., Suzuki, T., Nakamura, H., & Ito, K. (2008). Nonintrusive appliance load monitoring based on integer programming. In *Proceedings of SICE Annual Conference, Tokyo, Japan, 20–22 August 2008* (Vol. 174, pp. 2742–2747).
30. Laughman, C., Lee, K., Cox, R., Shaw, S., Leeb, S., Norford, L., et al. (2003). Power signature analysis. *IEEE Power and Energy Magazine*, 1, 56–63.
31. Li, J., West, S., & Platt, G. (2012). Power decomposition based on SVM regression. In *Proceedings of International Conference on Modelling, Identification Control, Wuhan, China, 24–26 June, 2012* (pp. 1195–1199).
32. Schoofs, A., Guerrieri, A., Delaney, D., O'Hare, G., & Ruzzelli, A. (2010). ANNOT: Automated electricity data annotation using wireless sensor networks. In *Proceedings of the 7th Annual IEEE Communications Society Conference on Sensor Mesh and Ad Hoc Communications and Networks, Boston, MA, USA, 21–25 June 2010* (pp. 1–9).
33. Rowe, A., Berges, M., & Rajkumar, R. (2010). Contactless sensing of appliance state transitions through variations in electromagnetic fields. In *Sensing Systems for Energy-Efficiency in Building, Zurich, Switzerland, 3–5 November 2010* (pp. 19–24).
34. Patel, S. N., Robertson, T., Kientz, J. A., Reynolds, M. S., Abowd, G. D. (2007). At the flick of a switch: Detecting and classifying unique electrical events on the residential power line. In *Proceedings of the 9th International Conference on Ubiquitous Computing, Innsbruck, Austria, 16–19 September 2007* (pp. 271–288).
35. Zeifman, M., & Roth, K. (2011). Nonintrusive appliance load monitoring: Review and outlook. *IEEE Transactions on Consumer Electronics*, 57(1), 76–84.
36. Chang, H. H., Yang, H. T., & Lin, C. L. (2007). Load identification in neural networks for a non-intrusive monitoring of industrial electrical loads. *Lecture Notes in Computer Science*, 5236, 664–674.
37. Shaw, S. R., Leeb, S. B., Norford, L. K., et al. (2008). Nonintrusive load monitoring and diagnostics in power systems. *IEEE Transactions on Instrumentation and Measurement*, 57(7), 1445–1454.
38. Cole, A. I., & Albicki, A. (1998). Data extraction for effective non-intrusive identification of residential power loads. In *Proceedings of Instrumentation and Measurement Technology Conference, St. Paul, MN, USA, 18–21 May 1998* (Vol. 2, pp. 812–815).
39. Hazas, M., Friday, A., & Scott, J. (2011). Look back before leaping forward: Four decades of domestic energy inquiry. *IEEE Pervasive Computing*, 10, 13–19.

40. Bonfigli, R., Squartini, S., Fagiani, M., et al. (2015). *Unsupervised algorithms for non-intrusive load monitoring: An up-to-date overview* (pp. 1175–1180). New York: IEEE.
41. Anderson, K. D., Berges, M. E., Ocleanu, A., et al. (2012). Event detection for Non Intrusive load monitoring. In *Conference on IEEE Industrial Electronics Society* (pp. 3312–3317). IEEE.
42. Makonin, S., Popowich, F., Bajic, I. V., et al. (2016). Exploiting HMM sparsity to perform online real-time nonintrusive load monitoring[J]. *IEEE Transactions on Smart Grid*, 7(6), 2575–2585.
43. Parson, O., Ghosh, S., Weal, M., et al. (2012). Non-intrusive load monitoring using prior models of general appliance types. In *Twenty-Sixth AAAI Conference on Artificial Intelligence* (pp. 356–362). AAAI Press.
44. Zhao, B., Stankovic, L., & Stankovic, V. (2017). On a training-less solution for non-intrusive appliance load monitoring using graph signal processing. *IEEE Access*, 4, 1784–1799.
45. Jia, R., Gao, Y., & Spanos, C. J. (2015). A fully unsupervised non-intrusive load monitoring framework. In *IEEE International Conference on Smart Grid Communications* (pp. 872–878). IEEE.
46. Fukushima, K. (1980). Neocognitron: A self-organizing neural network model for a mechanism of pattern recognition unaffected by shift in position. *Biological Cybernetics*, 36(4), 193–202.
47. Atlas, L. E., Homma, T., & Li, R. J. M. (1987). An artificial neural network for spatio-temporal bipolar patterns: Application to phoneme classification. In *Neural Information Processing Systems* (pp. 31–40).
48. LeCun, Y., Bottou, L., Bengio, Y., & Haffner, P. (1998). Gradient-based learning applied to document recognition. *Proceedings of the IEEE*, 86(11), 2278–2324.
49. Kelly, J., & Knottenbelt, W. (2015). The UK-DALE dataset, domestic appliance-level electricity demand and whole-house demand from UK homes. *Scientific Data*, 2(150007). <https://doi.org/10.1038/sdata.2015.7>.
50. Batra, N., Kelly, J., Parson, O., Dutta, H., Knottenbelt, W., Rogers, A., et al. (2014). *An open source toolkit for non-intrusive load monitoring*. Cambridge. <https://doi.org/10.1145/2602044.2602051>.
51. Werbos, P. J. (1990). Backpropagation through time: What it does and how to do it. *Proceedings of the IEEE*, 78(10), 1550–1560.
52. Dongshu, W., Jialing, H., Mussadiq, A. R., Zijian, Z., & Liehuang, Z. (2017). An Efficient Sparse Coding-based Data-mining Scheme in Smart Grid. MSN 2017 Accepted.
53. Elhamifar, E., & Sastry, S. (2015). Energy disaggregation via learning powerlets and sparse coding. In *AAAI* (pp. 629–635).
54. Lai, Y. X., Lai, C. F., Huang, Y. M., & Chao, H. C. (2012). Multi-appliance recognition system with hybrid SVM/GMM classifier in ubiquitous smart home. *Information and Sciences*. <https://doi.org/10.1016/j.ins.2012.10.002>.
55. Bao, C., Ji, H., Quan, Y., et al. (2016). Dictionary learning for sparse coding: Algorithms and convergence analysis. *IEEE Transactions on Pattern Analysis and Machine Intelligence*, 38(7), 1356–1369.
56. Guvensan, M. A., Taysi, Z. C., & Melodia, T. (2012). Energy monitoring in residential spaces with audio sensor nodes: TinyEARS. *Ad Hoc Networks 2012*. <https://doi.org/10.1016/j.adhoc.2012.10.002>.
57. Yoo, J., Park, B., & Hur, K. (2011). Context awareness-based disaggregation of residential load consumption. In *Proceedings of the 18th International Federation of Automatic Control (IFAC) World Congress, Milano, Italy, 28 August–2 September 2011* (pp. 13691–13695).
58. Berges, M., & Rowe, A. (2011). Poster abstract: Appliance classification and energy management using multi-modal sensing. In *Proceedings of the 3rd ACM Workshop on Embedded Sensing Systems for Energy-Efficiency in Building, Seattle, WA, USA, 1 November 2011*.
59. Anderson, K., Ocleanu, A., Benitez, D., Carlson, D., Rowe, A., Berges, M., et al. (2012). A Fully Labeled Public Dataset for Event-Based Non-Intrusive Load Monitoring Research.
60. Saitoh, T., Osaki, T., Konishi, R., et al. (2010). Current sensor based home appliance and state of appliance recognition. *Sice Journal of Control Measurement and System Integration*, 3(2), 86–93.

61. Lin, G. Y., Lee, S. C., Hsu, Y. J., et al. (2010). Applying power meters for appliance recognition on the electric panel. In *Industrial Electronics and Applications* (pp. 2254–2259). IEEE.
62. Shao, H., Marwah, M., & Ramakrishnan, N. (2012). A temporal motif mining approach to unsupervised energy disaggregation. In *Proceedings of the 1st International Workshop on Non-Intrusive Load Monitoring, Pittsburgh, PA, USA, 7 May 2012*.
63. Kelly, J., & Knottenbelt, W. (2015). *Neural NILM: Deep neural networks applied to energy disaggregation* (pp. 55–64).
64. Cheng, X., Li, L., Wu, H., Ding, Y., Song, Y., & Sun, W. (2016). A survey of the research on non-intrusive load monitoring and disaggregation, *40*, 3108–3117. <https://doi.org/10.13335/j.1000-3673.pst.2016.10.026>.
65. Batra, N., Parson, O., Berges, M., et al. (2015). A comparison of non-intrusive load monitoring methods for commercial and residential buildings [J/OL]. 2014-08-27. <http://arxiv.org/abs/1408.6595>.
66. Norford, L. K., & Leeb, S. B. (1996). Non-intrusive electrical load monitoring in commercial buildings based on steady-state and transient load-detection algorithms. *Energy and Buildings*, *24*(1), 51–64.
67. Shaw, S. R., Leeb, S. B., Norford, L. K., et al. (2008). Nonintrusive load monitoring and diagnostics in power systems. *IEEE Transactions on Instrumentation and Measurement*, *57*(7), 1445–1454.
68. Orji, U., Remscrim, Z., Laughman, C. et al. (2010). Fault detection and diagnostics for non-intrusive monitoring using motor harmonics. *Applied Power Electronics Conference and Exposition* (pp. 1547–1554). Palm Springs, CA: IEEE.
69. Yan, R., & Gao, R. X. (2009). Energy-based feature extraction for defect diagnosis in rotary machines. *IEEE Transactions on Instrumentation and Measurement*, *58*(9), 3130–3139.

Accountable Anonymous Credentials



Zuoxia Yu, Man Ho Au and Rupeng Yang

Abstract Anonymity refers to withholding the identification information associated with an interaction. In the cyberworld, anonymous authentication is an important tool for protecting privacy. However, users may misbehave under the cover of anonymity, thus, accountability is crucial in any practical privacy-preserving authentication. Balancing anonymity and accountability has always been a challenging research problem in privacy protection. Accountable anonymous credentials are the cryptographic schemes designed to address this challenge. Users are allowed to anonymously prove their possession of valid credentials to protect user privacy. If they misbehave, they will be de-anonymized or blacklisted. In other words, it is technically possible for a system to achieve both anonymity and accountability simultaneously. In this chapter, we review the concept of anonymous credentials and discuss various accountability mechanisms. We discuss how the recent development of blockchain and quantum computers have influenced the recent research advances in this area. Finally, we also discuss how anonymous credentials are applied in real-world applications in cryptocurrencies.

1 Introduction

Users may wish to enjoy services anonymously for a number of reasons. For instance, people may wish to discuss sensitive personal issues, to research unpopular topics, to report abuses by governments and companies or to fight against online

Z. Yu · M. H. Au (✉) · R. Yang
Department of Computing, The Hong Kong Polytechnic University,
Hong Kong, China
e-mail: csallen@comp.polyu.edu.hk

Z. Yu
e-mail: zuoxia.yu@gmail.com

R. Yang
School of Computer Science and Technology, Shandong University,
Jinan 250101, China
e-mail: orbbyrp@gmail.com

censorship. It may simply be the wish of retaining some degree of personal privacy in the cyberworld as a matter of preference. After all, many people believe individual privacy should be respected. In the digital age, the protection of privacy is a necessity since computers could be used to infer individuals' lifestyles easily through profiling [26]. Anonymous authentication is an important tool for privacy protection as discussed in [53]. Besides, anonymous users may contribute works of better quality, as suggested by a research [1] on the quality of contributions to Wikipedia.

Unfortunately, anonymity is a double-edged sword that can also be used by criminals to engage in unlawful activities. For this reason, many popular service providers, including Wikipedia, Yelp, Slashdot, Craigslist, and most major IRC networks forbid anonymous access [70]. A recent study revealed that users of Tor, an anonymity network, are treated as 'second-class web citizens' by various web services [42]. Naturally, this leads to the following important research problem.

How can service providers allow anonymous access while protecting themselves against unauthorized or misbehaving users?

One can see that any solution to this problem should satisfy the following three requirements.

- *Authenticity*. Only authorized users are allowed to access the service. There could be a registration process in which the authorized users are defined. This set might change over time.
- *Anonymity*. Users remain anonymous to the system. In particular, the system should not be able to tell if two actions are performed by the same user. In other words, a user's sessions are unlinkable.
- *Accountability*. If a user violates the service provider's policy, it should be possible to make the user accountable for the action. The violation may be decided at a time after the user has finished using the service.

Here, we would like to stress that unlinkability is a necessary requirement to ensure a user remain anonymous in many cases. The reason is that the identity of an individual could be revealed when his actions are combined with publicly available information. For example, [65] presented a new class of statistical de-anonymization attacks against high-dimensional microdata, such as individual transaction records. Based on their techniques, it is possible to de-anonymise the data from Netflix. Specifically, despite the fact that the Netflix data set are assigned with fake customer IDs, customers can be identified when this data set is analysed together with the information on IMDB data.

Anonymous credential systems [18, 26] are solutions developed for this problem. They are systems supporting privacy-preserving authentications and at the same time ensuring accountability. The basic architecture of an anonymous credential system (ACS) consists of three roles, namely, issuing authority I , user U and server S . A user obtains a credential from an issuing authority. During an authentication protocol, the user generates an authentication token from his credential and presents this token to the server for verification. Anonymity is guaranteed as the user could generate a fresh authentication token for each authentication and these tokens are not linkable

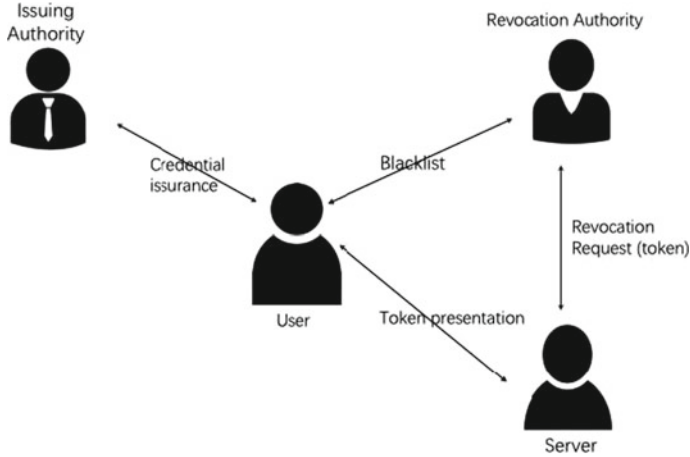


Fig. 1 Architecture of an anonymous credential system

nor bearing additional information about the credential. ACS could also feature a revocation authority, and its role depends on the type of accountability mechanisms supported. The general architecture of an ACS is shown in Fig. 1.

ACS can be classified according to the kind of punishments, that is, accountability mechanisms, available. Two broad categories are exposing the identity (anonymity revocation) or blocking future access (credential revocation) of the violator. Depending on the type of punishments supported, we call the former *revocable anonymity system* and the latter *anonymous blacklisting system* in this chapter. A revocable anonymity system is TTP-based if there exists a trusted third party (TTP) capable of de-anonymizing users. On the other hand, it is TTP-free if the identity of the violator can be computed from the misbehaviour directly. An anonymous blacklisting system can be classified similarly depending on whether such a trusted third party exists. At another dimension, ACS can also be classified according to how a credential is generated.

1.1 Organizations

This rest of this chapter is organized as follows. In Sect. 2, we present our classification of ACS. In Sect. 3, we survey existing constructions based on our classifications. In Sect. 4, we discuss recent research advances in ACS. In Sect. 5, we discuss real-world application of ACS and in particular, its applications in protecting the privacy of cryptocurrencies. We conclude in Sect. 6.

2 Classification of ACS

Our classification of ACS depends on three dimensions, namely, accountability, anonymity and authenticity. For accountability, an ACS accountability mechanism is objective if whether or not an interaction is a misbehaviour can be defined by rigorous mathematical formula. For example, in a electronic scheme, double-spending is considered a misbehaviour and it can be defined as using the credential too many times. On the other hand, in a group signature scheme, the verifier files a complaint to the group manager, who has the right to decide whether or not a misbehaviour occurred. Our classification separates judging misbehaviour from issuing accountability measures, the later include de-anonymization, revocation of credential or tracing of previous behaviours.

The second dimension is on anonymity provided. An ACS offered escrowed anonymity if there exists a trusted party capable of de-anonymizing a transaction. Linkable anonymity means that transaction from the same user can be linked. In other words, it is a pseudonymous system. Full anonymity means that user's actions are both anonymous and unlinkable.

Finally, we also classify schemes according to how legitimate users are defined (or enrolled). We use GM to denote the case when the set of legitimate users are defined by a group manager. We use ad-hoc group to refer to schemes where the set of the legitimate users can be defined in a ad-hoc manner by either the user or the verifier.

Our classification is summarized in Table 1.

3 Survey of Existing Schemes

Group Signature. The notion of group signature is put forth by Chaum and van Heyst [30]. This primitive allows member of a group to sign on behalf of the group while no other information about his own identity can be revealed from the signature. Anyone can check the validity of the signature by the public key of the group. Another participant of this primitive is called group manager, who is responsible for the setup of the system and has the ability to revoke the anonymity of the group users in the case of dispute.

Roughly speaking, group signature is a signature scheme with protocols which can prove the knowledge of signatures on committed values. Since the introduction of this primitive, many works have been done in this area. The formal security definition of group signature is given by Bellare et al. [5]. Later, this security notion is extended by Bellare et al. [6] to dynamic groups. Early efficient works mainly consider the construction of group signature schemes secure in the static groups, including [9, 11, 22]. Subsequently, the schemes proven secure in the dynamic groups are first given in [34, 40].

Table 1 Classification of Existing ACSs

	Subjective			Objective(e.g. No. of Usage, Time-related)			Level	GM	Ad-Hoc group
	De-anon	Revo	Trace	De-anon	Revo	Trace			
Group signature [30]	•						Escrow	•	
ACS [26]					⊙	⊙	Full	•	
Pseudonym system	•	•	•		•	•	Escrow	•	
Traceable signatures [43]	•	▲	▲				Escrow	•	
Group signature with revocation [20]	•	▲					Escrow	•	
Ring signatures [71]							Full		•
Linkable ring signatures [58]					•		Full*		•
Traceable ring signatures [36]				•	•		Full*		•
Bitcoin [63]					•	•	linkable		•
CryptoNote/Monero [69, 82].					•		Full		•
Ecash [25]				•	•	⊙	Full	•	
BLAC, EPID [78]		•					Full	•	
k-TAA [77]				•	•		Full		
Decentralized ACS [37]					⊙	⊙	Full		•

1. ⊙ refers to the optional system feature
2. ▲ means the revoked(or traced) credential must be located at first
3. • denotes the possession of that property
4. ‘De-anon’ is the abbreviation of de-anonymization, ‘Revo’ represents revocation, and ‘GM’ is short for group manager

It is not hard to see that group signature is a kind of ACS. More precisely, group signature supports the authenticity and accountability with the help of the designated group manager, and the anonymity level of group signature is identity escrow.

Group Signature with Revocation. Original definition of group signature does not support the revocation of the group members. Since the deletion of group members can be very useful in some cases, the group signature with membership revocation has attracted many attentions. One simple solution is to generate a new public key and refresh all signing keys of those unrevoked group members. However, this method is quite inefficient and inconvenient, especially in the large groups. To efficiently revoke group members without changing the signing key of each member, Camenisch and Lysyanskaya [20] introduce an elegant method via utilizing the dynamic accumulator in combination of zero-knowledge proofs. The main idea of their work is to incorporate the public key of the accumulator into the public key of the group signature, while integrating the secret key of the accumulator scheme with the secret key. Each time the user joins in the group, group manager adds his credential to the accumulator and returns the membership certificate to the users. Now, the proof of knowledge of the signature also contains a part that signer's credential is accumulated into the accumulator. The revocation of user is the process of deleting his credential from the accumulator.

Therefore, if we enhance the group signature with the revocation property, then the corresponding ACS will possess the property of revocation of users.

Traceable Signature. Usually, the traceability of the misbehaving users without compromising the anonymous of the honest users is preferable in ACS. While the only way to find signatures of a specific identity in group signature is to revoke the anonymity of all signatures, which threatens the anonymity of honest members. To avoid this and allow further tracing ability, traceable signature is more applicable to this case. Traceable signature allows the group manager to delegate the revoking (or opening) ability authority to clerks but only on specific group members, besides its original ability to open signature individually. In this way, misbehaving users can be traced without affecting the anonymity of the honest users.

Since the formal definition and first implementation in [43], numerous of works have been done about this primitive. Ge and Tate [38] proposes the efficiency improvements about the first implement. The pairing-based constructions with short signature are introduced by Nguyen and Safavi-Naini [66] and Choi et al. [31]. The first traceable signature scheme secure in standard model is proposed by Libert and Yung [52]. Blazy and Pointcheval introduces the traceable signature with some extra features in standard model [8].

Ring Signature. A ring signature allows a user to anonymously sign a message on behalf of a ring, which is selected by the signer. The signature can be verified by anyone with the public key, but there is no way to revoke the anonymity of a signature. Hence, ring signature can provide full anonymity in the ad-hoc group. This notion is first proposed by Rivest et al. [71] to capture the anonymity and authenticity in the ad-hoc groups. Then ring signature has been studied extensively. Early constructions

of ring signature schemes are mainly proposed in the random oracle model [10, 14, 35, 64] via utilizing the Fiat–Shamir methodology on the ring identification schemes. Subsequently, many works consider the constructions of ring signature in the standard model, including [7, 32, 73, 74].

Linkable Ring Signature. A linkable ring signature, presented by Liu et al. [58], is a ring signature scheme which can also allow one to determine whether two signatures are signed by the same users without revealing the signer. In other words, this primitive can provide anonymity and linkability simultaneously in an ad-hoc group. Since in some cases, such as e-voting system, the mechanism to detect double signing and anonymity are both needed. Since its introduction, numerous works have been done. For instance, works [2, 59, 81] improves the security model while [2, 76, 80] reduces the signature size, and unconditional anonymity is provided in [57].

When using this linkable ring signature as an anonymous credential system, the linkability of it can guarantee the revocation of those signatures signed by a same signer.

Traceable Ring Signature. A traceable ring signature, introduced by Fujisaki and Suzuki [36], is a linkable ring signature with de-anonymity. In a traceable ring signature, each signature is associated with a tag, which is composed of a list of ring members and issues. If the signer signed the same message with the same tag, then everyone can see that these two signatures are linked, whereas the anonymity of the signer will be revoked if he signed two different messages with the same tag besides the revealing of linkability of the two signatures.

Therefore, if we use traceable ring signature as a underlying tool, we can get an ACS with de-anonymity of misbehaving users, credential revocation and fully anonymity in ad-hoc groups.

Anonymous Credential System. The notion of anonymous credential system is first presented by Chaum in [26]. As mentioned in Sect. 2, there are three different roles in an anonymous credential system, namely, the issuing authority, the user, and the server; in the system, a user first obtains a credential from an issuing authority and then generates a fresh and unlinkable authentication token for his credential each time authenticating with the server; the server accept the user if and only if he has registered to the issuing authority.

After its invention, there are numerous works considering constructing anonymous credential systems with better efficiency, security and usability [13, 19, 21, 28, 33, 60]. Especially, in [19, 20], revocable anonymous credential systems are constructed. In a revocable anonymous credential system, there is an additional revocation authority, who can subjectively determine which authentication is related to a misbehaviour and is able to locate and revoke the user who launches this authentication. Thus, it could provide accountability for misbehaved users.

An anonymous credential system is sometimes referred to as a pseudonym system [60] since it allows users to interact with different organizations using different pseudonyms (and the same pseudonym with the same organization). In other words, it offers pseudonymity as interactions of the same user with the same organization can be linked while interactions with different organizations cannot be linked.

k-Times Anonymous Authentication. In many real world applications, e.g. electronic voting, the number of usage for each credential should be limited. This could be achieved via the k -times anonymous authentication (k -TAA) protocol, which is presented by Teranishi et al. in [77]. In a k -TAA protocol, the user could pass the authentication anonymously as long as he has not used his credential more than k times; but when the user attempts to authenticate for a $k + 1$ time, this misbehaviour can be detected and his identity will be revealed. In this way, ‘anonymity revocation’ under objective condition (i.e. limited number of usage for each credential) is realized. There are also a few variant of the k -TAA protocol, e.g. in [16], periodic k -TAA protocol, which only limits number of usage for each credential in each time period, is proposed, and in [67], dynamic k -TAA protocol, which allows each server to independently grant or revoke users from their own groups, is introduced.

Electronic Cash. One typical application and special form of k -TAA protocol is the electronic cash (Ecash) system. The notion of Ecash is first presented by Chaum [25]. In the system, there are three different parties, namely, the bank, the user and the merchant. Similar to that in the scenario of anonymous credential system, a user first withdraws money from the bank, then authenticates anonymously with the merchant to spend the money. In early works [25, 27], the check of payment needs the bank to be online, while in subsequent works [17, 24, 29], offline Ecash systems are constructed, where the merchant only needs to communicate with the bank periodically. The key accountability requirement for (offline) Ecash is that any user who spends more money than he has withdrawn should be de-anonymized and punishment can be imposed on him then.

Blacklistable Anonymous Credential System. One may note that in previous accountable anonymous credential systems, misbehaviours are either determined by a trusted third party or predefined when the system is setup. However, in practice, it is often required to determine misbehaviours by the verifier subjectively. To close this gap, in two independent and concurrent works [15, 78], blacklistable anonymous credential (BLAC) system is presented. A BLAC system, as indicated by its name, is an enhanced version of the normal anonymous credential system, where the server is further allowed to specify a blacklist in each authentication. The blacklist is made up of transcripts in previous authentications, and a user can pass the authentication if and only if he is legally registered in the system and he has never launched an authentication in the blacklist. Thus, the BLAC system could support ‘subjective revocation of credential’. There are also several works in this line of research. In particular, in [79], BLAC system with constant communication cost is constructed; in [3, 4], BLAC systems with fine-grained access policy are proposed; besides, in [84], BLAC system supporting ad-hoc groups is developed.

4 Recent Research in Anonymous Credential Systems

Recent research in ACS attempts to address two issues. First, it aims to reduce the trust placed on credential issuer. Another active research direction is on strengthening security of ACS against quantum computers. The effort to address these issues results in new constructions of ACS including decentralized anonymous credential systems and post-quantum secure anonymous credential systems.

4.1 Decentralized Anonymous Credential Systems

A long-standing problem for previous anonymous credential systems is that ‘who can play the role of issuing authority?’. Typically, it is assumed that the issuing authority is an organization trusted by all servers. However, it is difficult to choose an organization that is trusted by all servers in practice, especially when servers can only obtain an anonymous proof revealing beyond ‘the user is legitimate to access your services’ during each authentication. In some schemes, it is assumed that the issuer and the server is the same entity. This is undesirable and may harm the privacy of users or even drive users away in some cases. For example, imagine Bob has a drinking problem and plans to seek help from an online forum about alcohol abuse. However, personal information is needed to register an account of the forum. Bob may not feel comfortable about the registration process and may choose not to seek help.

Such dilemma greatly limits the applicability of current anonymous credential systems. Fortunately, the blockchain technique provides a new way to solve this problem. In a nutshell, the blockchain technique presents a proper incentive to encourage people around the world to maintain copies of a public ledger. In this way, as long as most of (the computation power of) people in the world is not controlled by a malicious party, the public ledger is append-only and a consistent view of the ledger for everyone can be guaranteed. In the following, we review how a public ledger can help decentralizing the process of credential insurance.

Decentralized Anonymous Credential System. The novel idea of applying blockchain techniques to construct decentralized anonymous credential system (DACS) from the blockchain technique is proposed by Garman et al. [37]. Yang et al. [84] propose a more efficient version which supports anonymous blacklisting. Here, we present a more detailed description of the workflow of DACS, where the blockchain technique is used to provide a public append-only ledger in the system. For clarity, we illustrate its workflow in Fig. 2, and as a comparison, we also illustrate the workflow of traditional anonymous credential systems in Fig. 3.

In the beginning, a user registers by placing his personal information along with his self-generated credential to the ledger. Servers will collect these registration information and chooses eligible users (e.g. users older than 18) to form a candidate

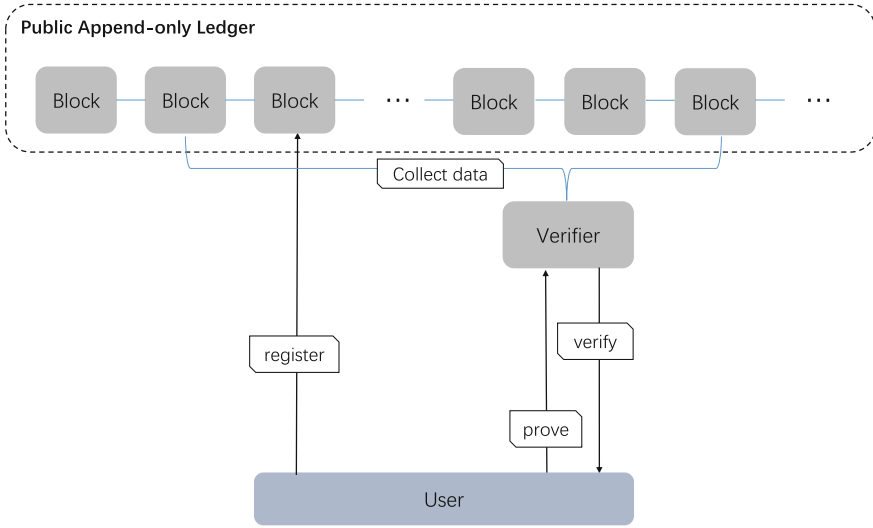


Fig. 2 Workflows of the decentralized anonymous credential systems

users set. Then to access services of a server in the system, the user needs to prove that his credential belongs to the candidate set.

Compared to traditional anonymous credential system, DACS greatly reduces trust assumptions by eliminating a trusted credential issuer and allow each server to specify the group of eligible users directly. An additional advantage is that since the public ledger is to be shared by many servers, a user do not reveal which service he would like to use in the registration process.

Decentralized Blacklistable Anonymous Credential System. We review the work due to Yang et al. [84], which uses blockchain technique to build a decentralized blacklistable anonymous credential systems (DBLACS). To explain how the decentralized blacklistable anonymous credential system works, we illustrate its workflow in Fig. 4. As a comparison, we present the workflow of traditional blacklistable anonymous credential systems in Fig. 5. Similar to DACS, DBLACS does not require a central issuer. To register, a user uploads his personal information together with his self-generated credential to the public append-only ledger. Servers will collect data from the ledger. The difference is that besides registration information, servers will also collect blacklists of other servers and use them to enhance its own blacklist. Each server will publish its selected candidate users set and blacklist to the ledger regularly. To access a service, a user first obtains the latest candidate users set and blacklist from the ledger. Then, he checks if he is eligible (i.e. he checks that he is in the candidate users set and that he is not in the blacklist). Finally, he executes an authentication protocol with the server and proves that he satisfies the access requirement. We remark that the authentication transcript itself is sufficient for the server to blacklist the authenticating user.

Fig. 3 Workflows of the anonymous credential systems

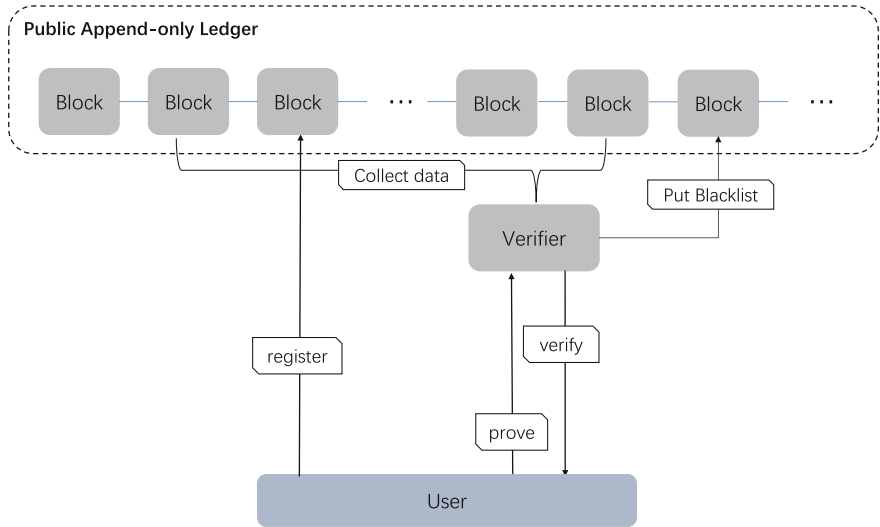
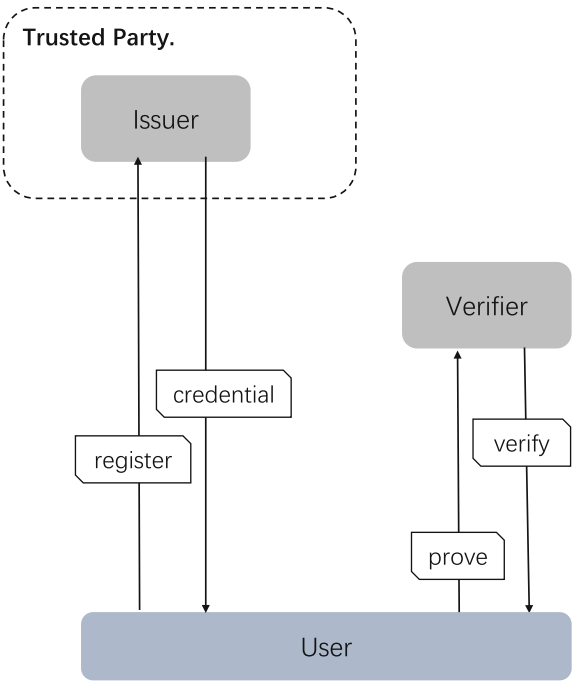
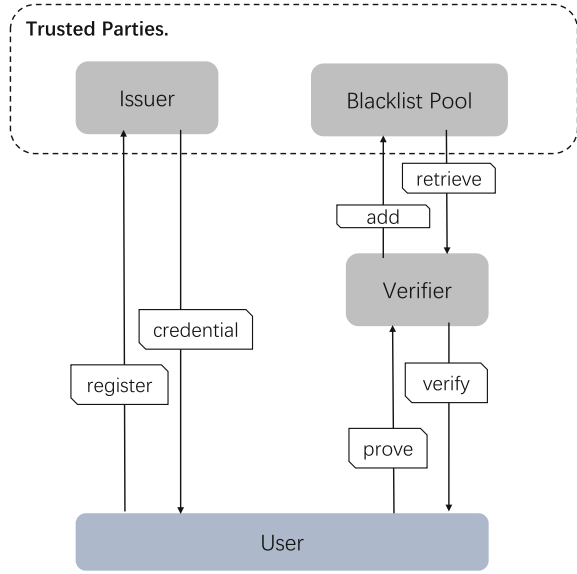


Fig. 4 Workflows of the decentralized blacklistable anonymous credential systems

Fig. 5 Workflows of the blacklistable anonymous credential systems



Similar to the DACS, the DBLACS reduces trust in the credential generation process. As a blacklisting anonymous credential system, the blockchain technique leads to several additional desirable properties. First, as each server places his/her own blacklist on the ledger, servers can conveniently obtain blacklists of other servers. Blacklist sharing, in practice, could further deter users from misbehaving. Second, users can inspect blacklists from the ledger in advance instead of requesting it from the server. This ensures consistency of the blacklist and partially prevent blacklist gaming attack in which a malicious server may provide a different blacklist to different authenticating users to gain additional information.

4.2 Post-Quantum Secure Anonymous Credential Systems

Most current anonymous credential systems are built from traditional number-theoretical assumptions, which are either based on the hardness of factoring or based on the hardness of computing discrete logarithm. Unfortunately, both problems can be solved by quantum computers using the celebrated Shor algorithm [75] (or its variants). Recent development in quantum computers made this concern a legitimate risk that needs to be addressed.

In recent years, a number of cryptographic constructions are developed based on hardness of lattice problems, which is believed to be hard for quantum computers. In the remaining part of this section, we will focus on progress in constructing lattice-based anonymous credential systems.

Lattice-Based Group Signature. Research on lattice-based anonymous credential systems starts from constructing lattice-based group signature schemes [23, 39]. However, in early constructions, the signature size is linear in the number of group users, which prevents the scheme from using in settings involving numerous users. Then in subsequent works [46, 49, 54, 68], group signature schemes with logarithmic signature size are constructed. In particular, the group signature constructed in [49] is widely considered to be practical as it does not require a lattice with trapdoor. Based on the more concise lattices known as ideal lattices, Ling et al. [56] developed group signature schemes with constant signature size.

Another line of work aims to improve the functionality of lattice-based ACS. In [47], lattice-based group signature scheme supporting user revocation is constructed. Then in [48], lattice-based group signature scheme allowing users to register at any time, is proposed. Recently, in [55], fully dynamic group signature scheme, which enables the group manager to dynamically add and remove users, is also built from lattice assumptions.

Besides, group signature with better privacy guarantee is also constructed from lattice. For instance, in [51], Libert et.al. construct lattice-based group signature scheme with message-dependent opening, which supports a two-layer opening authority, where the first authority can specify a message and the second authority can open signatures on that message.

Lattice-Based Ring Signature. There are also several works in constructing lattice-based ring signature schemes. The first lattice-based ring signature scheme [12] has a signature size linear in the number of ring members. Then in [49], ring signature scheme with logarithmic signature size is constructed from lattice-based accumulator. Subsequently, lattice-based linkable ring signature schemes [83, 85] is presented.

Advanced Anonymous Credential Systems from Lattice. Due to its complexity, the first lattice-based anonymous credential system is not given until the year 2016. In [48], based on a general framework for constructing lattice-based zero-knowledge proofs, which is denoted as abstract Stern's protocol, anonymous credential system from lattice assumptions is presented. Then in [83], lattice-based k-times anonymous authentication and blacklistable anonymous credential system are constructed. These are built on a novel technique proving/disproving the correct evaluation of a lattice-based weak pseudorandom function. In an independent and concurrent work [50], zero-knowledge proof for lattice-based pseudorandom function is also presented and is used to construct the first lattice-based compact electronic cash.

5 Applications of Anonymous Credential Systems to Cryptocurrencies

In the seminar work of Nakamoto [63], bitcoin, a fully decentralized cryptocurrency is presented. The core part of the bitcoin is the blockchain technique, which realizes a public append-only ledger. All transactions, in which the consent is represented by

signatures of the payers, are recorded in this ledger. In this way, anyone can check if a transaction is valid. Creation of monetary unit is achieved through a process known as mining, which requires computing nodes of the bitcoin network to solve a certain hard problem. During these process, the nodes also help maintaining the append-only ledger and record all valid transactions on it.

One problem of the bitcoin is that it does not protect the anonymity of users. In particular, transactions of the same user could be linked easily [44]. Recognizing its weaknesses, various attempts have been made to improve privacy protection. Several of these solutions are related to the use of ACS. We describe them in greater details in this section.

CryptoNote and Monero. The CryptoNote framework is presented in [82]. It uses several cryptographic primitives to enhance the privacy of bitcoin, including linkable ring signature scheme, homomorphic commitment scheme, and range proof. Monero [69] is currently the most well known cryptocurrency based on CryptoNote.

We explain how CryptoNote/Monero works, where the whole workflow is also called a ring confidential transaction (RingCT) protocol. To hide address of the payer, a new way of representing consent is needed. The reason is that verification of an ordinary digital signature requires the public key (i.e. address) of the payer. To tackle this challenge, the transaction is signed by the payer using a linkable ring signature, where the ring is formed by the address of the actual payer and a number of decoys (called mixins). The anonymity provided by the linkable ring signature scheme could protect the privacy of the payer while its linkability prevents double-spending. Then to hide the identity of payee, the payer will send money to a temporary address which is a randomized version of the receiver's address, whose secret key can be computed from the receiver's secret key. It is also guaranteed that it is hard to compute the secret key of the temporary address without the receiver's secret key. Finally, the transferred money in each transaction is stored in a commitment. Anyone could check that the input money and the output money in a transaction are equivalent since the commitment scheme is homomorphic. Moreover, to avoid a 'negative transfer amount' attack,¹ a range proof is used to ensure that each committed value is positive.

However, a few problems remains. First, the linkable ring signature scheme employed by Monero has a signature size linear in the size of ring. This prevents payers from choosing a large enough ring to hide their identities. Typically ring size as of current version of Monero is 5. In fact, recent works have shown that a large fraction of users in Monero can be de-anonymized [45, 62]. Besides, cryptographic primitives are used in a non-standard way in Monero, and it lacks a formal security proof for the whole system.

There are a few works attempt to solve these problems recently. In [76], a new linkable ring signature scheme that achieves a constant signature size is presented and is used to improve current RingCT protocol. However, the new protocol needs a trusted setup, which is not favourable for decentralized cryptocurrencies. Then in [83, 85], trusted setup-free linkable ring signature schemes achieving logarithmic

¹ A user Alice with address A_1 , A_2 and A_3 could create money out of nothing by making a transaction that receives \$0 from address A_1 and sends \$-1 to address A_2 and \$1 to address A_3 .

signature size are also presented. Both schemes are based on lattice assumptions, which makes them secure against quantum computers. In addition, the work [85] also discusses how to use their linkable ring signature scheme to construct RingCT protocol.

ZCash. Privacy-preserving decentralized cryptocurrencies are constructed by combining previous techniques in constructing provably secure cryptocurrency and the blockchain technique.

In [61], a decentralized version of traditional Ecash, which is called Zerocoin, is presented. The protocol in Zerocoin is similar to the decentralized anonymous credential system constructed in [37]. It integrates the protocol with Bitcoin in an elegant manner. Informally speaking, user Alice changes her bitcoin into a Zerocoin by launching a mint transaction that contains her one-show credential but has no output address. Then, to redeem her bitcoin, she creates a proof to show that she has a fresh credential on the blockchain and attaches it on a spend transaction to transfer money from an unused mint transaction in the blockchain to her new address. The spend transaction will be put on the blockchain only if the proof is valid. Now, if there are enough mint transactions, no one could link Alice's two addresses, thus her privacy is protected.

In [72], Zerocash is proposed. The main difference between Zerocash and Zerocoin is that the former employs zero-knowledge succinct non-interactive arguments of knowledge, thus can obtain a much smaller proof size and verification time. Besides, it also considers transfer amount privacy. Based on the work [72], ZCash, a new decentralized cryptocurrency is built.

Zerocoin and Zerocash can provide a very strong protection for users' privacy. However, both of them required a trusted setup and the one who performs the setup procedure has the ability to create money. To address this problem, Groth et al. [41], constructs a trusted setup-free version of the Zerocoin system from their newly proposed one-out-of-many proofs. However, the verification effort [41] is linear in the size of the ledger.

6 Conclusion

In this chapter, we review existing developments in the area of anonymous credentials and their applications in cryptocurrencies. Thanks to the numerous research effort, it is possible to construct systems offering various trade-offs between anonymity, accountability and authenticity. We would like to remark that offering the highest level of anonymity may not be the most challenging or most desirable. The designer should choose schemes offering the appropriate level of privacy protection.

References

1. Anthony, D., Smith, S. W., & Williamson, T. (2007). The Quality of Open Source Production: Zealots and Good Samaritans in the Case of Wikipedia. Technical Report TR2007-606, Dartmouth College, Computer Science, Hanover, NH, September 2007.
2. Au, M. H., Chow, S. S. M., Susilo, W., & Tsang, P. P. (2006). Short linkable ring signatures revisited. In *European Public Key Infrastructure Workshop* (Vol. 4043, pp. 101–115). Berlin: Springer.
3. Au, M. H., & Kapadia, A. (2012). Perm: Practical reputation-based blacklisting without ttps. In *Proceedings of the 2012 ACM Conference on Computer and Communications Security* (pp. 929–940). ACM.
4. Au, M. H., Kapadia, A., Susilo, W., & Au, M. H. (2012). Blacr: Ttp-free blacklistable anonymous credentials with reputation. In *NDSS*.
5. Bellare, M., Micciancio, D., & Warinschi, B. (2003). Foundations of group signatures: Formal definitions, simplified requirements, and a construction based on general assumptions. In *Eurocrypt* (Vol. 2656, pp. 614–629). Berlin: Springer.
6. Bellare, M., Shi, H., & Zhang, C. (2005). Foundations of group signatures: The case of dynamic groups. In *Cryptographers' Track at the RSA Conference* (pp. 136–153). Berlin: Springer.
7. Bender, A., Katz, J., & Morselli, R. (2006). Ring signatures: Stronger definitions, and constructions without random oracles. In *TCC* (Vol. 6, pp. 60–79). Berlin: Springer.
8. Blazy, O., & Pointcheval, D. (2012). Traceable signature with stepping capabilities. In *Cryptography and Security* (pp. 108–131). Berlin: Springer.
9. Boneh, D., Boyen, X., & Shacham, H. (2004). Short group signatures. In *Crypto* (Vol. 3152, pp. 41–55). Berlin: Springer.
10. Boneh, D., Gentry, C., Lynn, B., & Shacham, H. (2003). Aggregate and verifiably encrypted signatures from bilinear maps. In *Eurocrypt* (Vol. 2656, pp. 416–432). Berlin: Springer.
11. Boneh, D., & Shacham, H. (2004). Group signatures with verifier-local revocation. In *Proceedings of the 11th ACM Conference on Computer and Communications Security* (pp. 168–177). ACM.
12. Brakerski, Z., & Kalai, Y. T. (2010). A framework for efficient signatures, ring signatures and identity based encryption in the standard model. *IACR Cryptology ePrint Archive*, 2010, 86.
13. Brands, S. A. (2000). *Rethinking public key infrastructures and digital certificates: building in privacy*. Mit Press.
14. Bresson, E., Stern, J., & Szydlo, M. (2002). Threshold ring signatures and applications to ad-hoc groups. In *Annual International Cryptology Conference* (pp. 465–480). Berlin: Springer.
15. Brickell, E., & Li, J. (2007). Enhanced privacy id: A direct anonymous attestation scheme with enhanced revocation capabilities. In *Proceedings of the 2007 ACM Workshop on Privacy in Electronic Society* (pp. 21–30). ACM.
16. Camenisch, J., Hohenberger, S., Kohlweiss, M., Lysyanskaya, A., & Meyerovich, M. (2006). How to win the clonewars: efficient periodic n-times anonymous authentication. In *Proceedings of the 13th ACM Conference on Computer and Communications Security* (pp. 201–210). ACM.
17. Camenisch, J., Hohenberger, S., & Lysyanskaya, A. (2005). Compact e-cash. In *Eurocrypt* (Vol. 3494, pp. 302–321). Berlin: Springer.
18. Camenisch, J., & Lysyanskaya, A. (2001). An efficient system for non-transferable anonymous credentials with optional anonymity revocation. In B. Pfitzmann (Ed.), *Advances in Cryptology - EUROCRYPT 2001, International Conference on the Theory and Application of Cryptographic Techniques, Innsbruck, Austria, May 6–10, 2001, Proceeding* (Vol. 2045, pp. 93–118)., Lecture notes in computer science Berlin: Springer.
19. Camenisch, J., & Lysyanskaya, A. (2001). An efficient system for non-transferable anonymous credentials with optional anonymity revocation. *Advances in Cryptology-EUROCRYPT, 2001*, 93–118.
20. Camenisch, J., & Lysyanskaya, A. (2002). Dynamic accumulators and application to efficient revocation of anonymous credentials. In *Crypto* (Vol. 2442, pp. 61–76). Berlin: Springer.

21. Camenisch, J., & Lysyanskaya, A. (2002). A signature scheme with efficient protocols. In *International Conference on Security in Communication Networks* (pp. 268–289). Berlin: Springer.
22. Camenisch, J., & Lysyanskaya, A. (2004). Signature schemes and anonymous credentials from bilinear maps. In *Annual International Cryptology Conference* (pp. 56–72). Berlin: Springer.
23. Camenisch, J., Neven, G., & Rückert, M. (2012). Fully anonymous attribute tokens from lattices. In *SCN* (pp. 57–75). Berlin: Springer.
24. Canard, S., & Gouget, A. (2007). Divisible e-cash systems can be truly anonymous. In *Eurocrypt* (Vol. 4515, pp. 482–497). Berlin: Springer.
25. Chaum, D. (1983). Blind signatures for untraceable payments. In *Advances in Cryptology* (pp. 199–203). Berlin: Springer.
26. Chaum, D. (1985). Security without identification: Transaction systems to make big brother obsolete. *Communications of the ACM*, 28(10), 1030–1044.
27. Chaum, D. (1989). Online cash checks. In *Workshop on the Theory and Application of Cryptographic Techniques* (pp. 288–293). Berlin: Springer.
28. Chaum, D., & Evertse, J. -H. (1986). A secure and privacy-protecting protocol for transmitting personal information between organizations. In *Crypto* (Vol. 86, pp. 118–167). Berlin: Springer.
29. Chaum, D., Fiat, A., & Naor, M. (1990). Untraceable electronic cash. In *Proceedings on Advances in Cryptology* (pp. 319–327). New York, Inc.: Springer.
30. Chaum, D., & Van Heyst, E. (1991). Group signatures. In *Advances in Cryptology? EURO-CRYPT? 91* (pp. 257–265). Berlin: Springer.
31. Choi, S. G., Park, K., & Yung, M. (2006). Short traceable signatures based on bilinear pairings. In *IWSEC* (Vol. 6, pp. 88–103).
32. Chow, S. S. M., Wei, V. K., Liu, J. K., & Hon Yuen, Tsz. (2006). Ring signatures without random oracles. In *Proceedings of the 2006 ACM Symposium on Information, Computer and Communications Security* (pp. 297–302). ACM.
33. Damgård, I. B. (1990). Payment systems and credential mechanisms with provable security against abuse by individuals. In *Proceedings on Advances in Cryptology* (pp. 328–335). New York, Inc.: Springer.
34. Delerablée, C., & Pointcheval, D. (2006). Dynamic fully anonymous short group signatures. *Vietcrypt*, 4341, 193–210.
35. Dodis, Y., Kiayias, A., Nicolosi, A., & Shoup, V. (2004). Anonymous identification in ad hoc groups. In *Eurocrypt* (Vol. 3027, pp. 609–626). Berlin: Springer.
36. Fujisaki, E., & Suzuki, K. (2007). Traceable ring signature. In *Public Key Cryptography* (Vol. 4450, pp. 181–200). Berlin: Springer.
37. Garman, C., Green, M., & Miers, I. (2014). Decentralized anonymous credentials. In *NDSS*.
38. Ge, H., & Tate, S. R. (2006). Traceable signature: better efficiency and beyond. In *International Conference on Computational Science and Its Applications* (pp. 327–337). Berlin: Springer.
39. Gordon, S. D., Katz, J., & Vaikuntanathan, V. (2010). A group signature scheme from lattice assumptions. In *ASIACRYPT* (pp. 395–412). Berlin: Springer.
40. Groth, J. (2007). Fully anonymous group signatures without random oracles. *Advances in Cryptology-ASIACRYPT, 2007*, 164–180.
41. Groth, J., & Kohlweiss, M. (2015). One-out-of-many proofs: Or how to leak a secret and spend a coin. In *Annual International Conference on the Theory and Applications of Cryptographic Techniques* (pp. 253–280). Berlin: Springer.
42. Khattak, S., Fifield, D., Afroz, S., Javed, M., Sundaresan, S., McCoy, D., Paxson, V., & Murdoch, S. J. (2016). Do you see what I see? differential treatment of anonymous users. In *23rd Annual Network and Distributed System Security Symposium, NDSS 2016, San Diego, California, USA, February 21–24 2016*. The Internet Society.
43. Kiayias, A., Tsiounis, Y., & Yung, M. (2004). Traceable signatures. In *Eurocrypt* (Vol. 3027, pp. 571–589). Berlin: Springer.
44. Koshy, P., Koshy, D., & McDaniel, P. (2014). An analysis of anonymity in bitcoin using p2p network traffic. In *International Conference on Financial Cryptography and Data Security* (pp. 469–485). Berlin: Springer.

45. Kumar, A., Fischer, C., Tople, S., & Saxena, P. (2017). A traceability analysis of monero's blockchain. *IACR Cryptology ePrint Archive*, 2017, 338.
46. Laguillaumie, F., Langlois, A., Libert, B., & Stehlé, D. (2013). Lattice-based group signatures with logarithmic signature size. In *ASIACRYPT* (pp. 41–61). Berlin: Springer.
47. Langlois, A., Ling, S., Nguyen, K., & Wang, H. (2014). Lattice-based group signature scheme with verifier-local revocation. In *PKC* (pp. 345–361). Berlin: Springer.
48. Libert, B., Ling, S., Mouhartem, F., Nguyen, K., & Wang, H. (2016). Signature schemes with efficient protocols and dynamic group signatures from lattice assumptions. In *ASIACRYPT* (pp. 373–403). Berlin: Springer.
49. Libert, B., Ling, S., Nguyen, K., & Wang, H. (2016). Zero-knowledge arguments for lattice-based accumulators: logarithmic-size ring signatures and group signatures without trapdoors. In *EUROCRYPT* (pp. 1–31). Berlin: Springer.
50. Libert, B., Ling, S., Nguyen, K., & Wang, H. (2017). Zero-knowledge arguments for lattice-based prfs and applications to e-cash. In *International Conference on the Theory and Application of Cryptology and Information Security* (pp. 304–335). Berlin: Springer.
51. Libert, B., Mouhartem, F., & Nguyen, K. (2016). A lattice-based group signature scheme with message-dependent opening. In *ACNS* (pp. 137–155). Berlin: Springer.
52. Libert, B., & Yung, M. (2009). Efficient traceable signatures in the standard model. *Pairing-Based Cryptography-Pairing*, 2009, 187–205.
53. Andrew, Y. (2016). Lindell. Anonymous authentication, Online Database.
54. Ling, S., Nguyen, K., & Wang, H. (2015). Group signatures from lattices: simpler, tighter, shorter, ring-based. In *PKC* (pp. 427–449). Berlin: Springer.
55. Ling, S., Nguyen, K., Wang, H., & Xu, Y. (2017). Lattice-based group signatures: Achieving full dynamicity with ease. *Cryptology ePrint Archive*, Report 2017/353. <http://eprint.iacr.org/2017/353>.
56. Ling, S., Nguyen, K., Wang, H., & Xu, Y. (2018). Constant-size group signatures from lattices. In *IACR International Workshop on Public Key Cryptography* (pp. 58–88). Berlin: Springer.
57. Liu, J. K., Au, M. H., Susilo, W., & Zhou, J. (2014). Linkable ring signature with unconditional anonymity. *IEEE Transactions on Knowledge and Data Engineering*, 26(1), 157–165.
58. Liu, J. K., Wei, V. K., & Wong, D. S. (2004). Linkable spontaneous anonymous group signature for ad hoc groups. In *ACISP* (Vol. 4, pp. 325–335). Berlin: Springer.
59. Liu, J. K., & Wong, D. S. (2005). Linkable ring signatures: Security models and new schemes. In *International Conference on Computational Science and Its Applications* (pp. 614–623). Berlin: Springer.
60. Lysyanskaya, A., Rivest, R. L., Sahai, A., & Wolf, S. (1999). Pseudonym systems. In *Selected Areas in Cryptography* (Vol. 1758, pp. 184–199). Berlin: Springer.
61. Miers, I., Garman, C., Green, M., & Rubin, A. D. (2013). Zerocoin: Anonymous distributed e-cash from bitcoin. In *2013 IEEE Symposium on Security and Privacy (SP)* (pp. 397–411). IEEE.
62. Miller, A., Möser, M., Lee, K., & Narayanan, A. (2017). An empirical analysis of linkability in the monero blockchain. arXiv preprint. [arXiv:1704.04299](https://arxiv.org/abs/1704.04299).
63. Nakamoto, S. (2008). Bitcoin: A peer-to-peer electronic cash system.
64. Naor, M. (2002). Deniable ring authentication. In *Crypto* (Vol. 2, pp. 481–498). Berlin: Springer.
65. Narayanan, A., & Shmatikov, V. (2008). Robust de-anonymization of large sparse datasets. In *2008 IEEE Symposium on Security and Privacy (S&P 2008), May 18–21 2008, Oakland, California, USA* (pp. 111–125). IEEE Computer Society.
66. Nguyen, L., & Safavi-Naini, R. (2004). Efficient and provably secure trapdoor-free group signature schemes from bilinear pairings. In *International Conference on the Theory and Application of Cryptology and Information Security* (pp. 372–386). Berlin: Springer.
67. Nguyen, L., & Safavi-Naini, R. (2005). Dynamic k-times anonymous authentication. In *ACNS* (Vol. 3531, pp. 318–333). Berlin: Springer.
68. Nguyen, P. Q., Zhang, J., & Zhang, Z. (2015). Simpler efficient group signatures from lattices. In *PKC* (pp. 401–426). Berlin: Springer.
69. Noether, S., & Mackenzie, A. (2016). Ring confidential transactions. *Ledger*, 1, 1–18.

70. The Tor Project. List of irc/chat networks that block or support tor. Accessed on 6 Jan 2018.
71. Rivest, R., Shamir, A., & Tauman, Y. (2001). How to leak a secret. *Advances in Cryptology?ASIACRYPT 2001* (pp. 552–565).
72. Sasson, E. B., Chiesa, A., Garman, C., Green, M., Miers, I., Tromer, E., & Virza, M. (2014). Zerocash: Decentralized anonymous payments from bitcoin. In *2014 IEEE Symposium on Security and Privacy (SP)* (pp. 459–474). IEEE.
73. Schäge, S., & Schwenk, J. (2010). A cdh-based ring signature scheme with short signatures and public keys. In *Financial Cryptography* (Vol. 6052, pp. 129–142). Berlin: Springer.
74. Shacham, H., & Waters, B. (2007). Efficient ring signatures without random oracles. In *Public Key Cryptography* (Vol. 4450, pp. 166–180). Berlin: Springer.
75. Shor, P. W. (1994). Algorithms for quantum computation: Discrete logarithms and factoring. In *1994 Proceedings of the 35th Annual Symposium on Foundations of Computer Science* (pp. 124–134). IEEE.
76. Sun, S. -F., Au, M. H., Liu, J. K., & Yuen, T. H. (2017). Ringct 2.0: A compact accumulator-based (linkable ring signature) protocol for blockchain cryptocurrency monero. In *European Symposium on Research in Computer Security* (pp. 456–474). Berlin: Springer.
77. Teranishi, I., Furukawa, J., & Sako, K. (2004). K-times anonymous authentication. In *Asiacrypt* (Vol. 3329, pp. 308–322). Berlin: Springer.
78. Tsang, P. P., Au, M. H., Kapadia, A., & Smith, S. W. (2007). Blacklistable anonymous credentials: Blocking misbehaving users without ttps. In *Proceedings of the 14th ACM Conference on Computer and Communications Security* (pp. 72–81). ACM.
79. Tsang, P. P., Au, M. H., Kapadia, A., & Smith, S. W. (2008). Perea: Towards practical ttp-free revocation in anonymous authentication. In *Proceedings of the 15th ACM Conference on Computer and Communications Security* (pp. 333–344). ACM.
80. Tsang, P. P., & Wei, V. K. (2005). Short linkable ring signatures for e-voting, e-cash and attestation. In *ISPEC* (Vol. 3439, pp. 48–60). Berlin: Springer.
81. Tsang, P. P., Wei, V. K., Chan, T. K., Au, M. H., Liu, J. K., & Wong, D. S. (2004). Separable linkable threshold ring signatures. In *Indocrypt* (Vol. 3348, pp. 384–398). Berlin: Springer.
82. van Saberhagen, N. (2013). Cryptonote v 2. 0.
83. Yang, R., Au, M. H., Lai, J., Xu, Q., & Yu, Z. (2017). Lattice-based techniques for accountable anonymity: Composition of abstract sterns protocols and weak prf with efficient protocols from lwr. *Cryptology ePrint Archive*, Report 2017/781. <https://eprint.iacr.org/2017/781>.
84. Yang, R., Au, M. H., Xu, Q., & Yu, Z. (2017). Decentralized blacklistable anonymous credentials with reputation. In *IACR Cryptology ePrint Archive* (Vol. 2017, p. 389).
85. Zhang, H., Zhang, F., Tian, H., & Au, M. H. (2018). Anonymous post-quantum cryptocash. In *FC*.

Author Biographies

Zuoxia Yu received her bachelor's degree and master's degree from Shandong University, China, in 2012 and 2015, respectively. Currently, she is a Ph.D. student at Department of Computing, the Hong Kong Polytechnic University.

Man Ho Au received his Ph.D. from the University of Wollongong in 2009. Currently, he is an assistant professor at the Department of Computing, Hong Kong Polytechnic University. His research interests include information security and blockchain technology. His recent research activities are generously supported by funding agencies such as Hong Kong Research Grant Council (RGC), Hong Kong Innovation and Technology Commission (ITC), National Natural Science Foundation of China (NSFC) and industries. Dr. Au has published over 130 refereed papers in reputable journal and conferences, including ACM CCS, ACM SIGMOD, NDSS, IEEE TIFS, TC, TKDE, etc. He received the 2009 PET runner-up award for outstanding research in privacy enhancing technologies, the best paper award at ACISP 2016 and ISPEC 2017. He is now serving

as a committee member of the ISO/IEC JTC 1/SC 27 working group 2 Cryptography and security mechanisms. He is also a committee member of the Hong Kong Blockchain Society R&D division.

Rupeng Yang received his bachelor's degree and master's degree from Shandong University, China, in 2012 and 2015, respectively. Currently, he is a Ph.D. student at School of Computer Science and Technology, Shandong University. Besides, he is also a research associate in the Hong Kong Polytechnic University.

CAPTCHA Design and Security Issues



Yang-Wai Chow, Willy Susilo and Pairat Thorncharoensri

Abstract The concept of reverse Turing tests, or more commonly known as CAPTCHAs, for distinguishing between humans and computers has been around for many years. The widespread use of CAPTCHAs these days has made them an integral part of the internet for providing online services, which are intended for humans, with some level of protection against automated abuse. Since their inception, much research has focused on investigating various issues surrounding the design and security of CAPTCHAs. A fundamental requirement of CAPTCHAs necessitates that they must be designed to be easy for humans but difficult for computers. However, it is well recognized that the trade-off between usability and security is difficult to balance. In addition, numerous attacks have been developed to defeat CAPTCHAs. In response to this, many different CAPTCHA design variants have been proposed over the years. Despite the fact that CAPTCHAs have been around for more than two decades, the future of CAPTCHAs remains an open question. This chapter presents an overview of research examining a wide range of issues that have been conducted on different types of CAPTCHAs.

Keywords Audio · Image · CAPTCHA · Machine learning · Recognition · Security · Segmentation · Text · Usability

1 Introduction

CAPTCHAs, an acronym for *Completely Automated Public Turing test to tell Computers and Humans Apart*, have been around for many years. The term refers to automated tests that can be solved correctly by humans, but current computer pro-

Y.-W. Chow (✉) · W. Susilo · P. Thorncharoensri
Institute of Cybersecurity and Cryptology, School of Computing
and Information Technology University of Wollongong, Wollongong, Australia
e-mail: caseyc@uow.edu.au

W. Susilo
e-mail: wsusilo@uow.edu.au

P. Thorncharoensri
e-mail: pairat@uow.edu.au

grams will have difficulty solving. Over the years, CAPTCHAs have become an integral part of the Internet for deterring the automated abuse of online services that are intended for human users. CAPTCHAs have been used for protecting services against email spam, fraudulent online registrations, Denial of Service (DoS) attacks, online voting fraud, etc. [19].

It is widely recognized that the first use of CAPTCHAs was by the AltaVista search engine in 1997, as a method of deterring the automated submission of URLs to their service. It was reported that the use of this CAPTCHA was successful in reducing the amount of spam by over 95% [6]. This system was invented by the DEC Systems Research Center, and it was later patented as a computerized method for a server to selectively accept access requests from client computers [17, 49]. Since then, CAPTCHAs have become a ubiquitous part of the Internet, and have even been used in online services provided by major international companies such as Amazon, Baidu, eBay, Facebook, Google, Microsoft, PayPal, and Yahoo.

The term CAPTCHA was introduced by von Ahn et al. [77], where they put forward the challenge of using hard Artificial Intelligence (AI) problems for security purposes. While the term CAPTCHA has been adopted as the most widely used term when referring to automated challenge response tests for ascertaining whether an online service is being used by a human or a computer program (otherwise known as a “bot”), such tests have also been referred to as *Human Interaction Proofs* (HIPs) [6]. In addition, CAPTCHAs are also called *reverse Turing tests*. One of the earliest notions of the reverse Turing test appeared in an unpublished manuscript by Naor [57]. This stems from the idea of the Turing test [76], where the intention of the original Turing test was for a human to attempt to distinguish between another human and a machine based on responses to questions posed to both the human and the machine. A reverse Turing test is one where a computer is used to distinguish between a human and a machine. This has also been referred to as an *automated Turing test*, since a computer is used to automate the process [77].

Despite the fact that many people consider CAPTCHAs to be annoying, CAPTCHAs have seen widespread adoption in many online services. This has resulted in much research on the security of CAPTCHAs, because many techniques for attacking and defeating CAPTCHAs have been developed. This in turn, has given rise to an arms race between the development of new CAPTCHAs and techniques for defeating them. Furthermore, unlike other computer security mechanisms, CAPTCHAs are unique in the sense that a practical CAPTCHA scheme must be designed to be secure, i.e., robust against automated attacks, while at the same time it must be usable by humans.

This usability versus security requirement is a difficult act to balance. The design of a robust CAPTCHA must in some way capitalize on the difference in ability between humans and current computer programs [17]. With advances in machine learning and computer vision research, the challenge of whether it is possible to design a CAPTCHA that is easy for humans but difficult for current computer programs is an open challenge. To this end, it is important to examine previous research on CAPTCHAs to be able to identify any potential gaps in ability between humans and

computers, as well as to avoid potential pitfalls and design flaws that can easily be exploited in a CAPTCHA.

To date, there are many different types of CAPTCHAs. Visual CAPTCHAs are the most prevalent, and include text-based and image-based CAPTCHAs. Audio CAPTCHAs have been developed in place of visual CAPTCHAs for users who are blind or visually impaired. In addition, other forms of CAPTCHAs, such as 3D-based CAPTCHAs [74], Math CAPTCHAs [41], game-based CAPTCHAs [53], and social authentication [85], have also been proposed. This chapter presents an overview of research conducted on different types of CAPTCHAs over the years. Research on CAPTCHAs has examined a variety of issues ranging from usability and design to robustness and security.

2 Text-Based CAPTCHAs

Of the different types of CAPTCHAs that have been deployed to protect online services, text-based CAPTCHAs are by far the most popular. The challenge presented to a user in this type of CAPTCHA typically involves the user having to identify a sequence of characters in an image, where the text contained within the image is deliberately rendered with some level of distortion and/or noise to deter character recognition programs from correctly solving the challenge. The reason for its widespread usage is due to its intuitiveness, as it is easily understood by users worldwide without much instruction, and most humans have been trained to recognize characters since childhood. In addition, from a security point of view, the brute force search space can be very large, and from a computation perspective, the generation of CAPTCHA challenges can easily be automated without the need for manual effort [19, 84].

2.1 *Security and Usability*

A fundamental requirement of a practical CAPTCHA necessitates that humans must be able to solve the challenge with a high degree of success, while the likelihood that a computer program can correctly solve it must be very small [61]. As a benchmark, Chellapilla et al. [19] state that the human success rate should approach at least 90%, while the success of computer programs should ideally be less than 1 in 10,000. CAPTCHAs that are difficult or time-consuming for legitimate users to solve are often seen as annoying and greatly inconvenience the users.

It has been estimated that with more than 100 million CAPTCHAs being used by humans all over the world everyday, with each case taking a few seconds to solve, this collectively amounts to hundreds of thousands of man-hours per day. Furthermore, each person will have to utilize some mental effort when it comes to solving a CAPTCHA challenge [79]. In addition, demographics play a role in a

user's solving abilities, e.g., in general, non-native English speakers perform slower on English-centric CAPTCHAs [13].

The trade-off between security and usability is difficult to balance, as security considerations push designers to increase the difficulty of CAPTCHAs to deter computer programs, while usability requirements restrict them to make a scheme only as difficult as it needs to be. Moreover, while technology and computing techniques are constantly evolving and improving, humans on the other hand, must rely on their inherent abilities and are not likely to get better at solving CAPTCHAs [17]. In a large-scale study on CAPTCHA usability, it was reported that humans often find CAPTCHAs difficult to solve, and that most research mainly focused on making them hard for machines while not paying much attention to usability issues [13].

Design Considerations. The problem faced by CAPTCHA designers is that the security versus usability requirements are often in conflict. A number of design considerations that deal with the trade-off between security and usability are described as follows:

- **Text familiarity:** Text-based CAPTCHAs generated using familiar text (e.g., English words), increases the usability of the resulting CAPTCHA. This is due to the fact that humans find familiar text easier to read as opposed to unfamiliar text [80]. However, language models can be exploited to break CAPTCHAs using a set of words from a dictionary and holistic approaches. Researchers have shown that CAPTCHAs based on language models can successfully be defeated using holistic approaches of recognizing entire words rather than identifying individual characters, which can be difficult if characters are extremely distorted or overlapping [4, 54].

Instead of using words that can be found in a dictionary, it is possible to use *language-like* strings that are not part of any language. For example, phonetic text or Markov dictionary strings are pronounceable strings that are not actual words of any language. The reason for using pronounceable strings is for the resulting CAPTCHA to have the advantage of text familiarity for humans, while at the same time attempt to circumvent dictionary and holistic attacks. Nevertheless, while humans perform better at correctly identifying pronounceable strings in contrast to purely random character strings, certain characters (e.g., vowels) in pronounceable strings typically appear at higher frequencies when compared with other characters [80].

- **Color and visual clutter:** The use of color is an important consideration in the design of visual CAPTCHAs. From a usability perspective, the incorporation of color is good for attracting a user's visual attention. At the same time, color can make a CAPTCHA more appealing and less intrusive in its context of use, e.g., if it matches a webpage's color [17]. In addition, appropriate use of color can potentially aid in the recognition and comprehension of text [84].

On the other hand, the use of color can have negative effects on both the usability and security of a CAPTCHA. This is because the misuse of color can result in the text being difficult to read for humans, e.g., if the text color is similar to the background color. Furthermore, colors may cause problems for people who

are color-blind. At the same time, color can result in a computer easily being able to distinguish the text from the background, e.g., if the text is displayed in a distinct color. It has been observed that in many CAPTCHAs, the use of color is neither helpful for its usability nor security [84].

Many CAPTCHAs also adopt the use of visual clutter, e.g., this may be in the form of background textures, noise, or lines to connect characters together, in an attempt to impede automated attacks. This can be detrimental to the usability of the CAPTCHA, as humans may have difficulty distinguishing the text from the clutter. As such, the use of color and visual clutter must be carefully considered when designing a CAPTCHA. In general, if the color or visual clutter does not contribute to the security of the CAPTCHA, the reason for its use may only be for esthetic purposes.

- **Distortion:** Affine transformations and distortion of characters are commonly used techniques to impede character recognition using Optical Character Recognition (OCR) software [17]. Transformations alone, which include translation, clockwise/counterclockwise rotation and scaling, are easy for both computers and humans to solve. As such, these are typically combined with some level of distortion. Distortions are elastic deformations that can either be at the level of individual characters (i.e., local warping) or deformations to the overall text (i.e., global warping). In fact, the initial design of the popular “reCAPTCHA” was to deliberately use distorted strings that could not be recognized by OCR programs [79].

While distortion is a mechanism employed to hinder automated attacks, it has severe implications on the usability of CAPTCHAs, because humans find it difficult to recognize distorted text. For this reason, CAPTCHA systems typically allow the users multiple attempts at solving challenges [84]. An additional consideration when dealing with distorted text from a usability point of view, is that the use of certain character combinations can be confusing. For example, digits and letters like the digit “0” and the letter “O”, the digit “1”, and the letter “l”, are common causes of confusion. The same applies to upper and lower case pairs like “S” and “s”, as well as “Z” and “z”. Furthermore, certain character combinations like “VV” can be misinterpreted as “W”, “rn” as “m”, and so on [84].

2.2 *Attacking CAPTCHAs*

Since its inception, the security of CAPTCHAs has attracted much attention and has been examined by researchers and practitioners alike. This has resulted in the development of a variety of techniques for attacking and defeating CAPTCHAs. Many researchers have highlighted various flaws in the design of CAPTCHAs that can be exploited, resulting in them being vulnerable to automated attacks. This section presents some of the important work in the area of attacking text-based CAPTCHAs.

In early work on CAPTCHA security, researchers were able to successfully break the “EZ-Gimpy” and “Gimpy” CAPTCHAs. These were CAPTCHAs that were designed by a team at Carnegie Mellon University, and EZ-Gimpy was previously

used by Yahoo in their online services to screen out bots [54]. The work by Mori and Malik [54] showed that CAPTCHAs based on language models are susceptible to attacks, because a database of words can be constructed to defeat the CAPTCHA. In their attack, they used a holistic approach of attempting to match the shape contexts of entire words extracted from a CAPTCHA to a database of known objects. This was possible because the text in EZ-Gimpy and Gimpy were based on a set of English words. They explained that a holistic approach was adopted because in severe clutter, it was difficult to identify individual characters with occluded or ambiguous parts [54]. A pool of candidate words was identified and ranked based the matching of shape contexts, and the one with the best matching score was selected as the solution.

It was reported that this attack was able to break EZ-Gimpy 92% of the time and had a success rate of 33% against the Gimpy CAPTCHA. In addition, using font and lexicon information, the same attack could also be used against “PessimPrint” [5] and “BaffleText” [21]. These are two other pioneering CAPTCHAs that were designed by the research community. In other early work, it was demonstrated that distortion estimation techniques could be used to break the EZ-Gimpy and Gimpy-r CAPTCHAs with high degrees of success [56]. Since distortion techniques are commonly used to deter character recognition, this research investigated techniques to estimate and remove distortion prior to the character recognition process.

In later work by Chellapilla et al. [18, 20], they were successful in using machine learning to break a variety of CAPTCHAs. This led them to proposing the well known and widely accepted *segmentation-resistant* principle for text-based CAPTCHA design.

Segmentation-Resistant. The segmentation-resistant principle is recognized as one of the foundational guiding principles for the development of text-based CAPTCHAs. In seminal work by a Microsoft research team, Chellapilla et al. [18, 20] demonstrated that machine learning algorithms were capable of successfully solving a variety of CAPTCHA schemes. In their study, they deliberately avoided the use of language models when attempting to break the CAPTCHAs. As such, their work showed that computers were able to outperform humans when it came to the task of recognizing single characters, which had some level of distortion and/or clutter.

This led to the establishment of the segmentation-resistant principle. The task of solving a text-based CAPTCHA consists of two main challenges. The first is *segmentation*; the identification and separation of text contained within a CAPTCHA into its constituting characters in the correct order. The second is *recognition*; this refers to the task of recognizing the individual characters. Since it was shown that computers are better at the recognition task, this implies that if a computer program can adequately segment a CAPTCHA into its constituting characters, the CAPTCHA is essentially broken. Therefore, it is widely accepted that one of the underlying requirements of a secure text-based CAPTCHA scheme is that it must be segmentation-resistant [1, 19].

The team subsequently adopted this principle in the design of a CAPTCHA that was deployed on a number of Microsoft’s online services. Unfortunately, it was shown that the CAPTCHA could be segmented using a low-cost attack [83]. This

attack showed that even though certain CAPTCHAs may be designed to be resistant against segmentation, segmentation may, in fact, be possible after some preprocessing. Nevertheless, despite being able to defeat the CAPTCHA, the authors stated that their work did not negate the segmentation resistance principle [83]. In addition, their work also showed that string length is a factor that must be considered in the design of a text-based CAPTCHA. This is because unlike CAPTCHAs that contain a random number of characters, CAPTCHAs with fix length strings are easier to segment as the total number of characters is known beforehand.

Since the introduction of the segmentation-resistant principle, a variety of CAPTCHAs have been developed with this principle in mind. The mainstream methods of deterring segmentation can broadly be classified into three general categories [14, 62]. It should be noted that the use of these methods has significant implications on the usability of the resulting CAPTCHA. The three general categories are described as follows:

- **Background confusion:** The purpose of this approach is to attempt to prevent segmentation by making it difficult to distinguish between the text and the background. This can be done by using a complex background, by using very similar colors for the text and the background, by adding noise, or any combination of these. In a study by Bursztein et al. [14], they concluded that backgrounds should only be for cosmetic purposes as the use of background confusion as a security mechanism does not add to the robustness of a CAPTCHA. This is because for usability, a human must be able to differentiate between the text and the background.
- **Using lines:** This is an approach where random lines that cross multiple characters are used to deter segmentation. These may consist of small lines that cross some characters, or larger lines that cover the entire CAPTCHA [14]. The aim of this is to attempt to confuse segmentation algorithms by linking characters together.
- **Collapsing:** The idea behind this approach is to increase the difficulty of a segmentation task by joining or overlapping characters. This is typically achieved by removing the space between characters, tilting characters and/or overlapping them, which results in the characters being *crowded* together. This approach is considered to be the most effective mechanism for deterring segmentation [14, 83].

Segmentation Techniques. While a variety of CAPTCHAs have been designed with the segmentation-resistant principle in mind, many of them have been found to be susceptible to segmentation attacks. Over the years, researchers have shown that design flaws can be exploited to segment CAPTCHAs. Among others, the following are several segmentation techniques that have been documented by various researchers [61]:

- **De-noising algorithms:** The addition of noise is a commonly use technique to confuse segmentation algorithms. As such, de-noising techniques are used to remove random noise from a CAPTCHA before a segmentation operation. Of the various de-noising techniques that have been proposed over the years, the Gibbs algorithm [35], which is also known as the Markov random field technique, has been found to be a very effective de-noising algorithm [14]. The way that this algorithm works is

by computing an energy value for every pixel based on its surrounding pixels, and subsequently removing pixels with an energy value that is below a certain threshold. This process is then repeated until there are no more pixels to remove. Other de-noising algorithms include the dilate-erode approach, in which a CAPTCHA image is up-sampled, dilated then eroded. This results in noise, such as lines, being removed while retaining solid thick characters [17].

- **Histogram-based segmentation:** The idea behind this method is to project a CAPTCHA's pixels to their respective vertical, or in some cases diagonal, pixel positions [2, 82, 83]. By doing so, a histogram can be constructed based on the number of pixels at each position. In general, parts of the histogram that have higher pixel numbers are typically made up of pixels that belong to the characters of a CAPTCHA. On the other hand, parts that contain low pixel numbers usually represent the separation between characters or the end of a character, and are thus potential positions that can be used for segmentation. This method has been shown to be effective against CAPTCHAs in which their characters are only slightly joined, overlapping, or are connected using thin lines [43, 82, 83]. In addition, this method can be used as a step to separate groups of characters, before applying other segmentation techniques.
- **Color Filling Segmentation (CFS):** This technique is akin to performing a flood fill algorithm and is often used in conjunction with other segmentation techniques. The initial step is to identify a pixel with a color that is associated with text in a CAPTCHA. Once identified, all the neighboring pixels which have the same color and are connected to the initial pixel are traced. This is repeated until all connected pixels are identified. The end result is that the connected pixels will reveal either individual characters or groups of connected characters [14, 32, 33, 83]. In the latter case, this technique will make it easier for other segmentation methods, since sections containing characters have been identified.
- **Opportunistic segmentation:** This approach seeks to exploit regular and predictable features of a CAPTCHA. By relying on educated guesses, potential locations to perform segmentation can be approximated based on prior knowledge of a CAPTCHA. Examples of such prior knowledge include CAPTCHAs that contain a fixed number of characters, where characters often appear at certain locations, and if the characters have roughly the same width. These factors make a CAPTCHA vulnerable to opportunistic segmentation, because it is easy to make educated guesses as to the likely positions for segmentation cuts [14]. Others have also exploited the fact that in some poorly designed CAPTCHAs, each unique character always contains the same number of pixels. As such, pixel-counting attacks can be used to distinguish between characters [82].
- **Segmentation based on patterns and shapes:** This is a segmentation technique that attempts to identify patterns and shapes that can be used to characterize certain characters. For instance, characters like "a", "b", "d", "e", "g", "o", "p", and "q", all contain loops or circular regions, characters like "i", "j", and "l", typically consist of small vertical blocks of pixels, and so on [2, 26, 73]. Once the characteristic patterns and shapes of the characters in a CAPTCHA have been determined, this

information can be used to identify particular features in a CAPTCHA that can be exploited to facilitate the segmentation process.

The segmentation techniques described here represent some of the common methods that have been implemented to attack a variety of diverse CAPTCHAs. Many segmentation approaches use a combination and/or variations of the techniques described here. There are also other more specialized attacks and segmentation techniques that have been used to attack specific CAPTCHAs. A systematic study on a number of text-based CAPTCHAs found that solely focusing on being segmentation-resistant alone is not enough to guarantee that a CAPTCHA is secure, because there may be side-channel attacks that can be exploited to defeat a CAPTCHA [9]. In addition, other research has shown that image processing and pattern recognition tools, such as k -means clustering, digital image in-painting, character recognition based on cross-correlation, and so on, can be used to successfully break a variety of CAPTCHAs [48].

While much work on attacking CAPTCHAs has focused devising techniques for breaking individual schemes, many such solutions are only applicable to specific CAPTCHAs or schemes that possess certain exploitable features. With advances in areas such as machine learning, recent research efforts have aimed at developing more universal approaches that can be used to solve text-based CAPTCHAs in general.

Bursztein et al. [10] demonstrated a generic method of solving CAPTCHAs in a single step using machine learning to attack both the segmentation and recognition tasks at the same time. Many previous approaches performed these processes sequentially as separate steps. Their results showed that this approach was successful in defeating various real-world CAPTCHAs, and they concluded that combining the solving of segmentation and recognition problems is likely to be the way forward for automated CAPTCHA attacks [10]. In later work, Gao et al. [34] introduced a simpler and more computationally efficient approach of using Log-Gabor filters as a generic attack on text-based CAPTCHAs. Their experiments demonstrated that this generic method of attack was successful in defeating a wide range of representative text-based CAPTCHAs.

With the availability of such universal attacks, it has been suggested that traditional text-based CAPTCHAs may be reaching the end of its usefulness in deterring automated programs. Nevertheless, this does not discount the effort that has gone into the development and understanding of CAPTCHAs over the years, as it has taken many years of research to achieve such generic attacks. It does, however, require researchers and developers to reconsider how reverse Turing tests are to be designed in the future, and whether there are any alternatives. This remains an open challenge [10, 34].

2.3 *Design Variants*

In efforts to overcome the limitations of traditional text-based CAPTCHAs, other design paradigms have been proposed. Examples of such paradigms include

CAPTCHAs that are generated using 3D models, as well as CAPTCHA challenges that make use of animation. A number of these approaches are presented here.

3D-based CAPTCHAs. 3D approaches to CAPTCHA design typically involve the rendering of 3D models of text-objects, or of other objects, to an image [42, 50]. Since CAPTCHAs must capitalize on the difference in ability between humans and computers, the assumption in 3D CAPTCHAs is that it is difficult for computer programs to recognize 3D content, whereas this should be easy for humans. The reason for this is because 3D perception is an integral part of the human visual system. However, it has been demonstrated that 3D-based CAPTCHAs are by no means immune to attacks [62, 86].

As an example, a simple 3D CAPTCHA scheme was proposed based on the rendering of 3D text models [44]. However, it can clearly be seen that this approach is not secure against automated attacks, because the front face of characters is rendered under the same lighting conditions and thus appear to have the same shade. In addition, no distortion is applied to the characters. More importantly, this approach fails to take into account the fact that the field of 3D object recognition is a well-studied discipline in computer vision.

Nguyen et al. [62] presented techniques that can be used to extract information from 3D text-based CAPTCHAs, and showed that this can be exploited to break a number of such CAPTCHAs. The 3D CAPTCHAs that were investigated in their study were generated by perturbing a regular pattern in a way where a human would recognize 3D text embedded within the pattern. Humans can easily use the resulting CAPTCHA due to the human cognitive ability to perceive 3D from depth cues in 2D images. In contrast, it was assumed that this approach would be difficult for computers. However, the study showed that information about the text could effectively be extracted from the 3D CAPTCHAs, which essentially reduced the CAPTCHA challenge to the task of character recognition.

A number of other 3D CAPTCHA approaches were discussed in Ross et al. [67], in which they pointed out scalability problems with certain 3D CAPTCHAs. This was due to the fact that the generation process involved in some schemes required a substantial amount of manual effort. In their work, they proposed a prototype CAPTCHA scheme that they called “Sketcha”. This CAPTCHA is constructed from oriented line drawings of 3D models, where the challenge was to correctly orient the images. Another idea for 3D CAPTCHAs was proposed using the concept of *emerging images* [51]. The underlying notion for this was to render abstract representations of 3D models in 3D environments, and rely on the human ability to perceive objects as a whole, rather than as individual parts, in order to perceive objects in the scene. In other work, a CAPTCHA that was built on the human ability to perceive 3D text from stereoscopic images was proposed [74].

Animated CAPTCHAs. Unlike traditional CAPTCHAs where the challenge is presented within a single image, animated CAPTCHAs attempt to incorporate a time dimension into the challenge. Several researchers and practitioners have developed animated CAPTCHAs by distributing the information that is required to solve the challenge over a number of animation frames. The assumption in animated

CAPTCHAs is that humans can easily perceive information presented over multiple frames, whereas computers will have difficulty processing animated information. This has been dubbed the *zero knowledge per frame* principle, because the required information to solve the CAPTCHA is not completely contained within a single frame [27]. Since the information required to solve an animated CAPTCHA is distributed over a number of frames, this also means that the task of solving animated CAPTCHAs is typically more time-consuming compared to single image CAPTCHAs.

Researchers have proposed various ideas for the design of animated CAPTCHAs. For example, a sketch of an animated CAPTCHA was proposed based on moving characters amidst a noisy background [27]. Another idea was to present distorted text on the face of a deforming animated surface [31]. In other work, an animated CAPTCHA based on visual phenomena was proposed. The notion for this approach is that by grouping different entities that move together, objects that are superimposed over a noisy background of the same color will be visible to humans when the objects are moving [58]. Other examples include an animated approach with moving objects where the user's task was to solve the challenge by identifying the correct object and its current location [3], and an animated CAPTCHA based on the concept of motion parallax [24]. In the motion parallax approach, the CAPTCHA was built on the idea that humans are able to perceive depth through motion. Therefore, by placing text at different depths in a 3D scene, humans should be able to perceive foreground characters and separate this from the background when the viewpoint is moving.

The addition of a time dimension in animated CAPTCHAs is assumed to increase the security of the resulting CAPTCHA. Nevertheless, techniques that can successfully attack animated CAPTCHAs have been developed. Nguyen et al. [59, 60] demonstrated that even though the information required to solve animated CAPTCHAs is distributed over multiple frames, information from the frames can be extracted and collated to solve the CAPTCHA. An example of a method that was developed to defeat animated text-based CAPTCHAs is known as a *Pixel Delay Map*. This was devised based on the notion that characters required to solve an animated CAPTCHA are typically displayed at certain locations for longer periods of time [59, 60]. The reason for this is to facilitate usability, because even though there may be constant changes in the animation frames, a human has to be given sufficient time to identify the characters. Hence, this can be used to extract characters from multiple animated frames and the extracted characters can subsequently be passed through a character recognition process.

Researchers have also developed techniques for defeating moving image object recognition CAPTCHAs [81]. Their approach was shown to be successful in defeating the "NuCaptcha", which was considered to be the state-of-the-art in animated CAPTCHA design. The challenge in this video based animated CAPTCHA was presented as overlapping characters that were moving in the animated frames. The CAPTCHA was built on the concept that the human mind is able to see the different parts that are moving together, and fill in the blanks to perceive the characters [24, 63]. The attack on moving object CAPTCHAs that was developed by Xu et al. [81], was based on the fact that the characters in most animated CAPTCHAs are rigid

objects that do not deform over the multiple animation frames. As such, salient features could be identified and their positions tracked over different frames to extract and segment the characters. A related method was also concurrently developed by Bursztein [9].

Other Variants. A text-based CAPTCHA that was based on the recognition of characters and identifying their locations has previously been proposed [61]. The idea behind this was to display many characters, most of which were not relevant to the challenge, in the CAPTCHA image. These characters were organized in a two-dimensional manner and overlapped both vertically and horizontally to deter segmentation. A user is presented with a string of text, and the user's task is to identify the location of each character from the string in the two dimensional arrangement of the text. This method supported a variety of non-keyboard interactions, such as drag-and-drop, mouse movement, and clicking, and was thus designed to be suitable for different devices. The purpose was to cater for the modern-day ubiquitous use of mobile devices and touch screens. Clickable CAPTCHAs [23] and drag-and-drop CAPTCHAs [16] have also been proposed by other researchers.

Microsoft developed a related two-layer CAPTCHA, in which text was positioned and overlapped in two rows instead of the traditional approach of only having a single line of text. However, this approach was defeated by Gao et al. [32], who demonstrated a method of separating the two rows of text and subsequently extracting the individual characters.

3 Image-Based CAPTCHAs

Other than text-based CAPTCHAs, image-based CAPTCHAs are another category of visual CAPTCHAs that have been examined by various researchers and practitioners. In image-based CAPTCHAs, the challenge presented to the user typically involves an image recognition task. Compared with text recognition, image recognition is seen as a much harder problem for computer programs to solve. This is because there is still a large domain of unsolved image perception and interpretation problems for computers [88]. Moreover, humans find images less bothersome [30].

Thus, this makes image-based challenges an attractive alternative to text-based CAPTCHAs as they can potentially be easy for humans, but difficult for computers. However, unlike text-based CAPTCHAs, which are easy to generate, one of the fundamental requirements of image-based CAPTCHAs is the need to obtain a source of images. Furthermore, there must also be a way to obtain the solution to an image recognition challenge, e.g., using pre-labeled images, to facilitate automated grading.

One of the first research works on image-based CAPTCHAs was presented in Chew and Tygar [22]. In their work, they introduced an image-based CAPTCHA that used labeled photographs that were sourced from Google Image Search [37]. While this was an innovative solution as new images are constantly added to the database, it was highlighted that the problem with this approach was that it is likely

that the image labels may not accurately reflect the image content. The reason for this is because the method of labeling photo is based on descriptive text surrounding the image, which may not be accurate [30]. Therefore, this approach relied on the manual effort to remove inaccurately labeled images from the CAPTCHA database. It was also pointed out that while the process of constructing an image database could be automated using an image classification program, an attacker could develop a similar classification program to defeat the CAPTCHA [30].

A solution to the problem of obtaining accurately labeled images was described by von Ahn and Dabbish [78]. This work involved getting humans to manually label images by presenting this as an interactive entertainment task in the form of a game called “ESP”. The labeled images could be used to build a database for an image-based CAPTCHA, which was the basis of the “PIX” and “ESP-PIX” CAPTCHAs [15]. However, it has been argued that this approach suffered from a number of problems, including the problem of limited scalability and the subjective nature of abstract images made it potentially frustrating for humans [30, 88].

Elson et al. [30] developed an image-based CAPTCHA that they named “Asirra”, in which the challenge presented to the user was to correctly distinguish between images of cats and dogs. This is a trivial task for humans but purported to be difficult for computers. The Asirra CAPTCHA’s solution to the problem of obtaining labeled images for its database was to source images from Petfinder.com [64]. This is a website that promotes the adoption of pets, and many new accurately labeled photographs are added to its database every day. The security of Asirra relied on the large image database size and the difficulty of computers in accurately distinguishing between cats and dogs [30]. Unfortunately, it was shown that machine learning attacks could defeat Asirra. Golle [36] described a classifier that could accurately distinguish between images of cats and dogs, and demonstrated its success in solving Asirra challenges at a high success rate.

In other work, an image-based CAPTCHA called “ARTiFACIAL” was proposed by Rui and Liu [68]. This CAPTCHA was based on the difference in ability between humans and computers at the task of recognizing human facial features. While humans can easily recognize faces, even in the presence of distortion or occlusion, this is difficult for computer programs especially under varying conditions, such as head orientations, face asymmetry, lighting and shading, and background clutter. To generate a challenge in ARTiFACIAL, a texture of a human face was mapped onto a 3D model of a head. This could then be used to generate images of a face under different conditions, e.g., global head transformation, local facial feature deformations, different illumination conditions, and background clutter [68]. As a result, it allowed image challenges and solutions to be generated without manual effort, and was therefore easily scalable. The challenge presented to the user was to correctly identify various facial features. Goswami et al. [39] proposed a related image-based CAPTCHA that was also based on human face recognition. In their approach, a composite image containing distorted real and synthetic human faces amid a complex background was presented to the user. The user’s task was to distinguish and select only the real human faces.

“IMAGINATION” is an image-based CAPTCHA generation system that was proposed by Datta et al. [28]. This idea behind this CAPTCHA system was to exploit human imagination through the interpretation of images amidst distortion/clutter. The challenge that was presented by the system consisted of two processes; a click and an annotate process. In the click process, the user was presented with a composite image which consisted of a set of eight tiled images. The user had to click near the geometric center of the image that he/she wanted to annotate. The selected image underwent a controlled distortion, and the user was presented with a set of word choices. The user then had to select the appropriate word that described the distorted image [28].

Researchers have also proposed a CAPTCHA that was based on the notion of using image orientation [38]. In this CAPTCHA, users are presented with images that have undergone some form of random rotation. The user’s task is to correctly rotate the images to their upright orientation. This image orientation CAPTCHA attempts to take advantage of the gap between humans and computers in identifying the correct orientation of images. However, the images used in the database must be carefully selected as they must not contain any visual cues that can reveal the upright orientation, and at the same time images that are hard for humans to correctly orientate should also not be used. As such, a set of guidelines in conjunction with a social feedback mechanism was proposed to filter candidate images [38]. A related idea for image orientation CAPTCHA design that was based on the orientation of cropped sub-images was presented in Kim et al. [45].

Other researchers presented a video CAPTCHA, where the user’s task was to provide three words describing the content in a video [46]. This video CAPTCHA scheme was generated based on YouTube videos, which had labels/tags that were supplied by the person who uploaded the video. The user passed the challenge if any of the three words provided by the user matched the labels/tags that were supplied by the video uploader. The researchers developed this CAPTCHA to distinguish between humans and computers based on video understanding. Experiment results on the security and usability of their proposed scheme suggested that it was comparable with other visual CAPTCHAs [46].

A systematic study on a number of image-based CAPTCHAs was conducted by Zhu et al. [88]. This study evaluated and presented attacks against several such CAPTCHAs and described the reasons why they could be broken. Their work analyzed a number of image-based CAPTCHAs including Asirra, the video CAPTCHA, the image orientation CAPTCHA, and others. These were evaluated in terms of whether the manual effort was involved in CAPTCHA generation, ease of automated grading, whether it was easy for humans and computers to solve, its scalability, etc. In addition, they described methods for attacking the ARTiFACIAL and IMAGINATION CAPTCHAs. This led the researchers to propose a number of guidelines for the design of robust image-based CAPTCHAs. These guidelines state that image recognition CAPTCHAs must rely on *semantic information*, multiple types of objects and prevent machine learning attacks by avoiding the possibility of exploiting a priori knowledge. Based on the lessons learned and their set of guidelines, they subsequently developed an image-based CAPTCHA called “Cortcha”, which was

designed to be scalable, did not require manual labeling and could use an unlimited number of object types [88]. In Cortcha, the user was presented with a selection of candidate objects and an inpainted image. The user's task was to choose a candidate object, drag it around and drop it at a position in the inpainted image where it would look natural and semantically meaningful.

While semantic information has been described as a requirement for robust image-based CAPTCHAs, Sivakorn et al. [70] developed an attack for breaking semantic image CAPTCHAs using deep learning. Their attack extracts semantic information from images using image annotation services and libraries, to solve a CAPTCHA challenge by identifying image content and selecting candidate images that depict similar objects. This approach was shown to be highly successful in automatically solving Google's image-based version of reCAPTCHA. Furthermore, it also achieved very high accuracy in attacking an image CAPTCHA used by Facebook. As a result of their study, they proposed several safeguards for reducing the accuracy of their automated attack [70]. Among others, these recommendations include introducing content homogeneity, employing more complicated semantic relations, and using adversarial images to reduce classification accuracy.

4 Audio CAPTCHAs

While text-based and image-based CAPTCHAs have received much attention and have been commonly deployed on many online services, these are visual CAPTCHAs that cannot be used by people who are blind or visually impaired. As such, audio CAPTCHAs were introduced to provide an accessible alternative to visual CAPTCHAs. This category of CAPTCHA usually involves the user performing some form of speech recognition task in the midst of distorted speech [47]. However, despite the fact that audio CAPTCHAs are commonly used alongside visual CAPTCHAs, the security of this type of CAPTCHA is often overlooked [12].

Studies have shown that audio CAPTCHA is more difficult to use and more time consuming, when compared with their visual counterparts for both blind and sighted users [7, 13]. Part of the reason for this is because visual CAPTCHAs are perceived as a whole even when the focus is on the answer box, whereas audio playback is linear and reviewing an audio CAPTCHA requires users to replay it from the beginning before focusing on the answer box. An optimized interface for addressing the usability of audio CAPTCHAs was presented in Bigham and Cavender [7].

In the work conducted by Soupionis and Gritzalis [72], they presented an overview of several existing audio CAPTCHA implementations at the time. These audio CAPTCHAs were evaluated in terms of their different characteristics, which included attributes such as duration, vocabulary, production procedure and noise. Their work was aimed at developing an audio CAPTCHA that was suitable for use in Voice over Internet Protocol (VoIP) applications. To this end, they suggested a set of required VoIP CAPTCHA attributes and presented an implementation of the proposed audio

CAPTCHA. However, the security of the proposed CAPTCHA was not thoroughly examined.

To deter automated speech recognition attacks by computers, distortion and background noise is typically added to an audio CAPTCHA. Background noise like running water has different characteristics from the human voice and can easily be distinguished, whereas noise in the form of background human voices from multiple speakers is more difficult to solve. Similar to methods for breaking text-based CAPTCHAs, Tam et al. [75] showed how machine learning techniques can also be used to solve audio CAPTCHAs. In their approach, a heuristic was developed based on the use of energy peaks to segment audio for a training set. They showed that this approach was able to successfully defeat three different audio CAPTCHAs.

In another study on the security of audio CAPTCHAs, Bursztein and Bethard [12] demonstrated that while off-the-shelf speech recognition programs may perform poorly when it comes to attacking audio CAPTCHAs, it is possible to develop an automated program for solving them. They developed a tool called “Decaptcha” that used supervised learning to recognize speech patterns. Decaptcha looks at voice energy spikes by isolating such spikes in a wave file using a discrete Fourier transform [12]. It was shown that this approach of analyzing energy spikes was able to break an audio CAPTCHA at a high success rate. The work on Decaptcha was extended in Bursztein et al. [11] and used to successfully defeat a number of audio CAPTCHAs, including those used by Digg, eBay, Microsoft, reCAPTCHA, and Yahoo. These CAPTCHAs were described as noncontinuous audio CAPTCHAs, as they consisted of a sequence of spoken letters and/or digits that were distorted using various types of noise, such as white noise, Gaussian noise, echos, semantic noises, and so on [11]. It was reported that Decaptcha had lower performance when it came to semantic noises that were used in reCAPTCHA, and at the same time this type of noise was the least harmful to human understanding. As such, it was recommended that future audio CAPTCHAs should investigate the use of semantic noise.

Different methods of attacking audio versions of reCAPTCHA were presented in a number of other studies [8, 69, 71]. Sano et al. [69] described the fact that previous attacks on audio CAPTCHAs were aimed at solving noncontinuous audio CAPTCHAs. These methods of attack consisted of two phases, namely, a segmentation stage and a classification stage [11, 75]. However, the security mechanism in continuous audio CAPTCHAs relies on the difficulty in performing accurate segmentation. They described a method of using Hidden Markov models to construct a speech recognition solver to attack a version of reCAPTCHA that used continuous audio. To improve the security of audio CAPTCHAs, they suggested that increasing the number of voices and adopting semantic noise can potentially achieve this. Bock et al. [8] on the other hand presented a low-resource method of attack that used free, nonspecialized and publicly available speech recognition services to successfully defeat an audio version of reCAPTCHA. In addition, Solanki et al. [71] also demonstrated low-cost attacks against seven major audio CAPTCHAs using off-the-shelf speech recognition services.

5 Other Designs and Issues

Although much of the research on CAPTCHAs has focused on their security in deterring automated attacks by computers, attackers can bypass the security of CAPTCHAs by using *relay attacks*. This may be in the form of CAPTCHA smuggling, in which an attacker redirects the task of solving a CAPTCHA to an unsuspecting victim, or by creating a paid CAPTCHA solving service where human labor is employed to solve CAPTCHA challenges. Egele et al. [29] described CAPTCHA smuggling and discussed the feasibility of creating CAPTCHA farms for implementing such man-in-the-middle attacks. In other research, Motoyama et al. [55] examined the economics of behind paid CAPTCHA solving services. Either way, relay attacks bypass the protection offered by CAPTCHAs and side steps the need for developing automated programs for solving CAPTCHAs by using humans to solve the challenges.

The notion of Game CAPTCHAs is seen as an approach for potentially making the task of solving CAPTCHAs more fun for users. While there are different types of game CAPTCHAs, a number of studies have looked at a category of such CAPTCHAs known as Dynamic Cognitive Game (DCG) CAPTCHAs [52, 53]. DCG CAPTCHAs present a challenge to the user in the form of a simple game that requires the user to perform cognitive tasks, which are typically accomplished by interacting with a series of dynamic images. For example, it might take the form of moving objects within an images, where the user's task is to drag-and-drop the objects to match specific targets. Despite the fact that such CAPTCHAs will generally take a longer time to solve, users may potentially find the game-like activities enjoyable.

For accessibility, visual CAPTCHAs are often used alongside audio CAPTCHAs. It has been suggested that audio CAPTCHAs might be weaker than visual CAPTCHAs [11]. This is possibly due to the human visual system occupying a much larger section of the human brain when compared to the human audio processing system. Furthermore, with advances in modern signal processing and machine learning, the difference in audio capabilities between humans and computers is possibly less significant than when compared to the difference in visual processing capabilities [11]. This implies that an attacker can exploit this by attacking the security of the weaker alternative. In addition, attackers can also exploit other CAPTCHA design and implementation flaws. Examples of these were explored in side-channel attacks on a Math CAPTCHA, in which solutions were not uniformly distributed, as well as a gender classification CAPTCHA [40, 41].

In related work, CAPTCHAs have been proposed for other purposes including as graphical passwords [87] and for bot prevention in multiplayer online games [25]. Researchers have also proposed a CAPTCHA inspired photograph-based *social authentication* approach to verifying a user's identity. Yardi et al. [85] presented system called "Lineup" where the task presented to users was to identify people in photos whom they know. This system relied on the social network graph in Facebook to build its photo authentication framework. However, Polakis et al. [66] demonstrated a technique of defeating such social authentication using face recognition software. They

later proposed a more robust social authentication approach, where challenges were generated by selecting photos that failed face recognition software and transforming those photos to deter image matching techniques [65].

6 Conclusion

Over the years, much research has gone into developing a greater understanding of CAPTCHAs. Numerous CAPTCHA schemes, which include a variety of visual and audio CAPTCHAs, have been proposed to date, and various studies have examined these diverse schemes in terms of their human usability, robustness against automated attacks, semantic information, and so on. With advances in technology and the various techniques that have been developed for attacking CAPTCHAs, researchers nowadays have greater insight into the field of CAPTCHA design and security, and must consider different strategies for developing CAPTCHAs. As such, even though it has been many years since the notion of CAPTCHAs was first introduced, the question as to whether it is possible to design a CAPTCHA that is easy for humans but difficult for computers, still remains an open challenge.

References

1. Ahmad, A. S. E., Yan, J., & Marshall, L. (2010). The robustness of a new CAPTCHA. In M. Costa & E. Kirda (Eds.), *Proceedings of the Third European Workshop on System Security, EUROSEC 2010, Paris, France, April 13, 2010* (pp. 36–41). ACM.
2. Ahmad, A. S. E., Yan, J., & Tayara, M. (2011). The robustness of Google CAPTCHAs. University of Newcastle, UK, Technical Report (Vol. 1278, pp. 1–15).
3. Athanasopoulos, E., Antonatos, S., & Markatos, E. P. (2006). Enhanced CAPTCHAs: Using animation to tell humans and computers apart. In H. Leitold (Ed.), *Communications and Multimedia Security, 10th IFIP TC-6 TC-11 International Conference, CMS 2006, Heraklion, Crete, Greece, October 19–21, 2006, Proceedings* (Vol. 4237, pp. 97–108)., Lecture notes in computer science. Berlin: Springer.
4. Baecher, P., Büscher, N., Fischlin, M., & Milde, B. (2011). Breaking recaptcha: A holistic approach via shape recognition. In J. Camenisch, S. Fischer-Hübner, Y. Murayama, A. Portmann, & C. Rieder (Eds.), *Future Challenges in Security and Privacy for Academia and Industry - 26th IFIP TC 11 International Information Security Conference, SEC 2011, Lucerne, Switzerland, June 7–9, 2011. Proceedings* (Vol. 354, pp. 56–67)., IFIP advances in information and communication technology. Berlin: Springer.
5. Baird, H. S., Coates, A. L., & Fateman, R. J. (2003). Pessimist print: A reverse turing test. *International Journal on Document Analysis and Recognition*, 5(2–3), 158–163.
6. Baird, H. S., & Popat, K. (2002). Human interactive proofs and document image analysis. In D. P. Lopresti, J. Hu, & R. S. Kashi (Eds.), *Document Analysis Systems V, 5th International Workshop, DAS 2002, Princeton, NJ, USA, August 19–21, 2002, Proceedings* (Vol. 2423, pp. 507–518)., Lecture notes in computer science. Berlin: Springer.
7. Bigham, J. P., & Cavender, A. (2009). Evaluating existing audio CAPTCHAs and an interface optimized for non-visual use. In D. R. O. Jr, R. B. Arthur, K. Hinckley, M. R. Morris, S. E. Hudson, & S. Greenberg (Eds.), *Proceedings of the 27th International Conference on Human*

- Factors in Computing Systems, CHI 2009, Boston, MA, USA, April 4–9, 2009* (pp. 1829–1838). ACM.
8. Bock, K., Patel, D., Hughey, G., & Levin, D. (2017). unCaptcha: A low-resource defeat of reCaptcha's audio challenge. In W. Enck & C. Mulliner (Eds.), *11th USENIX Workshop on Offensive Technologies, WOOT 2017, Vancouver, BC, Canada, August 14–15, 2017*. USENIX Association.
 9. Bursztein, E. *How we broke the nucaptcha video scheme and what we propose to fix it*. <https://www.elie.net/blog/security/how-we-broke-the-nucaptcha-video-scheme-and-what-we-propose-to-fix-it>
 10. Bursztein, E., Aigrain, J., Moscicki, A., & Mitchell, J. C. (2014). The end is nigh: Generic solving of text-based captchas. In S. Bratus & F. F. X. Lindner (Eds.), *8th USENIX Workshop on Offensive Technologies, WOOT '14, San Diego, CA, USA, August 19, 2014*. USENIX Association.
 11. Bursztein, E., Beauxis, R., Paskov, H. S., Perito, D., Fabry, C., & Mitchell, J. C. (2011). The failure of noise-based non-continuous audio captchas. In *32nd IEEE Symposium on Security and Privacy, S&P 2011, 22–25 May 2011, Berkeley, California, USA* (pp. 19–31). IEEE Computer Society.
 12. Bursztein, E., & Bethard, S. (2009). Decaptcha: Breaking 75% of eBay audio CAPTCHAs. In *Proceedings of the 3rd USENIX Conference on Offensive Technologies, WOOT'09*, pp. 8–8, Berkeley, CA, USA, 2009. USENIX Association.
 13. Bursztein, E., Bethard, S., Fabry, C., Mitchell, J. C., & Jurafsky, D. (2010). How good are humans at solving captchas? A large scale evaluation. In *31st IEEE Symposium on Security and Privacy, S&P 2010, 16–19 May 2010, Berkeley/Oakland, California, USA* (pp. 399–413). IEEE Computer Society.
 14. Bursztein, E., Martin, M., & Mitchell, J. C. (2011). Text-based CAPTCHA strengths and weaknesses. In Y. Chen, G. Danezis, & V. Shmatikov (Eds.), *Proceedings of the 18th ACM Conference on Computer and Communications Security, CCS 2011, Chicago, Illinois, USA, October 17–21, 2011* (pp. 125–138). ACM.
 15. C. M. University. The official CAPTCHA site. <https://www.captcha.net/>
 16. Chaudhari, S. K., Deshpande, A. R., Bendale, S. B., & Kotian, R. V. (2011). 3D drag-n-drop CAPTCHA enhanced security through CAPTCHA. In *Proceedings of the International Conference and Workshop on Emerging Trends in Technology, ICWET '11*, pp. 598–601, New York, NY, USA, 2011. ACM.
 17. Chellapilla, K., Larson, K., Simard, P. Y., & Czerwinski, M. (2005). Building segmentation based human-friendly human interaction proofs (HIPs). In H. S. Baird & D. P. Lopresti (Eds.), *Human Interactive Proofs, Second International Workshop, HIP 2005, Bethlehem, PA, USA, May 19–20, 2005, Proceedings* (Vol. 3517, pp. 1–26)., Lecture notes in computer science. Berlin: Springer.
 18. Chellapilla, K., Larson, K., Simard, P. Y. & Czerwinski, M. (2005). Computers beat humans at single character recognition in reading based human interaction proofs (HIPs). In *CEAS 2005 - Second Conference on Email and Anti-Spam, July 21–22, 2005, Stanford University, California, USA*.
 19. Chellapilla, K., Larson, K., Simard, P. Y., & Czerwinski, M. (2005). Designing human friendly human interaction proofs (HIPs). In G. C. van der Veer & C. Gale (Eds.), *Proceedings of the 2005 Conference on Human Factors in Computing Systems, CHI 2005, Portland, Oregon, USA, April 2–7, 2005* (pp. 711–720). ACM.
 20. Chellapilla, K., & Simard, P. Y. (2004). Using machine learning to break visual human interaction proofs (HIPs). In *Advances in Neural Information Processing Systems 17 [Neural Information Processing Systems, NIPS 2004, December 13–18, 2004, Vancouver, British Columbia, Canada]* (pp. 265–272).
 21. Chew, M., & Baird, H. S. (2003). BaffleText: a human interactive proof. In T. Kanungo, E. H. B. Smith, J. Hu, & P. B. Kantor (Eds.), *Document Recognition and Retrieval X, Santa Clara, California, USA, January 22–23, 2003, Proceedings*, (Vol. 5010, pp. 305–316)., SPIE.

22. Chew, M., & Tygar, J. D. (2004). Image recognition CAPTCHAs. In K. Zhang & Y. Zheng (Eds.), *Information Security, 7th International Conference, ISC 2004, Palo Alto, CA, USA, September 27–29, 2004, Proceedings* (Vol. 3225, pp. 268–279)., Lecture notes in computer science. Berlin: Springer.
23. Chow, R., Golle, P., Jakobsson, M., Wang, L., & Wang, X. (2008). Making CAPTCHAs clickable. In M. Spasojevic & M. D. Corner (Eds.), *Proceedings of the 9th Workshop on Mobile Computing Systems and Applications, HotMobile 2008, Napa Valley, California, USA, February 25–26, 2008* (pp. 91–94). ACM.
24. Chow, Y., & Susilo, W. (2011). AniCAP: An animated 3D CAPTCHA scheme based on motion parallax. In D. Lin, G. Tsudik, & X. Wang (Eds.), *Cryptology and Network Security - 10th International Conference, CANS 2011, Sanya, China, December 10–12, 2011. Proceedings* (Vol. 7092, pp. 255–271)., Lecture notes in computer science. Berlin: Springer.
25. Chow, Y., Susilo, W., & Zhou, H. (2010). CAPTCHA challenges for massively multiplayer online games: Mini-game CAPTCHAs. In A. Sourin & O. Sourina (Eds.), *2010 International Conference on CyberWorlds, Singapore, October 20–22, 2010* (pp. 254–261). IEEE Computer Society.
26. Cruz-Perez, C., Starostenko, O., Uceda-Ponga, F., Aquino, V. A., & Reyes-Cabrera, L. (2012). Breaking reCAPTCHAs with unpredictable collapse: Heuristic character segmentation and recognition. In J. A. Carrasco-Ochoa, J. F. M. Trinidad, J. A. Olvera-López, & K. L. Boyer (Eds.), *Pattern Recognition - 4th Mexican Conference, MCPR 2012, Huatulco, Mexico, June 27–30, 2012. Proceedings* (Vol. 7329, pp. 155–165)., Lecture notes in computer science. Berlin: Springer.
27. Cui, J. S., Mei, J. T., Zhang, W. Z., Wang, X., & Zhang, D. (2010). A CAPTCHA implementation based on moving objects recognition problem. In *2010 International Conference on E-Business and E-Government* (pp. 1277–1280).
28. Datta, R., Li, J., & Wang, J. Z. (2005). IMAGINATION: A robust image-based CAPTCHA generation system. In H. Zhang, T. Chua, R. Steinmetz, M. S. Kankanhalli, & L. Wilcox (Eds.), *Proceedings of the 13th ACM International Conference on Multimedia, Singapore, November 6–11, 2005* (pp. 331–334). ACM.
29. Egele, M., Bilge, L., Kirda, E., & Kruegel, C. (2010). CAPTCHA smuggling: Hijacking web browsing sessions to create CAPTCHA farms. In S. Y. Shin, S. Ossowski, M. Schumacher, M. J. Palakal, & C. Hung (Eds.), *Proceedings of the 2010 ACM Symposium on Applied Computing (SAC), Sierre, Switzerland, March 22–26, 2010* (pp. 1865–1870). ACM.
30. Elson, J., Douceur, J. R., Howell, J., & Saul, J. (2007). Asirra: A CAPTCHA that exploits interest-aligned manual image categorization. In P. Ning, S. D. C. di Vimercati, & P. F. Syverson (Eds.), *Proceedings of the 2007 ACM Conference on Computer and Communications Security, CCS 2007, Alexandria, Virginia, USA, October 28–31, 2007* (pp. 366–374). ACM.
31. Fischer, I., & Herfet, T. (2006). Visual CAPTCHAs for document authentication. In *8th IEEE International Workshop on Multimedia Signal Processing (MMSP 2006)* (pp. 471–474).
32. Gao, H., Tang, M., Liu, Y., Zhang, P., & Liu, X. (2017). Research on the security of Microsoft's two-layer captcha. *IEEE Transactions Information Forensics and Security*, 12(7), 1671–1685.
33. Gao, H., Wang, W., Qi, J., Wang, X., Liu, X., & Yan, J. (2013). The robustness of hollow captchas. In A. Sadeghi, V. D. Gligor, & M. Yung (Eds.), *2013 ACM SIGSAC Conference on Computer and Communications Security, CCS'13, Berlin, Germany, November 4–8, 2013* (pp. 1075–1086). ACM.
34. Gao, H., Yan, J., Cao, F., Zhang, Z., Lei, L., Tang, M., Zhang, P., Zhou, X., Wang, X., & Li, J. (2016). A simple generic attack on text captchas. In *23rd Annual Network and Distributed System Security Symposium, NDSS 2016, San Diego, California, USA, February 21–24, 2016*. The Internet Society.
35. Geman, S., & Geman, D. (1984). Stochastic relaxation, Gibbs distributions, and the Bayesian restoration of images. *IEEE Transactions on Pattern Analysis and Machine Intelligence*, 6, 721–741.
36. Golle, P. (2008). Machine learning attacks against the Asirra CAPTCHA. In P. Ning, P. F. Syverson, & S. Jha (Eds.), *Proceedings of the 2008 ACM Conference on Computer and Commu-*

- ications Security, CCS 2008, Alexandria, Virginia, USA, October 27–31, 2008 (pp. 535–542). ACM.
37. Google Inc. Google Image Search. <https://images.google.com/>
 38. Gossweiler, R., Kamvar, M., & Baluja, S. (2009). What's up CAPTCHA?: A CAPTCHA based on image orientation. In J. Quemada, G. León, Y. S. Maarek, & W. Nejdl, (Eds.), *Proceedings of the 18th International Conference on World Wide Web, WWW 2009, Madrid, Spain, April 20–24, 2009* (pp. 841–850). ACM.
 39. Goswami, G., Powell, B. M., Vatsa, M., Singh, R., & Noore, A. (2014). FaceDCAPTCHA: Face detection based color image CAPTCHA. *Future Generation Computer Systems*, 31, 59–68.
 40. Hernández-Castro, C. J., Moreno, M. D. R., Barrero, D. F., Gibson, S., & FunCAPTCHA case analysis. (2017). Using machine learning to identify common flaws in CAPTCHA design. *Computers and Security*, 70, 744–756.
 41. Hernández-Castro, C. J., & Ribagorda, A. (2010). Pitfalls in CAPTCHA design and implementation: The math CAPTCHA, a case study. *Computers and Security*, 29(1), 141–157.
 42. Hoque, M. E., Russomanno, D. J., & Yeasin, M. (2006). 2D captchas from 3D models. *Proceedings of the IEEE SoutheastCon, 2006*, 165–170.
 43. Huang, S., Lee, Y., Bell, G., & Ou, Z. (2010). An efficient segmentation algorithm for CAPTCHAs with line cluttering and character warping. *Multimedia Tools Applications*, 48(2), 267–289.
 44. Imsamai, M., & Phimoltares, S. (2010). 3D CAPTCHA: A next generation of the CAPTCHA. In *Proceedings of the International Conference on Information Science and Applications (ICISA 2010), Seoul, South Korea, 21-23 April, 2010* (pp. 1–8). IEEE Computer Society.
 45. Kim, J., Chung, W., & Cho, H. (2010). A new image-based CAPTCHA using the orientation of the polygonally cropped sub-images. *The Visual Computer*, 26(6–8), 1135–1143.
 46. Kluever, K. A., & Zanibbi, R. (2009). Balancing usability and security in a video CAPTCHA. In L. F. Cranor (Ed.), *Proceedings of the 5th Symposium on Usable Privacy and Security, SOUPS 2009, Mountain View, California, USA, July 15–17, 2009*. ACM: ACM International Conference Proceeding Series.
 47. Kochanski, G., Lopresti, D. P., & Shih, C. (2002). A reverse turing test using speech. In J. H. L. Hansen & B. L. Pellom (Eds.), *7th International Conference on Spoken Language Processing, ICSLP2002 - INTERSPEECH 2002, Denver, Colorado, USA, September 16–20, 2002*. ISCA.
 48. Li, S., Shah, S. A. H., Khan, M. A. U., Khayam, S. A., Sadeghi, A., & Schmitz, R. (2010). Breaking e-banking captchas. In C. Gates, M. Franz, & J. P. McDermott (Eds.), *Twenty-Sixth Annual Computer Security Applications Conference, ACSAC 2010, Austin, Texas, USA, 6–10 December 2010* (pp. 171–180). ACM.
 49. Lillibridge, M., Abadi, M., Bharat, K., & Broder, A. (2001). Method for selectively restricting access to computer systems, Feb. 27 2001. US Patent 6,195,698.
 50. Macias, C. R., & Izquierdo, E. (2009). Visual word-based captcha using 3d characters. In *3rd International Conference on Imaging for Crime Detection and Prevention (ICDP 2009)* (pp. 1–5).
 51. Mitra, N. J., Chu, H., Lee, T., Wolf, L., Yeshurun, H., & Cohen-Or, D. (2009). Emerging images. *ACM Transactions on Graphics*, 28(5), 163:1–163:8.
 52. Mohamed, M., Gao, S., Sachdeva, N., Saxena, N., Zhang, C., Kumaraguru, P., et al. (2017). On the security and usability of dynamic cognitive game CAPTCHAs. *Journal of Computer Security*, 25(3), 205–230.
 53. Mohamed, M., Sachdeva, N., Georgescu, M., Gao, S., Saxena, N., Zhang, C. et al. (2014). A three-way investigation of a game-captcha: automated attacks, relay attacks and usability. In S. Moriai, T. Jaeger, & K. Sakurai (Eds.), *9th ACM Symposium on Information, Computer and Communications Security, ASIA CCS '14, Kyoto, Japan - June 03–06, 2014* (pp. 195–206). ACM.
 54. Mori, G., & Malik, J. (2003). Recognizing objects in adversarial clutter: Breaking a visual CAPTCHA. In *2003 IEEE Computer Society Conference on Computer Vision and Pattern Recognition (CVPR 2003), 16–22 June 2003, Madison, WI, USA* (pp. 134–144). IEEE Computer Society.

55. Motoyama, M., Levchenko, K., Kanich, C., McCoy, D., Voelker, G. M., & Savage, S. (2010). Re: CAPTCHAs-understanding CAPTCHA-solving services in an economic context. In *19th USENIX Security Symposium, Washington, DC, USA, August 11–13, 2010, Proceedings* (pp. 435–462). USENIX Association
56. Moy, G., Jones, N., Harkless, C., & Potter, R. (2004). Distortion estimation techniques in solving visual captchas. In *2004 IEEE Computer Society Conference on Computer Vision and Pattern Recognition (CVPR 2004), with CD-ROM, 27 June–2 July 2004, Washington, DC, USA* (pp. 23–28). IEEE Computer Society.
57. Naor, M. (1996). Verification of a Human in the Loop or Identification via the Turing Test. <http://www.wisdom.weizmann.ac.il/~naor/PAPERS/human.pdf>
58. Naumann, A. B., Franke, T., & Bauckhage, C. (2009). Investigating CAPTCHAs based on visual phenomena. In T. Gross, J. Gulliksen, P. Kotzé, L. Oestreicher, P. A. Palanque, R. O. Prates, & M. Winckler (Eds.), *Human-Computer Interaction - INTERACT 2009, 12th IFIP TC 13 International Conference, Uppsala, Sweden, August 24–28, 2009, Proceedings, Part II*, (Vol. 5727, pp. 745–748)., Lecture notes in computer science. Berlin: Springer.
59. Nguyen, V. D., Chow, Y., & Susilo, W. (2012). Attacking animated CAPTCHAs via character extraction. In J. Pieprzyk, A. Sadeghi, & M. Manulis (Eds.), *Cryptology and Network Security, 11th International Conference, CANS 2012, Darmstadt, Germany, December 12–14, 2012. Proceedings* (Vol. 7712, pp. 98–113). Berlin: Springer.
60. Nguyen, V. D., Chow, Y., & Susilo, W. (2012). Breaking an animated CAPTCHA scheme. In F. Bao, P. Samarati, & J. Zhou (Eds.), *Applied Cryptography and Network Security - 10th International Conference, ACNS 2012, Singapore, June 26–29, 2012. Proceedings* (Vol. 7341, pp. 12–29)., Lecture notes in computer science. Berlin: Springer.
61. Nguyen, V. D., Chow, Y., & Susilo, W. (2014). A CAPTCHA scheme based on the identification of character locations. In X. Huang & J. Zhou (Eds.), *Information Security Practice and Experience - 10th International Conference, ISPEC 2014, Fuzhou, China, May 5–8, 2014. Proceedings* (Vol. 8434, pp. 60–74)., Lecture notes in computer science. Berlin: Springer.
62. Nguyen, V. D., Chow, Y., & Susilo, W. (2014). On the security of text-based 3D CAPTCHAs. *Computers and Security*, 45, 84–99.
63. NuCaptcha Inc. NuCaptcha. <http://www.nucaptcha.com/>
64. Petfinder. Petfinder. <https://www.petfinder.com/>
65. Polakis, I., Ilia, P., Maggi, F., Lancini, M., Kontaxis, G., Zanero, S., Ioannidis, S., & Keromytis, A. D. (2014). Faces in the distorting mirror: Revisiting photo-based social authentication. In G. Ahn, M. Yung, & N. Li (Eds.), *Proceedings of the 2014 ACM SIGSAC Conference on Computer and Communications Security, Scottsdale, AZ, USA, November 3–7, 2014* (pp. 501–512). ACM.
66. Polakis, I., Lancini, M., Kontaxis, G., Maggi, F., Ioannidis, S., Keromytis, A. D., & Zanero, S. (2012). All your face are belong to us: Breaking Facebook’s social authentication. In R. H. Zakon (Ed.), *28th Annual Computer Security Applications Conference, ACSAC 2012, Orlando, FL, USA, 3–7 December 2012* (pp. 399–408). ACM.
67. Ross, S. A., Halderman, J. A., & Finkelstein, A. (2010). Sketcha: A captcha based on line drawings of 3D models. In M. Rappa, P. Jones, J. Freire, & S. Chakrabarti (Eds.), *Proceedings of the 19th International Conference on World Wide Web, WWW 2010, Raleigh, North Carolina, USA, April 26–30, 2010* (pp. 821–830). ACM.
68. Rui, Y., & Liu, Z. (2004). ARTiFACIAL: Automated reverse Turing test using FACIAL features. *Multimedia System*, 9(6), 493–502.
69. Sano, S., Otsuka, T., Itoyama, K., & Okuno, H. G. (2015). HMM-based attacks on Google’s ReCAPTCHA with continuous visual and audio symbols. *JIP*, 23(6), 814–826.
70. Sivakorn, S., Polakis, I., & Keromytis, A. D. (2016). I am robot: (deep) learning to break semantic image CAPTCHAs. In *IEEE European Symposium on Security and Privacy, EuroS&P 2016, Saarbrücken, Germany, March 21–24, 2016* (pp. 388–403). IEEE.
71. Solanki, S., Krishnan, G., Sampath, V., & Polakis, J. (2017). In (cyber)space bots can hear you speak: Breaking audio CAPTCHAs using OTS speech recognition. In B. M. Thuraisingham, B. Biggio, D. M. Freeman, B. Miller, & A. Sinha (Eds.), *Proceedings of the 10th ACM Workshop on Artificial Intelligence and Security, AISec@CCS 2017, Dallas, TX, USA, November 3, 2017*. ACM.

72. Soupionis, Y., & Gritzalis, D. (2010). Audio CAPTCHA: Existing solutions assessment and a new implementation for VoIP telephony. *Computers and Security*, 29(5), 603–618.
73. Starostenko, O., Cruz-Perez, C., Uceda-Ponga, F., & Aquino, V. A. (2015). Breaking text-based captchas with variable word and character orientation. *Pattern Recognition*, 48(4), 1101–1112.
74. Susilo, W., Chow, Y., & Zhou, H. (2010). STE3D-CAP: stereoscopic 3D CAPTCHA. In S. Heng, R. N. Wright, & B. Goi (Eds.), *Cryptology and Network Security - 9th International Conference, CANS 2010, Kuala Lumpur, Malaysia, December 12–14, 2010. Proceedings* (Vol. 6467, pp. 221–240)., Lecture notes in computer science. Berlin: Springer.
75. Tam, J., Simsa, J., Hyde, S., & von Ahn, L. (2008). Breaking audio CAPTCHAs. In D. Koller, D. Schuurmans, Y. Bengio, & L. Bottou (Eds.), *Advances in Neural Information Processing Systems 21, Proceedings of the Twenty-Second Annual Conference on Neural Information Processing Systems, Vancouver, British Columbia, Canada, December 8–11, 2008* (pp. 1625–1632). Curran Associates, Inc.
76. Turing, A. (1950). Computing machinery and intelligence. *Mind*, 59(236), 433–460.
77. von Ahn, L., Blum, M., Hopper, N. J., & Langford, J. (2003). CAPTCHA: Using hard AI problems for security. In E. Biham (Ed.), *Advances in Cryptology - EUROCRYPT 2003, International Conference on the Theory and Applications of Cryptographic Techniques, Warsaw, Poland, May 4–8, 2003, Proceedings* (Vol. 2656, pp. 294–311)., Lecture notes in computer science. Berlin: Springer.
78. von Ahn, L., & Dabbish, L. (2004). Labeling images with a computer game. In E. Dykstra-Erickson & M. Tscheligi (Eds.), *Proceedings of the 2004 Conference on Human Factors in Computing Systems, CHI 2004, Vienna, Austria, April 24–29, 2004* (pp. 319–326). ACM.
79. von Ahn, L., Maurer, B., McMillen, C., Abraham, D., & Blum, M. (2008). reCAPTCHA: Human-based character recognition via web security measures. *Science*, 321(5895), 1465–1468.
80. Wang, S. -Y., Baird, H. S., & Bentley, J. L. (2006). Captcha challenge tradeoffs: Familiarity of strings versus degradation of images. In *18th International Conference on Pattern Recognition (ICPR'06)* (Vol. 3, pp. 164–167).
81. Xu, Y., Reynaga, G., Chiasson, S., Frahm, J., Monroe, F., & van Oorschot, P. C. (2014). Security analysis and related usability of motion-based captchas: Decoding codewords in motion. *IEEE Transactions on Dependable and Secure Computing*, 11(5), 480–493.
82. Yan, J., & Ahmad, A. S. E. (2007). Breaking visual captchas with naive pattern recognition algorithms. In *23rd Annual Computer Security Applications Conference (ACSAC 2007), December 10–14, 2007, Miami Beach, Florida, USA* (pp. 279–291). IEEE Computer Society.
83. Yan, J., & Ahmad, A. S. E. (2008). A low-cost attack on a Microsoft captcha. In P. Ning, P. F. Syverson, & S. Jha (Eds.), *Proceedings of the 2008 ACM Conference on Computer and Communications Security, CCS 2008, Alexandria, Virginia, USA, October 27–31, 2008* (pp. 543–554). ACM.
84. Yan, J., & Ahmad, A. S. E. (2008). Usability of captchas or usability issues in CAPTCHA design. In L. F. Cranor (Ed.), *Proceedings of the 4th Symposium on Usable Privacy and Security, SOUPS 2008, Pittsburgh, Pennsylvania, USA, July 23–25, 2008* (pp. 44–52). ACM: ACM International Conference Proceeding Series.
85. Yardi, S., Feamster, N., & Bruckman, A. (2008). Photo-based authentication using social networks. In C. Faloutsos, T. Karagiannis, & P. Rodriguez (Eds.), *Proceedings of the first Workshop on Online Social Networks, WOSN 2008, Seattle, WA, USA, August 17–22, 2008* (pp. 55–60). ACM.
86. Ye, Q., Chen, Y., & Zhu, B. (2014). The robustness of a new 3D CAPTCHA. In J. Ramel, M. Liwicki, J. Ogier, K. Kise, & R. Smith (Eds.), *11th IAPR International Workshop on Document Analysis Systems, DAS 2014, Tours, France, April 7–10, 2014* (pp. 319–323). IEEE Computer Society.
87. Zhu, B. B., Yan, J., Bao, G., Yang, M., & Xu, N. (2014). Captcha as graphical passwords - a new security primitive based on hard AI problems. *IEEE Transactions on Information Forensics and Security*, 9(6), 891–904.

88. Zhu, B. B., Yan, J., Li, Q., Yang, C., Liu, J., Xu, N., Yi, M., & Cai, K. (2010). Attacks and design of image recognition CAPTCHAs. In E. Al-Shaer, A. D. Keromytis, & V. Shmatikov (Eds.), *Proceedings of the 17th ACM Conference on Computer and Communications Security, CCS 2010, Chicago, Illinois, USA, October 4–8, 2010* (pp. 187–200). ACM.

Ring Signature



Joseph K. Liu

Abstract In this chapter, we discuss the basics of ring signature—a kind of anonymous signature that allows a user to sign on behalf of a self-formed group such that the verifier only knows that the signer is one of the users of this group but cannot find out the identification information (such as public key) of the real signer. We give the security model and a simple construction based on discrete logarithm setting. Then, we cover a variant called linkable ring signature, which provides linkability in addition to the property of a normal ring signature. Finally, we present a commercial application of (linkable) ring signature in blockchain called Ring Confidential Transaction (RingCT), which is the privacy-preserving protocol used in Monero, one of the largest cryptocurrencies in the world.

1 Introduction

A ring signature scheme (for examples [1, 2]) allows members of a group to sign messages on behalf of the group without revealing their identities. In other words, the verifier only knows that the signer is one of the users in the group, yet no one can tell who the actual signer is. We say that signer anonymity is provided. The formation of the group is arbitrary or spontaneous. The group can be simply formed by the actual signer who just needs to include the public keys or identities of the other group members in the signing algorithm. These diversion group members can be totally unaware of being conscripted into the group. In addition, it is not possible to decide whether two signatures have been issued by the same group member for a normal ring signature. It is also impossible for any verifier to revoke the anonymity. That is, the anonymity is protected unconditionally, or at least computationally by some mathematical hard problems.

The notion of ring signature was first proposed in [2], though the concept has been mentioned earlier in [3] as the context of threshold proof of knowledge. In this context, the prover proves to the verifier that he knows the answer of t questions

J. K. Liu (✉)

Faculty of Information Technology, Monash University, Melbourne, Australia
e-mail: joseph.liu@monash.edu

© Springer Nature Singapore Pte Ltd. 2019

K.-C. Li et al. (eds.), *Advances in Cyber Security: Principles, Techniques, and Applications*, https://doi.org/10.1007/978-981-13-1483-4_5

out of n questions but the verifier does not know which t questions that the prover knows the answer. [2] then formulated the concept as the notion of ring signature and provided a concrete definition and instantiation of it.

There are a number of differences between a ring signature and a group signature (for examples, [4–6]) although both signature schemes provide signer anonymity. We summarize the differences as follows:

- **Key Generation** For group signature, there is only one single group public key and a group manager who is also responsible to issue each user secret key. For ring signature, user secret key and public key are generated by each user independently (in the case of public key cryptosystem). In the case of identity-based cryptosystem, user secret key is generated in the normal way, that is, by the Private Key Generator (PKG) while user identity is still chosen by the user.
- **Group Formation** For group signature, the group is formed by the group manager. If a new user wants to join the group, he/she has to interactive with the group manager who is then issuing a secret key to this new user. For ring signature, the formation of the group is ad hoc and fully determined by the actual signer, who just needs to include the public key or identities of other users in the signature generation algorithm in order to form this ad hoc group.
- **Anonymity Revocation** For group signature, the group manager is able to revoke the anonymity of every signature generated by any user of the group. For ring signature, however, there is no way to tell who the actual signer is, unless the actual signer reveals the randomness used to generate the signature.

1.1 Variants

After the introduction of the ring signature notion in [2] at 2001, there are many follow-ups. Since the instantiation given in [2] relies on trapdoor permutation, such as RSA, together with a symmetric cipher function such as AES, it may not be very efficient. A ring signature without using any symmetric cipher (instead using hash functions as random oracles) was later proposed by Abe et al. [1] which can be constructed using either RSA-type key or DL-type key. The first Identity-based ring signature was given by Zhang et al. [7]. The first constant size ring signature was given in [8]. There are many improvement and variants on ring signature for different aspects, such as functional, security, and efficiency improvement. Here, we only focus on the functional variants of ring signature.

Linkable Ring Signature. The normal ring signature is unlinkable. That is, no one can determine whether two signatures (with some overlapping ring members) are generated by the same user or not. Sometimes, it may not be the best for some applications. For example, if we deploy ring signature in e-voting, we have to detect if there is any double voting occurs. (More applications will be described in Sect. 1.2.) A variant called *Linkable Ring Signature* was proposed in [9]. In this notion, an additional property is added: Linkability. With linkability, anyone can determine

whether two signatures are generated by the same signer or not. Yet the verifier still cannot find out who this signer is. In other words, anonymity is still preserved.

Revocable Ring Signature. The normal ring signature is not revocable. That is, no one can find out who the actual signer is. Again, this anonymity protection may be too strong in some scenarios. One may want to reduce to a certain level such that a third party or an authority should be able to revoke the anonymity, either unconditionally or within some conditions. A variant called *Revocable Ring Signature* was proposed in [10] which allows the ring signature to be revoked if and only if it is linked with another ring signature. That is why the authors called it as *Revocable-iff-Linked Ring Signature*. Another unconditional revocable ring signature was later proposed in [11].

Threshold Ring Signature. In a normal ring signature, the verifier can confirm that the signature is generated by one of the users of the group (by using one secret key). This can be easily extended to a threshold manner. A t -out-of- n threshold ring signature [12] confirms that the signature is generated by t users within the group of n users (using t secret keys) and yet the verifier cannot tell which t users have participated in the signature generation process.

In the rest of this chapter, we will focus on the normal ring signature and the linkable ring signature.

1.2 Applications

Ring signature schemes could be used for whistle blowing [2], anonymous membership authentication for ad hoc groups [13] and many other applications which do not want complicated group formation stage but require signer anonymity. For example, in the whistle blowing scenario, a whistleblower gives out a secret as well as a ring signature of the secret to the public. From the signature, the public can be sure that the secret is indeed given out by a group member while cannot figure out who the whistleblower is. At the same time, the whistleblower does not need any collaboration of other users who have been conscripted by him into the group of members associated with the ring signature. Hence, the anonymity of the whistleblower is ensured and the public is also certain that the secret is indeed leaked by one of the group members associated with the ring signature.

Ring signature scheme can be used to derive other primitives as well. It had been utilized to construct noninteractive deniable ring authentication [14], perfect concurrent signature [15], and multi-designated verifiers signature [16].

The above-mentioned applications may be still in theoretical interest. Perhaps, the most successful commercial application of (linkable) ring signature is cryptocurrency. Bitcoin is the first cryptocurrency and the underlying technology is blockchain. It provides a decentralized distributed ledger system. Once the data (e.g., transaction details) is written to the blockchain, it cannot be modified or removed. The information on the blockchain (including the transaction amount, the pseudonym of the sender and receiver) is public. In order to provide user privacy, Monero (another

cryptocurrency, with current market capitalization more than US\$6 billion¹) uses linkable ring signature in their transactions (they called it Ring Confidential Transaction) to anonymize the sender and also to hide the transaction amount from the public. More details about Ring Confidential Transaction will be given in Sect. 4.

2 Security Model

2.1 Ring Signature

Syntax of Ring Signature. A *ring signature*, (RS) scheme, is a tuple of four algorithms (Setup, KeyGen, Sign and Verify).

- $\text{param} \leftarrow \text{Setup}(\lambda)$ is a probabilistic polynomial time (PPT) algorithm which, on input a security parameter λ , outputs the set of security parameters param which includes λ . We denote by $\mathcal{M}$ and Σ the domain of messages and signatures, respectively.
- $(sk_i, pk_i) \leftarrow \text{KeyGen}(\text{param})$ is a PPT algorithm which, on input a security parameter $\lambda \in \mathbb{N}$, outputs a private/public key pair (sk_i, pk_i) . We denote by $\mathcal{SK}$ and $\mathcal{PK}$ the domains of possible private keys and public keys, respectively.
- $\sigma \leftarrow \text{Sign}(n, \mathcal{Y}, sk, M)$ which, on input a group size n , a set $\mathcal{Y}$ of n public keys in $\mathcal{PK}$, a private key whose corresponding public key is contained in $\mathcal{Y}$, and a message M , produces a signature σ .
- $\text{accept/reject} \leftarrow \text{Verify}(n, \mathcal{Y}, M, \sigma)$ which, on input a group size n , a set $\mathcal{Y}$ of n public keys in $\mathcal{PK}$, a message-signature pair (M, σ) returns accept or reject. If accept, the message-signature pair is *valid*.

Correctness. RS schemes must satisfy:

- (Verification Correctness.) Signatures signed according to specification are accepted during verification.

Notions of Security of Ring Signature. Security of RS schemes has two aspects: unforgeability and anonymity. Before giving their definition, we consider the following oracles which together model the ability of the adversaries in breaking the security of the schemes.

- $pk_i \leftarrow \mathcal{JO}(\perp)$. The *Joining Oracle*, on request, adds a new user to the system. It returns the public key $pk \in \mathcal{PK}$ of the new user.
- $sk_i \leftarrow \mathcal{CO}(pk_i)$. The *Corruption Oracle*, on input a public key $pk_i \in \mathcal{PK}$ that is a query output of $\mathcal{JO}$, returns the corresponding private key $sk_i \in \mathcal{SK}$.

¹As of 4th January 2018 from <https://coinmarketcap.com/>.

- $\sigma' \leftarrow \mathcal{SO}(n, \mathcal{Y}, pk_\pi, M)$. The *Signing Oracle*, on input a group size n , a set $\mathcal{Y}$ of n public keys, the public key of the signer $pk_\pi \in \mathcal{Y}$, and a message M , returns a valid signature σ' .

If the scheme is proven in random oracle model, a random oracle is simulated.

1. **Unforgeability.** Unforgeability for RS schemes is defined in the following game between the Simulator $\mathcal{S}$ and the Adversary $\mathcal{A}$ in which $\mathcal{A}$ is given access to oracles $\mathcal{JO}$, $\mathcal{CO}$, $\mathcal{SO}$ (and the random oracle):
 - (a) $\mathcal{S}$ generates and gives $\mathcal{A}$ the system parameters param .
 - (b) $\mathcal{A}$ may query the oracles according to any adaptive strategy.
 - (c) $\mathcal{A}$ gives $\mathcal{S}$ a group size $n \in \mathbb{N}$, a set $\mathcal{Y}$ of n public keys in $\mathcal{PK}$, a message $M \in \mathcal{M}$ and a signature $\sigma \in \Sigma$.

$\mathcal{A}$ wins the game if:

- (1) $\text{Verify}(n, \mathcal{Y}, M, \sigma) = \text{accept}$;
- (2) All of the public keys in $\mathcal{Y}$ are query outputs of $\mathcal{JO}$;
- (3) No public keys in $\mathcal{Y}$ have been input to $\mathcal{CO}$; and
- (4) σ is not a query output of $\mathcal{SO}$.

We denote by

$$\text{Adv}_{\mathcal{A}}^{\text{unf}}(\lambda) = \Pr[\mathcal{A} \text{ wins the game}]$$

Definition 1 (*unforgeability*) A RS scheme is unforgeable if for all PPT adversary $\mathcal{A}$, $\text{Adv}_{\mathcal{A}}^{\text{unf}}(\lambda)$ is negligible.

2. **Anonymity.** It should not be possible for an adversary $\mathcal{A}$ to tell the public key of the signer with a probability (non-negligibly) larger than $1/n$, where n is the cardinality of the ring, even assuming that the adversary has unlimited computing resources. If the anonymity is provided unconditional (instead of computational), the probability should be strictly equal to $1/n$.

Specifically, anonymity for RS schemes is defined in the following game between the Simulator $\mathcal{S}$ and the unbounded Adversary $\mathcal{A}$ in which $\mathcal{A}$ is given access to oracle $\mathcal{JO}$.

- (a) $\mathcal{S}$ generates and gives $\mathcal{A}$ the system parameters param .
- (b) $\mathcal{A}$ may query $\mathcal{JO}$ according to any adaptive strategy.
- (c) $\mathcal{A}$ gives $\mathcal{S}$ a group size $n \in \mathbb{N}$, a set $\mathcal{Y}$ of n public keys in $\mathcal{PK}$ such that all of the public keys in $\mathcal{Y}$ are query outputs of $\mathcal{JO}$, a message $M \in \mathcal{M}$. Parse the set $\mathcal{Y}$ as $\{pk_1, \dots, pk_n\}$. $\mathcal{S}$ randomly picks $\pi_R \in \{1, \dots, n\}$ and computes $\sigma_\pi = \text{Sign}(n, \mathcal{Y}, sk_\pi, M)$, where sk_π is a corresponding private key of pk_π . σ_π is given to $\mathcal{A}$.
- (d) $\mathcal{A}$ outputs a guess $\pi' \in \{1, \dots, n\}$.

We denote by

$$\mathbf{Adv}_{\mathcal{A}}^{\text{Anon}}(\lambda) = |\Pr[\pi' = \pi] - \frac{1}{n}|$$

Definition 2 (*Anonymity*) An RS scheme is computational anonymous if for any adversary $\mathcal{A}$, $\mathbf{Adv}_{\mathcal{A}}^{\text{Anon}}(\lambda)$ is negligible. An RS scheme unconditional anonymous if for any *unbounded* adversary $\mathcal{A}$, $\mathbf{Adv}_{\mathcal{A}}^{\text{Anon}}(\lambda)$ is zero.

2.2 Linkable Ring Signature

Next, we give the security model of linkable ring signature. Basically it is similar to the normal ring signature, with some minor differences. We first outline the differences here.

1. There is an event ID. Linkability can occur within the same event ID (and thus unlinked for different event IDs). This is called event linkable. If event linkable is not necessary, we can simply put a public constant as the event ID.
2. There is one more algorithms: Link. It is used to determine if two signatures are generated by the same signer.
3. There are two more security notions: linkability and non-slanderability. Linkability guarantees that two signatures should be linked if they are generated using the same secret key. Non-slanderability guarantees that two signatures should be unlinked if they are generated using two different secret keys.

Syntax of Linkable Ring Signature. A *linkable ring signature*, (LRS) scheme, is a tuple of five algorithms (Setup, KeyGen, Sign, Verify and Link).

- $\text{param} \leftarrow \text{Setup}(\lambda)$ is a probabilistic polynomial time (PPT) algorithm which, on input a security parameter λ , outputs the set of security parameters param which includes λ . We denote by $\mathcal{EID}$, $\mathcal{M}$ and Σ the domains of event-id, messages, and signatures, respectively.
- $(sk_i, pk_i) \leftarrow \text{KeyGen}(\text{param})$ is a PPT algorithm which, on input a security parameter $\lambda \in \mathbb{N}$, outputs a private/public key pair (sk_i, pk_i) . We denote by $\mathcal{SK}$ and $\mathcal{PK}$ the domains of possible private keys and public keys, respectively.
- $\sigma \leftarrow \text{Sign}(e, n, \mathcal{Y}, sk, M)$ which, on input event-id e , group size n , a set $\mathcal{Y}$ of n public keys in $\mathcal{PK}$, a private key whose corresponding public key is contained in $\mathcal{Y}$, and a message M , produces a signature σ .
- $\text{accept/reject} \leftarrow \text{Verify}(e, n, \mathcal{Y}, M, \sigma)$ which, on input event-id e , group size n , a set $\mathcal{Y}$ of n public keys in $\mathcal{PK}$, a message-signature pair (M, σ) returns accept or reject. If accept, the message-signature pair is *valid*.
- $\text{linked/unlinked} \leftarrow \text{Link}(e, n_1, n_2, \mathcal{Y}_1, \mathcal{Y}_2, M_1, M_2, \sigma_1, \sigma_2)$ which, on input event-id e , group size n_1, n_2 , two sets $\mathcal{Y}_1, \mathcal{Y}_2$ of n_1, n_2 public keys respectively, two valid signature and message pairs $(M_1, \sigma_1, M_2, \sigma_2)$, outputs linked or unlinked.

Correctness. LRS schemes must satisfy:

- (Verification Correctness.) Signatures signed according to specification are accepted during verification.
- (Linking Correctness.) If two signatures are signed for the same event according to specification, then they are linked if and only if the two signatures share a common signer.

Notions of Security of Linkable Ring Signature. Security of LRS schemes has four aspects: unforgeability, anonymity, linkability, and non-slanderability. Before giving their definition, we consider the following oracles which together model the ability of the adversaries in breaking the security of the schemes.

- $pk_i \leftarrow \mathcal{JO}(\perp)$. The *Joining Oracle*, on request, adds a new user to the system. It returns the public key $pk \in \mathcal{PK}$ of the new user.
- $sk_i \leftarrow \mathcal{CO}(pk_i)$. The *Corruption Oracle*, on input a public key $pk_i \in \mathcal{PK}$ that is a query output of $\mathcal{JO}$, returns the corresponding private key $sk_i \in \mathcal{SK}$.
- $\sigma' \leftarrow \mathcal{SO}(e, n, \mathcal{Y}, pk_\pi, M)$. The *Signing Oracle*, on input an event-id e , a group size n , a set $\mathcal{Y}$ of n public keys, the public key of the signer $pk_\pi \in \mathcal{Y}$, and a message M , returns a valid signature σ' .

If the scheme is proven in random oracle model, a random oracle is simulated.

1. **Unforgeability.** Unforgeability for LRS schemes is defined in the following game between the Simulator $\mathcal{S}$ and the Adversary $\mathcal{A}$ in which $\mathcal{A}$ is given access to oracles $\mathcal{JO}$, $\mathcal{CO}$, $\mathcal{SO}$ and the random oracle:

- (a) $\mathcal{S}$ generates and gives $\mathcal{A}$ the system parameters param .
- (b) $\mathcal{A}$ may query the oracles according to any adaptive strategy.
- (c) $\mathcal{A}$ gives $\mathcal{S}$ an event-id $e \in \mathcal{ETD}$, a group size $n \in \mathbb{N}$, a set $\mathcal{Y}$ of n public keys in $\mathcal{PK}$, a message $M \in \mathcal{M}$ and a signature $\sigma \in \Sigma$.

$\mathcal{A}$ wins the game if:

- (1) $\text{Verify}(n, \mathcal{Y}, M, \sigma) = \text{accept}$;
- (2) All of the public keys in $\mathcal{Y}$ are query outputs of $\mathcal{JO}$;
- (3) No public keys in $\mathcal{Y}$ have been input to $\mathcal{CO}$; and
- (4) σ is not a query output of $\mathcal{SO}$.

We denote by

$$\text{Adv}_{\mathcal{A}}^{\text{unf}}(\lambda) = \Pr[\mathcal{A} \text{ wins the game}]$$

Definition 3 (*unforgeability*) A LRS scheme is unforgeable if for all PPT adversary $\mathcal{A}$, $\text{Adv}_{\mathcal{A}}^{\text{unf}}(\lambda)$ is negligible.

2. **Anonymity.** It should not be possible for an adversary $\mathcal{A}$ to tell the public key of the signer with a probability (non-negligibly) larger than $1/n$, where n is the cardinality of the ring, even assuming that the adversary has unlimited computing

resources. If the anonymity is provided unconditional (instead of computational), the probability should be strictly equal to $1/n$.

Specifically, anonymity for LRS schemes is defined in the following game between the Simulator $\mathcal{S}$ and the Adversary $\mathcal{A}$ in which $\mathcal{A}$ is given access to oracle $\mathcal{JO}$.

- (a) $\mathcal{S}$ generates and gives $\mathcal{A}$ the system parameters param .
- (b) $\mathcal{A}$ may query $\mathcal{JO}$ according to any adaptive strategy.
- (c) $\mathcal{A}$ gives $\mathcal{S}$ an event-id $e \in \mathcal{EID}$, a group size $n \in \mathbb{N}$, a set $\mathcal{Y}$ of n public keys in $\mathcal{PK}$ such that all of the public keys in $\mathcal{Y}$ are query outputs of $\mathcal{JO}$, a message $M \in \mathcal{M}$. Parse the set $\mathcal{Y}$ as $\{pk_1, \dots, pk_n\}$. $\mathcal{S}$ randomly picks $\pi_R \in \{1, \dots, n\}$ and computes $\sigma_\pi = \text{Sign}(e, n, \mathcal{Y}, sk_\pi, M)$, where sk_π is a corresponding private key of pk_π . σ_π is given to $\mathcal{A}$.
- (d) $\mathcal{A}$ outputs a guess $\pi' \in \{1, \dots, n\}$.

We denote by

$$\mathbf{Adv}_{\mathcal{A}}^{\text{Anon}}(\lambda) = |\Pr[\pi' = \pi] - \frac{1}{n}|$$

Definition 4 (*Anonymity*) A LRS scheme is computational anonymous if for any adversary $\mathcal{A}$, $\mathbf{Adv}_{\mathcal{A}}^{\text{Anon}}(\lambda)$ is negligible. A LRS scheme unconditional anonymous if for any *unbounded* adversary $\mathcal{A}$, $\mathbf{Adv}_{\mathcal{A}}^{\text{Anon}}(\lambda)$ is zero.

3. Linkability.

Linkability for LRS schemes is mandatory, that is, it should be infeasible for a signer to generate two signatures such that they are determined to be unlinked using LRS.Link. The following definition/game essentially captures a scenario that an adversary tries to generate two LRS signatures, using strictly fewer than two user private keys, so that these two signatures are determined to be unlinked using LRS.Link. If the LRS scheme is unforgeable (as defined above), then these signatures can only be generated if at least two user private keys are known. If less than 2 user private keys are known, then there must be one common signer to both of the signatures. Therefore, this model can effectively capture the definition of linkability.

Linkability for LRS scheme is defined in the following game between the Simulator $\mathcal{S}$ and the Adversary $\mathcal{A}$ in which $\mathcal{A}$ is given access to oracles $\mathcal{JO}$, $\mathcal{CO}$, $\mathcal{SO}$ and the random oracle:

- (a) $\mathcal{S}$ generates and gives $\mathcal{A}$ the system parameters param .
- (b) $\mathcal{A}$ may query the oracles according to any adaptive strategy.
- (c) $\mathcal{A}$ gives $\mathcal{S}$ an event-id $e \in \mathcal{EID}$, group sizes $n_1, n_2 \in \mathbb{N}$ (w.l.o.g. we assume $n_1 \leq n_2$), sets $\mathcal{Y}_1$ and $\mathcal{Y}_2$ of public keys in $\mathcal{PK}$ of sizes n_1 and n_2 resp., messages $M_1, M_2 \in \mathcal{M}$ and signatures $\sigma_1, \sigma_2 \in \Sigma$.

$\mathcal{A}$ wins the game if:

- (1) All public keys in $\mathcal{Y}_1 \cup \mathcal{Y}_2$ are query outputs of $\mathcal{JO}$;
- (2) $\text{Verify}(e, n_i, \mathcal{Y}_i, M_i, \sigma_i) = \text{accept}$ for $i = 1, 2$ such that σ_i are not outputs of $\mathcal{SO}$;
- (3) $\mathcal{CO}$ has been queried less than 2 times (that is, $\mathcal{A}$ can only have at most 1 user private key); and
- (4) $\text{Link}(\sigma_1, \sigma_2) = \text{unlinked}$.

We denote by

$$\text{Adv}_{\mathcal{A}}^{\text{Link}}(\lambda) = \Pr[\mathcal{A} \text{ wins the game}]$$

Definition 5 (*Linkability*) A LRS scheme is linkable if for all PPT adversary $\mathcal{A}$, $\text{Adv}_{\mathcal{A}}^{\text{Link}}$ is negligible.

4. *Non-slanderability.*

Non-slanderability ensures that no signer can generate a signature which is determined to be linked by LRS.Link with another signature which is not generated by the signer. In other words, it prevents adversaries from framing honest users. Non-slanderability for LRS schemes is defined in the following game between the Simulator $\mathcal{S}$ and the Adversary $\mathcal{A}$ in which $\mathcal{A}$ is given access to oracles $\mathcal{JO}$, $\mathcal{CO}$, $\mathcal{SO}$, and the random oracle:

- (a) $\mathcal{S}$ generates and gives $\mathcal{A}$ the system parameters param .
- (b) $\mathcal{A}$ may query the oracles according to any adaptive strategy.
- (c) $\mathcal{A}$ gives $\mathcal{S}$ an event e , group size n , a message M , a set of n public keys $\mathcal{Y}$, the public key of an insider $pk_{\pi} \in \mathcal{Y}$ such that pk_{π} has not been queried to $\mathcal{CO}$ or has not been included as the insider public key of any query to $\mathcal{SO}$. $\mathcal{S}$ uses the private key sk_{π} corresponding to pk_{π} to run $\text{Sign}(e, n, \mathcal{Y}, sk_{\pi}, M)$ and to produce a signatures σ' given to $\mathcal{A}$.
- (d) $\mathcal{A}$ queries oracles with arbitrary interleaving, except that pk_{π} cannot be queried to $\mathcal{CO}$, or included as the insider public key of any query to $\mathcal{SO}$. In particular, $\mathcal{A}$ is allowed to query any public key which is not pk_{π} to $\mathcal{CO}$.
- (e) $\mathcal{A}$ delivers group size n^* , a set of n^* public keys $\mathcal{Y}^*$, a message M^* and a signature $\sigma^* \neq \sigma'$.

$\mathcal{A}$ wins the game if:

- (1) $\text{Verify}(e, n^*, \mathcal{Y}^*, M^*, \sigma^*) = \text{accept}$;
- (2) σ^* is not an output of $\mathcal{SO}$;
- (3) All of the public keys in $\mathcal{Y}^*, \mathcal{Y}$ are query outputs of $\mathcal{JO}$;
- (4) pk_{π} has not been queried to $\mathcal{CO}$; and
- (5) $\text{Link}(\sigma^*, \sigma') = \text{linked}$.

We denote by

$$\text{Adv}_{\mathcal{A}}^{\text{NS}}(\lambda) = \Pr[\mathcal{A} \text{ wins the game}]$$

Definition 6 (*Non-slanderability*) An LRS scheme is *non-slanderable* if for all PPT adversary $\mathcal{A}$, $\text{Adv}_{\mathcal{A}}^{NS}$ is negligible.

3 Construction of Basic Schemes

We give the basic construction of ring signature and linkable ring signature scheme in this section. Among hundreds of constructions in the literature, we choose the most basic and easy to understand constructions. Once the readers have understood the idea behind these basic ones, they should be able to read the more complicated instantiations existed in the literature.

3.1 Ring Signature

A ring signature scheme can be regarded as a noninteractive 1-out-of- n proof of knowledge. We choose the present the discrete-log (DL) based construction from [1] (instead of the first construction from [2] which requires ideal cipher (such as AES)) as it is more efficient and easier to understand.

It is actually an 1-out-of- n generalization of Schnorr Signature. If we set $n = 1$, it becomes a Schnorr Signature then. This generalization converts the “challenge” (generated from the commitment of the user) used in the Schnorr signature into another “challenge” associated with another user. That is, the commitment of user i is used to generate the “challenge” of user $i + 1$. This then forms a loop and the actual signer uses his secret key to “close” the loop, as in the $n = 1$ (Schnorr Signature) case that the signer uses his secret key to produce the “response”.

In the original paper [1], each user can choose to have either DL-based or RSA-based key. For simplicity, we use the all DL-based setting with the same group domain for all users.

- **Setup:** Let $\mathbb{G}$ be a group of prime order q such that the underlying discrete logarithm problem is intractable. Let $H_1 : \{0, 1\}^* \rightarrow \mathbb{Z}_q$ and $H_2 : \{0, 1\}^* \rightarrow \mathbb{G}$ be two hash functions. Let $g = H_2(\text{“GENERATOR”} - \mathfrak{g})$. The public parameters are $\text{param} = (\mathbb{G}, g, q, H_1, H_2, \text{“GENERATOR”} - \mathfrak{g})$. Note that everyone can check the correctness of the generation of g .²
- **KeyGen:** Assume there are n users. User i , where $i \in [1, n]$, randomly chooses $x_i \in_R \mathbb{Z}_q$ and computes $y_i = g^{x_i}$. His secret key is $sk_i = x_i$ and the corresponding public key is $pk_i = y_i$.
- **Sign:** On input $(n, \mathcal{Y}, sk_\pi, m)$ where n is the number of users included in the ring signature, $\mathcal{Y} = \{pk_1, \dots, pk_n\} = \{y_1, \dots, y_n\}$ is the set of public keys of users in the ring, $sk_\pi = x_\pi$ is the secret key corresponding to the public key pk_π such that

²If the setup process can be trusted, we can eliminate H_2 and simply put g as the public parameter.

$pk_\pi \in \mathcal{Y}$ (w.l.o.g., $\pi \in [1, n]$) and m is the message to be signed, the user (with the knowledge of sk_π) computes the following:

1. Pick $u \in_R \mathbb{Z}_q$, and compute

$$c_{\pi+1} = H_1(\mathcal{Y}, m, g^u).$$

2. For $i = \pi+1, \dots, n, 1, \dots, \pi-1$, pick $s_i \in_R \mathbb{Z}_q$ and compute

$$c_{i+1} = H_1(\mathcal{Y}, m, g^{s_i} y_i^{c_i}).$$

3. Compute $s_\pi = u - x_\pi c_\pi \bmod q$.

The signature is $\sigma = (c_1, s_1, \dots, s_n)$.

- Verify: On input $(\mathcal{Y}, m, \sigma)$,

1. For $i = 1, \dots, n$, compute

$$z'_i = g^{s_i} y_i^{c_i}$$

and then

$$c_{i+1} = H_1(\mathcal{Y}, m, z'_i)$$

if $i \neq n$.

2. Check whether $c_1 \stackrel{?}{=} H_1(\mathcal{Y}, m, z'_n)$. If yes, accept. Otherwise, reject.

3.2 Linkable Ring Signature

We give the construction of the first linkable ring signature from [9] here. It is also based on the discrete-log setting and can be seen as an extension from [1], which was given in Sect. 3.1. Note that we slightly generalize the scheme to event linkable.

- Setup: Let $\mathbb{G}$ be a group of prime order q such that the underlying discrete logarithm problem is intractable. Let $H_1 : \{0, 1\}^* \rightarrow \mathbb{Z}_q$ and $H_2 : \{0, 1\}^* \rightarrow \mathbb{G}$ be two hash functions. Let $g = H_2(\text{"GENERATOR"} - g)$. The public parameters are $\text{param} = (\mathbb{G}, g, q, H_1, H_2, \text{"GENERATOR"} - g)$. Note that everyone can check the correctness of the generation of g .
- KeyGen: Assume there are n users. User i , where $i \in [1, n]$, randomly chooses $x_i \in_R \mathbb{Z}_q$ and computes $y_i = g^{x_i}$. His secret key is $sk_i = x_i$ and the corresponding public key is $pk_i = y_i$.
- Sign: On input $(event, n, \mathcal{Y}, sk_\pi, m)$ where $event$ is the event description, n is the number of users included in the ring signature, $\mathcal{Y} = \{pk_1, \dots, pk_n\} = \{y_1, \dots, y_n\}$ is the set of public keys of users in the ring, $sk_\pi = x_\pi$ is the secret key corresponding to the public key pk_π such that $pk_\pi \in \mathcal{Y}$ (w.l.o.g., $\pi \in [1, n]$),

and m is the message to be signed, the user (with the knowledge of sk_π) computes the following:

1. Compute $h = H_2(event)$ and $\tilde{y} = h^{x_\pi}$.
2. Pick $u \in_R \mathbb{Z}_q$, and compute

$$c_{\pi+1} = H_1(event, \mathcal{Y}, \tilde{y}, m, g^u, h^u).$$

3. For $i = \pi+1, \dots, n, 1, \dots, \pi-1$, pick $s_i \in_R \mathbb{Z}_q$ and compute

$$c_{i+1} = H_1(event, \mathcal{Y}, \tilde{y}, m, g^{s_i} y_i^{c_i}, h^{s_i} \tilde{y}^{c_i}).$$

4. Compute $s_\pi = u - x_\pi c_\pi \bmod q$.

The signature is $\sigma = (c_1, s_1, \dots, s_n, \tilde{y})$.

- Verify: On input $(event, \mathcal{Y}, m, \sigma)$,

1. Compute $h = H_2(event)$ and for $i = 1, \dots, n$, compute

$$z'_i = g^{s_i} y_i^{c_i}, \quad z''_i = h^{s_i} \tilde{y}^{c_i}$$

and then

$$c_{i+1} = H_1(event, \mathcal{Y}, \tilde{y}, m, z'_i, z''_i)$$

if $i \neq n$.

2. Check whether $c_1 \stackrel{?}{=} H_1(event, \mathcal{Y}, \tilde{y}, m, z'_n, z''_n)$. If yes, accept. Otherwise, reject.
- Link: On input two signatures $\sigma_1 = (\cdot, \tilde{y}_1)$, $\sigma_2 = (\cdot, \tilde{y}_2)$, two messages m_1, m_2 , and an event description $event$, first check whether two signatures are valid. If yes, output link if $\tilde{y}_1 = \tilde{y}_2$ and output unlink otherwise.

4 Ring Confidential Transaction

Recall that Monero is based on CryptoNote, where each user may have a number of distinct accounts. Each account consists of a one-time address and a coin, and it is always associated with an account key used to authorize its spending. In each transaction, a user can spend many of her/his accounts with the corresponding keys. The goal of ring confidential transaction (RingCT) protocol is to protect the anonymity of spenders as well as the privacy of transactions.

Informally, a RingCT protocol mainly comprises of two phases: the generation and the verification of ring confidential transactions, which are operated by the spender and recipients, respectively. When a user s would like to spend m of her/his accounts, w.l.o.g., denoted by $A_s = \{(pk_s^{(k)}, cn_s^{(k)})\}_{k \in [m]}$ where $pk_s^{(k)}$ is the user's k -th account

address and $cn_s^{(k)}$ is the coin w.r.t. this account, s/he first chooses t output accounts $\{(pk_{out,j}, cn_{out,j})\}_{j \in [t]}$ for all output addresses $R = \{pk_{out,j}\}_{j \in [t]}$ accordingly, such that the sum of balances of her/his input accounts equals to that of output accounts, and then additionally selects $n - 1$ groups of input accounts with each containing m different accounts to anonymously spend A_s for some payments (i.e., creating a ring confidential transaction). Whenever receiving this transaction from the P2P blockchain network, the miners check the validity of the transaction with public information along with it and add it to a (new) block if valid.

By a thorough analysis of the protocol in [17], we find that the RingCT protocol essentially involves linkable ring signatures and commitments (that are used to hide account balance). To be compatible within the protocol, these two cryptographic primitives should satisfy the following properties simultaneously:

- Public keys generated by the key generation algorithm of linkable ring signature should be homomorphic.
- Commitments should be homomorphic with respect to (w.r.t.) the same operation as public keys.
- Commitments to zero are well-formed public keys, each corresponding secret key of which can be derived from the randomness of commitments.

To further capture the essential properties and securities required by the ring confidential transaction protocol for Monero, we initiate the formalization of RingCT protocol and its security models, the details of which are shown in the following subsections.

4.1 Formalization of RingCT

In general, a RingCT protocol consists of a tuple of poly-time algorithms (Setup, KeyGen, Mint, Spend, Verify), the syntax of which is described as follows:

- $pp \leftarrow \text{Setup}(1^\lambda)$: the *Setup* algorithm takes a security parameter $\lambda \in \mathbb{N}$, and outputs the public system parameters pp . All algorithms below have implicitly pp as part of their inputs.
- $(sk, pk) \leftarrow \text{KeyGen}(pp)$: the *key generation* algorithm takes as input pp and outputs a public and secret key pair (pk, sk) . In the context of Monero, pk is always set as a one-time address, which together with a coin constitutes an account.
- $(cn_{pk}, ck) \leftarrow \text{Mint}(pk, a)$: the *Mint* algorithm takes as input an amount a and a valid address pk s.t. $(pk, sk) \leftarrow \text{KeyGen}(pp)$, and outputs a coin cn_{pk} for pk as well as the associated coin key ck .³ The coin cn together with address pk forms an

³We note that ck will be privately sent to the user possessing account address pk , e.g., by using public key encryption: Suppose Alice wants to send a coin to Bob. Bob will first send pk to Alice. Alice then uses pk to encrypt ck and sends the ciphertext to Bob. No one except Bob can decrypt the ciphertext to get ck .

account $act \doteq (pk, cn_{pk})$, the corresponding secret key of which is $ask \doteq (sk, ck)$ that is required for authorizing its spending.

- $(tx, \pi, S) \leftarrow \text{Spend}(m, K_s, A_s, A, R)$: on input a group $A_s = \{act^{(k)}\}_{k \in [m]}$ of m accounts together with the corresponding account secret keys $K_s = \{ask^{(k)}\}_{k \in [m]}$, an arbitrary set A of groups of input accounts containing A_s , a set $R = \{pk_{out}^{(j)}\}_{j \in [t]}$ of t output addresses and some transaction string $m \in \{0, 1\}^*$, the algorithm outputs a transaction tx (containing m , A and A_R which denotes the set of output accounts w.r.t. R), a proof π , and a set S of serial numbers.
- $1/0 \leftarrow \text{Verify}(tx, \pi, S)$: on input the transaction tx containing m , A and A_R , proof π and serial numbers S , the algorithm verifies whether a set of accounts with serial numbers S is spent properly for the transaction tx towards addresses R , and outputs 1 or 0, meaning a valid or invalid spending, respectively.

4.2 Security Definitions

A RingCT protocol should at least satisfy the properties formalized below.

Definition 7 (Perfect Correctness) This property requires that a user can spend any group of her accounts w.r.t. an arbitrary set of groups of input accounts, each group containing the same number of accounts as the group she intends to spend. Specifically, a RingCT protocol $\Pi = (\text{Setup}, \text{KeyGen}, \text{Mint}, \text{Spend}, \text{Verify})$ is called perfectly correct if for all PPT adversaries $\mathcal{A}$, it holds that

$$\Pr \left[\begin{array}{l} pp \leftarrow \text{Setup}(1^\lambda); (m, A, R) \leftarrow \mathcal{A}(pp, A_s, K_s) \\ \text{where } (A_s, K_s) = \{((pk, cn), (sk, ck))\} \text{ s.t.} \\ (pk, sk) \leftarrow \text{KeyGen}(pp), (cn_{pk}, ck) \leftarrow \text{Mint}(pk, a); \\ (tx, \pi, S) \leftarrow \text{Spend}(m, K_s, A_s, A, R). \end{array} \right] = 1.$$

Definition 8 (Balance) This property requires that any malicious user cannot (1) spend any account without her control and (2) spend her own/controllable accounts with a larger output amount. Specifically, a RingCT protocol $\Pi = (\text{Setup}, \text{KeyGen}, \text{Mint}, \text{Spend}, \text{Verify})$ is called balanced w.r.t. insider corruption if for all PPT adversaries $\mathcal{A}$, it holds that

$$\Pr \left[\mathcal{A} \text{ Wins} : \begin{array}{l} pp \leftarrow \text{Setup}(1^\lambda); (\{act_i'\}_{i=1}^\mu, \{\mathcal{S}_i\}_{i=1}^\nu) \\ \leftarrow \mathcal{A}^{\text{AddGen}, \text{ActGen}, \text{Spend}, \text{Corrupt}}(pp) \end{array} \right] \leq \text{negl}(\lambda),$$

where all oracles AddGen , ActGen , Spend and Corrupt are defined as below:

- $\text{AddGen}(i)$: on input a query number i , picks randomness τ_i , runs algorithm $(sk_i, pk_i) \leftarrow \text{KeyGen}(pp; \tau_i)$, and returns address pk_i .
- $\text{ActGen}(i, a_i)$: on input address index i and an amount a_i , runs algorithm $(cn_{pk_i}, ck_i) \leftarrow \text{Mint}(pk_i, a_i)$, then adds i and account $act_i = (pk_i, cn_{pk_i})$ to initially empty lists $\mathcal{I}$ and $\mathcal{G}$, respectively, and outputs (act_i, ck_i) for address pk_i ,

where pk_i is assumed to have been generated by AddGen. The associated secret key with account act_i is $ask_i \doteq (sk_i, ck_i)$. The oracle also uses ask_i to determine the serial number s_i of act_i and adds it to initially empty list $\mathcal{S}$.

- $\text{Spend}(\mathbf{m}, A_s, A, R)$: takes in transaction string $\mathbf{m}$, input accounts A containing A_s and output addresses R , runs $(tx, \pi, S) \leftarrow \text{Spend}(\mathbf{m}, K_s, A_s, A, R)$ and returns (tx, π, S) after adding it to list $\mathcal{T}$, where $A_s \subset \mathcal{G}$ and we assume that at least one account/address in A_s has not been corrupted so far.
- $\text{Corrupt}(i)$: on input query number $i \in \mathcal{I}$, uses account key ask_i to determine the serial number s_i of account act_i with address pk_i , then adds s_i and (s_i, a_i) to lists $\mathcal{C}$ and $\mathcal{B}$ respectively, where a_i is the balance of the account with address pk_i , and finally returns τ_i .

At last, $\mathcal{A}$ outputs all her spends with some new accounts $(act'_1, act'_2, \dots, act'_\mu, S_1, S_2, \dots, S_\nu)$ such that $S_i = (tx_i, \pi_i, S_i)$, where all spends are paid to, w.l.o.g., the challenger with account address pk_c ,⁴ i.e., $tx_i = (\mathbf{m}_i, A_i, A_{\{pk_c\}})$, and $A_i \subset \mathcal{G} \cup \{act'_i\}_{i=1}^\mu$ for all $i \in [\nu]$. We call $\mathcal{A}$ wins in the experiment if her outputs satisfy the following conditions:

1. $\text{Verify}(tx_i, \pi_i, S_i) = 1$ for all $i \in [\nu]$.
2. $S_i \notin \mathcal{T} \wedge S_i \subset \mathcal{S}$ for all $i \in [\nu]$, and $S_j \cap S_k = \emptyset$ for any different $j, k \in [\nu]$.
3. Let $S_i = \{s_{i,j}\}$ and $E = \bigcup_{i=1}^\nu \{a_{i,j} : (s_{i,j}, a_{i,j}) \in \mathcal{B} \wedge s_{i,j} \in S_i \cap \mathcal{C}\}$, it holds that

$$\sum_{a_{i,j} \in E} a_{i,j} < \sum_{i=1}^\nu a_{out,i}, \text{ where } a_{out,i} \text{ denotes the balance of output account in } S_i.$$

Definition 9 (*Anonymity*) This property requires that two proofs of spending with the same transaction string $\mathbf{m}$, input accounts A , output addresses R , and distinct spent accounts $A_{s_0}, A_{s_1} \in A$ are (computationally) indistinguishable, meaning that the spender's accounts are successfully hidden among all the honestly generated accounts. Specifically, a RingCT protocol $\Pi = (\text{Setup}, \text{KeyGen}, \text{Mint}, \text{Spend}, \text{Verify})$ is called anonymous if for all PPT adversaries $\mathcal{A} = (\mathcal{A}_1, \mathcal{A}_2)$, it holds that

$$\left| \Pr \left[b' = b : \begin{array}{l} pp \leftarrow \text{Setup}(1^\lambda); (\mathbf{m}, A_{s_0}, A_{s_1}, A, R) \leftarrow \\ \mathcal{A}_1^{\text{AddGen}, \text{ActGen}, \text{Spend}, \text{Corrupt}}(pp); b \leftarrow \{0, 1\}, \\ (tx^*, \pi^*, S^*) \leftarrow \text{Spend}(\mathbf{m}, K_{s_b}, A_{s_b}, A, R); \\ b' \leftarrow \mathcal{A}_2^{\text{Spend}, \text{Corrupt}}(pp, (tx^*, \pi^*, S^*)) \end{array} \right] - \frac{1}{2} \right| \leq \text{negl}(\lambda),$$

where all oracles are defined as before, $A_{s_i} \in A$ and $A_{s_i} \subset \mathcal{G}$ for $i \in \{0, 1\}$. In addition, the following restrictions should be satisfied:

- For all $i \in \{0, 1\}$, any account in A_{s_i} has not been corrupted.
- Any query in the form of $(\cdot, A_s, \cdot, \cdot)$ s.t. $A_s \cap A_{s_i} \neq \emptyset$ has not been issued to Spend oracle.

⁴Note that in this case, assuming pk_c has been generated by AddGen, the challenger knows all balances of the spent accounts and output accounts involved in the adversarial spends $\{S_i\}_{i=1}^\nu$.

Definition 10 (*Non-slanderability*) This property requires that a malicious user cannot slander any honest user after observing an honestly generated spending. That is, it is infeasible for any malicious user to produce a valid spending that shares at least one serial number with a previously generated honest spending. Specifically, a RingCT protocol $\Pi = (\text{Setup}, \text{KeyGen}, \text{Mint}, \text{Spend}, \text{Verify})$ is called non-slanderable if for all PPT adversaries $\mathcal{A}$, it holds that

$$\Pr \left[\mathcal{A} \text{ Wins} : \begin{array}{l} pp \leftarrow \text{Setup}(1^\lambda); ((\hat{tx}, \hat{\pi}, \hat{S}), (tx^*, \pi^*, S^*)) \\ \leftarrow \mathcal{A}^{\text{AddGen}, \text{ActGen}, \text{Spend}, \text{Corrupt}}(pp) \end{array} \right] \leq \text{negl}(\lambda),$$

where all oracles are defined as before, and $(\hat{tx}, \hat{\pi}, \hat{S})$ is one output of the oracle Spend for some (m, A_s, A, R) . We call $\mathcal{A}$ succeeds if the output satisfies the following conditions: (1) $\text{Verify}(tx^*, \pi^*, S^*) = 1$; (2) $(tx^*, \pi^*, S^*) \notin T$; (3) $\hat{S} \cap \mathcal{C} = \emptyset$ but $\hat{S} \cap S^* \neq \emptyset$.

We note that our non-slanderability definition already covers *linkability* property of a linkable ring signature. Thus, we do not need to explicitly define linkability.

4.3 Technical Description

Now we give the technical description of the RingCT protocol used in Monero.

- **Setup:** Let $\mathbb{G}$ be a group of prime order q such that the underlying discrete logarithm problem is intractable. Let $H_1 : \{0, 1\}^* \rightarrow \mathbb{Z}_q$ and $H_2 : \{0, 1\}^* \rightarrow \mathbb{G}$ be two hash functions, and g, h be two generators in $\mathbb{G}$. The public parameters $pp = (\mathbb{G}, g, h, q, H)$.
- **KeyGen:** Randomly choose $x \in_R \mathbb{Z}_q$ and compute $y = g^x$. The secret key is $sk = x$ and the corresponding public key is $pk = y$.
- **Mint:** Given an amount a and a coin address pk , randomly choose $r \in_R \mathbb{Z}_q$ and compute $C = h^a g^r$. Output $cn_{pk} = C$ and $ck = r$. Note that an account $act \doteq (y, C)$ is formed and the corresponding secret key is $ask \doteq (x, r)$.
- **Spend:** The spender performs the following steps to spend his m accounts $A_s = \{act^{(k)}\}_{k \in [m]}$ to a set $R = \{pk_{out}^{(j)}\}_{j \in [t]}$ of t output addresses, using the corresponding account secret keys $K_s = \{ask^{(k)}\}_{k \in [m]}$:
 1. Parse $\{act^{(k)}\}_{k \in [m]}$ into $\{(y_s^{(1)}, C_s^{(1)}), \dots, (y_s^{(m)}, C_s^{(m)})\}$ and parse $\{ask^{(k)}\}_{k \in [m]}$ into $\{(x_s^{(1)}, r_s^{(1)}), \dots, (x_s^{(m)}, r_s^{(m)})\}$ where $\{y_s^{(k)} = g^{x_s^{(k)}}\}_{k \in [m]}$ and $\{C_s^{(k)} = h^{a_s^{(k)}} g^{r_s^{(k)}}\}_{k \in [m]}$.
 2. Suppose $|R| = t$ (that is, there are t output addresses). Randomly choose $r_1, \dots, r_t \in \mathbb{Z}_q$ and compute

$$C_{out}^j = h^{a_{out}^{(j)}} g^{r_j} \quad \text{for } j \in [t]$$

where

$$a_{out}^{(1)} + \dots + a_{out}^{(t)} = a_s^{(1)} + a_s^{(m)} \quad (1)$$

which represents that the sum of input amounts of all spender's wallets should be equal to the sum of all output amounts. (This step can also be regarded as Mint.)

3. Use a public key encryption scheme $ENC_{pk}(\cdot)$ with public key pk to compute the ciphertext

$$ctxt_j = ENC_{pk_{out}^{(j)}}(r_j) \quad \text{for } j \in [t]$$

and send to the corresponding receivers' addresses.

4. Create a new public key as

$$y_s^{(m+1)} = \frac{\prod_{k=1}^m (y_s^{(k)} \cdot C_s^{(k)})}{\prod_{j=1}^t C_{out}^{(j)}} \quad (2)$$

Note that if Eq. (1) is satisfied, Eq. (2) becomes

$$\begin{aligned} y_s^{(m+1)} &= \frac{\prod_{k=1}^m (y_s^{(k)} \cdot g^{r_s^{(k)}})}{\prod_{j=1}^t g^{r_j}} \\ &= g^{\sum_{k=1}^m (x_s^{(k)} + r_s^{(k)}) - \sum_{j=1}^t r_j} \\ &= g^{x_s^{(m+1)}} \end{aligned}$$

such that the spender knows the value of $x_s^{(m+1)}$.

5. Randomly pick $n - 1$ group public keys where each group contains $m + 1$ public keys from the blockchain. Denote these public keys as

$$\begin{aligned} Y_1 &= \{y_1^{(1)}, \dots, y_1^{(m+1)}\} \\ &: = \quad : \\ &: = \quad : \\ Y_{s-1} &= \{y_{s-1}^{(1)}, \dots, y_{s-1}^{(m+1)}\} \\ Y_{s+1} &= \{y_{s+1}^{(1)}, \dots, y_{s+1}^{(m+1)}\} \\ &: = \quad : \\ &: = \quad : \\ Y_n &= \{y_n^{(1)}, \dots, y_n^{(m+1)}\} \end{aligned}$$

We further denote $Y_s = \{y_s^{(1)}, \dots, y_s^{(m+1)}\}$ as the group of public keys from the spender.

6. Compute $m + 1$ linking tags as $s_k = H_2(y_s^{(k)})^{x_s^{(k)}}$ for $k \in [m + 1]$.

$$\begin{pmatrix}
y_1^{(1)} & \cdots & y_s^{(1)} & \cdots & y_n^{(1)} \\
\vdots & \ddots & \vdots & \ddots & \vdots \\
y_1^{(k)} & \cdots & y_s^{(k)} & \cdots & y_n^{(k)} \\
\vdots & \ddots & \vdots & \ddots & \vdots \\
y_1^{(m)} & \cdots & y_s^{(m)} & \cdots & y_n^{(m)} \\
y_1^{(m+1)} & \cdots & y_s^{(m+1)} & \cdots & y_n^{(m+1)}
\end{pmatrix} \quad s_k = H(y_s^{(k)})^{x_s^{(k)}}, \forall k \in [m+1]$$

$$\text{SoK} \left\{ \begin{array}{l} (\{x_k\}_{k=1}^{m+1}) : \\ \quad \{y_1^{(k)} = g^{x_k} \wedge s_k = H(y_1^{(k)})^{x_k}\}_{k=1}^{m+1} \vee \\ \quad \{y_2^{(k)} = g^{x_k} \wedge s_k = H(y_2^{(k)})^{x_k}\}_{k=1}^{m+1} \vee \\ \quad \vdots \\ \quad \{y_n^{(k)} = g^{x_k} \wedge s_k = H(y_n^{(k)})^{x_k}\}_{k=1}^{m+1} \end{array} \right\} (tx)$$

Fig. 1 Abstraction of linkable ring signature in RingCT

7. Generate a linkable ring signature on a group of n public keys $\mathcal{Y} = \{Y_1, \dots, Y_n\}$ using the vector of $m+1$ secret keys $\{x_s^{(1)}, \dots, x_s^{(m+1)}\}$ with $m+1$ linking tags $\mathcal{S} = \{s_1, \dots, s_{m+1}\}$ on some transaction string m , as follows:

(a) Pick random $u_1, \dots, u_{m+1} \in_R \mathbb{Z}_q$, and compute

$$c_{s+1} = H_1(\mathcal{Y}, \mathcal{S}, m, \{g^{u_1}, H_2(y_s^{(1)})^{u_1}\}, \dots, \{g^{u_{m+1}}, H_2(y_s^{(m+1)})^{u_{m+1}}\}).$$

(b) For $i = s+1, \dots, n, 1, \dots, s-1$, pick $v_i^{(1)}, \dots, v_i^{(m+1)} \in_R \mathbb{Z}_q$ and compute

$$c_{i+1} = H_1(\mathcal{Y}, \mathcal{S}, m, \{g^{v_i^{(1)}} y_i^{(1)c_i}, H_2(y_i^{(1)})^{v_i^{(1)}} s_1^{c_i}\}, \dots, \{g^{v_i^{(m+1)}} y_i^{(m+1)c_i}, H_2(y_i^{(m+1)})^{v_i^{(m+1)}} s_{m+1}^{c_i}\}).$$

(c) Compute $v_s^{(k)} = u_k - x_s^{(k)} c_s \bmod q$ for $k \in [m+1]$.

(d) The signature is

$$\sigma = \left(c_1, \{v_1^{(1)}, \dots, v_1^{(m+1)}\}, \dots, \{v_n^{(1)}, \dots, v_n^{(m+1)}\}, \{s_1, \dots, s_{m+1}\} \right)$$

The abstraction (using Proof-of-Knowledge representation) is shown in Fig. 1.

8. Output the following:

- transaction string: $m, \{Y_1, \dots, Y_n\}, \{(pk_{out}^{(1)}, C_{out}^{(1)}), \dots, (pk_{out}^{(t)}, C_{out}^{(t)})\}$;
- the signature σ (as the proof); and
- a set of serial numbers S which can be the block number

- Verify: To verify a transaction, first verify the linkable ring signature σ :

1. For $i = 1, \dots, n$, compute

$$z_i'^{(1)} = g^{v_i^{(1)} y_i^{(1)C_i}}, \dots, z_i'^{(m+1)} = g^{v_i^{(m+1)} y_i^{(m+1)C_i}}$$

$$z_i''^{(1)} = H_2(y_i^{(1)})^{v_i^{(1)} s_1^{C_i}}, \dots, z_i''^{(m+1)} = H_2(y_i^{(m+1)})^{v_i^{(m+1)} s_{m+1}^{C_i}}$$

and then

$$c_{i+1} = H_1(\mathcal{Y}, \mathcal{S}, m, z_i'^{(1)}, z_i''^{(1)}, \dots, z_i'^{(m+1)}, z_i''^{(m+1)})$$

if $i \neq n$.

2. Check whether

$$c_1 \stackrel{?}{=} H_1(\mathcal{Y}, \mathcal{S}, m, z_n'^{(1)}, z_n''^{(1)}, \dots, z_n'^{(m+1)}, z_n''^{(m+1)}).$$

If yes, move to the next step. Otherwise, reject.

3. Check whether any of the linking tag $\{s_1, \dots, s_m\}$ has been appeared in the blockchain. If anyone is appeared in the previous transaction, reject this transaction. Otherwise accept this transaction. Note that the final tag s_{m+1} is not needed because it is generated from the secret key of the “Commitment of zero” which is only used to determine if the amount of input is equal to the amount of output.

4.4 Range Proof

Recall that a coin $cn = h^a g^r$ where a represents the amount of this coin. If input amount is equal to output amount, the “ h -term” will be canceled from the division (input coin divided by output coin). However, one with a coin valued $a_{in} = 5$ may try to spend into two output wallets valued as $a_{out_1} = 6$ and $a_{out_2} = -1$, respectively. The “ h -term” can still be canceled out! Therefore, we need to have another checking to prevent this situation happened. Monero deploys a range proof for commitment. To ensure the committed value a lays between $0 \leq a \leq 2^\ell$ for some positive integer ℓ , first change a into a binary representation as

$$a = a_0 2^0 + a_1 2^1 + \dots + a_\ell 2^\ell$$

where $a_i \in \{0, 1\}$ for $i = 0, \dots, \ell$.

Then for each committed a value C , separate into different commitments as $C_i = h^{2^{a_i}} g^{r_i}$ for $i = 0, \dots, \ell$. For each i , generate a normal (not linkable) 1-out-of-2 ring signature on the public keys $\{C_i, C_i/h^{2^{a_i}}\}$. In this way, if $a_i = 0$, $C_i = g^{r_i}$ and the spender knows r_i , which is the secret key (the $DL_g(C_i)$) corresponding to C_i . If

$a_i = 1$, $C_i = h^{2^i} g^{r_i}$ and the spender also knows r_i , which is then the secret key (the $DL_g(C_i/h^{2^i})$) corresponding to C_i/h^{2^i} .

In the verification, verify these $\ell + 1$ ring signatures and check whether $C = \prod_{i=0}^{\ell} C_i$.

5 Future Works

One of the major limitations that prevent (linkable) ring signature to be scalable for commercial applications is the size of the signature. The size of the basic ones presented in Sect. 3 suffers from linear growing rate with the number users included in the group. Although there are some constant size ring signature (e.g., [8]) or linkable ring signature (e.g., [18, 19]), they all require a trusted setup for the generation of some parameters. The main reason for that is because accumulator is used to construct constant size (linkable) ring signature. RSA-based accumulator (used in [8, 18]) requires the generation of two primes which forms the trapdoor to revoke anonymity. Pairing-based accumulator (used in [19]) requires the generation of a random value (the exponent α in the q-SDH instance) which is also the trapdoor to revoke anonymity.

Instead of making the size constant, it is still acceptable if size is of logarithmic scale. There are some recent works (e.g., [20]) to construct an $O(\log N)$ size ring signature, where N is the number of users in the group. Recently, there are also some construction from lattice (e.g., [21]). However, although the asymptotic size is of $O(\log N)$, the actual size is too large to be used in any practical scenario. It will be an interesting work to construct a practical short size (linkable) ring signature.

Another direction for future work is to construct post-quantum secure (and practical) ring signature scheme and RingCT protocol, especially for large-scale setting. Currently, there are some constructions from lattice-based cryptography for ring signature (e.g., [21]) yet they are far from practical to be used due to the large signature size. A recent work [22] gave another lattice-based construction of a linkable ring signature scheme and a RingCT protocol that enjoys a practical size of signature (and transaction). But the RingCT protocol only supports a coin-type setting (that is, one input wallet and one output wallet) without any changes supported. Since the size grows linear with the number of users, it can only support a small number of anonymized users (e.g., 20 users). Another recent work [23] has been done to construct post-quantum secure ring signature from symmetric primitives. This may open another new direction in this aspect.

References

1. Abe, M., Ohkubo, M., & Suzuki, K. (2002). 1-out-of-n signatures from a variety of keys. In Y. Zheng (Ed.), *Advances in Cryptology - ASIACRYPT 2002, Proceedings* (vol. 2501, pp. 415–432)., Lecture notes in computer science Berlin: Springer.

2. Rivest, R.L., Shamir, A., & Tauman, Y. (2001). How to leak a secret. In C. Boyd (Ed.), *Advances in Cryptology - ASIACRYPT 2001, Proceedings* (vol. 2248, pp. 552–565)., Lecture notes in computer science. Berlin: Springer.
3. Cramer, R., Damgård, I., & Schoenmakers, B. (1994). Proofs of partial knowledge and simplified design of witness hiding protocols. In Y. Desmedt (Ed.), *Advances in Cryptology - CRYPTO '94, Proceedings* (vol. 839, pp. 174–187)., Lecture notes in computer science. Berlin: Springer.
4. Bellare, M., Micciancio, D., & Warinschi, B. (2003). Foundations of group signatures: formal definitions, simplified requirements, and a construction based on general assumptions. In E. Biham (Ed.), *Advances in Cryptology - EUROCRYPT 2003, Proceedings* (vol. 2656, pp. 614–629)., Lecture notes in computer science. Berlin: Springer.
5. Camenisch, J., & Stadler, M. (1997). Efficient group signature schemes for large groups (Extended Abstract). In B. S. K. Jr (Ed.), *Advances in Cryptology - CRYPTO '97, Proceedings* (vol. 1294, pp. 410–424)., Lecture notes in computer science. Berlin: Springer.
6. Chaum, D., & van Heyst, E. (1991). Group signatures. In D. W. Davies (Ed.), *Advances in Cryptology - EUROCRYPT '91, Proceedings* (vol. 547, pp. 257–265)., Lecture notes in computer science. Berlin: Springer.
7. Zhang, F., & Kim, K. (2002). ID-based blind signature and ring signature from pairings. In Y. Zheng (Ed.), *Advances in Cryptology - ASIACRYPT 2002, Proceedings* (vol. 2501, pp. 533–547)., Lecture notes in computer science. Berlin: Springer.
8. Dodis, Y., Kiayias, A., Nicolosi, A., & Shoup, V. (2004). Anonymous identification in Ad Hoc groups. In C. Cachin & J. Camenisch (Eds.), *Advances in Cryptology - EUROCRYPT 2004, Proceedings* (vol. 3027, pp. 609–626)., Lecture notes in computer science. Berlin: Springer.
9. Liu, J. K., Wei, V. K., & Wong, D. S. (2004). Linkable spontaneous anonymous group signature for Ad Hoc groups (Extended Abstract). In *Information Security and Privacy: 9th Australasian Conference, ACISP 2004* (vol. 3108, pp. 325–335)., Lecture notes in computer science. Berlin: Springer.
10. Au, M. H., Liu, J. K., Susilo, W., & Yuen, T. H. (2006). Constant-size id-based linkable and revocable-iff-linked ring signature. In *INDOCRYPT 2006* (vol. 4329, pp. 364–378)., Lecture notes in computer science. Berlin: Springer.
11. Liu, D. Y. W., Liu, J. K., Mu, Y., Susilo, W., & Wong, D. S. (2007). Revocable ring signature. *Journal of Computer Science and Technology*, 22(6), 785–794.
12. Bresson, E., Stern, J., Szydlo, M. (2002). Threshold ring signatures and applications to ad-hoc groups. In *22nd Annual International Cryptology Conference on Advances in Cryptology - CRYPTO 2002, Santa Barbara, California, USA, August 18-22, 2002, Proceedings* (vol. 2442, pp. 465–480)., Lecture notes in computer science. Berlin: Springer.
13. Bresson, E., Stern, J., & Szydlo, M. (2002). Threshold ring signatures and applications to Ad-hoc groups. In M. Yung (Ed.), *Advances in Cryptology - CRYPTO 2002, Proceedings* (vol. 2442, pp. 465–480)., Lecture notes in computer science. Berlin: Springer.
14. Susilo, W., & Mu, Y. (2004). Non-interactive deniable ring authentication. In J.I. Lim & D.H. Lee (Eds.), *Information Security and Cryptology - ICISC 2003, Revised Papers* (vol. 2971, pp. 386–401)., Lecture notes in computer science. Berlin: Springer.
15. Susilo, W., Mu, Y., & Zhang, F. (2004). Perfect concurrent signature schemes. In J. Lopez, S. Qing, & E. Okamoto (Eds.), *Information and Communications Security, 6th International Conference, ICICS 2004, Proceedings* (vol. 3269, pp. 14–26)., Lecture notes in computer science. Berlin: Springer.
16. Laguillaumie, F., & Vergnaud, D. (2004). Multi-designated verifiers signatures. In J. Lopez, S. Qing, & E. Okamoto (Eds.), *Information and Communications Security, 6th International Conference, ICICS 2004, Proceedings* (vol. 3269, pp. 495–507)., Lecture notes in computer science. Berlin: Springer.
17. Noether, S. (2015). Ring signature confidential transactions for monero. *IACR Cryptology*. [arxiv:2015.1098](https://arxiv.org/abs/2015.1098)
18. Au, M. H., Chow, S. S. M., Susilo, W., & Tsang, P. P. (2006). Short linkable ring signatures revisited. In *Public Key Infrastructure, Third European PKI Workshop: Theory and Practice, EuroPKI 2006, Turin, Italy, June 19-20, 2006, Proceedings* (vol. 4043, pp. 101–115)., Lecture notes in computer science. Berlin: Springer.

19. Au, M. H., Liu, J. K., Susilo, W., & Yuen, T. H. (2013). Secure id-based linkable and revocable-iff-linked ring signature with constant-size construction. *Theoretical Computer Science*, 469, 1–14.
20. Groth, J., & Kohlweiss, M. (2015). One-out-of-many proofs: Or how to leak a secret and spend a coin. In *Advances in Cryptology - EUROCRYPT 2015 - 34th Annual International Conference on the Theory and Applications of Cryptographic Techniques, Sofia, Bulgaria, April 26-30, 2015, Proceedings, Part II* (vol. 9057, pp. 253–280), Lecture notes in computer science. Berlin: Springer.
21. Libert, B., Ling, S., Nguyen, K., & Wang, H. (2016). Zero-knowledge arguments for lattice-based accumulators: Logarithmic-size ring signatures and group signatures without trapdoors. In *Advances in Cryptology - EUROCRYPT 2016 - 35th Annual International Conference on the Theory and Applications of Cryptographic Techniques, Vienna, Austria, May 8-12, 2016, Proceedings, Part II* (vol. 9666, pp. 1–31), Lecture notes in computer science. Berlin: Springer.
22. Torres, W.A.A., Steinfeld, R., Sakzad, A., Liu, J.K., Kuchta, V., Bhattacharjee, N., et al. (2018). Post-quantum one-time linkable ring signature and application to ring confidential transactions in blockchain (lattice ringct v1.0). In *ACISP 2018* (vol. 10946, pp. 558–576), Lecture notes in computer science. Berlin: Springer.
23. Derler, D., Ramacher, S., & Slamanig, D. (2018). Post-quantum zero-knowledge proofs for accumulators with applications to ring signatures from symmetric-key primitives. In *PQCrypto 2018* (vol. 10786, pp. 419–440), Lecture notes in computer science. Berlin: Springer.

Data Authentication with Privacy Protection



Jianghua Liu, Yang Xiang, Wanlei Zhou, Xinyi Huang and Jinhua Ma

Abstract Digital signatures, with the properties of data integrity and authenticity authentication, protect a signed message from any alteration. However, appropriate alteration of signed message should be allowed for the purposes of privacy protection in some scenarios, such as medical data sharing, outsourced databases, etc. Redactable signatures, a branch of homomorphic signatures for editing, allow any party to delete some submessage blocks from a signed message and generate a valid signature on the remaining message without any help of the original signer. This chapter provides a basic introduction on the state-of-the-art redactable signature schemes. We mainly consider the redaction control problem of redactable signature schemes in different applications. We also present three integrated solutions, which hopefully offer more insights into this crucial problem.

J. Liu

School of Information Technology, Deakin University, Burwood, VIC 3125, Australia
e-mail: liujiang@deakin.edu.au

Y. Xiang (✉)

School of Software and Electrical Engineering, Swinburne University of Technology,
Hawthorn, VIC 3122, Australia
e-mail: yxiang@swin.edu.au

Y. Xiang

The State Key Laboratory of Integrated Service Networks (ISN), Xidian University,
Xi'an, China

W. Zhou

School of Software, University of Technology Sydney, 15 Broadway, Ultimo,
NSW 2007, Australia
e-mail: wanlei.zhou@uts.edu.au

X. Huang · J. Ma

College of Mathematics and Informatics, Fujian Normal University, Fuzhou 350000,
Fujian, China
e-mail: xyhuang@fjnu.edu.cn

J. Ma

e-mail: jinhuma55@hotmail.com

1 Introduction

The increasingly developed technologies of telecommunication, computer networking, data processing, and storage have brought us into the era of information society. However, neither the communication network nor the third party is secure or trustworthy. It is clear that with the widespread implementation and deployment of these systems, senders, and receivers of sensitive or valuable information require secure means to validate and authenticate the message they exchange. The validation and authentication of information refer to the methods for certifying its integrity and source. Digital signatures, an indispensable primitive in modern cryptography, provide integrity and source authentication of a digital document [1]. It is widely applied in management protocols, financial transactions, distributing software updates, blockchain, and many other important fields.

The standard security definition of general digital signature schemes is “existentially unforgeable under adaptive chosen-message attacks (EUF-CMA)” [2] which prevents the forging of a signature for any “new” message that has never been signed by the original signer. This also indicates that a general digital signature does not allow any alteration of the signed digital document matching to it. While the traditional digital signatures protect documents from modification by malicious users or attackers, they also prevent the signed documents from being processed which hinders the flexible and efficient use of digital documents. There exists some reality requirement of the privacy protection or bandwidth saving of a signed document. For example, privacy security is crucial for medical records. A personal medical record contains a patient’s personal information. For individual privacy, the patient may not wish to reveal his/her critical diseases therapies to a surgeon, such as cancer. However, if the entire medical record is signed with a general digital signature, patients must disclose their entire privacy records to the surgeon for verification. Therefore, the privacy of personal medical record is incompatible with its integrity. This is called the “digital document sanitizing problem” [3]. Thus, the traditional digital signatures cannot assure both the integrity and confidentiality of a document.

Redactable signatures, a straightforward approach, can inherently solve the above theoretical incompatibility and practical requirements of privacy information redaction in authenticated medical document releasing. In the definition of redactable signature schemes (RSSs), parts of a signed document are allowed to be removed by any party while preserving the source and integrity verifiability of the remaining subdocument. Another outstanding advantage of redactable signature is that the reserved subdocument and its signature of the original document does not reveal any content information about deleted parts. Assume $\mathcal{M}$ is a document signed in RSSs, σ is its corresponding signature. Anyone is permitted to redact partial subdocument of a signed document $\mathcal{M}$ and publicly generate a corresponding signature σ' without any help from the original signer. The derived signature σ' for a redacted subdocument $\mathcal{M}'$ is still verifiable under the public key of original signer. Therefore, RSSs are such a useful primitive that comes in handy in scenarios where only parts of the authenticated data are releasable or required for privacy preserving, but the origin

and integrity authentication of these data must still hold and re-signing is impossible or with striking performance compromise.

The concept of redactable signature was first introduced by Johnson et al. [4]. They proposed the first RSS based on the combination of Merkle hash trees [5], GGM tree [6], and pseudorandom generator [7]. In particular, they use GGM tree to generate pseudorandom value for each leaf of Merkle hash tree by working down this tree, then a hash of the root is computed by working up the Merkle tree. Finally, the hash root of Merkle hash tree is signed by a conventional DSS. The length of signature in this scheme is relatively short. Johnson et al. [4] also proposed a set-homomorphic signature scheme with the underlying properties of modular exponentiation and cryptographic accumulator technique [8]. This scheme also supports union and subset operations on sets. Simultaneously, Steinfeld et al. [9] put forward the concept of “Content Extraction Signature” (CES), another type of malleable homomorphic signatures for editing, which has the essentially similar function with redactable signature. One can produce a verifiable extracted signature for selected partial document, without leaking the privacy of unextracted content. They proposed several CES schemes based on commitment scheme, hash tree, multi-exponent RSA, respectively. A widespread application of redactable signature is the privacy protection of patient data [10–13]. For instance, the sensitive information in patient’s EHR should be deleted before disclosing or processing.

Since the introduction of RSSs in [4, 9], their ideas have been extended to address the redaction problem of different data structures, such as lists [14, 15], graphs [16], trees [17, 18], and sets [19–22]. However, RSSs for different data structures have different security models. In particular, most of present constructions do not provide the transparency security property which was defined in [17]. In 2015, Derler et al. [23] presented a general framework for the construction of RSS which covers arbitrary data structures. They also presented three RSSs with transparency property in a black-box way. Pohls et al. [24] introduced the accountability notion of RSSs and presented a generic construction of RSSs which can prohibits the arbitrary alteration of third parties. It is clear that in an RSS, the signer must have full control to determine which subdocument can be redacted. In some scenarios, the signer may even need to force some portions as mandatory for inclusion in any disclosed subdocument.

Much more works on RSSs with redaction control exist. Steinfeld et al. [9] introduced “Content Extraction Access Structure” (*CEAS*) which can be used by signer to specify which portions the redactor is allowed to redact. This *CEAS* is an encoding of the collection of n indexes of n blocks, where n is the number of submessage blocks in the original signed message. Although they did give an overview of how to design the *CEAS*, the encoding length of 2^n bits for any *CEAS* is exponential in n which cannot be compactly encoded. In order to implement a more expressive structure, more flexible encode of fragment extraction policy is needed. Bull et al. [25] proposed a new approach for encoding the extraction policy for fragment grouping which enables the signer to designate which subsets of the original document are valid and extractable subsets. While the encoding of *CEAS* can be represented with a $n \times n$ matrix (in fact a labeled directed graph), it is still complex and has not been applied in the construction of a concrete scheme. Later, Bull et al. [26] introduced a

new hierarchical extraction policy which is much powerful and the encoding of this design is dramatically smaller. Yet, this kind of extraction policy can only be used for extraction access control of hierarchically structured documents.

Different from the above redaction control mechanisms, Miyazaki et al. [27] proposed the first RSS with disclosure condition control for government documents publication. In [27], the former sanitizer can partially limit the redaction operations of subsequent sanitizers. However, the signature length of [27] is relatively long, and it reveals the number and positions of sanitized portions. In order to solve these problems, Miyazaki et al. [19] proposed a new digital signature sanitizing scheme with disclosure condition control based on bilinear maps. Nonetheless, the computation cost of [19] is still high. Recently, Ma et al. [28] presented a new secure and efficient design of RSS with message blocks redaction control. With the same properties, the signature computation cost of [28] is smaller than [19] and the signature length is shorter than that of [19, 27]. Nevertheless, [19, 27, 28] were limited in government documents publication. And, they only achieved partial redaction control and cannot prevent malicious operations of redactors.

This chapter aims to provide a general overview of redactable signature scheme constructions and their security and performance, and then elaborate on schemes that can achieve privacy preserving and redaction control. The chapter is organized as follows. The algorithm and security definitions of redactable signature scheme are described in Sect. 2. Section 3 introduces the arbitrary redaction problem in terms of reviewing related works. Section 4 introduces the preliminaries required by this chapter. Section 5 describes our proposed solutions. Section 6 gives performance analysis of the proposed solutions. Section 7 concludes this chapter.

2 Formal Definition of General RSSs

In this section, we first present the algorithm and security definitions of redactable signature scheme. Then, we elaborate the state-of-the-art constructions of redactable signature schemes in terms of security properties and data structures. In the following, a message $\mathcal{M}$ is represented as n subdocument blocks. $\mathcal{X}$ is the subset a redactor intends to redact from $\mathcal{M}$. $\mathcal{M}'$ is the message after removing $\mathcal{X}$ from $\mathcal{M}$ ($\mathcal{M}' \leftarrow \mathcal{M} \setminus \mathcal{X}$). An example workflow for RSSs is given in Fig. 1.

2.1 Algorithm Definition

Definition 1 An RSS is composed of four polynomial-time algorithms (KeyGen, Sign, Verify, Redact) such that

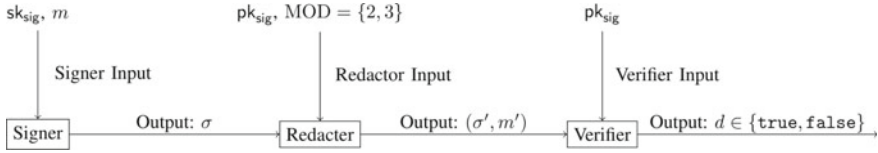


Fig. 1 Example workflow of redactable signature schemes

$\text{KeyGen}(1^\lambda)$: The input of this probabilistic algorithm is a security parameter 1^λ and the output is a public key pk for verification and a secret key sk for signing: $(pk, sk) \leftarrow \text{KeyGen}(1^\lambda)$.

$\text{Sign}(sk, \mathcal{M})$: The input of this algorithm includes a secret key sk , a message $\mathcal{M} = \{m_1, m_2, \dots, m_n\}$. It outputs a message–signature pair $(\mathcal{M}, \sigma)$: $(\mathcal{M}, \sigma) \leftarrow \text{Sign}(sk, \mathcal{M})$.

$\text{Verify}(pk, \mathcal{M}, \sigma)$: The input of this algorithm includes a public key pk and a message/signature pair $(\mathcal{M}, \sigma)$. The output of this algorithm is a decision $b \in \{1, 0\}$, with $b = 0$ meaning invalid and $b = 1$ meaning valid: $b \leftarrow \text{Verify}(pk, \mathcal{M}, \sigma)$.

$\text{Redact}(pk, \mathcal{X}, \mathcal{M}, \sigma)$: The input of this algorithm consists of the public key pk of signer, a submessage $\mathcal{X}$ to be redacted, a message $\mathcal{M}$, and a signature σ . It removes the submessage $\mathcal{X}$ from $\mathcal{M}$ and updates the signature σ . Then, for the remaining message $\mathcal{M}' \leftarrow \mathcal{M} \setminus \mathcal{X}$, it outputs the updated signature σ' (or $\perp$, indicating an error): $(\mathcal{M}', \sigma') \leftarrow \text{Redact}(pk, \mathcal{X}, \mathcal{M}, \sigma)$.

2.2 Security Definition

Correctness of RSS. In general, the correctness property of RSSs requires that every genuinely computed original or redacted signature must be valid under Verify algorithm.

Definition 2 (Signing Correctness) For any security parameter λ , key pair $(pk, sk) \leftarrow \text{KeyGen}(1^\lambda)$, message $\mathcal{M}$ and any signature $\sigma \leftarrow \text{Sign}(sk, \mathcal{M})$, we have $\text{Verify}(pk, \mathcal{M}, \sigma) = 1$.

Definition 3 (Redaction Correctness) For any security parameter λ , key pair $(pk, sk) \leftarrow \text{KeyGen}(1^\lambda)$, message $\mathcal{M}$, and any $\sigma \leftarrow \text{Sign}(sk, \mathcal{M})$ with $\text{Verify}(pk, \mathcal{M}, \sigma) = 1$, any submessage $\mathcal{X}$ to be redacted, and any pair $(\mathcal{M}', \sigma') \leftarrow \text{Redact}(pk, \mathcal{M}, \sigma, \mathcal{X})$ such that we have $\text{Verify}(pk, \mathcal{M}', \sigma') = 1$.

Unforgeability of RSS. The unforgeability definition of RSSs is similar to the standard unforgeability definition of conventional DSS. Informally, it requires that without having access to the secret key sk , it should be computationally infeasible for any attacker to generate a valid message–signature pair $(\mathcal{M}, \sigma)$, such that they can

pass the verification test, and $\mathcal{M}$ is neither a submessage nor equals of any message queried to the signing oracle (i.e., $\mathcal{M} \notin \mathcal{M}_j$).

Definition 4 (*Unforgeability*) An $\text{RSS} := (\text{KeyGen}, \text{Sign}, \text{Verify}, \text{Redact})$ is EUF-CMA (existentially unforgeable under adaptive chosen-message attacks) if the advantage of any PPT adversary $\mathcal{A}$ in winning the following game is a negligible function of the security parameter λ .

Game 1 : $\text{Unforgeability}_{\mathcal{A}}^{\text{RSSs}}$

- **Setup**: The challenger runs $(pk, sk) \leftarrow \text{KeyGen}(1^\lambda)$ and sends pk to $\mathcal{A}$.
- **Query Phase**: Let $\mathcal{M}_1, \mathcal{M}_2, \dots, \mathcal{M}_Q$ denote the Q queries from $\mathcal{A}$. For each query, the challenger runs $(\mathcal{M}_i, \sigma_i) \leftarrow \text{Sign}(sk, \mathcal{M}_i)$ and forwards $(\mathcal{M}_i, \sigma_i)$ to $\mathcal{A}$.
- **Output**: After the queries, $\mathcal{A}$ outputs a forged signature σ^* on a new message $\mathcal{M}^*$.

We say $\mathcal{A}$ wins the above game if $\text{Verify}(pk, \mathcal{M}^*, \sigma^*) = 1$ and $\mathcal{M}^* \notin \mathcal{M}_i$.

Privacy of RSS. In addition to the unforgeability, privacy is another basic security requirement of RSSs. This security feature requires that it is infeasible for any user except the signer and redactor to infer any information of any redacted content besides what can be derived from the received message–signature pair.

Definition 5 (*Privacy*) An $\text{RSS} := (\text{KeyGen}, \text{Sign}, \text{Verify}, \text{Redact})$ satisfies privacy preserving requirement if for any PPT adversary $\mathcal{A}$ the advantage in winning the following game is a negligible function of the security parameter λ .

Game 2 : $\text{Privacy}_{\mathcal{A}}^{\text{RSSs}}$

- **Setup**: The challenger runs $(pk, sk) \leftarrow \text{KeyGen}(1^\lambda)$ and sends pk to $\mathcal{A}$.
- **Phase 1**: The adversary $\mathcal{A}$ can adaptively conduct a polynomially bounded number of queries to the signing oracle. Let $\mathcal{M}_1, \mathcal{M}_2, \dots, \mathcal{M}_{Q_1}$ denote the Q_1 queries from $\mathcal{A}$. For each query, the challenger runs $(\mathcal{M}_i, \sigma_i) \leftarrow \text{Sign}(sk, \mathcal{M}_i)$ and forwards $(\mathcal{M}_i, \sigma_i)$ to $\mathcal{A}$.
- **Challenge**:
 1. At the end of **Phase 1**, adversary $\mathcal{A}$ finds two identical message $\mathcal{M}_0$ and $\mathcal{M}_1$ besides the difference of redaction subsets, i.e., $\mathcal{M}_0 \setminus \mathcal{X}_0 = \mathcal{M}_1 \setminus \mathcal{X}_1$ with $\mathcal{X}_0 \neq \mathcal{X}_1$. Then, adversary $\mathcal{A}$ sends $\mathcal{M}_0$ and $\mathcal{M}_1$ to challenger. Note that $\mathcal{A}$ is also allowed to choose redaction subsets $\mathcal{X}_0$ and $\mathcal{X}_1$.
 2. The challenger chooses $\mathcal{M}_b$ randomly by choosing a bit $b \in \{0, 1\}$ and computes a redactable signature through $(\mathcal{M}_b, \sigma_b) \leftarrow \text{Sign}(sk, \mathcal{M}_b)$ and $(\mathcal{M}'_b, \sigma'_b) \leftarrow \text{Redact}(pk, \mathcal{M}_b, \sigma_b, \mathcal{X}_b)$. Then the challenger outputs $(\mathcal{M}'_b, \sigma'_b)$.
- **Phase 2**: In this phase, the adversary $\mathcal{A}$ can proceed again for polynomially bounded number of queries to the signing oracle adaptively in the same way as **Phase 1**.
- **Guess**: Finally, a guess b' of b is exported by $\mathcal{A}$. The adversary wins the above game if $b' = b$.

The $\text{Adv}_{\mathcal{A}}^{\text{Privacy}}(\lambda)$ is defined as the advantage that $\mathcal{A}$ has in the above game. The privacy of RSSs requires that $\text{Adv}_{\mathcal{A}}^{\text{Privacy}}(\lambda)$ is a negligible function of the security parameter λ , such that $\text{Adv}_{\mathcal{A}}^{\text{Privacy}}(\lambda) = \left| \Pr[b' = b] - \frac{1}{2} \right| \leq \epsilon(\lambda)$.

Transparency of RSS. Transparency is a stronger notion than privacy in RSSs systems. It requires that no verifier is able to decide if a message–signature directly comes from Sign algorithm or Redact algorithm. This means that it is infeasible to tell whether a message–signature pair has been redacted or not. Thus, any transparent redactable signature scheme is also private, while the contrary is not necessarily established. This relationship has been proved in [17]. The transparency definition of RSSs is showed as follows.

Definition 6 (*Transparency*) An RSS $:= (\text{KeyGen}, \text{Sign}, \text{Verify}, \text{Redact})$ is transparent if for any PPT adversary $\mathcal{A}$ the advantage in winning the following game is a negligible function of the security parameter λ .

Game 3 : $\text{Transparency}_{\mathcal{A}}^{\text{RSSs}}$

- **Setup:** The challenger runs $(pk, sk) \leftarrow \text{KeyGen}(1^\lambda)$ and sends pk to $\mathcal{A}$.
- **Phase 1:** The adversary $\mathcal{A}$ can adaptively conduct a polynomially bounded number of queries to the signing oracle. Let $\mathcal{M}_1, \mathcal{M}_2, \dots, \mathcal{M}_{Q_2}$ denote the Q_2 queries from $\mathcal{A}$. For each query, the challenger runs $(\mathcal{M}_i, \sigma_i) \leftarrow \text{Sign}(sk, \mathcal{M}_i)$ and forwards $(\mathcal{M}_i, \sigma_i)$ to $\mathcal{A}$.
- **Challenge:**
 1. At the end of **Phase 1**, adversary $\mathcal{A}$ outputs a message $\mathcal{M}$, a release control policy $\mathcal{P}$, and the target outcome of redacted message $\mathcal{M}'$ which is $\mathcal{M}$'s redaction by providing $\mathcal{X}$. Then, $\mathcal{A}$ sends them to the challenger.
 2. The challenger randomly chooses a bit $b \in \{0, 1\}$. If $b = 1$ the challenger computes a redacted signature through algorithms $(\mathcal{M}, \sigma) \leftarrow \text{Sign}(sk, \mathcal{M})$ and $(\mathcal{M}', \sigma_b) \leftarrow \text{Redact}(pk, \mathcal{M}, \sigma, \mathcal{X})$, otherwise generates a fresh signature $(\mathcal{M}', \sigma_b) \leftarrow \text{Sign}(sk, \mathcal{M}', \mathcal{P})$. Then, the challenger outputs $(\mathcal{M}', \sigma_b)$.
- **Phase 2:** In this phase, the adversary $\mathcal{A}$ can proceed again for polynomially bounded number of queries to the signing oracle adaptively in the same way as **Phase 1**.
- **Guess:** Finally, a guess b' of b is exported by $\mathcal{A}$. The adversary wins the game if $b' = b$.

The $\text{Adv}_{\mathcal{A}}^{\text{Transparency}}(\lambda)$ is defined as the advantage that $\mathcal{A}$ has in the above game. The transparency of RSSs requires that $\text{Adv}_{\mathcal{A}}^{\text{Transparency}}(\lambda)$ is a negligible function of the security parameter λ , such that $\text{Adv}_{\mathcal{A}}^{\text{Transparency}}(\lambda) = \left| \Pr[b' = b] - \frac{1}{2} \right| \leq \epsilon(\lambda)$.

An RSS is secure if no PPT adversary $\mathcal{A}$ can win at least one of the above games with non-negligible advantage.

3 Overview of Arbitrary Redaction Control in RSSs

3.1 Problem Formulation

In the definition of conventional RSSs, anyone who possesses the document/signature pair can execute redaction operation publicly. However, current RSSs face the threat from dishonest redactor or additional redaction because the signature holder can modify the signed document unrestrictedly. Since subdocument pieces can be combined or organized in distinct manners, and releasing individual pieces of subdocument or arbitrary combination of subdocument pieces without considering their relationships often makes no sense. In some scenarios, some portions need to be forced by the signer as mandatory included in any released subdocument. This is necessary in protecting the meaning of released portions from being changed. Therefore, release control is crucial for signers to authorize redactable subdocument blocks of authenticated documents. It provides a feasible mechanism for signers to prevent the arbitrary redaction operation of a signed document from dishonest signature holders. With the release control mechanism, the use of released subdocument could be controlled by signers even if it has been forwarded to other parties and without any further contact.

In the previous work, Steinfeld et al. [9] introduced *CEAS* with which signers can specify which portions of the authenticated document is redactable. However, the encoding length of any *CEAS* is exponential in the number of subdocument blocks which cannot be compactly encoded. Afterwards, Bull et al. [26] introduced a new hierarchical redaction control policy whose encoding is dramatically smaller. Yet, this kind of redaction policy is only applicable to hierarchically structured documents. Miyazaki et al. [27] proposed the first authenticated document sanitizing scheme with redaction condition control. However, the signature length of this scheme is relatively long, and the redaction condition reveals the number of sanitized portions. In order to resolve these problems, Miyazaki et al. [19] proposed another authenticated document sanitizing scheme based on bilinear maps. Nonetheless, the computation cost of this scheme is relatively high. Recently, Ma et al. [28] also presented a secure and efficient design of RSSs with subdocument redaction condition control. In 2015, Pohls et al. [24] introduced the notion of accountable RSSs and presented a generic construction which can regulate other parties' redaction operation. At present, although there exist a number of related works that have introduced different methods to prevent unauthorized redaction manipulation, some significant characteristics are still unsatisfied, such as a lack of flexibility in selecting releasable blocks by the redactor or inability to detect illegal redaction by verifiers. Even worse, Some release control designs are achieved with the compromise of performance or security.

As described so far, standard RSSs would be sufficient for releasing verifiable medical documents with privacy preserving. However, it is unlikely for healthcare providers to have flexible and efficient control over how the medical documents they signed would be released by patients in the subsequent applications. This chapter mainly considers two types of flexible release control aiming at preventing dishonest

release operations from patients. For instance, in order to preserve the privacy information in authenticated medical document as much as possible, dishonest patients might not be willing to release sufficient number of signed medical subdocument blocks to third parties for some services. Therefore, healthcare providers should be endowed with the power to specify the minimal number of medical document blocks that patients have to release. The origin and integrity of the released subdocument blocks are verifiable iff the number of these released blocks is not less than the minimal value specified by healthcare providers, assuming the released subdocument has not been falsified maliciously. In addition to the minimum release control, the dependency and combination among released subdocument blocks are also crucial for the subsequent applications. For example, patients might not be willing to release a blood test report together with meta-data about the report such as when the blood test was taken and perhaps notes detailing the healthcare provider's interpretation of the report. For this reason, the interrelation of releasable medical subdocument blocks should also be regulated by healthcare providers. Thus, we wish to realize the flexible release control in RSSs such that healthcare providers can prevent medical documents from being shared out of their control.

It is obvious that redaction control is crucial for signers to regulate redactors' redaction operations of authenticated data. The redaction control policy provides a mechanism for signers to avoid arbitrary redaction operations by specifying which fragment or group of subdocuments can be legally redacted. This mechanism not only prohibits arbitrarily redaction operations but also resists additional redaction attacks (an attacker intercepts a redacted document and deletes those portions he/she deems undesirable, and forwards the additionally redacted document to a verifier). With redaction control policy, signers have some control over the use of the signed document even though it has been forwarded to third parties and no further contact will occur. At present, even though there exists some related works that have introduced different methods to realize redaction control policy, some significant characteristics are still unsatisfied in redactable signature environment which requires a secure, efficient, flexible and expressive redaction control mechanism.

3.2 Countermeasures

Redaction Control Mechanisms

As early as redactable signatures was proposed in [9], the concept of redaction control has been introduced. In this work, the authors introduced the notion of "Content Extraction Access Structure" which is an encoding of the subsets of submessage indexes in the original document which the signer can use to specify which extracted subdocuments the user is "allowed" to extract valid signatures for. Therefore the *CEAS* is an encoding of a collections of subsets of $[n]$, where $n = \text{len}(M)$ is the total number of submessages in the original signed document M . We do not specify a specific encoding scheme for *CEAS*, leaving this to be specified by the application.

Note that there are 2^n subsets of $[n]$ and hence 2^{2^n} collections of subsets of $[n]$ (distinct CEASs). Hence the encoding length of 2^n bits for an arbitrary CEAS is exponential in n . But in practice we envisage a “variable length” encoding scheme which allow “common” CEASs to be compactly encoded. The definition of “common” is application dependant and hence a suitable encoding scheme is also application dependant. Although they did give an overview of how to design the CEAS, the encoding length of 2^n bits for any CEAS is exponential in n which cannot be compactly encoded.

In order to implement a more expressive structure, more flexible encode of fragment extraction policy is needed. The potential for abuse accompanies the ability to disclose verifiable information contained in a document more selectively. For example, using the above scenario, to avoid the PMs responses being quoted out of context, it is desirable that the question and the response be linked so that the response is always preceded by the corresponding question. Hence there is a requirement that the information signer be able to exert some control over what verifiable content can be selectively disclosed by the document holder. Bull et al. [25] proposed a new approach for encoding the extraction policy for fragment grouping which enables the signer to designate which subsets of the original document are valid and extractable subsets. Conceivably, the document signer would want to be able to specify which fragments: may be extracted in isolation, be extracted only when accompanied by other specified fragments, and never be extracted (i.e., can only ever be provided with the entire document). While the encoding of CEAS can be represented with a $n \times n$ matrix (in fact a labeled directed graph), it is still complex and has not been applied in the construction of a concrete scheme.

Later, Bull et al. [26] introduced a new hierarchical extraction policy which is much powerful and the encoding of this design is dramatically smaller. This new Extraction Policy maps naturally onto the hierarchically structured documents commonly found in digital libraries. After giving a motivating example involving digital libraries we then conjecture as to how to enrich their functionality through the use of CESs. We also show how to implement the new extraction policy using XML signatures with a custom transform along with an improved design for the XML signature structure in order to achieve CES functionality. Yet, this kind of extraction policy can only be used for extraction access control of hierarchically structured documents.

A “legitimate mask” is introduced by Miyazaki et al. for each portion of the original document to assign a disclosure condition for the portion [27] proposed the first authenticated document sanitizing scheme with redaction condition control. The signer generates a digital signature assuring the authenticity of the original document without knowing which portions of the document will be sanitized. Sanitizer A sanitizer assigns to the portion, for which the condition disclosed and additional sanitizing is allowed has been assigned, one of the conditions sanitized, disclosed and additional sanitizing is allowed, or disclosed and additional sanitizing is prohibited and send the document to other sanitizers or to the verifier. A sanitizer does not know which portions of the document will be disclosed before the signer generates a digital signature for the document. A sanitizer may know the content of the portions of the original document to which the condition disclosed and allowed additional sanitizing or disclosed and prohibited additional sanitizing have been assigned, but he/she

cannot generate the original document. A verifier accepts disclosed document only if he/she verifies the authenticity of the signature on it. However, legitimate mask data can be used to count up how many masks appear in a sanitized document. Consequently their approach to assign disclosure condition is essentially incompatible to invisible property.

In order to resolve these problems, Miyazaki et al. [19] proposed another authenticated document sanitizing scheme by using the aggregate signature developed by Boneh, Gentry, Lynn, and Shacham [29], that is based on bilinear maps, as a building block. The aggregate signature scheme allows to aggregate all of the individual signatures for each portion of the document into one aggregate signature for the whole document. This property is helpful to hide the number of sanitized portion of the document. In addition, the authors can assign disclosure condition by controlling which individual signatures should be left in sanitized document. If the sanitizer knows the individual signature for some portion of the document, he/she can sanitize that portion because he/she can cancel out the effect of that portion from the aggregate signature by the individual signature. Otherwise it is infeasible for him/her to sanitize that portion. As a result our proposed scheme enables a sanitizer to hide the number of sanitized portion as well as to assign disclosure conditions to each portion of the document. Nonetheless, the computation cost of this scheme is relatively high.

Haber et al. [30] proposed a new signature algorithm that allows for controlled changes to the signed data. The change operations they study are removal of sub-documents (redaction), pseudonymization, and gradual deidentification of hierarchically structured data. These operations are applicable in a number of practically relevant application scenarios, including the release of previously classified government documents, privacy-aware management of audit-log data, and the release of tables of health records. When applied directly to redaction, their algorithm improves on [27] by reducing significantly the overhead of cryptographic information that has to be stored with the original data. Recently, Ma et al. proposed an efficient and secure redactable signature scheme with submessage blocks redaction control structure (SRCS). The proposed scheme has the properties of correctness, privacy, unforgeability, transparency, which are formally defined and proved. Compared with schemes [19, 27], the performance evaluate results show that the signature length of this new scheme is much more shorter than them, and the computation overhead is lower than scheme [13]. With a higher performance, this scheme can successfully guarantee the privacy and unforgeability of the signed messages and the transparency of redactable signature in a more efficient and flexible way

Accountability in RSSs

Even though redaction control mechanisms are very useful primitives in controlling the arbitrary redaction attacks in RSSs, their original definition does not consider accountability. This situation has been tackled by Pöhls and Samelin which show how to use SSSs to make RSSs accountable [24]. Redactable signature schemes (RSS) allow removing blocks from signed data. State-of-the-art schemes have public redactions, i.e., any party can remove parts from a signed message. This prohibits meaningful definitions of accountability. They address this gap by introducing the

notion of accountable redactable signature schemes (ARSS). They present a generic construction which couples a sanitizable signature scheme (SSS) to profit from its accountability with an RSS to maintain the reduced malleability of RSSs. Depending on the building blocks, the resulting scheme offers transparency or public accountability. Transparency provides stronger privacy guarantees, while public accountability meets legal and application requirements. A related direction are signer anonymous RSSs, where a verifier cannot decide which signing key was used [31], but can be traced by a trusted by party.

4 Preliminaries

The definitions of standard cryptographic primitives which used as building blocks to construct our schemes are introduced as following.

4.1 Access Structure

Definition 7 (*Access Structure* [32]) Let $\{P_1, P_2, \dots, P_n\}$ be a set of parties. A collection $\mathbb{A} \subseteq 2^{\{P_1, P_2, \dots, P_n\}}$ is monotone if $\forall B, C$: if $B \in \mathbb{A}$ and $B \subseteq C$ then $C \in \mathbb{A}$. An access structure (resp., monotone access structure) is a collection (resp., monotone collection) $\mathbb{A}$ of non-empty subsets of $\{P_1, P_2, \dots, P_n\}$, i.e., $\mathbb{A} \subseteq 2^{\{P_1, P_2, \dots, P_n\}} \setminus \{\emptyset\}$. The sets in $\mathbb{A}$ are called the authorized sets, and the sets not in $\mathbb{A}$ are called the unauthorized sets.

In our context, the role of parties is played by message blocks. Authorized redaction sets of message blocks are contained in the access structure $\mathbb{A}$. This chapter focuses on monotone access structure.

4.2 Monotone Span Program

Monotone span program (MSP), a linear algebraic model of computation, constitutes a significant component in realizing our fine-grained redaction control policy. The fine-grained redaction control policy in our first construction is depicted by a monotone boolean formula in the first stage, which is the combination of submessage blocks that are allowed to be disclosed. We will use monotone span program to represent the monotone boolean formula.

In order to represent the monotone boolean formula using monotone span program, we should first convert the monotone boolean formula into an access tree with the method introduced in [33]. The tree here we use is binary tree: every interior node is either *AND* or *OR* gate and each leaf node corresponds to message blocks. An

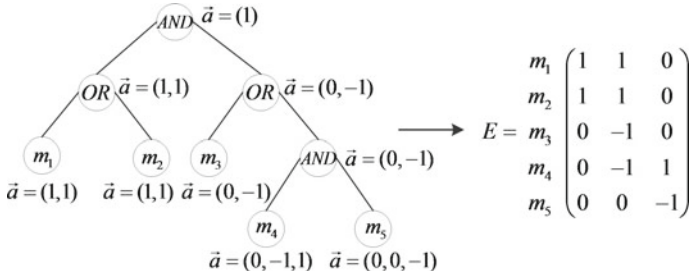


Fig. 2 Conversion from a binary tree to a matrix

access tree can be converted into an equivalent matrix $\mathbf{E}$ with the technique in [34]. Every node of the access tree can be labeled with one vector as follows: The vector of the root node is (1) . u is a global variable and initialized to 1. Children nodes will be labeled as $\vec{a}$ if their parent node is an OR gate and has been labeled as $\vec{a}$. If the parent node is an AND gate labeled by a vector $\vec{a}$, then its left child node and right child node are respectively labeled with $\vec{a}|1$ and $(0, \dots, 0)|-1$, where $(0, \dots, 0)$ denotes a zero vector of u length. Subsequently, u increases by 1. Once the entire tree is labeled, if vectors of all leaf nodes are different in length, we pad the shorter one with 0's at the end. Those vectors of all leaf nodes form a row of a linear secret-sharing matrix. Figure 2 gives a conversion example for a monotone boolean formula: “ $(m_1 OR m_2) AND (m_3 OR (m_4 AND m_5))$ ”, where $\mathcal{M} = \{m_1, m_2, m_3, m_4, m_5\}$.

Let $\mathcal{P} : \{0, 1\}^n \rightarrow \{0, 1\}$ denote an access policy [33]. A MSP for $\mathcal{P}$ is an $\ell \times t$ matrix $\mathbf{E}$ over a finite field $\mathbb{F}$. ℓ and t are the length and width of MSP respectively. Thus the size of MSP is $\ell + t$. Function $f : [\ell] \rightarrow [n]$ associates each row of $\mathbf{E}$ with an input variable $(x_1, \dots, x_n) \in \{0, 1\}^n$. An MSP accepts an input if it satisfies:

$$\begin{aligned} \mathcal{P}(x_1, \dots, x_n) = 1 &\iff \exists \vec{v} \in \mathbb{F}^{1 \times \ell} \\ \text{s.t. } \vec{v}\mathbf{E} &= [1, 0, 0, \dots, 0] \quad \text{and} \quad (\forall i : x_{f(i)} = 0 \Rightarrow v_i = 0) \end{aligned}$$

In another words, $\mathcal{P}(x_1, \dots, x_n) = 1$ if and only if some linear combinations of the rows in $\mathbf{E}$ indexed by $\{i | x_{f(i)} = 1\}$ span the vector $[1, 0, 0, \dots, 0]$. As for the above example, let the vector $[1, 0, 0, 1, 1]$ denote message blocks set $\{m_1, m_4, m_5\}$ as an input to the authentication policy $\mathcal{P}'$: “ $(m_1 OR m_2) AND (m_3 OR (m_4 AND m_5))$ ”, we have $\mathcal{P}'(1, 0, 0, 1, 1) = 1$ since the combination of $\mathbf{E}$'s first, fourth and fifth row can span $[1, 0, 0]$. This is consistent with the fact that $\{m_1, m_4, m_5\}$ satisfies the policy.

4.3 Linear Secret-Sharing Scheme

Definition 8 (*Linear Secret-Sharing Scheme (LSSS)* [32]) A secret-sharing scheme $\Pi_{\mathbb{A}}$ for the access structure $\mathbb{A}$ over a set $\mathcal{S}$ is called linear (over $\mathbb{Z}_p$) if

- The shares of a secret $s \in \mathbb{Z}_p$ for each party form a vector over $\mathbb{Z}_p$.
- For each access structure $\mathbb{A}$ on $\mathcal{S}$, there exists a matrix $\mathbf{E}$ with n rows and c columns called the sharing-generating matrix for Π . A function ρ defines each row number i of matrix $\mathbf{E}$ as $\rho(i)$, that labels the rows of $\mathbf{E}$ with elements from $\mathcal{S}$. Let vector $\vec{\omega} = (s, y_2, \dots, y_c)^T$, where s is the secret will be shared into n parts, and $y_2, \dots, y_c$ are chosen in $\mathbb{Z}_p$ randomly. $\mathbf{E}\vec{\omega}$ is the vector of n shares of s according to Π and each share in $\mathbf{E}\vec{\omega}$ “belongs” to the party $\rho(i)$. We refer to the pair $(\mathbf{E}, \rho)$ as the policy of the access structure $\mathbb{A}$.

References [32, 35] presented that the existence of an efficient LSSS for tree-access structure is equivalent to the existence of a small MSP for the monotone boolean formula of that access structure. LSSS enjoys the linear reconstruction property and security requirement. Unauthorized sets reveal no information about the secret. Let $A \in \mathbb{A}$ be an authorized set for the access structure $\mathbb{A}$ encoded by the policy $(\mathbf{E}, \rho)$ and define $I \subset \{1, 2, \dots, n\}$ as $I = \{i : \rho(i) \in A\}$. The reconstruction requirement asserts that the vector $(1, 0, \dots, 0)$ is in the span of rows of $\mathbf{E}$ indexed by I . Then, there exists constants $\{\omega_i \in \mathbb{Z}_p\}_{i \in I}$ such that, if $\{\lambda_i = (\mathbf{E}\vec{\omega})_i\}_{i \in I}$ are valid shares of a secret s according to Π then $s = \sum_{i \in I} \omega_i \lambda_i$. Additionally, it has been proved in [32] that constants $\{\omega_i \in \mathbb{Z}_p\}_{i \in I}$ can be found in time polynomial in the size of the share-generating matrix $\mathbf{E}$. On the contrary, if a set $A' \notin \mathbb{A}$ (in other words, A' does not satisfy $\mathbf{E}$), it is also true that for $I' = \{i : \rho(i) \in A'\}$, there exists a polynomial-time algorithm that can output a vector $\vec{\omega} \in \mathbb{Z}_p^{1 \times c}$, such that its first component is any non-zero element in $\mathbb{Z}_p$ and $\mathbf{E}_i \cdot \vec{\omega} = 0$ for all $i \in I'$, where $\mathbf{E}_i$ is the i -th row of matrix $\mathbf{E}$.

4.4 Threshold Secret-Sharing Schemes

Threshold secret-sharing schemes (TSSS) have been widely used as a sort of access control mechanism in many applications such as attribute-based cryptosystems [33, 34, 36] and storage of Bitcoin [37]. The authorized sets are those whose size is not less than the threshold value, that is, it realizes the t -out-of- n access structure $\mathcal{A}_t = \{A \subseteq \mathcal{P} = \{p_1, \dots, p_n\} : |A| \geq t\}$, where t and n are integers.

A typical threshold secret-sharing scheme was developed by Shamir [38] which is constructed from polynomial function. The size of shared secret and each share are the elements in a finite field $\mathbb{Z}_q$, where q is a prime and $q > n$. To share a secret $s \in \mathbb{Z}_q$, a dealer independently and randomly chooses $t - 1$ elements $a_1, \dots, a_{t-1}$ from $\mathbb{Z}_q$ as the polynomial coefficients. These coefficients and the shared secret value define a polynomial function of degree $t - 1$, i.e., $P(x) = s + \sum_{i=1}^{t-1} a_i x^i$, where s

forms the constant component of $P(x)$. Let $x_1, \dots, x_n \in \mathbb{Z}_q$ be n distinct and non-zero elements known to all parties (e.g., if $q > n$ is a prime, then we can set $x_i = i$). Then, the shared secret for each party is $s_i = P(i)$. For every t different pairs (x_i, s_i) , it is trivial to reconstruct the polynomial $P(x)$ with the Lagrange's interpolation theorem, and compute $s = P(0)$. Notice that $P(x_{i_\ell}) = s_{i_\ell}$ for $1 \leq \ell \leq t$. Thus, the reconstruction of $P(x)$ is a linear combination of the shares in a given set S , that is $s = \sum_{\ell=1}^t s_{i_\ell} \cdot \Delta_{\ell,S}(0)$, where $\Delta_{\ell,S}(0) = \prod_{1 \leq j \leq t, j \neq \ell} \frac{x_{i_j}}{x_{i_j} - x_{i_\ell}}$. On the contrary, if a subset $B \subseteq \mathcal{P}$ but $|B| < t$, it is impossible to get any information about polynomial $P(x)$.

4.5 Access Tree

Let $\mathcal{T}$ represent an access tree [33]. Each non-leaf node of $\mathcal{T}$ is described by a threshold value and its child nodes. If t_x is the threshold value of a node x , and num_x is the child node number, then $0 < t_x \leq num_x$. The threshold gate is an AND gate when $t_x = num_x$ and when $t_x = 1$, it means that x is an OR gate. Besides, it indicates that x has a general threshold value if $1 < t_x < num_x$. As for the leaf node of this tree, each of them is associated with a secret share. A few functions are also defined to facilitate working with this access tree. If x is a leaf node, then function $subm(x)$ denotes the secret share associated with this node. The function $parent(x)$ denotes the parent of node x . The child nodes of every inner node are numbered from 1 to num_x . The function $index(x)$ returns such a number associated with the node x . If a set of secret shares γ satisfies the access tree $\mathcal{T}_x$, then it is denoted as $\mathcal{T}_x(\gamma) = 1$. The access tree $\mathcal{T}_x$ is computed recursively in a bottom-up manner as follows. If x is a leaf node, then $\mathcal{T}_x(\gamma)$ returns 1 if and only if $subm(x) \in \gamma$. If x is a non-leaf node, evaluate $\mathcal{T}_y(\gamma)$ for all children y of node x . $\mathcal{T}_x$ returns 1 if and only if at least t_x children return 1.

4.6 Quasi-commutative Accumulator

Cryptographic accumulators are used to accumulate a finite set of values into a single succinct accumulator. For every accumulated value, one can efficiently compute a witness, which certifies its membership in the accumulator. However, it is computationally infeasible to find a witness for any non-accumulated value. Over time, cryptographic accumulators have been widely used in diverse applications such as accountable certificate management [39], anonymous credentials [40], etc. In this subsection, a hash-function family-based quasi-commutative accumulator is introduced. This accumulator not only provides the property of space-efficient but also content hiding of the accumulated elements. The hiding property means that it is infeasible to reveal any information of accumulated elements from the accumulator

value, which is guaranteed by the indistinguishability. The first quasi-commutative accumulator was introduced by Benaloh and Mare [41].

Let $\mathcal{H}_K : \mathcal{X}_K \times \mathcal{Y}_K \rightarrow \mathcal{X}_K$ denote a family of keyed quasi-commutative accumulator satisfying the following properties:

- *Quasi – Commutativity*: For any $k \in K$, and for $\forall y_1, y_2 \in \mathcal{Y}_k, \forall x \in \mathcal{X}_k$, there exists $\mathcal{H}_k(\mathcal{H}_k(x, y_2), y_1) = \mathcal{H}_k(\mathcal{H}_k(x, y_1), y_2)$.
- *Collision – Resistance*: Given $k \xleftarrow{R} K$ and an accumulator value $\mathcal{H}_k(x, y)$ (Note that $y \in \mathcal{Y}_k$ and $x \in \mathcal{X}_k$), it is computationally infeasible for any PPT adversary to find a pair of $(x' \in \mathcal{X}_k, y' \in \mathcal{Y}_k)$ such that $\mathcal{H}_k(x, y) = \mathcal{H}_k(x', y')$.
- *Indistinguishability*: Given $k \xleftarrow{R} K$, two sets $\mathcal{Y}_k^0$ and $\mathcal{Y}_k^1$ with equal size, and an accumulator value $\mathcal{H}_k(x_b, \mathcal{Y}_k^b)$ (Note that $x_b \in \mathcal{X}_k$ is chosen by challenger), it is computationally infeasible for any PPT adversary to output a guess b' of b such that $b' = b$ with negligible advantage.

The quasi-commutative property of $\mathcal{H}_k$ guarantees that if one accumulates a set of values $y_1, y_2, \dots, y_m \in \mathcal{Y}_k$ under an initial value $x \in \mathcal{X}_k$, then the accumulated value $z = \mathcal{H}_k(\mathcal{H}_k(\dots \mathcal{H}_k(\mathcal{H}_k(x, y_1), y_2), \dots, y_{m-1}), y_m)$ would be unchanged if the order of y_i were permuted. Thus, the set of values $y_1, y_2, \dots, y_m$ could be accumulated in an arbitrary order without changing the digest z . A concrete construction of this accumulator will be shown in our constructions.

4.7 Digital Signature Schemes

In a digital signature scheme (DSS), a *signer* S is allowed to “sign” a message using the secret key sk such that anyone who knows the associated public key pk can verify that the message has never being modified in transit and is indeed originated from S . A DSS is composed of three polynomial-time algorithms (DGen, DSign, DVerify), such that

DGen(1^λ): The input of this probabilistic algorithm is a security parameter 1^λ and the output is a key pair (pk, sk) .

DSign(sk, m): The input of this algorithm is a secret key sk and a message m . It outputs a signature σ of this message. This is denoted as $\sigma \leftarrow \text{DSign}_{sk}(m)$.

DVerify(pk, m, σ): The input of this deterministic algorithm includes a message m , a public key pk , and a signature σ . It outputs a bit $b \in \{0, 1\}$, with $b = 0$ indicating invalid and $b = 1$ meaning valid. This can be denoted as $b := \text{DVerify}_{pk}(m, \sigma)$.

A digital signature scheme is secure if it is computationally infeasible for any adversary to output a message–signature pair (m, σ) , such that they can pass the verification test and m has never been queried to the signing oracle. The standard security definition of DSS is existentially unforgeable under chosen-message attack (EUF-CMA) [2].

5 Concrete Solutions of Redaction Control in RSSs

5.1 Solution Based on MSP and LSSS

In this subsection, we will present a general construction of RSS with fine-grained redaction control. Our construction is built out of three standard cryptographic primitives, namely, an access control, a collision-free cryptographic accumulator and an EUF-CMA DSS. Our design is motivated by the algorithm given in [20]. To sign a message, one divides an original message into n submessage blocks according to the granularity of the information and the information holder's privacy. After that, the signer defines the message subsets that are authorized to disclose with a monotone boolean formula. This monotone boolean formula can be converted into an access binary tree $\mathcal{T}$, and $\mathcal{T}$ is then converted into an equivalent matrix $\mathbf{E}$. Afterwards, a secret is randomly chosen and shared among n parts by the matrix $\mathbf{E}$ through a linear secret-sharing scheme, and each share is concatenated to a submessage block before accumulating. The concatenation and accumulation realize the binding and hiding of submessage blocks and their corresponding secret share. Finally, the accumulated value is signed with the signing algorithm of a fixed DSS. Those secret shares are associated with the tree-access structure $\mathcal{T}$ that controls which subset a third party is able to generate a valid signature for. That is, only those secret shares coincide with the redaction control policy can be used to recover the secret. In detail, our scheme is described as follows.

KeyGen(1^λ). This algorithm runs a standard DSS and gets $(sk, pk) \leftarrow \text{DKeyGen}(1^\lambda)$. It also chooses a cryptographic collision-free accumulator constructed by quasi-commutative hash-function H_k . The private key of the signer is $SK = \{sk, k\}$, and the public key is $PK = \{pk\}$.

Sign($sk, \mathcal{M}, \mathcal{P}$). To sign an unordered message $\mathcal{M}$, the signer performs the following steps:

1. Divide original message $\mathcal{M}$ into n message blocks, i.e., $\mathcal{M} = \{m_1, \dots, m_n\}$.
2. Set the monotone boolean formula for message $\mathcal{M} = \{m_1, \dots, m_n\}$ according to the redaction control policy $\mathcal{P}$.
3. Convert the redaction control policy $\mathcal{P}$ into an access binary tree $\mathcal{T}$ according to the monotone span program.
4. Convert the access binary tree $\mathcal{T}$ into an equivalent matrix $\mathbf{E}$ using the method given in the monotone span program, it is $n \times t$ matrix, where n is the number of message blocks of original message $\mathcal{M}$, and $t = \text{Height}(\mathcal{T}) - 1$. A function ρ defines each row number i of the matrix $\mathbf{E}$ as $\rho(i)$.
5. Construct a vector $\vec{\omega} = (s, y_2, \dots, y_t)^T$ in which $y_i \xleftarrow{R} \mathbb{Z}_p$ and s is the secret to be shared into n parts. For $1 \leq i \leq n$, it calculates $s_i = \mathbf{E} \cdot \vec{\omega}$, and each share “belongs” to $\rho(i)$.
6. Choose $r \xleftarrow{R} \mathcal{X}_k$, i.e., $r \xleftarrow{R} (\mathbb{Z}/n\mathbb{Z})^\times$ for quasi-commutative hash-function $\mathcal{H}_k$ by the way introduced in collision-resist accumulator.

7. Accumulate each element $m_i \| s_i$ and r using $\mathcal{H}_k$, the accumulated short digest value $d \leftarrow \mathcal{H}_k(r, m_1 \| s_1, m_2 \| s_2, \dots, m_n \| s_n)$.
8. Sign the concatenation of the accumulated value d and secret s , i.e., $\sigma_S \leftarrow \text{DSign}_{sk}(d \| s \| k)$.
9. Output $(\mathcal{M}, \sigma)$, where $\sigma = (\sigma_S, \mathcal{P}, r, \langle s_i \rangle_{i \in [n]})$.

Redact $(pk, \mathcal{X}, \mathcal{M}, \sigma)$. To redact a subset $\mathcal{X} \subsetneq \mathcal{M}$, in which $\mathbf{X} = \{m'_1, m'_2, \dots, m'_c\}$ and $c = |\mathcal{X}|$, the redactor performs as follows:

1. Check the validity of $(\mathcal{M}, \sigma)$ using **Verify** algorithm. If the signature is not valid, return $\perp$.
2. If $\mathcal{X} \not\subseteq \mathcal{M}$, return $\perp$.
3. If $\mathcal{P}(\mathcal{M}') \neq 1$, return $\perp$, where $\mathcal{M}' \leftarrow \mathcal{M} \setminus \mathcal{X}$.
4. Compute $r' \leftarrow \mathcal{H}_k(r, m'_1 \| s'_1, m'_2 \| s'_2, \dots, m'_c \| s'_c)$.
5. Output $(\mathcal{M}', \sigma_R)$, where $\sigma_R = (\sigma_S, \mathcal{P}, r', \langle s_i \rangle_{i \in [n] - [c]})$.

Verify $(pk, \mathcal{M}^*, \sigma^*)$. This algorithm works analogously to the **Sign** algorithm. To verify the validity of the signature, the verifier performs as follows:

1. Compute the accumulate value $d^* \leftarrow \mathcal{H}_k(r^*, m_1^* \| s_1^*, m_2^* \| s_2^*, \dots, m_e^* \| s_e^*)$.
2. Define $I \subset \{1, 2, \dots, n\}$ as $I = \{i : \rho(i) \in \mathcal{M}^*\}$. The reconstruction requirement of the secret asserts that the vector $(1, 0, \dots, 0)$ is in the span of rows of $\mathbf{E}$ indexed by I . Then, there exists constants $\{\omega_i \in \mathbb{Z}_p\}_{i \in I}$ such that, if $\{m_i^*\}_{i \in I}$ is a valid redaction set respecting the redaction policy $\mathcal{P}$ then $s^* = \sum_{i \in I} \omega_i s_i^*$.
3. Check the validity of σ_S by using **DVerify** algorithm of DSS, i.e., $b \leftarrow \text{DVerify}_{pk}(d^* \| s^* \| k, \sigma_S)$ ($b \in \{0, 1\}$). It outputs 1, if both of concatenated components are identical to those signed by the signer, 0 otherwise, resp. $\perp$ on error.

The collision-free accumulator in our construction is constructed by using modular exponentiation [41]. Let $N = pq$, where $p = 2p' + 1, q = 2q' + 1, q', p'$ are all distinct safe primes such that $|p| = |q|$. On input of $r \xleftarrow{R} \mathbb{Z}_N$ and the set $\{x_1, x_2, \dots, x_n\}$, we compute $d \leftarrow r^{\prod_{i=1}^n \mathcal{H}_p(x_i)} \pmod{N}$, where $\mathcal{H}_p : \{0, 1\}^* \rightarrow \mathbb{P} \cap \mathbb{Z}_{N/4}$ is a cryptographic hash-function, modeled as a random oracle. Refer to [42] for more details about how to construct such a function. For a comprehensive understanding of our construction, we present an example which is shown in Fig. 3.

5.2 Solution Based on TSSS

This is designed to resolve the issue where data owner might not be willing to release sufficient information for a service in releasing their documents authenticated by other party. To sign an original medical document $\mathcal{M}$, a signer divides it into n subdocument blocks according to the granularity of document content. A seed is shared among n parts through a TSSS [38], and each share is appended to a subdocument before accumulating. After the short digest of these concatenation is generated, healthcare provider signs the concatenation of the short digest, the seed, a

threshold value, and some other associated parameters. Redacting a subset of subdocument blocks is simply removing these blocks from the original signed document and updating the signature accordingly (Note that the number of released subdocument blocks must satisfy the threshold value defined by healthcare providers; otherwise, the redaction would be invalid.). To verify a signature, a third party reconstructs the short digest, seed value, and the associated parameters signed by signer. Finally, the third party checks the validity of the concatenated parameters using DVerify algorithm of a fixed DSS. This construction consists of four algorithms: KeyGen, Sign, Verify and Redact.

KeyGen(1^λ): This algorithm fixes a DSS and chooses a quasi-commutative accumulator $\mathcal{H}_k$ [42]. Then, the key generation algorithm $(pk, sk) \leftarrow \text{DGen}(1^\lambda)$ of DSS is run.

Sign($sk, \mathcal{M}, \mathcal{P}$): The input of this algorithm includes a signing secret key sk , a document $\mathcal{M} = \{m_1, m_2, \dots, m_n\}$, and a release control policy $\mathcal{P}$. $\mathcal{P}$ is built upon the TSSS in [38] which allows signer to control the minimal number of subdocument blocks that a patient has to release. The signer chooses a seed value $s \in \mathbb{Z}_\rho$ and defines a threshold value t which is the minimal number of blocks that a patient must reserve, where ρ is a safe prime and $\rho > n$. This also means the maximal number of removal blocks is $n - t$. To share the seed value s , signer chooses $t - 1$ random numbers $a_1, \dots, a_{t-1} \in \mathbb{Z}_\rho$ independently and randomly as the coefficients of a polynomial function. These coefficients, the threshold value and seed value define a polynomial function of degree $t - 1$, i.e., $P(x) = s + \sum_{i=1}^{t-1} a_i x^i$. Then, the signer shares the seed value s into n shares with $P(x)$, and each share is $s_i = P(x_i)$, where $x_i \in \mathbb{Z}_\rho$. After the seed is shared, signer performs the following steps:

1. Choose $r \xleftarrow{R} \mathbb{Z}_N$ for $\mathcal{H}_k$, where $N = pq$, $p = 2p' + 1$, $q = 2q' + 1$, and both q' and p' are distinct safe primes of the same length.
2. Generate an identity for document $\mathcal{M}$ which can be $id \xleftarrow{R} \{0, 1\}^\lambda$.
3. Concatenate each x_i , m_i and s_i such that $R_i \leftarrow (x_i \| m_i \| s_i)$.

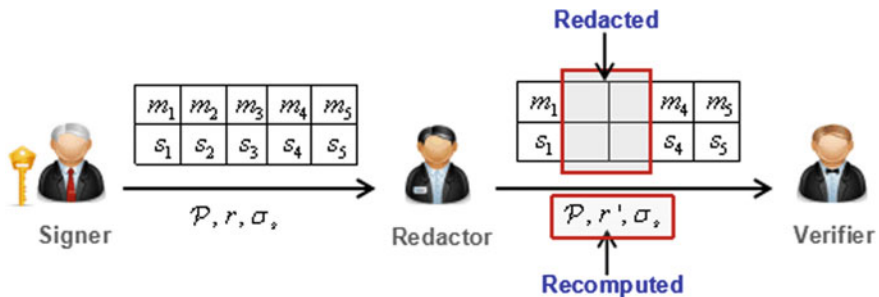


Fig. 3 The basic idea of an example for our scheme

4. Accumulate each tagged R_i and r using $\mathcal{H}_k$, i.e., compute the short digest $d \leftarrow \mathcal{H}_k(r, (id \parallel R_1), \dots, (id \parallel R_n)) = r \prod_{i=1}^{i=n} \mathcal{H}_p(id \parallel R_i) \pmod{N}$, where $\mathcal{H}_p : \{0, 1\}^* \rightarrow \mathbb{P} \cap \mathbb{Z}_{N/4}$ is a cryptographic hash-function.
5. Concatenate the document identity id , seed s , final digest d , hash key k , and the threshold value t and sign the concatenation with sk , i.e., $\sigma_s \leftarrow \text{DSign}_{sk}(id \parallel s \parallel d \parallel k \parallel t)$.
6. Output $(\mathcal{M}, \sigma)$, where $\sigma \leftarrow (\mathcal{R} = \{R_i\}_{i \in n}, r, t, \sigma_s)$.

$\text{Verify}(pk, \mathcal{M}^\tau, \sigma^\tau)$: This algorithm takes as input a public key pk , a document $\mathcal{M}^\tau$, and a signature σ^τ . It performs the following steps:

1. Compute $d' \leftarrow \mathcal{H}_k(r^\tau, (id \parallel R_1^\tau), \dots, (id \parallel R_n^\tau))$, where $R_i^\tau \in \mathcal{R}^\tau$.
2. For all elements in $\mathcal{M}^\tau$, retrieve the corresponding pair (x_i, s_i) from R_i^τ .
3. If $|\mathcal{M}^\tau| \geq t$, the verifier chooses arbitrary t distinct pairs (x_i, s_i) which can uniquely define the polynomial function P according to the uniqueness of Lagrange interpolation theorem. Finally, a seed s' is computed with $s' = \sum_{\ell=1}^t s_{i_\ell} \cdot \Delta_{\ell, s}(0)$, where $\Delta_{\ell, s}(0) = \prod_{1 \leq j \leq t, j \neq \ell} \frac{x_{i_j}}{x_{i_j} - x_{i_\ell}}$.
4. Concatenate the document identity id , seed s' , final digest d' , hash key k , and the threshold value t and verify the concatenation with $\text{DVerify}_{pk}((id \parallel s' \parallel d' \parallel k \parallel t), \sigma_s)$. It outputs 1, iff all concatenated components are identical to those signed by the signer, otherwise it outputs 0. $\perp$ on error.

$\text{Redact}(pk, \mathcal{X}, \mathcal{M}, \sigma)$: This algorithm takes as input the public key pk of signer, a set of subdocument blocks $\mathcal{X}$ to be redacted, a document $\mathcal{M}$, and a valid signature σ . To redact $\mathcal{X}$, in which $\mathcal{X} = \{m'_1, m'_2, \dots, m'_c\}$ and $c = |\mathcal{X}|$, it executes the redaction operation in the following steps:

1. Check the validity of $(\mathcal{M}, \sigma)$ using Verify algorithm. If the signature is not valid, return $\perp$.
2. If $\mathcal{X} \not\subseteq \mathcal{M}$, return $\perp$.
3. If $\mathcal{P}(\mathcal{M}') \neq 1$ ($|\mathcal{M}' \cap \mathcal{M}| < t$), return $\perp$, where $\mathcal{M}' \leftarrow \mathcal{M} \setminus \mathcal{X}$.
4. Define $I \subset \{1, 2, \dots, n\}$ as $I = \{i : m_i \in \mathcal{X}\}$. Accumulate the concatenated binary strings $\{R_i\}_{i \in I}$ onto r . In particular, it computes a short digest $r' \leftarrow \mathcal{H}_k(r, (id \parallel R'_1), \dots, (id \parallel R'_c))$, where $c = |\mathcal{X}|$.
5. Output $(\mathcal{M}', \sigma')$, where $\sigma' \leftarrow (\mathcal{R}' = \{R_i\}_{i \in [n] - [c]}, r', t, \sigma_s)$.

5.3 Solution Based on Access Tree

We develop an RSS with an advanced release control which can achieve the combination of minimal release and dependent release control of subdocument blocks. This hybrid release control grants data owner a more flexible redaction right for different subdocument blocks.

To sign an original medical document $\mathcal{M}$, a healthcare provider divides it into n subdocument blocks as in the previous construction. An access tree [33] is constructed according to the number and dependence of subdocument blocks. A seed

is shared through this access tree in a top-down manner. Thus, each leaf node of this tree is allocated a seed share which is associated with a subdocument block. We also consider the situation where some subdocument blocks may appear more than once, which can be solved by associating with different seed shares. Then, the concatenation of each seed share and subdocument block is accumulated. After a short digest of these concatenations is generated, healthcare provider signs the concatenation of the short digest, seed, access tree, and other parameters. Redaction of a subset of subdocument blocks is simply removing this subset from the original signed document and updating the signature accordingly. It should be noticed that the released subdocument blocks must satisfy the access tree defined by signer; otherwise, the redaction would be invalid. To verify a signature, a third party should reconstruct the short digest, seed value, and the associated parameters signed by healthcare provider. Finally, the third party checks the validity of the concatenation using DVerify algorithm of the fixed DSS. This construction consists of four algorithms: KeyGen, Sign, Verify and Redact.

KeyGen(1^λ): This algorithm fixes a DSS and chooses a quasi-commutative accumulator $\mathcal{H}_k$ in [42]. Then, the key generation algorithm $(pk, sk) \leftarrow \text{DGen}(1^\lambda)$ of DSS is run.

Sign($sk, \mathcal{M}, \mathcal{T}$): The input of this algorithm consists of a signing secret key sk , a document $\mathcal{M} = \{m_1, m_2, \dots, m_n\}$, and a release control tree $\mathcal{T}$. The signer chooses a polynomial q_x for each node x of the tree $\mathcal{T}$ in a top-down manner. For each node x , set the degree of the polynomial q_x to be $d_x = t_x - 1$, where t_x is the threshold value of node x . For the root node r , set $q_r(0) = s$ and randomly choose d_r other coefficients in $\mathbb{Z}_\rho$ to define the polynomial q_r completely, where ρ is a safe prime and $s \in \mathbb{Z}_\rho$. For any other node x , set $q_x(0) = q_{\text{parent}(x)}(\text{index}(x))$ and randomly choose d_x other coefficients in $\mathbb{Z}_\rho$ to complete the definition of polynomial q_x . Once all polynomials have been defined, each leaf node x is allocated a seed share $s_x = q_{\text{parent}(x)}(\text{index}(x))$. After the seed is shared, the signer performs the following steps:

1. Choose $r \xleftarrow{R} \mathbb{Z}_N$ for $\mathcal{H}_k$, where $N = pq$, $p = 2p' + 1$, $q = 2q' + 1$, and both q' and p' are distinct safe primes of the same length.
2. Generate an identity for the document which can be $id \xleftarrow{R} \{0, 1\}^\lambda$.
3. Concatenate $\text{index}(x_j)$, m_i , and s_{x_j} such that $R_j \leftarrow (\text{index}(x_j) \| m_i \| s_{x_j})$, where $j \in h$, and h is the number of leaf node in $\mathcal{T}$.
4. Accumulate each tagged R_j and r using $\mathcal{H}_k$, i.e., compute the short digest $d \leftarrow \mathcal{H}_k(r, (id \| R_1), \dots, (id \| R_h)) = r^{\prod_{j=1}^h \mathcal{H}_\rho(id \| R_j)} \pmod{N}$, where $\mathcal{H}_\rho : \{0, 1\}^* \rightarrow \mathbb{P} \cap \mathbb{Z}_{N/4}$ is a cryptographic hash-function.
5. Concatenate the document identity id , seed s , final digest d , hash key k , and the release control tree $\mathcal{T}$ and sign the concatenation with sk , i.e., $\sigma_s \leftarrow \text{DSign}_{sk}(id \| s \| d \| k \| \mathcal{T})$.
6. Output $(\mathcal{M}, \sigma)$, where $\sigma \leftarrow (\mathcal{R} = \{R_j\}_{j \in h}, r, \mathcal{T}, \sigma_s)$.

$\text{Verify}(pk, \mathcal{M}^\tau, \sigma^\tau)$: This algorithm takes as input a public key pk , a document $\mathcal{M}^\tau$, and a signature σ^τ . It performs the following steps:

1. Compute $d' \leftarrow \mathcal{H}_k(r^\tau, (id \parallel R_1^\tau), \dots, (id \parallel R_n^\tau))$, where $R_j^\tau \in \mathcal{R}^\tau$.
2. For all the elements in $\mathcal{M}^\tau$, retrieve the corresponding pair $(index(x_j), s_{x_j})$ from R_j^τ .
3. Consider the recursive case when x is a non-leaf node. For all nodes z that are children of x , choose an arbitrary t_x -sized set S_x of child nodes z such that the seed shares of these child nodes can satisfy node x . The seed share of x can be reconstructed as follows:

$$\begin{aligned}
 s_x &= \sum_{z \in S_x} q_z(0) \cdot \Delta_{i, S'_x}(0) \\
 &= \sum_{z \in S_x} q_{parent(z)}(index(z)) \cdot \Delta_{i, S'_x}(0) \\
 &= \sum_{z \in S_x} q_x(i) \cdot \Delta_{i, S'_x}(0) \\
 &= q_x(0), \quad (\text{using polynomial interpolation})
 \end{aligned}$$

where $i = index(z)$ and $S'_x = \{index(z) : z \in S_x\}$. Now that the seed share of any inner node of the access tree could be reconstructed in the above manner, the seed value of root node could also be reconstructed in this way in a bottom-up manner. We observe that the root seed value could be reconstructed if and only if the seed shares of leaf nodes satisfy the tree. This also implies the remaining subdocument blocks satisfy $\mathcal{T}$.

4. Concatenate the document identity id , root seed s' , final digest d' , hash key k , and the access tree $\mathcal{T}$ and verify the concatenation with $\text{DVerify}_{pk}((id \parallel s' \parallel d' \parallel k \parallel \mathcal{T}), \sigma_s)$. It outputs 1, iff all the concatenated components are identical to those signed by the signer, otherwise it outputs 0. $\perp$ on error.

$\text{Redact}(pk, \mathcal{X}, \mathcal{M}, \sigma)$: This algorithm takes as input the public key pk of signer, a redaction subset $\mathcal{X}$, a document $\mathcal{M}$, and a valid signature σ . To redact a set $\mathcal{X}$, in which $\mathcal{X} = \{m'_1, m'_2, \dots, m'_c\}$ and $c = |\mathcal{X}|$. It executes the redaction operation in the following steps:

1. Check the validity of $(\mathcal{M}, \sigma)$ using Verify algorithm. If the signature is not valid, return $\perp$.
2. If $\mathcal{X} \not\subseteq \mathcal{M}$, return $\perp$.
3. If $\mathcal{T}(\mathcal{M}') \neq 1$, return $\perp$, where $\mathcal{M}' \leftarrow \mathcal{M} \setminus \mathcal{X}$.
4. Define $I \subset \{1, 2, \dots, n\}$ as $I = \{i : m_i \in \mathcal{X}\}$. Accumulate those concatenated binary strings $\{R_j\}_{\{m_i \in I\}}$ onto r . In particular, it computes a short digest $r' \leftarrow \mathcal{H}_k(r, (id \parallel R_1^l); \dots; (id \parallel R_l^l))$, where l is the number of those leaf nodes whose associated subdocument block $m_i \in \mathcal{X}$.
5. Output $(\mathcal{M}', \sigma')$, where $\sigma' \leftarrow (\mathcal{R}' = \{R_j\}_{j \in [h] - [l]}, r', \mathcal{T}, \sigma_s)$.

6 Analysis of the Proposed Constructions

In the following, we analyze the security properties and efficiency of our three RSSs with flexible redaction control.

6.1 Security Analysis

Since all of the proposed three RSSs are essentially built upon quasi-commutative accumulator, conventional DSS, and secret-sharing schemes, the security of them can be proven in a uniform manner. The security of our constructions lies in the fact that, on one hand, the indistinguishability of quasi-commutative accumulator guarantees that the accumulator value leaks no information of the accumulated document. Thus, signing the accumulator further means no information about the removed subdocument blocks is leaked by the released signature, hence implying transparency. On the other hand, the collision-resistance property of quasi-commutative accumulator guarantees that none of the subdocument block in the signed document is modifiable without changing the accumulator value, hence implying unforgeability, assuming the underlying DSS is unforgeable. Furthermore, forgers cannot control the seed shares generated in the signing phase, thus only an authorized set of seed shares is sufficient to reconstruct the seed and recalculate the accumulator value.

The correctness of our constructions have been distinctly presented in their respective verification algorithm in Sect. 5. Moreover, it is obvious that transparency is a stronger notion than privacy [17], which implies privacy.

6.2 Efficiency Analysis

In order to show that our RSS constructions achieve more functionalities without obvious efficiency compromise, we give comparative analysis with several other related works.

Theoretical Analysis. Table 1 shows that our systems have higher computational efficiency than others. Since the encoding length of 2^n bits for any CEAS of [9] (Scheme CV, HT and RSAP) is exponential in n , which is relatively long and cannot be compactly encoded. Hence, Table 2 reveals that the communication cost of our systems are relatively smaller than others. According to Tables 1, 2 and 3, we can see that [19, 27] only realize partial disclosure condition control, but with higher computational overhead than ours. Though [20] is efficient, its construction does not consider redaction control. Our schemes are the first that realizes flexible redaction control with access control mechanisms, which is much more efficient and expressive than other mechanisms. Furthermore, our constructions are built on the collision-free

Table 1 Computation comparison

Schemes	Sign time	Verify time
[19]	$n \cdot T_H + n \cdot T_{Ex}$	$(2u - h) \cdot (T_H + T_{Pair})$
[20]	$n \cdot (T_H + T_{Ex}) + T_S$	$u \cdot (T_H + T_{Ex}) + T_V$
[23]	$T_{Acc} + n \cdot T_{wit} + T_S$	$T_V + u \cdot T_{V_{wit}}$
RSSs-MSP-LSSS	$T_S + T_H + T_{s_0}$	$T_V + 2 \cdot T_H + T_{r_0}$
RSSs-TSSS	$n \cdot (T_H + T_{Ex}) + T_{s_1} + T_S$	$u \cdot (T_H + T_{Ex}) + T_{r_1} + T_V$
RSSs-AC	$n \cdot (T_H + T_{Ex}) + T_{s_2} + T_S$	$u \cdot (T_H + T_{Ex}) + T_{r_2} + T_V$

Table 2 Communication comparison

Schemes	Sign length	Red. Sig. length
[19]	$(n + 1) \cdot l_S$	$(u - h + 1) \cdot l_S$
[20]	$l_S + l_{Acc}$	$l_S + l_{Acc}$
[23]	$l_S + l_{Acc} + n \cdot l_{wit} + l_P$	$l_S + l_{Acc} + u \cdot l_{wit} + l_P$
RSSs-MSP-LSSS	$l_S + (n + 1) \cdot l_R + l_{P_0}$	$l_S + u \cdot l_R + l_{P_0}$
RSSs-TSSS	$l_S + l_{Acc} + n \cdot l_R + l_{P_1}$	$l_S + l_{Acc} + u \cdot l_R + l_{P_1}$
RSSs-AC	$l_S + l_{Acc} + n \cdot l_R + l_{P_2}$	$l_S + l_{Acc} + u \cdot l_R + l_{P_2}$

Table 3 Functionality comparison

Schemes	Building blocks	Release control mechanism	Release control (RC)
[19]	AS	AS	ConditionalRC
[20]	Acc + DSS	$\perp$	No RC
[23]	Acc + DSS	Acc	GeneralRC
RSSs-MSP-LSSS	Acc + DSS + MSP + LSSS	MSP + LSSS	Fine – grainedRC
RSSs-TSSS	Acc + DSS + TSSS	TSSS	MinimalRC
RSSs-AC	Acc + DSS + AT	AT	HybridRC

accumulator which not only enhances the unforgeability of signature but also can hide the number and position of redaction operations in an efficient manner.

Practical Analysis. We simulate the performance of our constructions by calculating the running time and storage expense in Tables 4 and 5 based on the PBC library (version 0.5.14) and GMP library (version 6.1.2). The tests platform is set to be: Pentium (R) G640 CPU, 3.33 GB RAM, 500 G/5400 rpm hard disk, C programming language, and Ubuntu 10.10 LTS (64 Bit) OS. In the experiment, to achieve the security level, we set the group order to be 1024 bits. We apply RSA as the signature algorithm in our construction and fix the modulus to 1024 bits. Table 4 presents the running time of signing, redaction, and verification phases for 10, 50, and 100 subdocument blocks with different number of redaction blocks. The length of each subdocument block is also 1024 bits. We take the mean value of 10 runs for each

Table 4 Computation comparison (running time in s)

Schemes	$ \mathcal{M} $	$ \mathcal{X} $	Sign time	Redact time	Verify time
RSSs-MSP-LSSS	10	4	0.033452	0.006969	0.010037
	50	15	0.073173	0.007421	0.014284
	100	25	0.119522	0.007699	0.017447
RSSs-TSSS	10	4	0.058229	0.010901	0.018193
	50	15	0.184969	0.036990	0.087816
	100	25	0.347258	0.056654	0.175458
RSSs-AC	10	4	0.050572	0.010484	0.021770
	50	15	0.189742	0.0409615	0.089665
	100	25	0.342775	0.056150	0.168967

Table 5 Communication comparison (length of size in bit)

Schemes	$ \mathcal{M} $	$ \mathcal{X} $	Original Sig. Length	Redact Sig. Length
RSSs-MSP-LSSS	10	4	22,528	14,336
	50	15	104,448	71,680
	100	25	206,848	141,312
RSSs-TSSS	10	4	22,528	14,336
	50	15	104,448	73,728
	100	25	206,848	155,648
RSSs-AC	10	4	22,528	14,336
	50	15	104,448	73,728
	100	25	206,848	155,648

test result. As shown, the largest quantity of time is used for signing purposes, and this increases dramatically with the increase of the number of subdocument blocks, while redaction operation is much more lightweight comparing with signing and verification phases. Table 5 illustrates the differences in storage consumption of original signature and redacted signature by contrasting the length of original signature and redacted signature in signing and redacting of different number of subdocument blocks. It is obvious that the signature length increases linearly with the increase of $|\mathcal{M}|$. The number of redacted subdocument block is also relevant to the length of redacted signature.

In summary, through the comparison and implementation, we can see that our schemes achieve flexible redaction control of authenticated data redaction for privacy preserving without introducing much complexity.

7 Conclusion

With the advent of cloud computing, more and more data are outsourced to the cloud server to reduce the management cost and enjoy the ubiquitous access. However, the data outsourced to service provider introduces serious privacy challenges and data security in that user's data are no longer locally possessed but stored on the remote server which belongs to service provider. In this chapter, we focus on the redaction control in applying redactable signature to solve the authenticated data redaction with privacy preserving in outsourced database model. We first provide a brief introduction to the background knowledge of redactable signature schemes that have been proposed in the literature and dedicated to address the efficient and flexible redaction control problem in the outsourced database model. Then we elaborate on a state-of-the-art redaction control mechanisms in the redactable signature schemes, and show that most of the existing redaction control mechanisms in redactable signature schemes are achieved either at the compromise of computational cost or communication overhead. In addition, the redaction control are not flexible enough which affected the application of redactable signature in various of practical applications.

While efficient and flexible redaction control is necessary to further enrich the redaction control and improve the efficiency and scalability of redactable signature schemes. Another interesting direction is on accountability to prevent the arbitrary redaction control in redactable signature. In this chapter, we proposed three authenticated data redaction schemes with different redaction control mechanisms. The first one realized fine-grained redaction control with MSP and LSSS. Redactable signature scheme with threshold redaction control is followed. The third construction is with hybrid redaction control which not only control the number but also the combination of submessage blocks. All of our constructions are efficient and secure compared with other related works. Although we have proposed some solutions for the redaction control issues, there still some other challenges exist in redactable signature schemes such as the new application scenarios and security properties. We believe both research directions are interesting and call for more effort from the research community.

References

1. Diffie, W., & Hellman, M. (1976). New directions in cryptography. *IEEE Transactions on Information Theory*, 22, 644–654.
2. Goldwasser, S., Micali, S., & Rivest, R. L. (1988). A digital signature scheme secure against adaptive chosen-message attacks. *SIAM Journal on Computing*, 17, 281–308.
3. Miyazaki, K. (2003). Digital documents sanitizing problem. IEICE Technical Report, ISEC2003–20.
4. Johnson, R., Molnar, D., Song, D., & Wagner, D. (2002). Homomorphic signature schemes. In: *CT-RSA* (Vol. 2271, pp. 244–262). Berlin: Springer.
5. Becker, G. (2008). Merkle signature schemes, merkle trees and their cryptanalysis. Ruhr-University Bochum, Technical Report.

6. Goldreich, O., & Goldwasser, S. (1986). Micali: How to construct random functions. *Journal of the ACM (JACM)*, 33, 792–807.
7. Goldreich, O., Goldwasser, S., & Micali, S. (1984). How to construct randolli functions. In *1984 25th Annual Symposium on Foundations of Computer Science* (pp. 464–479). IEEE.
8. Derler, D., Hanser, C., & Slamanig, D. (2015). Revisiting cryptographic accumulators, additional properties and relations to other primitives. In *CT-RSA* (pp. 127–144).
9. Steinfeld, R., Bull, L., & Zheng, Y. (2001). Content extraction signatures. In *International Conference on Information Security and Cryptology* (pp. 285–304). Berlin: Springer.
10. Wu, Z. Y., Hsueh, C. W., Tsai, C. Y., Lai, F., Lee, H. C., & Chung, Y. (2012). Redactable signatures for signed cda documents. *Journal of Medical Systems*, 36, 1795–1808.
11. Slamanig, D., & Rass, S. (2010). Generalizations and extensions of redactable signatures with applications to electronic healthcare. In *Communications and Multimedia Security* (pp. 201–213). Berlin: Springer.
12. Brown, J., & Blough, D. M. (2012). Verifiable and redactable medical documents. In *AMIA Annual Symposium Proceedings* (Vol. 2012, p. 1148). American Medical Informatics Association.
13. Bauer, D., Blough, D. M., & Mohan, A. (2009). Redactable signatures on data with dependencies and their application to personal health records. In *Proceedings of the 8th ACM Workshop on Privacy in the Electronic Society* (pp. 91–100). ACM.
14. Samelin, K., Pöhls, H. C., Bilzhaue, A., Posegga, J., & De Meer, H. (2012). Redactable signatures for independent removal of structure and content. In *International Conference on Information Security Practice and Experience* (pp. 17–33). Berlin: Springer.
15. Chang, E. C., Lim, C. L., & Xu, J. (2009). Short redactable signatures using random trees. In *CT-RSA* (Vol. 9, pp. 133–147). Berlin: Springer.
16. Kundu, A., & Bertino, E. (2013). Privacy-preserving authentication of trees and graphs. *International Journal of Information Security*, 12, 467–494.
17. Brzuska, C., Busch, H., Dagdelen, O., Fischlin, M., Franz, M., Katzenbeisser, S., Manulis, M., Onete, C., Peter, A., Poettering, B., et al. (2010). Redactable signatures for tree-structured data: definitions and constructions. In *International Conference on Applied Cryptography and Network Security* (pp. 87–104). Berlin: Springer.
18. Hirose, S., & Kuwakado, H. (2013). Redactable signature scheme for tree-structured data based on merkle tree. In *2013 International Conference on Security and Cryptography (SECRYPT)* (pp. 1–8). IEEE.
19. Miyazaki, K., Hanaoka, G., & Imai, H. (2006). Digitally signed document sanitizing scheme based on bilinear maps. In *Proceedings of the 2006 ACM Symposium on Information, computer and communications security* (pp. 343–354). ACM.
20. Pöhls, H. C., Samelin, K., Posegga, J., & De Meer, H. (2012). Length-hiding redactable signatures from one-way accumulators in $O(n)$. Technical report, Technical Report MIP-1201, Faculty of Computer Science and Mathematics (FIM), University of Passau.
21. Pöhls, H. C., Samelin, K., Posegga, J., & de Meer, H. (2012). Transparent mergeable redactable signatures with signer commitment and applications. Technical report, Technical Report MIP-1206, University of Passau, 8 2012.
22. Pöhls, H. C., & Samelin, K. (2014). On updatable redactable signatures. In *International Conference on Applied Cryptography and Network Security* (pp. 457–475). Berlin: Springer.
23. Derler, D., Pöhls, H. C., Samelin, K., & Slamanig, D. (2015). A general framework for redactable signatures and new constructions. In *International Conference on Information Security and Cryptology* (pp. 3–19). Berlin: Springer.
24. Pöhls, H. C., & Samelin, K. (2015). Accountable redactable signatures. In *2015 10th International Conference on Availability, Reliability and Security (ARES)* (pp. 60–69). IEEE.
25. Bull, L., Squire, D. M., Newmarch, J., & Zheng, Y. (2003). Grouping verifiable content for selective disclosure. In *Australasian Conference on Information Security and Privacy* (pp. 1–12). Berlin: Springer.
26. Bull, L., Squire, D. M., & Zheng, Y. (2004). A hierarchical extraction policy for content extraction signatures. *International Journal on Digital Libraries*, 4, 208–222.

27. Miyazaki, K., Iwamura, M., Matsumoto, T., Sasaki, R., Yoshiura, H., Tezuka, S., et al. (2005). Digitally signed document sanitizing scheme with disclosure condition control. *IEICE Transactions on Fundamentals of Electronics, Communications and Computer Sciences*, 88, 239–246.
28. Ma, J., Liu, J., Wang, M., & Wu, W. (2017). An efficient and secure design of redactable signature scheme with redaction condition control. In *International Conference on Green, Pervasive, and Cloud Computing* (pp. 38–52). Berlin: Springer.
29. Boneh, D., Gentry, C., Lynn, B., & Shacham, H. (2003). Aggregate and verifiably encrypted signatures from bilinear maps. In *Eurocrypt* (Vol. 2656, pp. 416–432). Berlin: Springer.
30. Haber, S., Hatano, Y., Honda, Y., Horne, W., Miyazaki, K., Sander, T., Tezoku, S., & Yao, D. (2008). Efficient signature schemes supporting redaction, pseudonymization, and data de-identification. In *Proceedings of the 2008 ACM symposium on Information, Computer and Communications Security* (pp. 353–362). ACM.
31. Derler, D., Krenn, S., & Slamanig, D. (2016). Signer-anonymous designated-verifier redactable signatures for cloud-based data sharing. In *International Conference on Cryptology and Network Security* (pp. 211–227). Berlin: Springer.
32. Beimel, A. (1996). Secure schemes for secret sharing and key distribution. Technion-Israel Institute of technology, Faculty of computer science.
33. Goyal, V., Pandey, O., Sahai, A., & Waters, B. (2006). Attribute-based encryption for fine-grained access control of encrypted data. In *Proceedings of the 13th ACM Conference on Computer and Communications Security* (pp. 89–98). ACM.
34. Liu, J., Huang, X., & Liu, J. K. (2015). Secure sharing of personal health records in cloud computing: ciphertext-policy attribute-based signcryption. *Future Generation Computer Systems*, 52, 67–76.
35. Karchmer, M., & Wigderson, A. (1993). On span programs. In *1993 Proceedings of the Eighth Annual Structure in Complexity Theory Conference* (pp. 102–111). IEEE.
36. Liu, J., Ma, J., Wu, W., Chen, X., Huang, X., & Xu, L. (2017). Protecting mobile health records in cloud computing: A secure, efficient, and anonymous design. *ACM Transactions on Embedded Computing Systems (TECS)*, 16, 57.
37. Barber, S., Boyen, X., Shi, E., & Uzun, E. (2012). Bitter to better how to make bitcoin a better currency. In *International Conference on Financial Cryptography and Data Security* (pp. 399–414). Berlin: Springer.
38. Shamir, A. (1979). How to share a secret. *Communications of the ACM*, 22, 612–613.
39. de Meer, H., Liedel, M., Pöhls, H. C., Posegga, J., & Samelin, K. (2012). Indistinguishability of one-way accumulators. Technical report, Technical Report MIP-1210, Faculty of Computer Science and Mathematics (FIM), University of Passau.
40. Sudarsono, A., Nakanishi, T., & Funabiki, N. (2011). Efficient proofs of attributes in pairing-based anonymous credential system. In *PETS* (pp. 246–263). Berlin: Springer.
41. Benaloh, J., & De Mare, M. (1993). One-way accumulators: A decentralized alternative to digital signatures. In *Workshop on the Theory and Application of Cryptographic Techniques* (pp. 274–285). Berlin: Springer.
42. Barić, N., & Pfitzmann, B. (1997). Collision-free accumulators and fail-stop signature schemes without trees. In *Advances in Cryptology EUROCRYPT97* (pp. 480–494). Berlin: Springer.

A Methodology for Retrofitting Privacy and Its Application to e-Shopping Transactions



Jesus Diaz, Seung Geol Choi, David Arroyo, Angelos D. Keromytis, Francisco B. Rodriguez and Moti Yung

Abstract The huge growth of e-shopping has brought convenience to customers and increased revenue to merchants and financial entities. Moreover, e-shopping has evolved to possess many functions, features, and requirements (e.g., regulatory ones). However, customer privacy has been mostly ignored, and while it is easy to add simple privacy to an existing system, this typically causes loss of functions. What is needed is enhanced privacy on one hand, and retaining the critical functions and features on the other hand. This is a dilemma which typifies the “privacy versus utility” paradigm, especially when it is applied to an established primitive with operational systems, where applying conventional privacy-by-design principles is not possible and completely altering information flows and system topologies is not an option. This dilemma is becoming more problematic with the advent of regulations such as the European GDPR, which requires companies to provide better privacy guarantees whenever and wherever personal information is involved. In this chapter,

J. Diaz (✉)

BBVA Next Technologies, Madrid, Spain

e-mail: jesus.diaz.vico@bbva.com

S. G. Choi

United States Naval Academy, Annapolis, MD, USA

e-mail: choi@usna.edu

D. Arroyo

Spanish National Research Council (CSIC), Madrid, Spain

e-mail: david.arroyo@iec.csic.es

A. D. Keromytis

Georgia Institute of Technology, Atlanta, Georgia

e-mail: angelos@gatech.edu

F. B. Rodriguez

Universidad Autónoma de Madrid, Madrid, Spain

e-mail: f.rodriguez@uam.es

M. Yung

Columbia University, New York, NY, USA

e-mail: moti@cs.columbia.edu

M. Yung

Google Inc., Menlo Park, CA, USA

© Springer Nature Singapore Pte Ltd. 2019

K.-C. Li et al. (eds.), *Advances in Cyber Security: Principles,*

Techniques, and Applications, https://doi.org/10.1007/978-981-13-1483-4_7

we put forward a methodology for privacy augmentation design that is specially suitable for real-world engineering processes that need to adhere to the aforementioned constraints. We call this the “utility, privacy, and then utility again” paradigm. In particular, we start from the state-of-the-art industry systems that we need to adapt; then we add privacy enhancing mechanisms, reducing functionality in order to tighten privacy to the fullest (privacy); and finally, we incorporate tools which add back lost features, carefully relaxing privacy this time (utility again). Specifically, we apply this process to current e-shopping infrastructures, making them privacy respectful without losing functionality. This gives an e-shopping system with enhanced privacy features, presents a set of “utility-privacy trade-offs,” and showcases a practical approach implementing the notion of “privacy by design” while maintaining as much compatibility as possible with current infrastructures. Finally, we note that we implemented and tested performance of our design, verifying its reasonable added costs.

1 Introduction

Privacy for systems in production? The principle of privacy by design mandates that privacy-enhancing mechanisms need to be taken into account early at the design stage of any system. Although important and prevalent, however, this principle is not very helpful when we would like to enhance privacy of the infrastructures and systems that have already been deployed and well established. One could attempt to apply this principle by redesigning the whole (existing) system from scratch. Even in this case, however, one cannot rule out the existing system completely. In particular, the new design must still be greatly constrained by the main processes and information flows of the existing system. Otherwise, the amount of chain-effect changes that the new design could entail may be too costly and thereby unacceptable.

As an example of the costs of modifying deployed systems, the banking ecosystem comes to mind. IBM’s mainframes have been the foundation of most banking infrastructures for decades. In recent years, probably due to the arrival of PSD2¹ and similar initiatives, deep changes have been made in the banking industry. However, even with these years-long efforts, work remains to be done. This reflects the complexity of updating already established systems.

Still, with the advent of another European regulation, the GDPR,² we are urged to think about how to incorporate privacy into already existing processes. This places privacy engineers in a delicate spot. We need to not only maintain compatibility (i.e., reasonably similar interfaces) with related processes, but also introduce privacy in a context where this very privacy often directly conflicts with the provided services. Think, for instance, of enhancing privacy for fraud prevention and marketing tools,

¹https://ec.europa.eu/info/law/payment-services-psd-2-directive-eu-2015-2366_en. Last access on April 17th, 2018.

²<https://www.eugdpr.org/>. Last access on April 17th, 2018.

which have become essential parts of the e-commerce ecosystem. To support these services, a record of users' activities seems necessary, but this conflicts privacy.

Privacy versus utility inspiration: the group signature case. The evolution of privacy primitives in various specific domains often centers around the notion of balancing privacy needs and utility requirements. For example, consider the basic notion of "digital signature" [35, 65] whose initial realization as a public key infrastructure [43] mandated that a key owner be certified with its identity and its public verification key. This is done by a certification authority (CA) which signs a record (called certificate) identifying the user and its signature public verification key. Later on, for some applications, it was suggested that CA's sign anonymous certificates which only identify the keys (for example, a bulk of keys from a group of users is sent to the CA via a mix-net and the CA signs and publish the certificates on a bulletin board: only the owner of a key can sign anonymously with its certified key. Alternatively the CA blindly signs certificates). This brings digital signing to the domain of anonymous yet certified action (i.e., the action/message is known to originate from the group that was certified). However, it was noted quite early that under the mask of anonymity, users can abuse their power and sign undesired messages, where no one can find the abuser. Therefore, primitives like group signature [22] or traceable signature [46] were designed, assuring that the anonymity property of a signed message usually stays, but there are authorities which can unmask abusers, or unmask certain message signatures in order to keep balance between anonymity of well behaving signers while protecting the community against unacceptable message signing practices. More complex actions can be constructed based on this setting, e.g., checks that are anonymous to the general public, while the clearing house is the revocation authority which revokes anonymity in order to clear checks based on the checks' actual account. In any case, satisfactorily managing privacy and digital identities is a complicated task [8].

Utility, privacy, and then utility again. The above development on group signatures shows that even in one of the simplest case of anonymity versus basic message authenticity, there is already certain advantage in providing partial anonymity to perform in a desirable environment which balances various needs. Additionally, the described case of privacy by design for already deployed systems calls out for variants of this methodology. For this, extrapolating from the above staged methodology that gave us the primitives of group signature and traceable signature, we follow a methodology that can be viewed as "utility, privacy, and then utility again": first translating a primitive to an idealized anonymous primitive, but then identifying lost utility which complete anonymity prevents; and, in turn, relaxing privacy for additional utility. In the full circle of e-shopping, this gives rise to numerous trade-offs which we unveil and discuss (based on utility needed in various steps of the transaction system). Importantly, our methodology allows us to maintain the same basic information flow and main processes than in current e-shopping systems, thus making it easier to come up with a proposal compatible with the existing complex e-commerce ecosystem.

Our results. We put forward our approach in this chapter through to the involved case of the real-world (compound) process of e-shopping, to which we apply the aforementioned construction framework.³ As a result, we obtain an e-shopping system that maintains the same infrastructure and information flow than industry e-shopping systems and offers a higher privacy level, while still maintaining added value services such as marketing and fraud prevention tools.

We implemented a prototype of our mechanism. This allows us to check the actual applicability from a software development perspective (beyond paper design of transactions, crypto building blocks, and protocol exchanges), and it enables us to report the measurement results for the overall transaction processes, demonstrating that our system incurs low additional costs.

1.1 Organization

We contextualize our e-shopping proposal among related work in Sect. 2 and we describe our methodology for maintaining both utility and privacy in Sect. 3. Then, after some preliminaries in Sect. 4, we proceed to apply the methodology to the e-shopping case: we begin by modeling the e-shopping ecosystem, pinpointing the core entities and processes, as well as the added value tools it incorporates in Sect. 5, where we additionally define the privacy threats. Then, we sketch in Sect. 6 the result of applying privacy to the traditional system (*Privacy*); and finally, we analyze this system to show its shortcomings and proceed to recover utility in Sect. 7 (*Utility again*). Section 8 formalizes the security properties that our system needs to ensure and provides the necessary proofs. Next, in Sect. 9 we present the experimental results obtained from a prototype implementing our proposal. In Sect. 10, we chart a way to endow our infrastructure with additional functionality (typically available in industrial systems). In Sect. 11, we conclude and outline our future work.

2 Related Work

There is a plenty of work on ensuring privacy in the different subprocesses of e-shopping.

Payment. The most prolific area has been on anonymous payments, e-cash [21] being its main representative. There has been a huge boost since the proposal of Bitcoin [54], creating the so-called cryptocurrencies. While Bitcoin itself does not provide robust privacy, more advanced proposals have been made addressing it

³A conference proceedings version of this chapter is available in [34] and further contextualization is given in [29].

[10, 38, 51].⁴ These systems address only the payment subprocess, and are typically not concerned with additional functionalities, except [38], where Zerocash is extended to incorporate support for regulatory concerns. Some traditional e-cash proposals also incorporate utility to some extent, mainly enabling tracing (after the payment has been done) [18, 27, 55] or spending limitation [55, 68]. Privacy respectful payment systems out of the e-cash domain also exist, such as [44] which is built on mix networks to prevent linking customers and merchants, and [70] which introduces discounts based on the users' history (users are always pseudonymous).

Purchase. Privacy-preserving purchase systems have been divided in two types of systems depending on the information hidden to service providers [63]: private purchase systems hiding the purchased items [64], and anonymous purchase systems hiding buyers' identities [69]. In particular, the system in [69] works by interleaving proxies that contain software removing identifiable information about customers.

Profiling, delivery, and completion. There have been works focusing on privacy respectful user profiling [25, 59, 71], mostly for affinity programs, although some approaches are also applicable to fraud prevention [25]. Anonymous delivery systems of physical goods have also been proposed [5, 69], covering a crucial phase that has received much less attention. Finally, solutions related to the completion phase (leaving feedback, complains, etc.) have been basically ignored, although this phase has been shown to allow de-anonymization attacks [52]. Underlying most of these proposals are, often, cryptographic primitives such as oblivious transfer [2] or anonymous credentials [19, 24], which are of natural interest in this domain as core building blocks.

Comparison with our proposal. One common aspect among these previous works is that they deal only with specific subprocesses of the overall e-shopping process. They either focus solely on the purchase, payment (checkout), delivery, or completion phase. As noted in [33], a holistic approach must be adopted if we aim to protect users throughout all the process. Moreover, not doing so entails a single point of failure since privacy violations in any of the remaining unprotected phases erode the overall privacy protection.

Some proposals introduce extensive changes into the infrastructure and information flow [44] or require modifications that conflict with regulations or other practical concerns, like requiring the outsourcing of information that would probably be proprietary in many scenarios [25, 71].

To conclude, at present, the utility-privacy trade-off is clearly leaning towards utility in the industry and towards full privacy in the academic literature. And, importantly, in any case, there does not seem to exist a wide enough approach that covers all the phases of the e-shopping process. In this chapter, we aim at addressing both these issues by proposing a novel system that, we believe, typifies a methodology for introducing privacy to real-world processes.

⁴As well as many proposals in nonacademic forums. See, for instance, <https://z.cash/> (a modified implementation of Zerocash) and <https://cryptonote.org/>. Last access on March 21st, 2018.

3 Methodology

Well-established wisdom in the field states that, if instead of assuming privacy as a requirement from the beginning, it is just added to the system after it has been built, the achieved privacy is very weak. Indeed privacy by design is a necessary principle when architecting new information systems. However, in the real world, users' acceptance is a must to achieve effective and efficient privacy respectful products. Therefore, besides privacy, we have to bear in mind two additional requirements: compatibility and utility.

Compatibility. It has been now several decades since the first electronic communication and information systems were built. A lot of standardization efforts have taken place, relating to data representation, processes, interoperability, etc. Similarly, a vast amount of infrastructures have been deployed. Also, while initially these were standalone systems, with the improved capacity and quality of communications, we now live in a hyperconnected world, where even *things* talk to *things*. Consequently, if we have to change one of these connected components, we need to think of the side effects this change will have to the related systems.

Utility. Current widely deployed information systems have been built with the purpose of enhancing convenience to users and service providers, either by enabling a new use case, or by improving an existing one through the introduction of added value services. Social media platforms recommend new friends by examining the contact list in your mobile phone, second-level connections, common hobbies, etc. Advertising systems track your browsing habits to better filter your interests and offer you goods and services that will most probably be of your interest. Online shopping sites keep record of your purchases to offer you promotions, improve your shopping experience, etc. On the one hand, users of these (and many other) platforms find these enhanced services handy as they make their lives easier and many times (seemingly) cheaper. On the other hand, service providers and third party services which build on them, find them very useful for their business cases.

Bringing Compatibility, Utility, and Privacy together. Applying privacy by design is, by itself, a hard task that requires advanced knowledge of cryptographic primitives and information security tools. If, additionally, compatibility and utility have to be taken into account, the task can be daunting. As we have mentioned in Sect. 2, academic proposals usually lean towards the privacy side of this trade-off in detriment of compatibility and utility. On the other hand, industry systems favor compatibility and utility, and typically cover the privacy counterpart through legal means (terms of service, etc.) which barely guarantee against bad business practices [66] or security incidents.

In this chapter, we put forward our approach to reach a balance between these properties. We follow a methodology featuring three steps, which we referred to as *utility*, *privacy*, and *utility again* in the introduction:

1. (*Utility*) First, we model the entities and processes of the context under analysis. Specifically, we differentiate the main process from added value processes. Additionally, we identify the privacy threats that we need to address.
2. (*Privacy*) Second, while keeping the same entities and main process, we apply privacy-enhancing tools. This allows us to create a system that maintains the same topology than the original one, at the cost of losing added value processes.
3. (*Utility again*) Third, we extend the system obtained in the previous step, re-incorporating the lost functionality by building additional cryptographic primitives on top of the ones used in the core process.

As a result of the previous steps, we end up with a system that adheres to the established compatibility restrictions, since we impose from the beginning the need to maintain entities and processes. It also maintains similar utility, due to the expansion made in the third step. Also, privacy is integrated from the first stage of the methodology, allowing us to reach high levels of privacy.

4 Preliminaries

Notation. For an algorithm A , we let $A(x_1, \dots, x_n; r)$ denote the output of A on inputs $x_1, \dots, x_n$ and random coins r ; in addition, $y \leftarrow A(x_1, \dots, x_n)$ means choosing r uniformly at random and setting $y \leftarrow A(x_1, \dots, x_n; r)$. For a set S , we let $x \leftarrow S$ denote choosing x uniformly at random from S . We let $\langle O_A, O_B \rangle \leftarrow P(I_C)[A(I_A), B(I_B)]$ denote a two-party process P between parties A and B , where O_A (resp. O_B) is the output to party A (resp. B), I_C is the common input, and I_A (resp. I_B) is A 's (resp. B 's) private input; when party B does not have output, we sometimes write $O_A \leftarrow P(I_C)[A(I_A), B(I_B)]$. When a single party algorithm P uses a public key pk , we sometimes write $O \leftarrow P_{pk}(I)$ (although we may omit it when it is clear from the context). For readability, we assume that if any internal step fails, the overall process also fails and stops.

Basic cryptographic primitives. We assume readers are familiar with public key encryption [35, 65], digital signature and commitment schemes [15], and zero-knowledge proofs of knowledge (ZK-PoKs) [41]. Let $(\text{EGen}, \text{Enc}, \text{Dec})$ denote a public key encryption scheme, and $(\text{SGen}, \text{Sign}, \text{SVer})$ denote a digital signature scheme. For readability, we assume that it is possible to extract the signed message from the corresponding signature. We let $\text{com}_m \leftarrow \text{Com}(m; r_m)$ denote a commitment to a message m , where the sender uses uniform random coins r_m ; the sender can open the commitment by sending (m, r_m) to the receiver. We use $\pi \leftarrow \text{ProveZK}_L(x; w)$ and $\text{VerifyZK}_L(x, \pi)$ to refer to creating noninteractive proof π showing that the statement x is in language L (which will sometimes omit if obvious from the context) with the witness w , and to verifying the statement x based on the proof π .

Group signatures and traceable signatures. Group signatures [17, 22, 46, 48, 49] provide anonymity. In particular, a public key is set up with respect to a specific group

consisting of multiple members. Any member of the group can create a signature ϱ , but signature ϱ reveals no more information about the signer than the fact that some member of the group created ϱ . Group signatures also provide accountability; the group manager (GM) can open signature ϱ and identify the actual signer.

- $(pk_G, sk_G) \leftarrow \text{GS.Setup}(1^k)$ sets up a key pair; GM holds sk_G .
- $(mk_i, \ell') \leftarrow \text{GS.Join}(pk_G)[M(s_i), GM(\ell, sk_G)]$ allows member M with secret s_i to join group G , generating the private member key mk_i and updating the Group Membership List ℓ to ℓ' .
- $\varrho \leftarrow \text{GS.Sign}_{mk_i}(msg)$ issues a group signature ϱ .
- $\text{GS.Ver}_{pk_G}(\varrho, msg)$ verifies whether ϱ is a valid group signature.
- $i \leftarrow \text{GS.Open}_{pk_G}(sk_G, \varrho)$ returns the identity i having issued the signature ϱ .
- $\pi \leftarrow \text{GS.Claim}_{mk_i}(\varrho)$ creates a claim π of the ownership of ϱ .
- $\text{GS.ClaimVer}_{pk_G}(\pi, \varrho)$ verifies if π is a valid claim over ϱ .

Traceable signatures [46] are essentially group signatures with additional support of tracing (when we use the previous group signature operations, but with a traceable signature scheme, we use the prefix TS instead of GS).

- $t_i \leftarrow \text{TS.Reveal}_{sk_G}(i)$. The GM outputs the tracing trapdoor of identity i .
- $b \leftarrow \text{TS.Trace}(t_i, \varrho)$. Given the tracing trapdoor t_i , this algorithm checks if ϱ is issued by the identity i and outputs a Boolean value b reflecting the check.

Partially blind signatures. A blind signature scheme [21] allows a user U to have a signer S blindly sign the user's message m . Partially blind signatures [1] are a refinement of blind signatures in which, besides the blinded message m , a common public message is included in the final signature.

- $(pk_S, sk_S) \leftarrow \text{PBS.KeyGen}(1^k)$ sets up a key pair.
- $(\tilde{m}, \pi) \leftarrow \text{PBS.Blind}_{pk_S}(m, r)$. Run by a user U , it blinds the message m using a secret value r . It produces the blinded message $\tilde{m}$ and a correctness proof π of $\tilde{m}$.
- $\tilde{\varrho} \leftarrow \text{PBS.Sign}_{sk_S}(cm, \tilde{m}, \pi)$. Signer S verifies proof π and issues a partially blind signature $\tilde{\varrho}$ on $(cm, \tilde{m})$, where cm is the common message.
- $\varrho \leftarrow \text{PBS.Unblind}_{pk_S}(\tilde{\varrho}, \tilde{m}, r)$. Run by the user U , who verifies $\tilde{\varrho}$ and then uses the secret value r to produce a final partially blind signature ϱ .
- $\text{PBS.Ver}_{pk_S}(\varrho, cm, m)$ checks if ϱ is valid.

5 The Reference e-Shopping Process

Following [33], we first identify the core functionalities of the existing e-shopping system as follows, ruling out other various features in order to achieve a very high level of privacy.

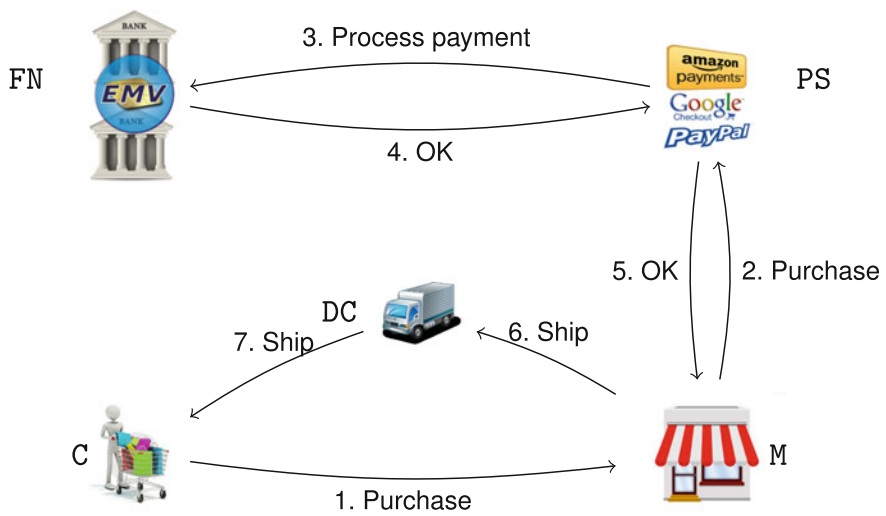


Fig. 1 The overall process of a traditional e-shopping

Entities. The involved parties are:

- Customers (C)* Individuals buying goods or services.
- Merchants (M)* Selling products and offering services to customers.
- Payment System (PS)* Platforms connecting customers and merchants, offering both added value services, e.g., marketing programs to customers, and fraud prevention mechanisms to merchants. For instance, Amazon, eBay or Alibaba.
- Financial Network (FN)* In our abstraction, we bundle all financial entities processing and executing transactions.
- Delivery Companies (DC)* Responsible for delivering physical goods.

Note that this abstraction, although may combine several “sub-roles” within the same entity (e.g., card issuers and banks within FN), still follows the separation of roles of the real world. This abstraction is nevertheless more specific than the one in [33], where the role of the PS was assumed by M. Given the high complexity of e-shopping platforms such as Amazon, it makes sense to make the distinction herein proposed.

Main processes. Assuming users have already registered in the system, we may consider four phases: purchase, checkout, delivery, and completion (see Fig. 1). First, in the *purchase phase*, C picks the products he wants to buy from M. In the *checkout phase*, the payment and delivery information specified by C are routed to PS, probably through M, and processed and executed by FN. Subsequently, in the *delivery phase*, and for physical goods, DC delivers them to C. Finally, in the *completion phase*, C verifies that everything is correct, maybe initiating a complaint and/or leaving feedback.

The aforementioned processes are the ones that allow to fulfill the final objective of e-shopping: delivering (or providing) the customer the purchased good (or service). As we will see next, and was described in [33], there are already many privacy threats in these processes. Still, we can identify added value processes that help building a richer ecosystem. In this chapter, we take into account marketing tools and fraud prevention tools. These are indeed services that, while not being among the strictly necessary processes, have become essential part of the overall experience and help increase revenue (marketing tools) and reduce losses (fraud prevention). Specifically, marketing tools such as coupons are typically made available to customers since the purchase phase, either by PS or M. As for fraud prevention techniques, they are applied by M, PS and FN during checkout.

5.1 Identifying the Threats

Once we have modeled the system and obtained its core entities and processes, the first step is to identify the main privacy risks that may appear.

For this purpose, we next review existing privacy threats in e-shopping. Table 1 summarizes the threats that have been exposed to some extent in the literature for each of the previously mentioned phases.

We note that some of them occur quite naturally in current industry systems (like threat 2.2, since M usually learns C's payment information, or threat 3.2, since DC learns both C and M addresses, being able to link C and M). However, as we will see in some of the reviewed attacks, sometimes it is enough with few additional information in order for an attacker to seriously undermine privacy. Therefore, it is advisable to keep the principle of *least information*.

Threats in the purchase stage. We first note that 9 out of 13 risks outlined in [7] affect the purchase process and the communications between C and M.

Additional vulnerabilities may lie in loyalty programs; M can apply loyalty programs to lure more customers into buying products. The promotions offered by M

Table 1 Summary from of privacy threats in the different e-shopping phases

Phase	Privacy threats
Purchase	1.1. Product info leaked to financial entities or 3rd parties 1.2. Link customers and merchants by 3rd parties
Checkout	2.1. Product info leaked to financial entities or 3rd parties 2.2. Payment info leaked to merchants or 3rd parties 2.3. Link customers and merchants by 3rd parties
Delivery	3.1. Shipping address leaked to merchants or 3rd parties 3.2. Link customers and merchants by delivery companies or 3rd parties
Completion	4.1. Private info leaks through feedback (All previous threats may affect completion)

will probably be based on C's profile, purchase history, and shopping cart. Since M will likely apply loyalty programs to increase their revenue, it is necessary to analyze how customers' personal information is treated. For this purpose, e-shopping platforms (Amazon, eBay, etc.) typically collect information such as purchase history, IP addresses, browser metadata, etc.

In [61], threat 1.1 in Table 1 is exposed for e-shops using PayPal. In this study, it was observed that 52% of the analyzed e-shops were sending product names, number of items and descriptions to PayPal. In addition, [61] also showed that PayPal leaked tracking information to Adobe's Omniture, including the referrer URL, which directly allows to link C and M (realizing threat 1.2 in Table 1). Moreover, note that in conventional e-shopping, risk 1.2 is always present, since PS, FN, and DC usually learn both C and M identities [7].

Threats in the checkout stage. In this stage, C specifies the payment information and shipping address. After applying fraud prevention techniques (e.g., reject purchases of more than a predefined price), M checks the promotions presented by C, if any, and forwards the payment information to FN. After validating the payment information (along with additional fraud prevention mechanisms), FN executes the payment. When checkout is completed, M updates C's profile.

This stage handles most pieces of information; risks 1 to 6 and risk 13 of [7] directly affect this stage. Namely, either M, PS or FN may misuse C's personal or payment information. Even if it is not misused by a dishonest entity, a *honest but curious* party may still pose a serious threat.

Concerning threat 2.1 in Table 1, as pointed out in [53], the current widely deployed 3-D Secure protocol, e.g., "Verified by Visa", "MasterCard SecuriCode", or "American Express SafeKey", requires a description of the transaction to be sent to FN (more exactly, the card issuer) in order for the cardholder to see and check it later. In particular, we know that some merchants leak product information to FN [61]. As to threat 2.2, in the protocol "Verified by Visa", M receives C's PAN (Primary Account Number, i.e., the credit card number) [72].

A relevant example of threat 2.3 in Table 1, which may also imply threats 2.1 and 2.2, appears in [28]. From a large set of simply anonymized financial data (without names, addresses or obvious identifiers), [28] shows that it is possible to de-anonymize 90% of the individuals, if the data contain three items: price, when, and where.

Moreover, the payment information processed by financial entities includes card and account numbers and identifiers that persist across online and offline platforms and systems (unlike, e.g., cookies). This further implies that financial entities possess very sensitive information that paves the way to link purchases with payment transactions and perform behavioral analysis over customers' data [61]. Finally, fraud prevention is very relevant in the payment phase. It is the main mechanism that merchants and financial entities employ to prevent losses, which are far from negligible [3, 4]. However, as pointed out in [3], new trends in these fraud prevention may pose a serious threat to privacy, like incorporating geolocation from mobile phones or information from social networks.

Threats in the delivery stage. Once M or PS receive the payment, it delivers the purchased goods to C . For digital goods, the files are sent via Internet, and using anonymizing networks [36] is a robust way to protect privacy. For physical goods, these will be shipped through some delivery company DC to the shipping address specified by C to M during checkout (thus, realizing threat 3.1 in Table 1). Also, as pointed out in [7], depending on the information available to DC , it may pose additional privacy threats. In the real world, the delivery company DC at least learns both C 's and M 's addresses (threat 3.2 in Table 1), which allows it to link them, and may also learn other data, such as product related information.

However, preventing M (or other entities) from learning C 's physical address and DC to learn both C 's and M 's addresses is costly. Probably, physical mix networks are the most privacy respectful option [5]. Alternatively, post office boxes or equivalent delivery methods offer an intermediate solution between complexity and privacy, as it reveals a nearby location instead of C 's address.

Threats in the completion stage. After receiving the purchased items, C verifies that everything is correct, checking the debited amount, the received items, etc. If C is satisfied, the purchase is completed. If some error is detected, C may initiate a complaint. The situation is more complicated for purchases through e-shopping platforms (e.g., Amazon) rather than directly with the merchant; in this case, although it is usually recommended to first contact the merchant,⁵ it may be necessary for the e-shopping platform to mediate. In these situations, the privacy risks described for the previous stages will also be present, since C may need to provide product or payment information, or her contact information.

Additionally, whichever the final result is, C may provide online feedback about M , for other customers to decide whether or not to buy from him; in some platforms, such as eBay, M may also evaluate C . Concerning the possibility of leaving feedback, [52] shows how insufficient privacy controls may lead to serious privacy threats. Indeed, it is possible to infer the purchase history of a specific user by correlating the feedback she has received with the feedback received by the sellers with whom she has interacted. Also, it is possible to perform a *category attack* to obtain a list of the people that has bought an item of a specific type (e.g., guns). Other attacks explained in [52] include a *broad profiling attack* and a *side information attack*, which also pose a serious threat to buyers (even enabling third parties to compromise their privacy in the case of the side information attack). In a related context, [56] explains how to identify users in the Netflix database from little external information. All these attacks are realizations of threat 4.1 in Table 1. A more general model of the privacy threats related to recommendation systems is described in [58, 62].

⁵See <https://payments.amazon.com/help/5968>. Last access on April 18th, 2018.

5.2 *Starting Point*

To summarize, in this section, we have modeled current industry e-shopping systems:

- Entities: customers, merchants, payment systems, financial entities, and delivery companies.
- Main processes: purchase, checkout, delivery, and completion.
- Added-value processes: marketing and fraud prevention tools.

We have established the information flow between entities that allows to implement the aforementioned processes. Additionally, we have identified privacy threats in each of these processes. Thus, we begin from this reference model, and proceed to address the identified privacy issues.

6 System with a High Level of Privacy and Less Functionalities

Following our methodology, we now add privacy-enhancing mechanisms (*privacy step*), constraining the system's functionality to the main processes in order to achieve a high level of privacy, but otherwise minimizing the modification of core functionalities. In particular, we change neither the participating entities nor the actual information flow over the full e-shopping process. However, this comes at the cost of losing the added value processes (marketing tools and fraud prevention tools). We start by informally stating our privacy objectives.

6.1 *Privacy Goal*

We assume that merchants can act maliciously, but PS, FN, and DC are semi-honest. Informally, we aim at achieving customer privacy satisfying the following properties:

- *Hide the identity of a customer and reveal it only if necessary*: The identity of a customer is sometimes sensitive information, and we want to hide it from other parties as much as possible. In the overall e-shopping process, observe that parties such as merchants, PS, and DC does not really need the identity of the customer in order for the transaction to go through. However, FN must know the identity to withdraw the actual amount of money from the customer's account and to comply with current regulations.

This addresses threats 1.2, 2.3, and 3.2 from Table 1.

- *Hide the payment information and reveal it only if necessary*: The information about the credit card number (or other auxiliary payment information) that a customer uses during the transaction is quite sensitive and thereby needs to be protected. In the overall e-shopping process, like the case of the customer identity,

observe that only FN must know this information to complete the financial transaction.

This addresses threat 2.2 from Table 1.

- *Hide the product information and reveal it only if necessary*: The information about which product a customer buys can also be sensitive. However, note that PS and FN do not really need to know what the customer is buying in order for the transaction to go through, but the merchants and DC must handle the actual product.

This addresses threat 1.1 and 2.1 from Table 1.

6.2 Approach for Privacy Enhancements

Below, we highlight our approaches to achieve our privacy goal.

Controlling the information of customer identity. We use the following privacy-enhancing mechanisms to control the information of customer identity.

- *Sender-anonymous channel from customers*: Customers use sender-anonymous channels such as Tor [36] for their communications. Thus, parties interacting with a customer would not be able to know from where the customer contacts them.
- *Customer group signatures on transaction data*: The transaction data on the customer side is authenticated by the customer's group signature. In our context, FN takes the role of the group manager, issuing member keys. Thus, if a merchant M verifies the group signature included by a customer in a transaction, M is confident that the customer has an account with FN. Moreover, the identity of the customer is hidden from other parties based on security of group signatures. However, since FN takes the role of the group manager, it can identify the customer by opening the signature and complete the account management task. However, FN is otherwise not required to take any active role with respect to managing the group or processing group signatures. Note that the group manager must be a trusted entity concerning the group management tasks, although this trust can be reduced with threshold techniques like those in [11].

Controlling the payment information. Customers encrypt their payment information with FN's public key. Thus, only FN can check if the identity in the payment information matches the one extracted from the customer's group signature.

Controlling the product information. The customer encrypts the information about the product he wants to purchase using a key-private public key encryption scheme (e.g., ElGamal encryption) [9]; he generates a key pair and uses the public key to encrypt the product information. The key pair can be used repeatedly since the scheme is key-private,⁶ and the public encryption key is never sent to other parties. The main

⁶Key-privacy security requires that an eavesdropper in possession of a ciphertext not be able to tell which specific key, out of a set of known public keys, is the one under which the ciphertext was created, meaning the receiver is anonymous from the point of view of the adversary.

purpose of doing this is for logging. Once FN logs the transactions, the customer can check the product information in each transaction by simply decrypting the related ciphertext.

Obviously, the encryption does not reveal any information about the product to other parties. Of course, the merchants should obtain this information to proceed with the transaction. To handle this, the customer sends the product information in both plaintext and ciphertext forms, and then proves consistency using a ZK proof. When this step is cleared, only the ciphertext part is transferred to other entities.

Note that this system satisfies all our privacy goals. However, it reduces utility, as is not compatible with many features required by the industry (or by regulation).

6.3 System Processes

Following the general e-shopping scenario described in Sect. 6, our privacy-enhanced system (but without utility) consists of Customers C_i , Merchants M_j , the Payment System PS, the Financial Network FN and delivery companies DC. The processes for communicating them are described next and depicted in Fig. 2.

Setup. All customers belong to a group G which, for simplicity, we assume to be managed by FN, who initially sets up this group G so that its members may issue group signatures. FN also generates a public key encryption key pair (pk_{FN}, sk_{FN}) .

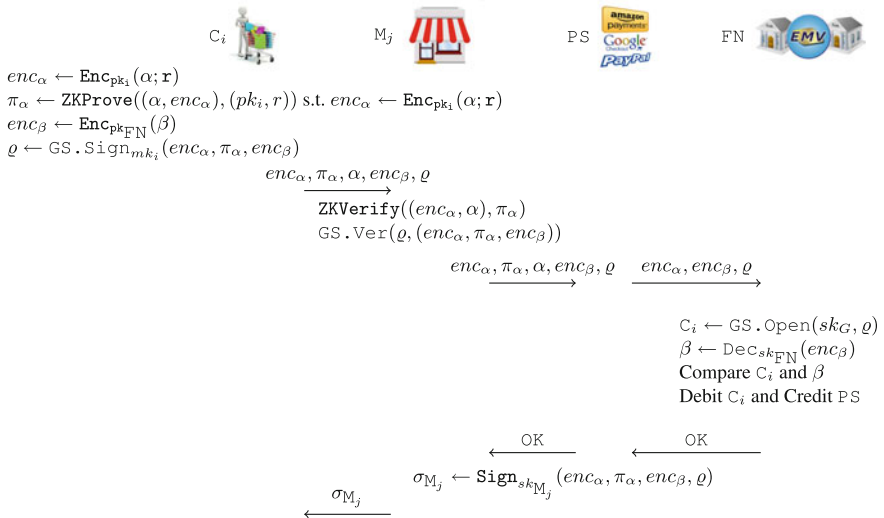


Fig. 2 The overall process of the system. Here, α and β are the product and purchase information, respectively. α has been obtained previously by C_i , browsing M_j 's web anonymously

PS and all M_j generate key pairs (pk_{PS}, sk_{PS}) and (pk_{M_j}, sk_{M_j}) , respectively). Finally, all companies (and additional entities) in DC are set up as in [5].

Purchase. In the purchase phase, C_i browses M_j 's web, getting a description of the products he wants to buy. We use α to denote the product information.

Checkout. In the checkout stage, C_i initiates the transaction with M_j by providing the necessary information. The process ends when C_i receives a confirmation of the order (with a suitable receipt). The process is as follows:

1. C_i creates encrypted versions of the messages to submit. The product information α is encrypted with his own public key. Here, we use the public key encryption scheme (e.g., ElGamal encryption) as a private key encryption scheme, in order to take advantage of the algebraic structure of the scheme admitting simple ZK proofs. That is, he runs $enc_\alpha \leftarrow Enc_{pk_i}(\alpha; r)$, and creates a ZK proof of consistency $\pi_\alpha \leftarrow ProveZK(x; w)$, where $x = (\alpha, enc_\alpha)$ and $w = (pk_i, r)$ such that $enc_\alpha = Enc_{pk_i}(\alpha; r)$. In addition, he fills up all the payment information β (i.e., the sensitive details such as a credit card number and the security code) and encrypts it with FN's public key, producing enc_β . Next, C_i issues a group signature over all the previous tokens. That is, $\varrho \leftarrow GS.Sig_{mki}(enc_\alpha, \pi_\alpha, enc_\beta)$. C_i sends the previous ciphertexts, group signature, and α to M_j .
2. M_j (and possibly PS afterwards) verify ϱ and enc_α . If it is correct, then PS submits enc_β , enc_α and ϱ to FN.
3. Upon receiving the previous tokens, FN decrypts enc_β (which was encrypted with its public key) and opens ϱ . If the identity of the customer who issued ϱ matches the identity in β , and the customer has enough funds, the payment is accepted and processed, informing PS of the result. FN also uses enc_α as transaction description.
4. PS will in turn inform M_j of the output of the transaction and, if accepted, M_j issues a conventional digital signature of enc_α , π_α , enc_β and ϱ . That is, it runs $\sigma_{M_j} \leftarrow Sig_{sk_{M_j}}(enc_\alpha, \pi_\alpha, enc_\beta, \varrho)$.
5. Finally, C_i receives and verifies σ_{M_j} . If correct, the transaction succeeds.

Delivery. Upon receiving the payment, M_j initiates the delivery. This can be done in a privacy-preserving way through the anonymous physical object delivery (APOD) system [5]. In APOD, C_i authenticates to M_j using a pseudonym, and obtains a credential that entitles him to ask DC to ship the goods. In our case, C_i can be authenticated to M_j by claiming ownership of the group signature ϱ that is included within σ_{M_j} (using $GS.Claim$), and afterwards proceed as in APOD.

Note that this approach for delivery addresses threats 3.1 and 3.2 from Table 1.

Completion. In order to perform additional actions related to some previous transaction, C_i has to prove having executed the transaction. For this purpose, the client runs $GS.Claim$ over the group signature ϱ included in σ_{M_j} . This entitles him to provide feedback over the received products, initiate a complaint, and/or ask for a refund.

Note that, throughout all the processes, C_i 's identity is never learned by either M_j nor PS. Moreover, FN learns C_i 's identity but does not learn M_j 's identity and does

not receive information about the products being bought. Furthermore, C_i receives a digital signature issued by M_j that he can use for initiating delivery, requesting refunds and/or leaving feedback in a privacy-preserving fashion.

Finally, note that with this, we also cover threat 4.1 from Table 1.

6.4 How to Proceed to the Next Step

In this step, we have built a system that provides the main functionality, i.e., raw purchase, checkout, delivery, and completion phases; while at the same time provides a high privacy level. Still, we have eliminated important functionalities (marketing tools and fraud prevention tools). Nevertheless, we have set the foundation for incorporating them back. Specifically, the introduction of group signatures and the underlying member keys will allow us to issue zero-knowledge proofs tailored to recover the lost functionality.

7 Privacy-Enhanced System with Richer Functionality

Next, we add important functionalities, in particular marketing and antifraud mechanisms, to the system described in Sect. 6, carefully relaxing privacy (*utility again*). In particular, each customer is associated with a pseudonym by default, and fraud prevention and marketing tools are applied by aggregating certain pieces of transaction history based on the pseudonym. Moreover, we allow customers to opt for anonymity in each transaction, which ensures that *privacy is not reduced beyond what this aggregation implies*.

Adding marketing tools: utility versus privacy. We would like the payment system PS (or merchants) to use marketing tools (e.g., coupons) so as to incentivize customers to purchase more products and thereby increase their revenue. For clarity of exposition, we will consider adding a feature of coupons and discuss the consequential privacy loss; other marketing features essentially follow the same framework.

When we try to add this feature to the system, PS *must at least have access to the amount of money each customer has spent so far*; otherwise, it is impossible for the coupons to be issued for more loyal customers. Obviously, revealing this information is a privacy loss. However, this trade-off between utility and privacy seems to be unavoidable, if the system is to be practically efficient, ruling out the use of fully homomorphic encryptions [39] or functional encryptions [13], which are potentially promising but, as of now, prohibitively expensive to address our problem. The main question is as follows:

- Can we make the system reveal *nothing more than* the purchase history of encrypted products?

- Can we provide the customers with an option to *control the leakage of this history*? In other words, can we give the customers an option to *exclude some or all of their purchase activities* from the history?

We address both of the above questions affirmatively. In order to do so, we first allow *each customer to use a pseudonym selectively*. That is, the payment system can aggregate the customer's purchase history of encrypted products only if the customer uses his pseudonym when buying a product. If the customer wants to exclude some purchase activity from this history, he can proceed with the transaction anonymously.

Still, there are a couple of issues to be addressed. First, we would like the system to work in *a single work flow* whether a customer chooses to go *pseudonymously or anonymously*. More importantly, we want a customer to be able to *use coupons even if he buys a product anonymously*. We will show below how we address these issues, when we introduce the notion of a checkout-credential.

Adding antifraud mechanisms: utility versus privacy. Merchants need to be protected against fraudulent or risky transactions, e.g., transactions that are likely to end up in nonpayments, or that are probably the result of stolen credit cards and similar cases. In current industry systems, this is typically done by having the PS send a risk estimation value to merchants (obtained using proprietary algorithms), who can also apply their own *filters* based on the specifics of the transaction (number of items, price, etc.). We would like to adopt this feature. Obviously, we have an utility-privacy trade-off. In particular, if the risk estimation is too specific and identifying, it will hinder the system from supporting anonymous transactions. We believe that this trade-off is inherent, and in this paper, we treat the specificity of risk estimation to be given as an appropriately-chosen system parameter, depending on the volume of the overall transactions and only mildly degrading the quality of anonymity in anonymous transactions. The main question we should ask will be as follows:

Can we relax anonymity of transactions but only to reveal *the risk estimation*?

As with the marketing tools, we use the checkout-credential for implementing this.

7.1 Our Approach

Checkout credentials. Recall that we would like our system to allow customers to perform unlinkable (anonymous) purchases while we also need to provide merchants with the fraud estimation of a transaction based on each customer's previous transactions. This goal is achieved in a privacy-respectful manner through the checkout-credential retrieval process.

The checkout-credential retrieval process is carried out before the actual checkout, and it is executed between PS and the customer. The resulting checkout-credential is the means used by PS to aggregate the available information related to each pseudonym and provide the marketing and antifraud information for merchants without violating each customer's privacy.

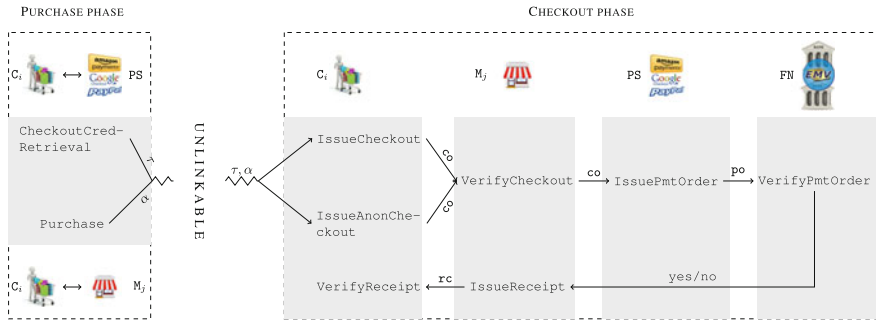


Fig. 3 System process flow. Here, τ is the checkout-credential and α is the product information

Figure 3 shows the augmented information flow of the *purchase* and *checkout* phases in our system. Delivery and completion are not depicted in Fig. 3 since, as we show in the following description, they are quite straightforward and do not suffer further modifications (with respect to the system in Sect. 6) besides integrating them with the new *purchase* and *checkout* processes. Specifically, note that while we have partitioned the main processes in multiple subprocesses, the overall flow is still the same. That is, *purchase* $\rightarrow$ *checkout* $\rightarrow$ *delivery* $\rightarrow$ *completion*. Finally, note also that the parties involved in each process are maintained compared to current systems.

Basically, a checkout-credential is a partially blind signature, requested by a customer and issued by PS. The common message of the checkout-credential includes *aggregated data related to fraud and marketing*, and the blinded message is a *commitment to the customer key*. During the actual checkout, a customer proves to merchants in ZK that he knows the committed key embedded in the checkout credential. *Since it was blindly signed, PS and merchants cannot establish a link any further than what the aggregated common information allows.*

At this point, when the customer decides to perform a pseudonymous checkout (in this case, the pseudonym is also shown during checkout), PS will be able to link the current checkout to the previous ones and update the customer's history (updating his eligibility to promotions and risk estimation). If he chooses an anonymous checkout, PS will not be able to link this transaction with others.

Protection against fraudulent anonymous transactions. There is an additional issue. An attacker may execute a large volume of pseudonymous transactions honestly, making its pseudonym have a low risk estimate value, and then perform a fraudulent anonymous transaction. Note in this case, the checkout-credential will contain low risk estimate and the transaction will likely go through, but problematically, *because of unlinkability of this fraudulent transaction, PS cannot reflect this fraud into the pseudonym's transaction history*. Moreover, taking advantage of this, the attacker can repeatedly perform fraudulent anonymous transactions with low risk estimate.

Recall that in our previous highly private system, the checkout is conducted using a token that contains a group signature issued by a customer and which can be opened by FN. In this system, we use traceable signatures, which augment group signature

with an additional tracing feature. In particular, if an anonymous transaction proves to be fraudulent a posteriori, FN can open the signature and give PS the tracing trapdoor associated with the token (i.e., the traceable signature). Given this trapdoor, PS can update the risk estimation even for anonymous checkouts.

Note that customers are offered a trade-off. When customers always checkout anonymously, they have no previous record and receive worse promotions and fraud estimates. When they always checkout pseudonymously, they get better offers and probably better fraud estimates, in exchange of low privacy. But there are also intermediate options. In all cases, they can take advantage of any coupons they are eligible for and receive fraud estimates based on previous pseudonymous purchases.

In any case, our system is compatible with many antifraud techniques in the industry without needing to resort to tracing and also applicable with anonymous checkouts (some are discussed in Sect. 10).

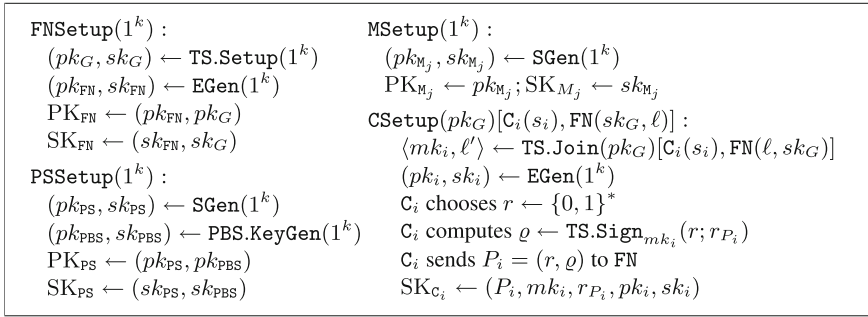
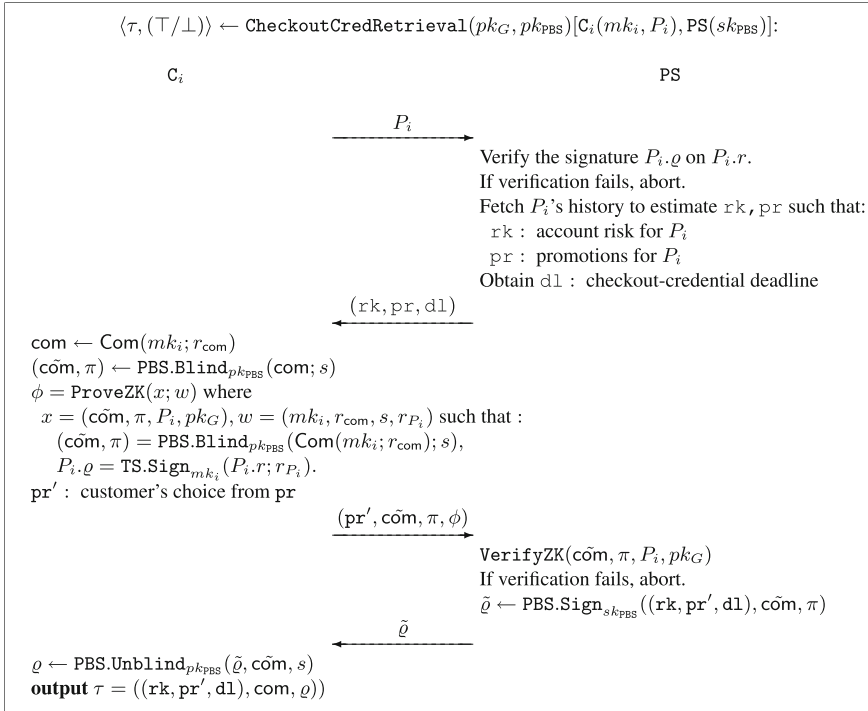
7.2 System Description

In this section, we describe our system. The processes composing each phase are defined next. The flow for purchase and checkout is depicted in Fig. 3.

Setup. FN, PS, and every merchant M_j and customer C_i run their corresponding setup processes in order to get their keys, according to the processes in Fig. 4. In particular, FN runs `FNSetup` to generate traceable signature and encryption keys. PS runs `PSSetup` to generate a key pair for partially blind signatures. M_j runs `MSetup` to generate signing keys. C_i and FN interact in order to generate key pairs for C_i , running `CSetup`. C_i contacts FN, creates an account, and joins a group G , obtaining a membership key mk_i using a secret s_i . In this case, C_i also sets up a pseudonym P_i , known to FN. The pseudonym P_i is a traceable signature on a random message created using his membership key mk_i ; we let $P_i.r$ denote the random message and $P_i.\rho$ the traceable signature on $P_i.r$. During the process, FN updates its membership database ℓ into ℓ' .

Checkout-retrieval and purchase. The purchase phase includes the processes of `CheckoutCredRetrieval` and `Purchase`. The purpose of this phase is for C_i to obtain a description of the products to buy from M_j and a credential authorizing him to proceed to checkout and including information necessary to apply marketing and antifraud tools.

During `CheckoutCredRetrieval`, C_i interacts pseudonymously with PS. The protocol starts by having the customer C_i send his pseudonym P_i . Then, PS retrieves the information of how loyal P_i is (i.e., rk), whether (and how) P_i is eligible for promotion (i.e., pr), and the deadline of the checkout-credential to be issued (i.e., dl), sending back (rk, pr, dl) to C_i . C_i chooses a subset pr' from the eligible promotions pr . Finally, C_i will have PS create a partially blind signature such that its common message is (rk, pr', dl) and its blinded message is a commitment com to his membership key mk_i . We stress that the private member key mk_i of the customer C_i

**Fig. 4** Full system setup processes**Fig. 5** The CheckoutCredRetrieval process

links the pseudonym (i.e., $P_i.\varrho \leftarrow \text{TS.Sign}_{mk_i}(P_i.r)$) and the blinded message (i.e., $com \leftarrow \text{Com}(mk_i; r_{com})$). The customer is supposed to create a ZK-PoK ϕ showing this link. Upon successful execution, the checkout-credential is set to τ . We use $\tau.rk$, $\tau.pr$, $\tau.dl$, $\tau.com$, $\tau.\varrho$ to denote the risk factor, promotion, deadline, commitment to the member key, and the resulting blind signature respectively. Refer to Fig. 5 for pictorial description. A checkout-credential issued with the process in Fig. 5 would

be verified during checkout using the `VerifyCheckoutCred` process, defined as follows:

`VerifyCheckoutCredPKPS( $\tau$ )` : **return** `PBSVerifypkPS( $\tau.\rho, (\tau.pr, \tau.rk, \tau.dl), \tau.com$ )`

Concurrently, C_i obtains through the `Purchase` process a product description of the items he wants to buy. Note that this can be done just by having C_i browse M_j 's website using sender anonymous channels:

$\alpha \leftarrow \text{Purchase}[C_i, M_j]$: **return** product description from M_j 's website

Finally, with both the product description α and the checkout-credential τ , C_i can initiate the checkout phase.

Checkout. After receiving the checkout-credential τ and having obtained a product description, C_i decides whether to perform an anonymous (`IssueAnonCheckout`) or pseudonymous (`IssueCheckout`) checkout process. Let α be the product information with the product name, merchant, etc.; also, let $\$$ be the price of the product and let β be the customer's payment information containing a random number uniquely identifying each transaction. The checkout process is formed as follows (refer to Fig. 6 for a detailed description of the algorithms). Note that the information flow is equivalent to that in Fig. 2, but here we include additional cryptographic tokens.

Step 1: Client issues a checkout object. A customer C_i enters the checkout phase by creating a checkout object co , executing `Issue(Anon)Checkout` using the checkout-credential τ obtained during checkout-credential retrieval. In either procedure, C_i generates a traceable signature ϱ on $(\$, enc_\alpha, enc_\beta)$, where enc_α is an encryption of the product information α , and enc_β is an encryption of the payment information β , and $\$$ is the price of the product. Then, C_i generates a ZK proof ψ showing that the checkout-credential and the traceable signature (and the pseudonym for `IssueCheckout`) use the same mk_i . In summary, we have $co = ([P_i, \tau, \$, \alpha, enc_\alpha, enc_\beta, \varrho, \psi])$.

Step 2: Merchant processes checkout co . When M_j receives the checkout object co (which includes the product information α in the clear, as well as encrypted), he verifies it with `VerifyCheckout`. If verification succeeds, M_j passes co to PS . Note that τ needs to be checked for uniqueness to prevent replay attacks. However, a used credential τ only needs to be stored up to $\tau.dl$. It is also possible for M_j to include additional antifraud information, like an Address Verification Service value⁷ (see Sect. 10).

Step 3: PS issues a payment order po . On receiving co from M_j , PS verifies co , runs `IssuePmtOrder`, and issues a payment order po with the minimum information required by FN for processing the payment that is, $po = (\$, enc_\alpha, enc_\beta, \varrho)$.

Step 4–5: Payment confirmations. Given the payment order po , FN verifies it by running `VerifyPmtOrder`. If the verification succeeds, FN processes the order and notifies PS of the completion; PS in turn sends the confirmation back to M_j .

⁷https://en.wikipedia.org/wiki/Address_Verification_System. Last access on March 21st, 2018.

<pre> co ← IssueCheckout(SK_{C_i}, τ, α, \$, β): Parse SK_{C_i} = (P_i, mk_i, r_{P_i}, pk_i, sk_i) enc_α ← Enc_{pk_i}(α; r_α) enc_β ← Enc_{pk_{FN}}(β) ρ ← TS.Sign_{mk_i}((\$, enc_α, enc_β); r_{gs}) ψ ← ProveZK(x, w) with x = (P_i, τ.com, \$, α, enc_α, enc_β, ρ) w = (mk_i, r_{P_i}, r_α, r_{com}, r_{gs}) such that P_i.ρ = TS.Sign_{mk_i}(P_i.r; r_{P_i}) enc_α = Enc_{pk_i}(α; r_α) τ.com = Com(mk_i; r_{com}) ρ = TS.Sign_{mk_i}((\$, enc_α, enc_β); r_{gs}) co ← (P_i, τ, \$, α, enc_α, enc_β, ρ, ψ) return co ⊤/⊥ ← VerifyCheckout(co): Parse co into ([P_i,]τ, \$, α, enc_α, enc_β, ρ, ψ) VerifyCheckoutCred_{pk_{PS}}(τ) Check if (τ.rk, τ.pr, τ.dl) is acceptable Check if τ is unique within τ.dl TS.Ver_{pk_{C_i}}((\$, enc_α, enc_β), ρ) VerifyZK([P_i,]τ.com, \$, α, enc_α, enc_β, ρ, ψ) If all the checks above pass, return 1 Otherwise return 0 ⊤/⊥ ← VerifyPmtOrder(SK_{FN}, po): Parse po into (\$, enc_α, enc_β, ρ) TS.Ver_{pk_{C_i}}((\$, enc_α, enc_β), ρ) β = Dec_{sk_{FN}}(enc_β) Check if β has not been used before Check if TS.Open_{sk_{C_i}}(ρ) equals C_i in β Verify the other billing info in β If all the checks above pass, return 1 Otherwise return 0 </pre>	<pre> co ← IssueAnonCheckout(SK_{C_i}, τ, α, \$, β): Parse SK_{C_i} = (P_i, mk_i, r_{P_i}, pk_i, sk_i) enc_α ← Enc_{pk_i}(α; r_α) enc_β ← Enc_{pk_{FN}}(β) ρ ← TS.Sign_{mk_i}((\$, enc_α, enc_β); r_{gs}) ψ ← ProveZK(x, w) with x = (τ.com, \$, α, enc_α, enc_β, ρ) w = (mk_i, r_α, r_{com}, r_{gs}) such that enc_α = Enc_{pk_i}(α; r_α) τ.com = Com(mk_i; r_{com}) ρ = TS.Sign_{mk_i}((\$, enc_α, enc_β); r_{gs}) co ← (τ, \$, α, enc_α, enc_β, ρ, ψ) return co po ← IssuePmtOrder(co): VerifyCheckout(co) If verification fails, return 0 Parse co into ([P_i,]τ, \$, α, enc_α, enc_β, ρ, ψ) If P_i is present, update P_i's history po ← (\$, enc_α, enc_β, ρ) return po rc ← IssueReceipt(SK_{M_j}, co): rc ← Sign_{sk_{M_j}}(co) return rc ⊤/⊥ ← VerifyReceipt(rc, co): Find identity M_j from α in co return SVer_{pk_{M_j}}(co, rc) </pre>
--	--

Fig. 6 Checkout algorithms

Step 6: M_j issues a receipt. M_j receives the confirmation from PS and runs `IssueReceipt`, issuing rc , a signature on co . Finally, C_i verifies rc with `VerifyReceipt`.

Delivery. Once C_i receives rc , he can use it to prove in ZK that he actually payed for some transaction co , and initiate additional processes, like having DC deliver the goods through APOD [5]. This proof is obtained with the processes in Fig. 7. In the showing process, if C_i received a receipt rc , he shows rc along with the corresponding checkout object co ; then, using his membership key mk_i , he claims ownership of a traceable signature contained in co . Even if he did not receive a receipt, he can prove ownership of ρ to FN (using `ShowReceiptZK` too). Since FN is semi-honest, C_i may ask FN to cancel the associated payment (or *force* PS and M_j to reissue the receipt).

In order to interconnect with APOD, C_i proves M_j being the owner of rc (through `ShowReceiptZK`). Then, M_j issues the credential `cred` required by APOD as in

$\begin{aligned} \pi &\leftarrow \text{ShowReceiptZK}(\text{SK}_{C_i}, \text{rc}, \text{co}): \\ \text{Parse } \text{co} &= ([P_i], \tau, \$, \alpha, \text{enc}_\alpha, \text{enc}_\beta, \varrho, \psi) \\ \pi &\leftarrow \text{TS.Claim}_{mk_i}(\varrho) \\ \text{return } \pi \end{aligned}$	$\begin{aligned} \top/\perp &\leftarrow \text{VerifyReceiptZK}(\text{rc}, \text{co}, \pi): \\ \text{Parse } \text{co} &= ([P_i], \tau, \$, \alpha, \text{enc}_\alpha, \text{enc}_\beta, \varrho, \psi) \\ &\text{VerifyReceipt}(\text{rc}, \text{co}) \\ &\text{TS.ClaimVer}_{pk_G}(\pi, \varrho) \\ &\text{If all the checks pass, return } 1 \\ &\text{Otherwise return } 0 \end{aligned}$
---	--

Fig. 7 Full system processes for claiming rc in Zero-Knowledge

[5]. Note however that the incorporation of APOD incurs in additional costs and the need for further cryptographic tokens for merchants (who could delegate this task to PS). A less anonymous delivery method, but probably good enough for many contexts, could be using Post Office boxes (or equivalent delivery methods) [33].

Completion. When C_i receives the goods, the completion phase may take place. In this phase, C_i may leave feedback or initiate a claim, for which he needs to prove having purchased the associated items. For this purpose, C_i can again make use of the ShowReceiptZK and VerifyReceiptZK processes, defined in Fig. 7.

8 Security

We assume that customers and merchants can act maliciously. PS is assumed to be semi-honest during checkout-credential retrieval, but malicious otherwise. FN is semi-honest. Additionally, we use the following oracles to give the adversary additional powers when necessary.

- (Add clients) This oracle, written AddC , allows the adversary to add a new client. The public/private key, pseudonym, and payment information of the client will be recorded. Finally, it returns the public key and pseudonym of the client.
- (Add merchants) This oracle, written AddM , allows the adversary to add a new merchant. However, the adversary does not observe any secret information of this merchant. The public/private key of the merchant will be recorded. Finally, it returns the public key of the merchant.
- (Corrupt clients) This oracle, written CorC , allows the adversary to corrupt a client in the system, i.e., the adversary will have all information about the target client.
- (Corrupt merchants) This oracle, written CorM , allows the adversary to corrupt a merchant in the system, that is, the adversary will have all the information about the target merchant.
- (Process checkout) This oracle, DoCheckout , is given as input a checkout co , and if co is valid, it will process the checkout (as would be done by PS and FN.)
- (Process confirmation) This oracle, DoConfirm , is given as input a checkout co , and if co is valid, returns the corresponding receipt rc (as would be done by the corresponding merchant M_j .)

- (Process transaction) This oracle, Transaction, executes the complete process, including the checkout-credential retrieval and checkout, as would be done by a customer C_i , producing the resulting co and rc .

8.1 Security Properties

Privacy. The system possesses the following privacy properties.

- *Customer anonymity.* Customer anonymity requires that if a customer creates an anonymous checkout co , then no coalition of merchants, PS , and other customers should be able to determine the identity or pseudonym of the customer from co . We describe this requirement by using the following game.

Experiment $\text{Exp}_{\mathcal{A}}^{\text{CA}}[b, k]$:
 $(\text{PK}_{\text{FN}}, \text{SK}_{\text{FN}}) \leftarrow \text{FNSetup}(1^k).$
 $(\text{PK}_{\text{PS}}, \text{SK}_{\text{PS}}) \leftarrow \text{PSSetup}(1^k).$
 $(C_0, C_1, M, \alpha, \$) \leftarrow \mathcal{A}(\text{PK}_{\text{FN}}, \text{PK}_{\text{PS}}, \text{SK}_{\text{PS}} : \text{AddC}, \text{CorC}, \text{AddM}, \text{CorM}, \text{DoCheckout})$
 If C_0 or C_1 is corrupted, **return** 0.
 Let (β_0, P_0) and (β_1, P_1) be the billing info and pseudonym of C_0 and C_1 .
 $\tau_0 \leftarrow \text{CheckoutCredRetrieval}(\text{PK}_{\text{PS}}, \text{PK}_{\text{FN}}, P_0)[C_0(\text{SK}_{C_0}), \mathcal{A}]$
 $\tau_1 \leftarrow \text{CheckoutCredRetrieval}(\text{PK}_{\text{PS}}, \text{PK}_{\text{FN}}, P_1)[C_1(\text{SK}_{C_1}), \mathcal{A}]$
 If τ_0 and τ_1 have different (risk, promo, deadline)s, **return** 0.
 $co \leftarrow \text{IssueAnonCheckout}(\text{SK}_{C_b}, \tau_b, \alpha, \$, \beta_b).$
 $\tilde{b} \leftarrow \mathcal{A}(co : \text{DoCheckout}).$
return $\tilde{b}.$

We say that a private payment system has **customer anonymity** if, for any stateful ppt algorithm $\mathcal{A}$, $|\Pr[\text{Exp}_{\mathcal{A}}^{\text{CA}}[0, k] - \Pr[\text{Exp}_{\mathcal{A}}^{\text{CA}}[1, k]]|$ is negligible in k .

This property matches the *Hide the identity of a customer* property in Sect. 6.1. Note however that we condition it to the customer choosing to run an anonymous checkout process.

- *Transaction privacy against merchants and PS.* No coalition of merchants, PS and other customers should be able to determine the payment information (credit card number, etc.) in a customer's transaction. The following game describes this requirement.

Experiment $\text{Exp}_{\mathcal{A}}^{\text{TPMPS}}[b, k]$:
 $(\text{PK}_{\text{FN}}, \text{SK}_{\text{FN}}) \leftarrow \text{FNSetup}(1^k).$
 $(\text{PK}_{\text{PS}}, \text{SK}_{\text{PS}}) \leftarrow \text{PSSetup}(1^k).$
 $(C, M, \alpha, \beta_0, \beta_1, \$) \leftarrow \mathcal{A}(\text{PK}_{\text{FN}}, \text{PK}_{\text{PS}}, \text{SK}_{\text{FN}} : \text{AddC}, \text{AddM})$
 Let P be the pseudonym of C .
 $\tau \leftarrow \text{CheckoutCredRetrieval}(\text{PK}_{\text{PS}}, \text{PK}_{\text{FN}}, P)[C(\text{SK}_C), \text{PS}(\text{SK}_{\text{PS}})]$
 $co \leftarrow \text{IssueCheckout}(\text{SK}_C, \tau, \alpha, \$, \beta_b).$
 $po \leftarrow \text{IssuePmtOrder}(co).$
 $\tilde{b} \leftarrow \mathcal{A}(co, po).$
return $\tilde{b}.$

We say that a private payment system has **transaction privacy against merchants and PS** if, for any stateful ppt algorithm $\mathcal{A}$, it holds that $|\Pr[\mathbf{Exp}_{\mathcal{A}}^{\text{TPMPS}}[0, k] - \Pr[\mathbf{Exp}_{\mathcal{A}}^{\text{TPMPS}}[1, k]]|$ is negligible in k .

This property matches the *Hide the payment information* property in Sect. 6.1.

- *Transaction privacy against FN.*

According to this requirement, the financial network FN should not be able to determine the detail of a customer's transaction beyond what is necessary, i.e., the customer identity and the amount of payment; in particular, the product information and the merchant identity of each transaction should be hidden from FN. We describe this requirement by using the following game.

Experiment $\mathbf{Exp}_{\mathcal{A}}^{\text{TFN}}[b, k]$:
 $(\text{PK}_{\text{FN}}, \text{SK}_{\text{FN}}) \leftarrow \text{FNSetup}(1^k).$
 $(\text{PK}_{\text{PS}}, \text{SK}_{\text{PS}}) \leftarrow \text{PSSetup}(1^k).$
 $(C, M_0, M_1, \alpha_0, \alpha_1, \$) \leftarrow \mathcal{A}(\text{PK}_{\text{FN}}, \text{PK}_{\text{PS}}, \text{SK}_{\text{FN}} : \text{AddC}, \text{AddM})$
 Let (β, P) be the payment information, and pseudonym of C .
 $\tau \leftarrow \text{CheckoutCredRetrieval}(\text{PK}_{\text{PS}}, \text{PK}_{\text{FN}}, P)[C(\text{SK}_C), \text{PS}(\text{SK}_{\text{PS}})]$
 $\text{co} \leftarrow \text{IssueCheckout}(\text{SK}_C, \tau, \alpha_b, \$, \beta).$
 $\text{po} \leftarrow \text{IssuePmtOrder}(\text{co}).$
 $\tilde{b} \leftarrow \mathcal{A}(\text{po}).$
return $\tilde{b}$.

We say that a private payment system has **transaction privacy against FN** if, for any stateful ppt algorithm $\mathcal{A}$, it holds that $|\Pr[\mathbf{Exp}_{\mathcal{A}}^{\text{TFN}}[0, k] - \Pr[\mathbf{Exp}_{\mathcal{A}}^{\text{TFN}}[1, k]]|$ is negligible in k .

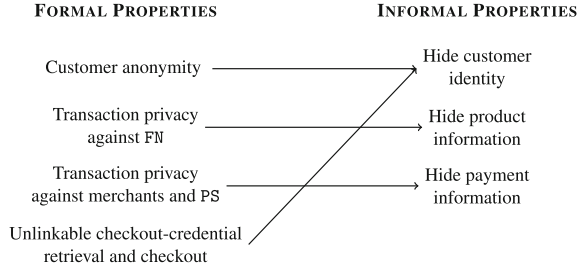
This property matches the *Hide the product information* stated in Sect. 6.1.

- *Unlinkable checkout-credentialretrieval and checkout.* If a customer runs an anonymous checkout, no coalition of merchants, PS, and other customers should be able to link the customer or his pseudonym to the corresponding checkout-credential retrieval procedure beyond what the common message in the credential reveals. We describe this requirement by using the following game.

Experiment $\mathbf{Exp}_{\mathcal{A}}^{\text{URC}}[b, k]$:
 $(\text{PK}_{\text{FN}}, \text{SK}_{\text{FN}}) \leftarrow \text{FNSetup}(1^k).$
 $(\text{PK}_{\text{PS}}, \text{SK}_{\text{PS}}) \leftarrow \text{PSSetup}(1^k).$
 $(C, M, \alpha, \$) \leftarrow \mathcal{A}(\text{PK}_{\text{FN}}, \text{PK}_{\text{PS}}, \text{SK}_{\text{PS}} : \text{AddC}, \text{CorC}, \text{AddM}, \text{CorM}, \text{DoCheckout})$
 If C is corrupted, **return 0**.
 Let (β, P) be the billing info and pseudonym of C respectively.
 $\tau_0 \leftarrow \text{CheckoutCredRetrieval}(\text{PK}_{\text{PS}}, \text{PK}_{\text{FN}}, P)[C(\text{SK}_C), \mathcal{A}]$
 $\tau_1 \leftarrow \text{CheckoutCredRetrieval}(\text{PK}_{\text{PS}}, \text{PK}_{\text{FN}}, P)[C(\text{SK}_C), \mathcal{A}]$
 If τ_0 and τ_1 have different (risk, promo, deadline)s, **return 0**.
 $\text{co} \leftarrow \text{IssueAnonCheckout}(\text{SK}_C, \tau_b, \alpha, \$, \beta).$
 $\tilde{b} \leftarrow \mathcal{A}(\text{co} : \text{DoCheckout}).$
return $\tilde{b}$.

We say that a private payment system has **unlinkable checkout-credentialretrieval and checkout** if, for any stateful ppt algorithm $\mathcal{A}$, $|\Pr[\mathbf{Exp}_{\mathcal{A}}^{\text{URC}}[0, k] - \Pr[\mathbf{Exp}_{\mathcal{A}}^{\text{URC}}[1, k]]|$ is negligible in k .

Fig. 8 Mapping between informal privacy properties in Sect. 6.1 and formal privacy properties in this section



Note that if the checkout-credential retrieval and checkout phases were linkable even in anonymous checkouts, it would not be possible to achieve customer anonymity. Thus, the need to ensure this property, which is not present in the version in Sect. 6.1, is consequence of having divided the whole process in two phases.

Note that this properties map to the properties in Sect. 6.1, with some additional conditions (see Fig. 8 for a pictorial representation). It is also worth noting that there are indirect connections between them. For instance, *transaction privacy against FN* and *transaction privacy against merchants and PS* undoubtedly improves resistance against differential privacy attacks aimed at deanonymizing customers (hence, affecting the *Customer anonymity*). However, as stated in the conclusion, a detailed analysis of these aspects is out of the scope of this chapter and is left for future work.

Robustness. The system also ensures the following robustness properties, needed to prevent faulty executions.

- *Checkout-credential unforgeability.* A customer should not be able to forge a valid checkout-credential that contains a risk factor or a promotion or a deadline set by his own choice. We describe this requirement by using the following game.

Experiment $\text{Exp}_{\mathcal{A}}^{\text{CCU}}[k]$:

$(\text{PK}_{\text{FN}}, \text{SK}_{\text{FN}}) \leftarrow \text{FNSetup}(1^k).$

$(\text{PK}_{\text{PS}}, \text{SK}_{\text{PS}}) \leftarrow \text{PSSetup}(1^k).$

$\tau \leftarrow \mathcal{A}(\text{PK}_{\text{FN}}, \text{PK}_{\text{PS}} : \text{AddC}, \text{CorC}, \text{CheckoutCredRetrieval}_{\text{SK}_{\text{PS}}})$

If $\text{VerifyCheckoutCred}_{\text{PK}_{\text{PS}}}(\tau) = 1$ and $(\tau.rk, \tau.pr, \tau.dl)$ was never observed by $\text{CheckoutCredRetrieval}_{\text{SK}_{\text{PS}}}$:

return 1;

Otherwise **return** 0.

We say that a private payment system has **checkout-credential unforgeability** if, for any stateful ppt algorithm $\mathcal{A}$, it holds that $\Pr[\text{Exp}_{\mathcal{A}}^{\text{CCU}}[k] = 1]$ is negligible in k .

- *Checkout unforgeability.* With a valid checkout-credential τ issued for a customer, no coalition of other customers, merchants, and PS should be able to forge a valid checkout co containing τ . We describe this requirement by using the following game.

Experiment $\text{Exp}_{\mathcal{A}}^{\text{CU}}[k]$:

$(\text{PK}_{\text{FN}}, \text{SK}_{\text{FN}}) \leftarrow \text{FNSetup}(1^k).$

$(\text{PK}_{\text{PS}}, \text{SK}_{\text{PS}}) \leftarrow \text{PSSetup}(1^k).$

$(C, \text{co}) \leftarrow \mathcal{A}(\text{PK}_{\text{FN}}, \text{PK}_{\text{PS}}, \text{SK}_{\text{PS}} : \text{AddC}, \text{AddM}, \text{CorC}, \text{CorM}, \text{Transaction})$

If co has been processed before, **return** 0.

If $\text{VerifyCheckout}(\text{co}) = 0$, **return** 0.

If C has never got risk/promotion in co , but co deducts C 's balance

return 1; otherwise **return** 0.

We say that a private payment system has **checkout unforgeability** if, for any stateful ppt algorithm $\mathcal{A}$, it holds that $\Pr[\text{Exp}_{\mathcal{A}}^{\text{CU}}[k] = 1]$ is negligible in k .

- *Fraudulent transaction traceability.* When a customer C performs a fraudulent transaction, FN and PS are able to trace the pseudonym that C used even if the transaction is anonymous.

Experiment $\text{Exp}_{\mathcal{A}}^{\text{FTT}}[k]$:

$(\text{PK}_{\text{FN}}, \text{SK}_{\text{FN}}) \leftarrow \text{FNSetup}(1^k).$

$(\text{PK}_{\text{PS}}, \text{SK}_{\text{PS}}) \leftarrow \text{PSSetup}(1^k).$

$(C, \text{co}) \leftarrow \mathcal{A}(\text{PK}_{\text{FN}}, \text{PK}_{\text{PS}}, \text{SK}_{\text{PS}} : \text{AddC}, \text{AddM}, \text{CorC}, \text{CorM}, \text{DoCheckout})$

Let P be C 's pseudonym

If $\text{VerifyCheckout}(\text{co}) = 0$, **return** 0.

Let ϱ be the traceable signature issued by C contained in co

$b \leftarrow \text{TS.Trace}(\text{TS.Reveal}(\text{TS.Open}(\varrho)), P.\varrho,)$

return b .

We say that a private payment system has **fraudulent transaction traceability** if, for any stateful ppt algorithm $\mathcal{A}$, it holds that $\Pr[\text{Exp}_{\mathcal{A}}^{\text{FTT}}[k] = 0]$ is negligible in k .

- *Receipt unforgeability.* No coalition of customers, merchants (other than the target merchant M), and PS should be able to forge a valid receipt that looks originating from M . We describe this requirement by using the following game.

Experiment $\text{Exp}_{\mathcal{A}}^{\text{RU}}[k]$:

$(\text{PK}_{\text{FN}}, \text{SK}_{\text{FN}}) \leftarrow \text{FNSetup}(1^k).$

$(\text{PK}_{\text{PS}}, \text{SK}_{\text{PS}}) \leftarrow \text{PSSetup}(1^k).$

$M \leftarrow \mathcal{A}(\text{PK}_{\text{FN}}, \text{PK}_{\text{PS}} : \text{AddC}, \text{AddM}, \text{CorC}, \text{CorM}, \text{DoCheckout})$

If merchant M is corrupted, **return** 0

$(\text{co}, \text{rc}) \leftarrow \mathcal{A}(\text{PK}_{\text{FN}}, \text{PK}_{\text{PS}} : \text{AddC}, \text{AddM}, \text{CorC}, \text{CorM}, \text{DoConfirm})$

If the merchant M is corrupted, **return** 0

If co was queried to DoCheckout , **return** 0

If $\text{VerifyReceipt}(\text{rc}, \text{co}) = 0$, **return** 0

return 1

We say that a private payment system has **receipt unforgeability** if, for any stateful ppt algorithm $\mathcal{A}$, it holds that $\Pr[\text{Exp}_{\mathcal{A}}^{\text{RU}}[k] = 1]$ is negligible in k .

- *Receipt claimability.* For a valid receipt from an uncorrupted customer, no other customer should be able to successfully claim the ownership of the confirmation.

Experiment $\text{Exp}_{\mathcal{A}}^{\text{RC}}[k]$: $(\text{PK}_{\text{FN}}, \text{SK}_{\text{FN}}) \leftarrow \text{FNSetup}(1^k).$ $(\text{PK}_{\text{PS}}, \text{SK}_{\text{PS}}) \leftarrow \text{PSSetup}(1^k).$ $(\text{co}, \text{rc}, \pi) \leftarrow \mathcal{A}(\text{PK}_{\text{FN}}, \text{PK}_{\text{PS}}, \text{SK}_{\text{PS}} : \text{AddC}, \text{AddM}, \text{CorC}, \text{CorM}, \text{Transaction})$ If rc is never issued by Transaction, **return** 0If the owner customer of (co, rc) is corrupted, **return** 0If $\text{VerifyReceiptZK}(\text{rc}, \text{co}, \pi) = 0$, **return** 0**return** 1

We say that a private payment system has **receipt claimability** if, for any stateful ppt algorithm $\mathcal{A}$, it holds that $\Pr[\text{Exp}_{\mathcal{A}}^{\text{RC}}[k] = 1]$ is negligible in k .

8.2 Security of Our System

In this section, we prove that our system satisfies the preceding security requirements. We also recall that all communications where one party is the customer are assumed to take place through an anonymizing network.

We base our proofs in the security properties of the underlying building blocks. Specifically, we mainly refer to the *blindness* and *unforgeability* properties of partially blind signatures (see, e.g., [57]); the *anonymity*, *misidentification security* and *framing security* properties of traceable signatures [46]; the *zero-knowledge* and *unforgeability* properties of zero-knowledge proof systems (see, e.g., [37]); the *unforgeability* property of digital signatures (see, e.g., [40]); and the property of *protection against identity compromise* of pseudonym systems (see, e.g., [50]).

Theorem 1 *Our system is customer anonymous.*

Proof Recall that in $\text{Exp}_{\mathcal{A}}^{\text{CA}}[b]$, $(P_b, \tau_b, \text{SK}_{C_b}, \beta_b)$ was used (other unimportant elements were omitted). We define hybrid games as follows:

Hybrid 0. This is the actual game $\text{Exp}_{\mathcal{A}}^{\text{CA}}[0]$.

Hybrid 1. It is the same as Hybrid 0 except that all ZK proofs are simulated by ZK simulator. From ZK properties for the ZK proofs, Hybrid 0 and Hybrid 1 are indistinguishable.

Hybrid 2. It is the same as Hybrid 1 except that in the first checkout-credential retrieval (to generate τ_0), it uses $\text{com} \leftarrow \text{Com}(\text{SK}_{C_1}; r_{\text{com}})$ instead of $\text{com} \leftarrow \text{Com}(\text{SK}_{C_0}; r_{\text{com}})$. From the hiding property of the commitment scheme, Hybrid 1 and Hybrid 2 are indistinguishable. Note that at this moment, the τ_0 and τ_1 are identically distributed.

Hybrid 3. It is the same as Hybrid 2 except that it generates co by running IssueAnonCheckout using τ_1 (and SK_{C_0}, β_0) instead of τ_0 . Hybrid 2 and Hybrid 3 are indistinguishable due to blindness of the underlying partial blind signature scheme. Note that the adversary (against blindness property) first generates a key pair for the blind signature and two different messages; after signing two messages

in a randomly chosen order by the game environment (for the blindness), the adversary should guess the message order (i.e., reversed or not). See [12] for more detail. We show the reduction. That is, we construct an adversary $\mathcal{B}$ breaking the blindness of the underlying partial blind scheme given an adversary distinguishing the two hybrids as follows:

$\mathcal{B}$ runs key generation algorithm for PBS to generate a key pair, and sends out the pair to the outer environment. At the same time $\mathcal{B}$ works as Hybrid game (2 or 3). In particular, when $\mathcal{A}$ chooses two customers, $\mathcal{B}$ chooses $\text{com}_0 = \text{Com}(\text{SK}_{C_1}; r_0)$ and $\text{com}_1 = \text{Com}(\text{SK}_{C_1}; r_1)$ as the two messages to distinguish and sends out $(\text{com}_0, \text{com}_1)$ to the outer environment. Once the outer environment gives the blind signature ϱ , $\mathcal{B}$ uses it to generate co . Finally, $\mathcal{B}$ outputs whatever $\mathcal{A}$ outputs.

When the signature ϱ is on com_0 , the simulation is identical to Hybrid 2; on the other hand, when ϱ is on com_1 , to Hybrid 3. Therefore, if $\mathcal{A}$ distinguishes the two hybrids with non-negligible probability, $\mathcal{B}$ also breaks the blindness property of the underlying signature with non-negligible probability.

Hybrid 4. It's the same as Hybrid 3 except that it generates co by running `IssueAnonCheckout` using $(\tau_1, \text{SK}_{C_1}, \beta_0)$ instead of $(\tau_1, \text{SK}_{C_0}, \beta_0)$. Hybrid 3 and Hybrid 4 are indistinguishable due to anonymity of the group signature scheme. The reduction is straightforward.

Hybrid 5. It is the same as Hybrid 3 except that it generates co by running `IssueAnonCheckout` using $(\tau_1, \text{SK}_{C_1}, \beta_1)$ instead of $(\tau_1, \text{SK}_{C_1}, \beta_0)$. Hybrid 4 and Hybrid 5 are indistinguishable due to semantic security of the public key encryption. The reduction is straightforward.

Hybrid 6. It is the same as Hybrid 5 except that in the first checkout-credential retrieval (to generate τ_0), it uses $\text{com} \leftarrow \text{Com}(\text{SK}_{C_0}; r_{\text{com}})$ instead of $\text{com} \leftarrow \text{Com}(\text{SK}_{C_1}; r_{\text{com}})$. From the hiding property of the commitment scheme, Hybrid 5 and Hybrid 6 are indistinguishable.

Hybrid 7. It's the same as Hybrid 6 except that ZK proofs are actually done instead of using simulations. From ZK properties for the ZK proofs, Hybrid 6 and Hybrid 7 are indistinguishable. Observe that Hybrid 7 is indeed $\text{Exp}_{\mathcal{A}}^{\text{CA}}[1]$, which concludes the proof.

Theorem 2 *Our system has the property of unlinkable checkout-credential retrieval/checkout.*

Proof The proof is the same as showing indistinguishability of Hybrid 3 and 4 in the previous proof.

Theorem 3 *Our system has transaction privacy against FN.*

Proof FN only views the encryption enc_α , and when PS creates a payment order, the payee is set to PS (instead of M_j) in order to prevent FN to link C_i and M_j . Altogether, this guarantees transaction privacy against FN from semantic security of the underlying encryption scheme.

Theorem 4 *Our system has transaction privacy against merchants and PS.*

Proof Payment information (credit card, billing address, etc.) is encrypted by C_i using FN's public key. Thus, transaction privacy against merchants and PS is guaranteed from semantic security of the underlying encryption scheme.

Claim 1 *Our system satisfies checkout-credential unforgeability.*

Proof Checkout-credential unforgeability simply follows from unforgeability of the partial blind signature scheme.

Theorem 5 *Our system satisfies checkout unforgeability.*

Proof Checkout unforgeability follows from soundness of ZK proofs. In particular, $\tau.com$ should be the commitment to mk_i due to the soundness of the proof in the checkout-credential retrieval. Moreover, the soundness of ZK proof ψ in the checkout object makes sure that both $\tau.com$ and ϱ use the same member key mk_i .

Claim 2 *Our system satisfies fraudulent transaction traceability.*

Proof Fraudulent transaction traceability holds immediately from the security against misidentification of the underlying traceable signature scheme.

Claim 3 *Our system satisfies receipt unforgeability.*

Proof Receipt unforgeability holds immediately from unforgeability of underlying the digital signature scheme.

Claim 4 *Our system satisfies receipt claimability.*

Proof Receipt unforgeability holds immediately from security against framing attacks of the underlying traceable signature scheme.

9 Testing Environment and Results

For showing the applicability of our approach, we summarize some preliminary results obtained through a prototype incorporating the functionalities described in Sect. 7. We then compare them with current industry systems. Note however that the latter systems are highly optimized ones, using distributed infrastructures. The building blocks we have used are: BFPV13 [12] for blind signatures, CPY06 [23] as traceable signatures, and Pedersen commitments [60] and SKREP as defined in [16] for proving correctness in ZK of the commitments and the various ZK proofs. The code of the prototype is available upon request.

We used a laptop (Intel Core i5-480M, 4GB DDR3, with Debian Wheezy) and a desktop PC (Intel Core i7-2600, 16GB DDR3, with Debian Wheezy). We center our attention in the most frequent actions: anonymous and pseudonymous checkouts. For RSA keypairs, we used a module of 1024 bits, while for ECC we used 160

Table 2 Summary of results. *AL* stands for round-trip Absolute Latency: total time since the customer starts the request until he receives the response. *T_{PS}* stands for Throughput at the Payment System's side: total number of requests successfully answered, per second (in real time, including time spent in data transfers). *Bytes* indicates the average size in bytes of the messages sent/received during the action, for each involved entity. All results are averaged over 1000 transactions of the corresponding type

<i>Action</i>		<i>AL</i> (s)	<i>T_{PS}</i> (reqs/s)	<i>Bytes</i> (sent/recv)
Checkout-credential retrieval		1.26(±0.49)	1.03	C: 4426/793 PS: 793/4426
Checkout	Anon.	1.68(±0.47)	3.01	C: 4212/291 M: 4133/4358 PS: 1549/3908 FN: 66/1403 C: 5850/291
	Pnym.	1.83(±0.43)	2.95	M: 6828/5996 PS: 1549/6603 FN: 66/1403

bit elements. Additionally, our prototype included a MySQL database where both PS and FN keep the necessary data. We also run the following fraud prevention and marketing procedures: each time a checkout-credential was requested, PS issued a \$5 discount for customers having already spent over \$100; it also checked that no more than 10 purchases were made during the same day and ran the AVS test. Additionally, during checkout, PS rejected any transaction of more than \$1000, and FN performed billing/shipping matching. During checkout-credential retrieval, the customer role was played by the laptop (with 4 parallel threads), and the PS role by the desktop PC (with 8 parallel threads). During checkout, the laptop ran as a customer and merchant (each process spawning 2 threads), with the desktop PC acting as PS and FN (each process spawning 4 threads). Note that the PS throughput measures the average time intervals between the time PS receives a request and the time it has processed the response, ignoring the time taken to transmit them. Finally, at the moment the tests were performed, each machine was in a different network, with the `traceroute` command showing a route of 16 hops between them, and average round-trip time of 44 ms. The results are summarized in Table 2.

To provide some context, Magento, one of the main e-commerce platform providers, claims to achieve 593 purchases per hour (~ 0.17 per second) with the 2.0 version of their system running on a 4 core domestic server or roughly 2500 orders per hour (~ 0.7 per second) using 100 parallel threads.⁸ Of course, it is important to note that we have simplified some necessary parts of the process, such as the payment transaction itself (which is just simulated through a database modification). This, however, is likely to be a relatively negligible (i.e., very fast) operation compared to the overall e-shopping transaction: for instance VISA processed 141.0

⁸<https://magento.com/sites/default/files/White%20Paper%20-%20Magento%202.0%20Performance%20and%20Scalability%203.31.16.pdf>. Last access on March 21st, 2018.

billion transactions in 2016,⁹ which makes roughly 4500 transactions per second (this does not necessarily imply quick payments, but serves to get an idea).

Taking into account the limitations of our experiments (both in hardware equipment and software optimization), it is quite notable that we achieved a rate of $1.03 T_{PS}$ (which may be seen as the equivalent of TPS) for checkout-credential retrieval and a rate of roughly 3 TPS for checkout (a bit higher for anonymous ones and a bit lower for pseudonymous). These figures are undoubtedly in the range of Magento's (even accounting for the mentioned payment simplification).

As for the communication costs, as seen in Table 2, the heavier load is taken by PS and FN. PS sends roughly $793 + 1549 = 2342$ Bytes and receives roughly $4426 + 3908 = 8334$ (anonymous checkouts) and $4426 + 6603 = 11029$ (pseudonymous checkouts) Bytes. FN sends roughly 66 Bytes and receives 1403 during checkout. Hence, PS supports approximately 10 times more communication overload than Bitcoin's peers in the best comparison. This is not bad, given the overhead of cryptography used heavily in privacy-oriented communication, and further, this proportion can probably be greatly improved by further optimization.

Concerning the sizes of the groups of customers in the group signature schemes, we note that this is a highly configurable aspect. For instance, groups can be set based on geographies, based on sign up time, or any other heuristic. As for the impact on performance of the sizes of the groups, we refer to [32], which we have used to implement our prototype and offers some raw statistics about the group sizes and throughput of the main operations, and to [30, 31] for possible implementations using standard PKIs.

10 Additional Functionality for the Full System

Next, we discuss how to implement privacy-preserving operations and support transactions that are usually added to the basic e-shopping life cycle in various scenarios.

Fraud prevention filters. Our system supports the following fraud prevention filters. Each filter is on the transaction-level (tx-level) or the account-level (acc-level), depending on whether it checks the information specific to transactions or to accounts (i.e., customers).

- *Pseudonym velocity filter (acc-level)*: It measures how many recent purchases have been initiated by the same pseudonym (similar to PayPal's IP velocity filter). It can be applied during checkout-credential retrieval.
- *Suspicious shipment changes (acc-level)*: This filter can be added by making the city/country of shipment visible, e.g., including it in the common message of the partially blind signature obtained during checkout-credential retrieval. Note that revealing the city/country would not be privacy sensitive in most occasions.

⁹<https://usa.visa.com/dam/VCOM/global/about-visa/documents/visa-facts-figures-jan-2017.pdf>. Last access on March 21st, 2018.

- *Address verification system (AVS, acc-level)*: This filter can be employed by introducing the billing address within the payment information encrypted under FN's public key. In this manner, only FN would be able to receive it and perform the AVS test as usual.
- *Billing/Shipping Address Mismatch Filter (tx-level)*: With Locality Sensitive Hashing (LSH) [20, 59], this filter can be added as follows. C computes two hashes $\tilde{b} \leftarrow H(b, r)$, $\tilde{s} \leftarrow H(s, r)$, where b and s are the billing and shipping address, respectively, and r is a random value. Then it sends $(r, \tilde{b}, \tilde{s})$ to M during checkout, who compares them. The probability of obtaining a match will be proportional to the similarity of b and s due to the properties of LSH. Since FN later checks if $\tilde{b}$ is equal to $H(\text{billing}, r)$ using the actual billing address *billing*, the filter works correctly.
- *Maximum price per order (tx-level)*: This filter is trivial to apply by M or PS.
- *Maximum number of items per order (tx-level)*: Trivial to apply by M or PS.
- *Other filters*: Filters like *Currency type*, *Bank Identification Number*, *Transaction type* [45] may be directly applied.

Note that the account-level filters (excluding AVS by FN) are applied by PS during the checkout-credential retrieval phase. Thus, anonymous checkouts do not affect their effectiveness. Transaction-level filters may be applied by either PS or merchants. Also, since an account risk estimation is passed to the checkout phase as part of the checkout-credential, both account and transaction risks may be considered jointly, even for completely anonymous checkouts.

Marketing techniques. In our system, PS issues promotions during checkout-credential retrieval, consulting the pseudonym's history. In [47], promotions are classified depending on for how long they can be applied (limited or unlimited) and the intended recipient (targeted or untargeted). Untargeted and unlimited (UU) promotions are trivial. The other three combinations may be achieved as follows:

- *Targeted and unlimited (TU)*. C creates a group signature on the promotion and includes it in the blindly signed message at checkout-credential retrieval. At checkout, C includes this group signature in the ZK proofs (verified in *VerifyZK* in Fig. 6).
- *Untargeted and limited (UL)*. Simply include a deadline in the promotion.
- *Targeted and limited (TL)*. Add a group signature as in TU promotions, specifying the target and deadline.

Our system could also be extended to support merchant-issued promotions. To do this, a group of merchants should be set up, and each merchant M_j should have a policy pr_{M_j} for issuing promotions. Before initiating checkout-credential retrieval, M_j would send $(\text{pr}_{M_j}, \text{Sign}(sk_{M_j}, \alpha))$ to customer C_i . C_i would then include pr_{M_j} within the common message and $\text{Sign}(sk_{M_j}, \alpha)$ within the blinded message, both to be signed by PS during checkout-credential retrieval. After verifying the group signature, PS would just grant the promotions that C_i is eligible for, based on pr_{M_j} . During checkout, M_j would also verify $\text{Sign}(sk_{M_j}, \alpha)$ in order to prevent C_i using pr_{M_j} with another M_i .

Anonymous product returns for physical goods. Product returns may not be directly applicable, since APOD [5] only explicitly supports delivery from the merchant to the customer, but we can overcome this issue by allowing the customer to specify a return path at the beginning of the APOD protocol and setting up an additional APOD PIN code set for the merchant to receive the returned package. Then, the customer can instruct the initial carrier to deliver back the product.

Contact customer. This might be necessary in extraordinary situations. For pseudonymous checkouts, a pseudonymous email address associated with the customer's account may be used. For anonymous checkouts, one-time email addresses should be employed, e.g., using an anonymous email service, like Bitmessage.ch. Alternatively, customers could prove in ZK ownership of a receipt, and then receive any notification related to it. However, this requires an active behavior from customers instead of just receiving an email.

Customer opinions. In order to add an opinion about a specific purchase, the customer may just generate a group-signed opinion and create a ZK proof (similar to those sent during checkout) covering this group signature and a claim (like in Fig. 7) of the receipt obtained during checkout. Any valid opinion would then just be shown in the corresponding website.

Subscriptions. If fees are paid in advance, this is easily solved. For physical goods (e.g., using APOD), customers may initially set up multiple shipment information, one for each delivery. For periodic digital goods, M may request C to claim ownership of the checkout group signatures as in Fig. 7 (adding a ZK proof with the same member key depending on some varying value for preventing precomputations) to send the periodic digital good.

For recurring payments, the associated instruction could be sent to FN within the payment information. Also, if customer consent is required to renew the subscription, a notification could be sent to him (see *Contact customer* above).

Taxation. Assuming that revealing the city, province, state, or country of shipment is not privacy threatening, and including it within the common message of the checkout-credential, our system provides all the typically necessary information for tax calculation by either PS or merchant. That is, customer (destination) locality, merchant (source) locality, and type of good.

Alternative payment methods. Note that we have omitted specific details about the payment method. Therefore, our system would be easily compatible with any payment method, such as card based payments or cryptocurrencies, such as Bitcoin [54] and Ripple.¹⁰ Indeed, with cryptocurrencies, although the entity FN still exists, its role is reduced, mainly acting as an entry point to the payment system. In particular, the payment information does not necessarily include the real identity of a client or the billing address; instead, clients will indirectly prove ownership of an account (represented by a public key) by demonstrating that they control the corresponding

¹⁰<https://ripple.com/>. Ripple is an open system for interoperation between different payment methods, e.g., Bitcoin, real currencies, or account-based transactions.

private key. Now, when FN opens the received group signature, FN cannot match the signer's identity with the one in the payment information, since the payment information would not contain the real identity of the customer. However, group signatures are still useful for enabling privacy-preserving fraud prevention and marketing techniques during the rest of the process. Additionally, in Bitcoin/Ripple, the balance of each account is public given the account identifier, and verifying that the customer has enough funds is straightforward. Still, due to lack of certain pieces of information (e.g., billing addresses), some FN-owned filters for verifying other aspects (e.g., the AVS test) may not be applicable. Nevertheless, merchants not willing to accept alternative payment methods may just reject them by using the *Bank Identification Number* filter (Bitcoin/Ripple "acting" as banks).

Combined with Ripple, our system will have greater payment flexibility, while still maintaining good privacy guarantees. With Bitcoin, the degree of trust placed in FN can be greatly reduced, due to the nature of Bitcoin guaranteeing verifiable payment transactions. Moreover, Bitcoin itself does not guarantee anonymity nor unlinkability very well [6], so the privacy guarantees in our system are beneficial. Finally, both Bitcoin and Ripple would benefit from the rich set of useful features mentioned above, and this allows them to be native part of a comprehensive e-commerce system.

11 Conclusion and Future Work

We have put forth our proposal for reaching a balance between privacy and utility in e-shopping. This is a complex scenario, where the diverse set of functionalities required by the industry makes it hard to provide them in a privacy respectful manner [33]. Moreover, the condition of having to maintain similar information flows and general architecture greatly constrains the application of traditional privacy-by-design principles. For this purpose, we have set out our methodology, extrapolated from simpler cases in cryptography which begin by offering a functionality constrained primitive providing the highest privacy protections; but then are modified to incorporate back some of the lost utility. We refer to this methodology as "*utility, privacy, and then utility again*". While we apply it to the context of e-shopping, this strategy is not restricted to it, and can be applied to transition from policy to engineering in privacy protection in already deployed systems [26]. In other words, our work contributes to build up the Business, Legal, and Technical framework [42] demanded to reconcile economic interests, citizens' rights, and users' needs in today's scenario.

Concerning our proposed e-shopping solution, with respect to the related works summarized in Sect. 2, our proposal has the advantage of integrating all core components of e-shopping (purchase, checkout, delivery, and completion) and the advanced functionality in industry systems (marketing and fraud prevention). To the best of our knowledge, this is a currently unsolved problem [33, 67].

Note that our system provides a basic infrastructure for building privacy respectful systems requiring user profiling. Specifically, users pseudonymously obtain customized credentials based on their history, and then anonymously prove possession of

those credentials unlinkably to the pseudonymous phase. We have also implemented a prototype of our system, showing its practicability and low added costs.

Nevertheless, further work is necessary. We can also include aggregated antifraud and promotions information that is publicly accessible from the checkout-credential. Hence, an open problem is reducing the impact of this leak for reidentification, both trying to conceal that data (we sketch initial ideas in Sect. 11.1) and by studying optimal partitions for fraud and promotion values assuming a minimum volume of purchases.

11.1 Sketch on ZK Approach for Fraud

The major aspect limiting the privacy level achieved by our proposal in Sect. 7 is the inclusion of antifraud and marketing metainformation in the public part of the checkout-credential. Next, we informally sketch a proposal for moving fraud information to the blindly signed part of the checkout-credential and proving in ZK its correctness.

Antifraud information is actually a risk score, e.g., a number between 0 and 10, where 0 means no risk and 10 means maximum risk. Then, as in `CheckoutCredRetrieval`:

1. The customer C_i initiates the process, sending his pseudonym P_i .
2. PS estimates P_i 's fraud risk to be, e.g., x , and sends it back to C_i .

Subsequently, instead of introducing x as part of the common message, PS and C_i proceed as follows:

1. C_i commits to x , includes the commitment in the blinded message, and issues a ZK proof of correctness.
2. PS verifies the proof and issues the blind signature (the checkout-credential).

Finally, during checkout, C_i requests M_j to specify its maximum acceptable fraud risk estimation. Say M_j accepts a risk up to y (and, for the sake of illustration, that $x < y$). Then, in addition to the current proofs, C_i attaches a proof showing that x lies in the interval $[0, y]$ [14]. This would effectively increase the size of possible candidates of having retrieved that credential to all those customers with a fraud risk estimation less than y , instead of equal to x .

Acknowledgements The work of Jesus Diaz was done in part in the Universidad Autónoma de Madrid and while visiting the Network Security Lab at Columbia University. The work of Seung Geol Choi was supported in part by ONR award N0001418WX01542 and NSF award #1618269. The work of David Arroyo was supported by projects S2013/ICE-3095-CM (CIBERDINE) and MINECO DPI2015-65833-P of the Spanish Government. The work of Francisco B. Rodriguez was supported by projects MINECO TIN2014-54580-R and TIN2017-84452-R of the Spanish Government. The work of Moti Yung was done in part while visiting the Simons Institute for Theory of Computing, UC Berkeley.

References

1. Abe, M., & Fujisaki, E. (1996). How to date blind signatures. In *ASIACRYPT* (pp. 244–251).
2. Aiello, W., Ishai, Y., & Reingold, O. (2001). Priced oblivious transfer: How to sell digital goods. In *EUROCRYPT* (pp. 119–135).
3. Anderson, R. J. (2012). Risk and privacy implications of consumer payment innovation. <http://www.cl.cam.ac.uk/~rja14/Papers/anderson-frb-kansas-mar27.pdf>.
4. Anderson, R. J., Barton, C., Böhme, R., Clayton, R., van Eeten, M., Levi, M., et al. (2012). Measuring the cost of cybercrime. In *WEIS 2012, Germany, 25–26 June 2012*.
5. Androulaki, E., & Bellovin, S. M. (2009). APOD: Anonymous physical object delivery. In *Privacy Enhancing Technologies* (pp. 202–215).
6. Androulaki, E., Karame, G., Roeschlin, M., Scherer, T., & Capkun, S. (2013). Evaluating user privacy in bitcoin. In *Financial Cryptography* (pp. 34–51).
7. Antoniou, G., & Batten, L. M. (2011). E-commerce: Protecting purchaser privacy to enforce trust. *Electronic Commerce Research*, 11(4), 421–456.
8. Arroyo, D., Diaz, J., & Gayoso, V. (2015). On the difficult tradeoff between security and privacy: Challenges for the management of digital identities. In *International Joint Conference - CISIS'15 and ICEUTE'15, 8th International Conference on Computational Intelligence in Security for Information Systems/6th International Conference on European Transnational Education, Burgos, Spain, 15–17 June 2015* (pp. 455–462).
9. Bellare, M., Boldyreva, A., Desai, A., & Pointcheval, D. (2001). Key-privacy in public-key encryption. In C. Boyd (Ed.), *ASIACRYPT 2001* (Vol. 2248, pp. 566–582). LNCS. Heidelberg: Springer.
10. Ben-Sasson, E., Chiesa, A., Garman, C., Green, M., Miers, I., Tromer, E., et al. (2014). Zero-cash: Decentralized anonymous payments from bitcoin. In *2014 IEEE Symposium on Security and Privacy, SP 2014, Berkeley, CA, USA, 18–21 May 2014* (pp. 459–474). <https://doi.org/10.1109/SP.2014.36>.
11. Benjumea, V., Choi, S. G., López, J., & Yung, M. (2008). Fair traceable multi-group signatures. In *FC 2008* (pp. 231–246).
12. Blazy, O., Fuchsbaauer, G., Pointcheval, D., & Vergnaud, D. (2013). Short blind signatures. *Journal of Computer Security*, 21(5), 627–661.
13. Boneh, D., Sahai, A., & Waters, B. (2011). Functional encryption: Definitions and challenges. In Y. Ishai (Ed.), *TCC 2011* (Vol. 6597, pp. 253–273). LNCS. Heidelberg: Springer.
14. Boudot, F. (2000). Efficient proofs that a committed number lies in an interval. In *Advances in Cryptology - EUROCRYPT 2000, International Conference on the Theory and Application of Cryptographic Techniques, Bruges, Belgium, 14–18 May 2000, Proceeding* (pp. 431–444).
15. Brassard, G., Chaum, D., & Crépeau, C. (1988). Minimum disclosure proofs of knowledge. *Journal of Computer and System Sciences*, 37(2), 156–189.
16. Camenisch, J., & Stadler, M. (1997). Efficient group signature schemes for large groups (extended abstract). In *CRYPTO* (pp. 410–424).
17. Camenisch, J., & Lysyanskaya, A. (2002). Dynamic accumulators and application to efficient revocation of anonymous credentials. In *CRYPTO* (pp. 61–76).
18. Camenisch, J., Piveteau, J.-M., & Stadler, M. (1996). An efficient fair payment system. In *ACM Conference on Computer and Communications Security* (pp. 88–94).
19. Camenisch, J., Dubovitskaya, M., & Neven, G. (2009). Oblivious transfer with access control. In *Proceedings of the 16th ACM Conference on Computer and Communications Security, CCS '09, New York, NY, USA* (pp. 131–140). ACM. <https://doi.org/10.1145/1653662.1653679>.
20. Charikar, M. (2002). Similarity estimation techniques from rounding algorithms. In *STOC* (pp. 380–388).
21. Chaum, D. (1982). Blind signatures for untraceable payments. In *CRYPTO* (pp. 199–203).
22. Chaum, D., & van Heyst, E. (1991). Group signatures. In *EUROCRYPT* (pp. 257–265).
23. Choi, S. G., Park, K., & Yung, M. (2006). Short traceable signatures based on bilinear pairings. In *IWSEC* (pp. 88–103).

24. Coull, S. E., Green, M., & Hohenberger, S. (2011). Access controls for oblivious and anonymous systems. *ACM Transactions on Information and System Security*, 14, 10:1–10:28. <https://doi.org/10.1145/1952982.1952992>.
25. Danezis, G., Kohlweiss, M., Livshits, B., & Rial, A. (2012). Private client-side profiling with random forests and hidden Markov models. In *Privacy Enhancing Technologies - 12th International Symposium, PETS 2012, Vigo, Spain, 11–13 July 2012. Proceedings* (pp. 18–37).
26. Danezis, G., Domingo-Ferrer, J., Hansen, M., Hoepman, J.-H., Le Metayer, D., Tirta, R., et al. (2014). *Privacy and data protection by design-from policy to engineering*. Technical report, ENISA.
27. Davida, G. I., Frankel, Y., Tsounis, Y., & Yung, M. (1997). Anonymity control in e-cash systems. In *Financial Cryptography* (pp. 1–16).
28. de Montjoye, Y.-A., Radaelli, L., Singh, V. K., & Pentland, A. (2015). Unique in the shopping mall: On the reidentifiability of credit card metadata. *Science*, 347(6221), 536–539.
29. Diaz, J. (2015). *Design and implementation of secure protocols for practical authentication and fair anonymity systems*. Ph.D. thesis, Escuela Politécnica Superior, Universidad Autónoma de Madrid.
30. Diaz, J., Arroyo, D., & Rodríguez, F. B. (2012). Anonymity revocation through standard infrastructures. In *EuroPKI* (pp. 112–127).
31. Diaz, J., Arroyo, D., & Rodríguez, F. B. (2014). New X.509-based mechanisms for fair anonymity management. *Computers & Security*, 46, 111–125. <http://www.sciencedirect.com/science/article/pii/S0167404814001023>.
32. Diaz, J., Arroyo, D., & de Borja Rodríguez, F. (2015). libgroupsig: An extensible C library for group signatures. *IACR Cryptology ePrint Archive*, 2015, 1146.
33. Diaz, J., Choi, S. G., Arroyo, D., Keromytis, A. D., Rodríguez, F. B., & Yung, M. (2015). Privacy threats in E-shopping (Position Paper). In *Data Privacy Management*.
34. Diaz, J., Choi, S. G., Arroyo, D., Keromytis, A. D., Rodríguez, F. B., & Yung, M. (2018). Privacy in e-shopping transactions: Exploring and addressing the trade-offs. In *Cyber Security Cryptography and Machine Learning - Second International Symposium, CSCML 2018, Beer Sheva, Israel, 21–22 June 2018, Proceedings* (pp. 206–226).
35. Diffie, W., & Hellman, M. E. (1976). New directions in cryptography. *IEEE Transactions on Information Theory*, 22(6), 644–654.
36. Dingleline, R., Mathewson, N., & Syverson, P. (2004). Tor: The second-generation onion router. In *Proceedings of the 13th Conference on USENIX Security Symposium - Volume 13, SSYM'04, Berkeley, CA, USA* (pp. 21–21). USENIX Association. <http://dl.acm.org/citation.cfm?id=1251375.1251396>.
37. Feige, U., Fiat, A., & Shamir, A. (1987). Zero knowledge proofs of identity. In *STOC* (pp. 210–217).
38. Garman, C., Green, M., & Miers, I. (2016). Accountable privacy for decentralized anonymous payments. *IACR Cryptology ePrint Archive*, 2016, 61.
39. Gentry, C. (2009). Fully homomorphic encryption using ideal lattices. In M. Mitzenmacher (Ed.), *41st ACM STOC, May/June 2009* (pp. 169–178). ACM Press.
40. Goldwasser, S., Micali, S., & Rivest, R. L. (1988). A digital signature scheme secure against adaptive chosen-message attacks. *SIAM Journal on Computing*, 17(2), 281–308.
41. Goldwasser, S., Micali, S., & Rackoff, C. (1989). The knowledge complexity of interactive proof systems. *SIAM Journal on Computing*, 18(1), 186–208.
42. Greenwood, D., Stopczynski, A., Sweatt, B., Hardjono, T., & Pentland, A. (2014). The new deal on data: A framework for institutional controls. *Privacy, Big Data, and the Public Good: Frameworks for Engagement* (p. 192).
43. ITU-T Recommendation. (1997). X.509. Information technology - open systems interconnection - the directory: Authentication framework.
44. Jakobsson, M., & M'Raihi, D. (1998). Mix-based electronic payments. In *Selected Areas in Cryptography* (pp. 157–173).
45. Jha, S., Guillen, M., Christopher Westland, J. (2012). Employing transaction aggregation strategy to detect credit card fraud. *Expert Systems with Applications*, 39(16), 12650–12657.

46. Kiayias, A., Tsiounis, Y., & Yung, M. (2004). Traceable signatures. In *Advances in Cryptology - EUROCRYPT 2004, International Conference on the Theory and Applications of Cryptographic Techniques, Interlaken, Switzerland, 2–6 May 2004, Proceedings* (pp. 571–589). <http://www.iacr.org/cryptodb/archive/2004/EUROCRYPT/2477/2477.pdf>.
47. Kumar, M., Rangachari, A., Jhingran, A., & Mohan, R. (1998). Sales promotions on the internet. In *Proceedings of the 3rd Conference on USENIX Workshop on Electronic Commerce - Volume 3, WOECE98, Berkeley, CA, USA* (pp. 14–14). USENIX Association. <http://dl.acm.org/citation.cfm?id=1267147.1267161>.
48. Libert, B., & Yung, M. (2012). Fully forward-secure group signatures. In *Cryptography and Security* (pp. 156–184).
49. Libert, B., Peters, T., & Yung, M. (2012). Group signatures with almost-for-free revocation. In *CRYPTO* (pp. 571–589).
50. Lysyanskaya, A., Rivest, R. L., Sahai, A., & Wolf, S. (1999). Pseudonym systems. In *Selected Areas in Cryptography* (pp. 184–199).
51. Miers, L., Garman, C., Green, M., & Rubin, A. D. (2013). Zerocoin: Anonymous distributed e-cash from bitcoin. In *2013 IEEE Symposium on Security and Privacy, SP 2013, Berkeley, CA, USA, 19–22 May 2013* (pp. 397–411).
52. Minkus, T., & Ross, K. W. (2014). I know what you're buying: Privacy breaches on ebay. In *PETS 2014, Amsterdam, July 2014*.
53. Murdoch, S. J., & Anderson, R. J. (2010). Verified by Visa and MasterCard SecureCode: Or, how not to design authentication. In *Financial Cryptography*.
54. Nakamoto, S. (2009). Bitcoin: A peer-to-peer electronic cash system. <http://www.bitcoin.org/bitcoin.pdf>.
55. Nakanishi, T., Haruna, N., & Sugiyama, Y. (1999). Unlinkable electronic coupon protocol with anonymity control. In *ISW* (pp. 37–46).
56. Narayanan, A., & Shmatikov, V. (2008). Robust de-anonymization of large sparse datasets. In *2008 IEEE Symposium on Security and Privacy (S&P 2008), 18–21 May 2008, Oakland, California, USA*.
57. Okamoto, T. (2006). Efficient blind and partially blind signatures without random oracles. In *TCC* (pp. 80–99).
58. Parra-Arnau, J., Rebollo-Monedero, D., & Forné, J. (2014). Optimal forgery and suppression of ratings for privacy enhancement in recommendation systems. *Entropy*, 16(3), 1586–1631.
59. Partridge, K., Pathak, M. A., Uzun, E., & Wang, C. (2012). Picoda: Privacy-preserving smart coupon delivery architecture.
60. Pedersen, T. P. (1991). Non-interactive and information-theoretic secure verifiable secret sharing. In *CRYPTO* (pp. 129–140).
61. Preibusch, S., Peetz, T., Acar, G., & Berendt, B. (2015). Purchase details leaked to PayPal (Short Paper). In *Financial Cryptography*.
62. Ramakrishnan, N., Keller, B. J., Mirza, B. J., Grama, A., & Karypis, G. (2001). Privacy risks in recommender systems. *IEEE Internet Computing*, 5(6), 54–62.
63. Rial, A. (2013). *Privacy-preserving E-commerce protocols*. Ph.D. thesis, Arenberg Doctoral School, KU Leuven.
64. Rial, A., Kohlweiss, M., & Preneel, B. (2009). Universally composable adaptive priced oblivious transfer. In *Pairing-Based Cryptography - Pairing 2009, Third International Conference, Palo Alto, CA, USA, 12–14 August 2009, Proceedings* (pp. 231–247).
65. Rivest, R. L., Shamir, A., & Adleman, L. M. (1978). A method for obtaining digital signatures and public-key cryptosystems. *Communications of the ACM*, 21(2), 120–126.
66. Rogaway, P. (2015). The moral character of cryptographic work. *IACR Cryptology ePrint Archive*, 2015, 1162.
67. Ruiz-Martinez, A. (2015). Towards a web payment framework: State-of-the-art and challenges. *Electronic Commerce Research and Applications*. <http://www.sciencedirect.com/science/article/pii/S1567422315000587>.
68. Sander, T., & Ta-Shma, A. (1999). Flow control: A new approach for anonymity control in electronic cash systems. In *Financial Cryptography* (pp. 46–61).

69. Stolfo, S., Yemini, Y., & Shaykin, L. (2006). Electronic purchase of goods over a communications network including physical delivery while securing private and personal information of the purchasing party, November 2 2006. US Patent App. 11/476,304.
70. Tan, C., & Zhou, J. (2002). An electronic payment scheme allowing special rates for anonymous regular customers. In *DEXA Workshops* (pp. 428–434).
71. Toubiana, V., Narayanan, A., Boneh, D., Nissenbaum, H., & Barocas, S. (2010). Adnostic: Privacy preserving targeted advertising. In *NDSS*.
72. Visa. (2011). Verified by Visa – acquirer and merchant implementation guide.

Pseudonymous Signature Schemes



**Przemysław Błażkiewicz, Lucjan Hanzlik, Kamil Kluczniak,
Łukasz Krzywiecki, Mirosław Kutylowski, Marcin Słowik
and Marta Wszola**

Abstract The chapter concerns cryptographic schemes enabling to sign digital data in a pseudonymized way. The schemes aim to provide a strong cryptographic evidence of integrity of the signed data and origin of the signature, but at the same time have to hide the identity of the signatory. There are two crucial properties that are specific for pseudonymous signatures: ability to recover the real identity of the signatory in certain circumstances and resilience to Sybil attacks. Despite using a single private key, the signatory can create a (single) unlinkable pseudonym for each domain or sector of activity and generate signatures corresponding to this pseudonym.

This research has been done when all authors have been affiliated with Wrocław University of Science and Technology.

P. Błażkiewicz · Ł. Krzywiecki · M. Kutylowski (✉) · M. Słowik · M. Wszola
Department of Computer Science, Faculty of Fundamental Problems of Technology,
Wrocław University of Science and Technology, Wrocław, Poland
e-mail: mirosław.kutylowski@pwr.edu.pl

P. Błażkiewicz
e-mail: przemysław.blaskiewicz@pwr.edu.pl

Ł. Krzywiecki
e-mail: lukasz.krzywiecki@pwr.edu.pl

M. Słowik
e-mail: marcin.slowik@pwr.edu.pl

M. Wszola
e-mail: marta.wszola@pwr.edu.pl

L. Hanzlik
Stanford University and CISPA, Saarland University, Saarland Informatics Campus, Campus
E9.1, 66123 Saarbrücken, Germany
e-mail: lucjan.hanzlik@stanford.edu

K. Kluczniak
CISPA, Saarland University, Saarland Informatics Campus, Campus E9.1,
66123 Saarbrücken, Germany
e-mail: kamil.kluczniak@cispa.saarland

1 Introduction

Replacing real identity with pseudonyms is one of the basic ideas of privacy protection. If the link between a pseudonym and a real person remains hidden, then the data concerning the holder of the pseudonym cannot be regarded as a data concerning an *identifiable person*, and therefore the goals of privacy protection are achieved according to legal regulations [26]. Therefore, whenever possible, it is recommended to replace the real identity with a pseudonym. However, this is not enough if the holders of pseudonyms interact with the system, authenticate themselves and authenticate digital data. If they use standard cryptographic techniques for these purposes, and the same public key is used for verification as the main public key of a given person, the pseudonymization becomes totally ineffective. Therefore, apart from pseudonyms, there is a need for signing data in a pseudonymous way. In this context “pseudonymous” means that the identity of the signatory is replaced by a pseudonym and all data used for verification may be linked only to this pseudonym.

In spite of the positive effect on data protection, using pseudonyms and pseudonymous signatures might provide room for misbehavior: a person aware of full anonymity may escape responsibility for their own behavior. Moreover, they might appear under many identities, just escaping a bad reputation earned so far. Therefore, creating and using really independent pseudonyms for different purposes does not seem to be a good choice, and a practical setup has to fulfill the following rules:

- except for a few application scenarios, in case of serious violation of rules or another extraordinary situation, a pseudonym and the identity of its owner must be linkable, provided that appropriate preconditions are fulfilled, and
- ability to create pseudonyms should be limited to one pseudonym per *domain*.

A *domain* should be understood as a virtual area of activity, which is in some sense self-contained.

In the most basic setup, the considered systems consist of the following:

- an issuing entity (the ID Authority),
- a set of users, and
- a set of domains.

The ID Authority checks user’s identity and admits them to join the system. It should be verifiable for third parties whether a certain pseudonymous person has indeed joined the system.

The domain can be seen as a service provider, for instance, an Internet website or a database. In particular, the services offered might be of sensitive matter, and in this case the users need some guarantee to remain anonymous. Take, for example, a web-based message board for alternative medicine enthusiasts. On the one hand, the users are likely to reveal considerable amount of sensitive information about their health conditions and so it is important to hide their identity in order to prevent data misuse. On the other hand, the users should be identifiable within the service, for instance, for enabling discussions, tracing posts, etc.

Another important privacy issue is *linkability*. Even though a user does not use their real identity browsing the message board and other websites, being identified as a particular service user by another service is not desirable. For instance, the users of the message board in the previous example are a perfect target group for companies producing and advertising unconventional, or even dangerous, drugs. The message board owner, being concerned about the users' well-being, may delete spam posts and not allow potentially harmful advertisements to be displayed. Nonetheless, other websites that the user logs into may disregard this matter. The information about the health issues of the particular message board user may be valuable to such aggressive advertiser even if no true identity is obtained. Furthermore, *linking* a user between various domains adds more pieces of information about them, which eventually may lead to an identity disclosure.

The compromise is to make the user's actions *linkable* within a single domain yet anonymous across domains, it should be infeasible to resolve whether two users contacting distinct domains are in fact the same person. According to an application scenario, there may be some exceptions from this general rule, but they should be strictly defined and guarded against misuse.

Putting these requirements in a semiformal language, they can be perceived as a security "left-or-right" game. In the most basic case, an adversary is challenged with two transcripts. With two users in the game setup, either both transcripts are produced by the same user (and it is not essential which user was involved in their generation) or one transcript is generated by one user and the other one by another user; the choice of scenario is based on a fair coin toss. The adversary's goal is to decide which scenario he has been presented with. If the probability of figuring out the answer successfully is at most negligibly distinct from a random guess (which is 0.5 in the "two users" scenario), then the scheme is considered to be secure. Even though the problem gets more complex in larger setups with many users, this simple game description is an excellent basis for the general intuition behind the unlinkability property.

The example given above is one of the use cases of the domain systems. It is defined formally in the next section alongside other, more sophisticated scenarios where domain pseudonyms can be used. Later, in Sect. 4.6, the system properties for implementing each of the use cases are proposed.

2 Application Scenarios and Requirements

In this section, a few potential use cases for domain (or *pseudonymous*) signature schemes are given. Each of these use cases comes with different requirements and applications. A more formal categorization of those requirements is presented in Sect. 4.

2.1 Login Functionality

Domain signatures can be used for creating a universal authentication mechanism for a user interacting with multiple services. In this scenario, as shown below:

- each service defines a separate domain,
- the domain pseudonym of a user plays the role of the user's ID in the service. That is, if a service S corresponds to a domain dom , then the identity of user A for service S is the domain pseudonym $\text{dnym}_{\text{dom},A}$ of user A in domain dom , and
- for login authentication as well as authenticating digital documents within service S , user A creates domain signatures corresponding to their pseudonym $\text{dnym}_{\text{dom},A}$.

This way the main threats for the password-based systems are mitigated as shown below:

- users are not forced to remember multiple passwords, instead they use a device implementing the domain signature scheme (with just one PIN number giving access to all the systems),
- users cannot reuse the same password for different systems (while reusing the same passwords is one of major risk factors in practice for login-password-based solutions today [27]), and
- different services cannot combine their knowledge about a user—thereby privacy of the users is protected *by-design*. (This does not exclude special procedures that enable, for instance, the join operation on databases. However, the domain signature scheme has to enforce strong restrictions for such operations.)

Remark 1 Note that this scenario of using domain signatures originates from the idea already implemented in German personal identity cards. The first functionality of this kind was the Restricted Identification protocol [5]: each user holds a secret key which is used to create a unique but static cryptographic password for each domain. The main advantage is that passwords are generated automatically and are unlinkable between the domains. However, the RI protocol lacks a mechanism to confirm the validity of a password. This is a consequence of the following assumptions for the system:

- personal identity document is immune against manipulations,
- target system and the identity document can create a secure communication channel, and
- target system can verify whether it is communicating with a valid identity document.

Fulfilling the last condition is a challenge, as no identifying information from the side of the identity document can be used. (The solution implemented in the German personal identity documents was to share the same private key for a large number of documents.)

Like any static password protocol, Restricted Identification cannot be used to provide nonvolatile authentication of digital data.

Later, a new mechanism called Pseudonymous Signature has been proposed by German Federal Office for Information Security [5]. This signature can be used exactly for the purpose described above.

2.2 *Record Authentication in Reputation Systems*

Reputation systems have two conflicting requirements as follows:

- Each opinion/recommendation should be authenticated by its author.
In this way Sybil attacks are prevented: it becomes impossible to appear under different identities and insert multiple, biased opinions in order to either increase or decrease reputation of a target entity.
- The real identity of the author of an opinion has to be confidential.
In many cases the authors are afraid to submit negative opinions. It has been observed that the customers publishing such negative but fair reports might be considered troublemakers and consequently blacklisted.

A domain signature scheme seems to solve this problem as given below:

- Each service or object S under evaluation defines a domain dom_S .
- A user A evaluating S creates a signature within the domain dom_S using their pseudonym $\text{dnym}_{\text{dom}_S, A}$.

This solution has the following advantages:

1. A may insert multiple opinions on S ; however, one would immediately link them as originating from the same person (note that allowing multiple opinions from a single user might be advantageous as long as they can be attributed to a single author),
2. there is a strong authentication of each opinion, any manipulation in its text is detectable, and
3. the author of an opinion remains anonymous.

More precisely, as one cannot link the pseudonyms in different domains, the signatures and pseudonyms do not provide additional knowledge that might be used to identify the author of an opinion. (Of course, the domain signature itself cannot prevent identifying the author based on the contents of the opinions.)

2.3 *Anonymization in a Filing System*

One of the major issues in running filing systems containing personal data is their protection complying with the legal regulations such as general data protection regulation ((GDPR) [26]). When the data concerns an identifiable person, then numerous requirements apply (for details see Sect. 3). The same regulation points to

pseudonymization as one of the major techniques that may help to fulfill these requirements.

Domain signatures may be used for creation of pseudonyms in the following way:

- Each filing system corresponds to a domain in a domain signature scheme.
- For a physical person, the primary identifier (such as name and/or personal number) is replaced by the domain pseudonym of this person.

In order to be able to run anonymization efficiently, the domain signature scheme has to fulfill the following properties:

1. The domain pseudonym $dnym_A$ of a user A holding a public key pk can be derived both by the owner of pk and by the owner of the domain (each party using a certain secret).
2. The owner of the domain should have the possibility of efficient conversion of domain pseudonyms back to the corresponding public keys.

Then an implementation of a filing system has to be based on the following principles:

- There is a separation between the data set holding records, where each primary identifier is replaced by the domain pseudonym, and a functional unit that is responsible for creating pseudonyms and linking them back to the public keys.
- The anonymized data set is implemented in a regular way (that is without non-standard protection), while the functional unit is based on a secure hardware unit.

This solution has the following advantages:

1. In principle, according to the legal definition, the database does not contain any personal data, as the identifying information has been replaced by domain pseudonyms, and therefore the data do not correspond to an identifiable person. (Of course, the technique proposed removes direct identification information only. It does not help when, for instance, the primary key is a name, but one of the fields is an email address of this person.)
2. Cross-checking different databases does not bring the attacker much advantage, as the domain pseudonyms used in different databases are unlinkable.
3. A user does not need to transmit their primary identifier in case of interaction with the filing system, their domain pseudonym is used instead. This concerns both inserting data to the system as well as sending queries about own personal data stored in the system.
4. The solution integrates strong anonymization with strong anonymous authentication.

The advantage over a standard solution based on encryption of the primary identifier with a secret key of the data set is that

- Any person can compute their pseudonym on their own and anonymize their record even before transmitting it to the data set manager,
- In particular, a person requesting access to their own data in a system need not reveal their identity to exercise the rights declared in the GDPR regulation [26], and

- Effective “forgetting a person” in a data set can be eased by deleting the public key of this person from the secure hardware unit.

2.4 Privacy-Preserving Self-organization

Consider self-organizing systems of autonomous vehicles, which communicate locally in order to resolve problems arising in traffic. One of the primary application examples is virtual traffic lights, where the vehicles arriving at a crossing make a joint decision on the order of leaving the crossing. As an assumption, each vehicle holds an on-board unit (OBU) that implements among others all the necessary security mechanisms.

While constructing such a system one has to keep in mind the following issues:

1. Since collecting data transmitted over the communication channel on a massive scale becomes technically feasible, privacy of the users may be endangered,
2. The self-organization protocol has to be immune to selfish and malicious behavior,
3. In case of misbehavior, it should be possible to derive the real identity of a responsible unit and ...
4. ...a transcript of the data transmitted should be authenticated sufficiently in order to serve as an evidence, for instance, in court trials, and
5. Cloning the OBU, as well as creating fake OBUs, should be infeasible or at least detectable.

Many of the above requirements can be directly fulfilled, thanks to the application of a domain signature scheme. Namely, the system can be set up in the following way:

- a pair (location, time) defines a domain dom (such domains must emerge ad hoc when needed, in particular, there is neither a Domain Authority nor a private key assigned to the domain),
- the domain pseudonym $\text{dnym}_{\text{dom},A}$ of a user A is created by the OBU of A and used during self-organization process in a domain dom ,
- $\text{dnym}_{\text{dom},A}$ is revealed to other participants together with a domain signature which indirectly authenticates the link between the pseudonym and the (anonymous) OBU of the user A , and
- the self-organization process executed for domain dom mimics a protocol P designed for honest participants; random decisions from this protocol are replaced by randomness derived from a PRNG, with the seed

$$\mathcal{H}(\text{Sort}(\text{dnym}_{\text{dom},A_1}, \dots, \text{dnym}_{\text{dom},A_k})),$$

where $A_1, \dots, A_k$ are the participants of the protocol.

This approach has to be based on the following properties:

- Unlinkability of the pseudonyms should guarantee that the pseudonyms have sufficiently many properties of random values and, in particular, are unpredictable.

- As the pseudonyms are computed deterministically (according to the rule “one pseudonym per user in a domain”), there is no room left for adjusting to the choices of other participants for one’s own advantage.
- The pseudonyms are useless for an adversary collecting the data from different domains; indeed, the unlinkability property guarantees that from their point of view the pseudonyms should be indistinguishable from random strings.
- The domain signature scheme has to support deanonymization. Thereby, in situations that are strictly defined, the link between a pseudonym and the real identity may be revealed by the execution of a multiparty protocol. Thereby, anonymity does not prevent enforcing the law.
- The so-called *seclusiveness* property of domain signatures should guarantee that no valid OBU can be created outside the official system. The only way to create a valid OBU without the consent of the ID Authority would be to clone the device.

Additional properties might be useful for this application scenario. For instance, the pseudonyms of the same user for domains with the same time coordinate might be linkable. In this case, one would detect clone devices used in the system.

2.5 *Direct Anonymous Attestation*

One of the ideas to improve immunity of relatively complex machines is to create a relatively small hardware-based security core called trusted platform module (TPM). Such a TPM module should, among others, enable remote attestation of the host system, thereby providing some argument for security status of this machine. The key element of such a process is providing data signed by the TPM.

On the one hand, the verifier of the data obtained from the TPM must be able to check that the signatures originate from a legitimate TPM. On the other hand, the attestation process should not reveal the identity of the TPM, as it may lead to security problems arising from traceability of TPM’s. Thereby, signatures that are anonymous in the following sense are needed:

- For each interaction (attestation), a separate signature is required, unlinkable to the signatures issued by the same TPM on different occasions.
- The scheme has to fulfill seclusiveness property in order to prevent creation of fake TPM’s.

On the other hand, if a TPM gets effectively revoked for some reason, then it is not of critical importance to protect its private keys.

3 Legal Framework

Expansion of IT systems and their growing role in both professional and private life have led to better understanding of privacy protection as security mechanism. Apart

from the technical progress, there are substantial efforts to influence the situation by legal regulations. In recent years, the European Union has been the main driving force in this area. Two fundamental regulations have been introduced in the EU: general data protection regulation (GDPR) [26] and regulation on electronic identification (eIDAS) [25]. They both refer directly to pseudonymization as a technical tool providing the means of privacy protection.

3.1 GDPR

3.1.1 Pseudonymization

According to the preamble of GDPR [26],

pseudonymization ... can reduce the risks to the data subjects concerned and help controllers and processors to meet their data-protection obligations.

Moreover,

... the controller should adopt internal policies and implement measures which meet in particular the principles of data protection by design and data protection by default. Such measures could consist, inter alia, of minimizing the processing of personal data, pseudonymising personal data as soon as possible, ...

Pseudonymization is the only pure technical mean named explicitly in GDPR [26]; however, the regulation seeks to be technology independent and “*the explicit introduction of ‘pseudonymization’ in this Regulation is not intended to preclude any other measures of data protection.*” This makes room not only for future anonymity technologies but also provides arguments against narrowing focus to replacing data such as names and personal ID numbers by pseudonyms.

Article 4 of GDPR [26] defines pseudonymization in a relatively broad sense as

(5) pseudonymisation means the processing of personal data in such a manner that the personal data can no longer be attributed to a specific data subject without the use of additional information, provided that such additional information is kept separately and is subject to technical and organizational measures to ensure that the personal data are not attributed to an identified or identifiable natural person;

Thereby,

1. the process of pseudonymization is not just to create new anonymous identifiers for a real person,
2. the main focus is to protect a person by breaking the link between the person and the data—once the data cannot be attributed to an identifiable person, then the goals of privacy protection are achieved, and
3. pseudonymization might be reversible—with the “additional data” one can link back the data and the data subject. Possibility of reversing the pseudonymization is also directly indicated in part (85) of the regulation preamble, where reversing

the pseudonymization by a non-authorized party is regarded as one of the security breaches.

Of course, pseudonymization can be achieved by strong encryption of the whole data. However, in practice, such an approach is not applicable frequently. For instance, it cannot be used for protection of medical databases: most of the data have to remain accessible for multiple parties. In this case, access limitations may endanger health and life of a patient.

3.1.2 Principles of Processing Personal Data

GDPR [26] formulates the following fundamental rules for processing of personal data:

Lawfulness, fairness and transparency: *Personal data shall be processed lawfully, fairly and in a transparent manner in relation to the data subject;*

Purpose limitation: *Personal data shall be collected for specified, explicit, and legitimate purposes and not further processed in a manner, that is, incompatible with those purposes;*

Data minimization: *Personal data shall be adequate, relevant, and limited to what is necessary in relation to the purposes for which they are processed;*

Accuracy: *Personal data shall be accurate and, where necessary, kept up to date; every reasonable step must be taken to ensure that personal data that are inaccurate, having regard to the purposes for which they are processed, are erased or rectified without delay;*

Storage limitation: *Personal data shall be kept in a form which permits identification of data subjects for no longer than is necessary for the purposes for which the personal data are processed; personal data may be stored for longer periods insofar as the personal data will be processed solely for archiving purposes in the public interest, scientific or historical research purposes, or statistical purposes in accordance with Article 89(1) subject to implementation of the appropriate technical and organizational measures required by this Regulation in order to safeguard the rights and freedoms of the data subject;*

Integrity and confidentiality: *Personal data shall be processed in a manner that ensures appropriate security of the personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, using appropriate technical or organizational measures;*

Accountability: *The controller [the party processing personal data] shall be responsible for, and be able to demonstrate compliance with the abovementioned rules.*

All these rules have direct implications for the design of any information system processing personal data. In particular, the following:

Lawfulness, fairness and transparency: Pseudonymization mechanism must be neither a black box solution nor an extremely complex one, transparency means also a kind of provable security.

Purpose limitation: In particular, if the link between the data and the data subject has to be used by certain parties, the system should be based on pseudonymization that is reversible according to the access control rights defined according to the purpose of the system. In practical situations, these access control rights might be fairly complicated.

Data minimization: In particular, the system must not contain identifiers of real persons unless it is explicitly necessary. If the identifiers such as names, ID numbers, etc. play the role of primary keys in a database, then in order to preserve functionality of the database it might be necessary to convert them to pseudonyms.

As using the same pseudonym in different data files increases the threat of recovering the real identity via intersection attack, it might be helpful to use *domain-specific pseudonyms*.

Accuracy: keeping data up to date and protecting privacy at the same time are to some extent conflicting requirements. Therefore, a technical solution used must support appropriate procedures, for instance, for updating personal data by the data subject without giving up anonymity. At the same time, the technical solution has to prevent updating the personal data by a third person. For this purpose, one can use *domain signatures*, where a request of a user not only points to their (domain) pseudonym, but also contains a proof that it originates from the (anonymous) data subject in a form of a *domain signature*.

Storage limitation: A fully anonymized personal data might be useless for statistical, historical, and research purposes. It might be necessary to link the records concerning the same (anonymous) person within a given data set. A good example of this situation is medical research. For such purposes, domain pseudonyms seem to be a very useful fundamental tool.

Integrity and confidentiality: While a digital signature is a powerful mechanism for protecting integrity of digital data, it might be difficult to use, as it automatically reveals the identity of the signatory. In many situations, the privacy of the signatory has to be protected as well. The domain signature system is a solution for this dilemma. Moreover, one can choose a scheme where under certain conditions one can deanonymize the signatory. This functionality may be very useful when the signatory inserts false information or attempts to misuse the system.

Accountability: Demonstrating compliance requires among others showing that the pseudonymization process does not create backdoors. This might be easier, if the pseudonym generation is not based on a random process, but a deterministic one based on strong cryptographic means. Such functionality is offered by domain pseudonyms.

3.1.3 Protection by Design and by Default

Article 25 of GDPR [26] introduces the concept of *data protection by design and by default*. It states in particular that

Taking into account the state of the art, the cost of implementation and the nature, scope, context and purposes of processing as well as the risks of varying likelihood and severity for rights and freedoms of natural persons posed by the processing, the controller shall, both at the time of the determination of the means for processing and at the time of the processing itself, implement appropriate technical and organizational measures, such as pseudonymisation, which are designed to implement data-protection principles, such as data minimisation, in an effective manner and to integrate the necessary safeguards into the processing in order to meet the requirements of this Regulation and protect the rights of data subjects.

Satisfying these rules is a challenge:

- The controller is obliged to implement “appropriate technical and organizational measures” according to the current state of the art (note that the phrase “at the time of the processing itself” is used). In order to meet this requirement it should be recommended to follow the approach used for selection of cryptographic primitives and determine a reasonable security margin so that the system should remain immune against attacks also in the foreseeable future.
- The solutions need not only protect personal data, but they need to be effective. Note that lack of access to the data for a party having necessary rights is itself a violation of the personal data protection rules.

Article 25 concerns in particular the issue of the consent of the data subject. According to the regulation, except for some explicitly named cases, personal data can be processed only when the data subject expressed their consent (Article 6). This creates another technical challenge: How to prove that data is processed lawfully without revealing the identity of the data subject? Note that this can be achieved easily with domain signatures based on personal identity cards: the consent can be signed with a domain signature corresponding to the domain representing the data controller.

3.2 *EIDAS*

The eIDAS regulation [25] aims to provide a framework for broadly understood *electronic identification and trust services* in Europe. Its main focus is on a few issues that include in particular:

- identification and authentication schemes,
- digital signatures, and
- cross-border and cross-sector recognition of identification, authentication, and digital signatures.

In this area, the main goals are as follows:

- means for identification and authentication issued by a member state should be accepted without any practical problems in the whole EU, especially in interactions with public bodies, and

- barriers to recognize electronic signatures within the whole EU should be removed.

Identification and authentication processes by definition may create personal data—For example, they contain information on activities of a given person. Moreover, the security mechanism used aims to provide trustworthy authentication, but as a side effect it may create high quality undeniable cryptographic data. This data may be misused by malicious parties. Therefore, a strong authentication mechanism may be a double-edged sword creating a lot of problems in the area of personal data protection.

The eIDAS regulation directly refers to the issue of privacy protection in Article 5 as given below:

Without prejudice to the legal effect given to pseudonyms under national law, the use of pseudonyms in electronic transactions shall not be prohibited.

The definitions of identification, authentication, and digital signatures are also compatible with pseudonymization. The exact wording of these definitions from Article 3 of the eIDAS regulation is as follows:

- (1) electronic identification means the process of using person's identification data in electronic form uniquely representing either a natural or legal person, or a natural person representing a legal person;
- (2) electronic identification means a material and/or immaterial unit containing person identification data and which is used for authentication for an online service;
- (3) person identification data means a set of data enabling the identity of a natural or legal person, or a natural person representing a legal person to be established;
- (4) electronic identification scheme means a system for electronic identification under which electronic identification means are issued to natural or legal persons, or natural persons representing legal persons;
- (5) authentication means an electronic process that enables the electronic identification of a natural or legal person, or the origin and integrity of data in electronic form to be confirmed;

So the very basic components of electronic identification are *person identification data* that “enable the identity of a person to be established”. Note that the identity of a person may be represented by a pseudonym: the most important issue is that there is exactly one person corresponding to such person identification data. Thereby, the regulation does not cover techniques such as anonymous credentials. The person identification data may take the form of keys (both private and public ones), certificates, passwords, etc., whatever needed by an implemented scheme.

The next component is *electronic identification means*, where the person identification data are stored, and which provides functionalities enabling online authentication. So the electronic identification means might be understood as, in particular, a personal identification document equipped with a microcontroller and enabling authentication of its holder.

Electronic identification is a process of using personal identification data. In general, it is not specified what is the outcome of this process. So, in particular, there is no provision that the real identity of the owner of the personal identification data has to be revealed. A good example of such a situation might be an e-voting scheme,

where identification of a voter is compulsory and person identification data plays the role of a virtual token enabling casting a vote. At the same time, anonymity of the voter must be guaranteed. In general, the scope of data created during electronic identification may depend very much on the purpose of identification, required data, and scope of protection needed by the person holding person identification data.

In this context, *authentication* is understood as a process of confirming electronic identification. The strength and kind of confirmation are left open as it may depend on a particular application case. For instance, the following facts can be confirmed through an authentication process:

- the person identification data have been used during the identification process,
- the person identification means have been used during the identification process, and
- the data obtained have been created by the person identification means.

According to the data minimization concept, an authentication process should not confirm more data than explicitly needed. In particular, if revealing the real identity is unnecessary, the authentication process should keep it hidden and prevent deducing it from additional data presented during the authentication process (such as public keys).

For digital signatures, Article 26 of the regulation states as follows:

An advanced electronic signature shall meet the following requirements:

(a) it is uniquely linked to the signatory;

(b) it is capable of identifying the signatory;

...

Note that the condition (a) excludes schemes such as ring signatures. The main point is that the signature corresponds to exactly one person—the signatory. The condition (b) states that the inspection of a signature enables identification of the adversary. Therefore, not only there is a unique link between the signature and the signatory but one can also find it effectively. However, the signatory still can appear under a pseudonym.

The regulation does not impose any limitations on the use of pseudonyms. Domain signatures are more restricted: a signatory cannot create pseudonyms completely freely, as for each domain exactly one pseudonym can be created for a given signatory. The classical digital signature schemes are even more confined: the signatory can use only one identity.

3.3 Domain Signatures Versus EU Regulations

Domain signature schemes combine the advantages of strong cryptographic evidence of integrity and origin of digital data with the security regime of personal data protection. The main points are as follows:

- data minimization— in a standard situation linking signatures created by the same signatory is possible only within a domain,
- replacing the real identity by domain pseudonyms aims to prevent the signatory from being an *identifiable person* (of course, the scheme itself cannot guarantee that the signed data does not reveal the identity of the signatory in an indirect way),
- domain signatures contribute to protection of personal data against manipulations: once such data is signed with a domain signature, any alternation becomes detectable. At the same time, this mechanism does not create new challenges that emerge when classical signatures are used. Indeed, in the latter case, the resulting data becomes “personal data” of the signatory, and thereby strict data protection rules apply.

4 Taxonomy of Domain Signature Systems

One of the problems concerning domain signatures is the variety of schemes that may emerge under the same name “domain signature”. The differences might be quite deep regarding the functionalities and security requirements determined by application cases. For this reason, this chapter tries to shed some light on the situation and define factors that may play a crucial role when selecting a scheme suitable for a given application case.

Notation

- For each property defined below, an acronym is assigned. This helps to create a transparent taxonomy of the existing schemes and, in particular, to find practical application cases where no solution exists so far.
- Each property may have subproperties. In this case, the acronyms are separated with a dot.
- Each property may have a value from a predefined list. The value of the parameter is given in square brackets.
- In a list of required properties and properties of schemes, the alternatives are separated by |.

4.1 Domain Creation

Functionality: This process concerns creation of domains in the system. There are the following ways for a domain to emerge in the system:

DomainVirtual: Each domain exists as a virtual entity. It means that there is no Domain Authority for a domain, and consequently there are no private keys of a

domain as there is no Domain Authority that would use them.

There are two subcases as follows:

Ad-hoc: A domain exists automatically, its parameters can be derived from the domain name or properties.

Created: A *Domain Management Authority* has to create a domain by deriving its *domain parameters*. Domain parameters may be regarded as public keys, although there are no private keys of the domain.

DomainManaged: There is a Domain Authority for each domain. In order to create such a domain an interaction between a *Domain Management Authority* and the Domain Authority of the newly created domain is necessary.

There are two subcases as follows:

Ad-hoc: The Domain Authority creates the domain parameters by itself (including creation of some private keys), the interaction is merely a kind of registration of the domain and the *Domain Management Authority* holds no private keys corresponding to the domain. This process may result in inserting an entry in the official list of domains, or issuing a certificate for the new domain.

Mutually-created: An interactive protocol is executed between the *Domain Management Authority* and the Domain Authority. The domain parameters are created letting both the Domain Authority and the *Domain Management Authority* create their shares of private keys corresponding to that domain. The domain parameters may prove themselves that the domain is legitimate. Alternatively, one can use an official list of domains or certificates issued separately for each domain.

4.2 Joining

Functionality: After executing the joining procedure a user can create their domain pseudonyms and domain signatures.

There are three main questions: “who is responsible for admitting the user?”, “which domains are concerned?”, and “what means are created during the joining procedure?”. These questions are directly addressed by the categories: **JoinAuth**, **JoinScope**, **JoinMech**.

JoinAuth[IDAuthority]: The ID Authority alone is responsible for admitting a user. The typical case is that the ID Authority provides an electronic ID document (eID) that enables creating domain pseudonyms and domain signatures.

JoinAuth[IDAuthority+DomainAuthority]: The ID Authority and the Domain Authority cooperate to admit the user. Cooperation might be either interactive or noninteractive. In the latter case, the ID Authority may provide, for instance, some data to the user for being used as an (anonymous) credential for the Domain Authority.

Note that it seems to be infeasible for the Domain Authority alone to execute the joining procedure. Indeed, it is unclear how to deliver secret data to the user. The

Domain Authority cannot deanonymize the user, so a kind of valid eID on the side of the user seems to be inevitable. However, then the ID Authority implicitly participates in the process, and thereby the case falls back to one of those already considered.

JoinScope[all]: After executing the Join procedure, a user can be active in all possible domains. This happens in the case where each user gets cryptographic keys that allow them to create pseudonyms and signatures for all domains.

JoinScope[domain]: After executing the Join procedure, a user can be active in a chosen domain or domains only.

For the result of the joining procedure, there are a few options as follows:

JoinMech[whitelist]: There is a list of valid domain users for a domain (typically created by the ID Authority and/or by the Domain Authority).

JoinMech[accumulator]: There is a single cryptographic accumulator allowing to check whether a user has been added to the accumulator. This is similar to the whitelist concept with the exception that there are no explicit entries corresponding to the users.

JoinMech[key]: A user joining the system gets a key or some number of keys. Possession of such keys will serve as a proof that a given user is a legitimate one. As the number of domains is potentially unlimited, while the size of cryptographic material held by a user should be limited due to practical reasons, the number of keys should be bounded by a small constant. In particular, solutions such as a separate signing key per domain are outside the scope of our interest.

JoinMech[certificate]: The user gets a separate certificate for each domain or a certificate that can be randomized and used for many domains (randomization is necessary in order to avoid linking). A certificate may have limited validity period.

JoinMech[health_certificate]: When needed, a user fetches a *certificate of health* from an appropriate authority. The certificate confirms that the user is a valid member of the system. At minimum, the interaction with the authority should not reveal which domain or domains are of interest to the identifiable user.

4.3 Revocation

Functionality: After executing the revocation procedure the verifier will not accept domain signatures created by a certain user.

Revocation is a crucial functionality for the schemes where a user authenticates digital data with cryptographic means. Indeed, in practice, it is always the case that some number of users lose control over them.

RevAv[false]: Revocation is not supported by the system.

RevAv[true]: Revocation is possible in some way. The details depend on the sub-categories described below.

Revocation may affect different scopes given as

RevScope[all]: The revocation concerns all domains at once.

RevScope[domain]: The revocation is performed per domain, i.e., revocation in one domain does not affect other domains.

In order to revoke a given user, certain actors of the system have to cooperate. The typical actors are the ID Authority and Domain Authorities. For instance, there are the following options to revoke user *A* in domain *dom*:

RevAuth[IDAuthority]: *A* can be revoked in *dom* by the central ID Authority without cooperation with any other party.

RevAuth[DomainAuthority]: Domain Authority can revoke a single user on its own. This, in practice, is trivial in some combinations, like blacklisting pseudonyms on a domain scope.

RevAuth[IDAuthority+DomainAuthority]: Cooperation of the ID Authority and Domain Authority of *dom* is necessary to revoke a user in *dom*. In particular, the Domain Authority for *dom'* and the ID Authority are unable to revoke *A* in *dom*;

RevAuth[IDAuthority+AnyDomainAuthority]: In this case, a joint decision of a single Domain Authority and the ID Authority enables revocation of *A* in all domains.

There are potentially many ways to realize revocation. In each case, there must be some additional input to the verification procedure apart from the domain signature itself.

There are at least the following options:

RevData[whitelist]: There is a list of valid domain users, the revoked ones are removed from the list.

RevData[blacklist]: There is a list of revoked domain users, user's data is added there once they get revoked.

RevData[accumulator]: There is a single cryptographic accumulator allowing to check whether a user has been added to the accumulator. Further, subdivision is possible depending on whether the accumulator holds data for valid users (whitelist accumulator) or revoked users (blacklist accumulator).

RevData[health_certificate]: The user can fetch a certificate of health from an appropriate authority stating that their pseudonyms and keys have not been revoked. Depending on the scheme, the certificate of health can concern signing time, specific signature, domain, etc. The users are not revoked explicitly, instead their ability to sign expires automatically after given time unless it is refreshed by the authority or authorities responsible for revocation.

4.4 *Deanonymization*

Functionality: In certain circumstances, a domain pseudonym in one domain has to be linked with the real ID of the owner or with their domain pseudonym in another domain. A few example reasons for such deanonymization are as follows:

- criminal activities of the user and necessity to reveal their real identity,
- moving user's record from one domain to another domain (e. g., when patient data is moved from one database to another), and
- merging two domains due to merging services of two providers.

There are the following main characteristics concerning deanonymization: “who performs deanonymization?”, “which links are revealed (e.g., a pseudonym is linked with the real identity, or two pseudonyms in different domains are linked)?”, and “when a link gets revealed to the recipient(s), does it come with a proof?”. These questions directly correspond to the categories **DeAnonAuth**, **DeAnonLink**, **DeAnonProof** discussed below:

DeAnonAuth[nobody]: There is no possibility to deanonymize a pseudonym (and signatures).

DeAnonAuth[IDAuthority]: The ID Authority is in charge of deanonymization.

DeAnonAuth[DomainAuthority]: A (possibly limited) deanonymization can be performed by a Domain Authority on their own. This is a rare case, but fits applications such as pseudonymization of filing systems.

DeAnonAuth[IDAuthority+DomainAuthority]: Both the ID Authority and a Domain Authority must participate in the deanonymization process (presumably, only the pseudonym corresponding to the domain managed by the Domain Authority is linked to the real identity).

DeAnonAuth[DeanonymizationAuthority]: There exists a special authority, separate from the ID and Domain Authorities, which is responsible for deanonymization.

DeAnonAuth[user]: A user can show that their own pseudonyms represent the same person.

DeAnonAuth[...]: Other combinations might be useful in certain cases such as **IDAuthority+DeanonymizationAuthority**.

For **DeAnonLink** there are different cases depending on which links get revealed as given below:

DeAnonLink[all]: Deanonymization concerns linking all pseudonyms with the ID of the user.

DeAnonLink[domain-ID]: Selectively, only a chosen pseudonym is linked with the ID of the user.

DeAnonLink[domain-domain]: Only translation of a pseudonym in one domain to a pseudonym in another domain is provided.

Each of the revealed links might come with a different level of a “proof” as follows:

DeAnonProof[none]: The deanonymization procedure reveals the link only, there is no proof for its validity.

DeAnonProof[interactive]: The deanonymization procedure involves an interactive zero-knowledge proof of the link (thereby, the proof is not transferable to third parties).

DeAnonProof[signature]: The deanonymization procedure produces a proof that can be verified by third parties.

4.5 Continuity

Functionality: It is inevitable that at some point in time, the secret keys of the user will have to be recovered or changed. This may be due, for instance, to aging of the device holding these keys resulting in its dysfunction or a key leakage. As it might be difficult or impossible to hold a backup copy of the keys, it might be necessary to replace the signing keys of the user (and presumably, thereby, also the pseudonyms). Nevertheless, in most cases, a user should not lose their anonymous identity in each domain. Implementing such a replacement might be a challenge as given below:

- a simple declaration that the new pseudonym replaces the old one would enable identity hijacking, a strong proof for linking the old and new pseudonyms must be provided,
- the identity of the user must not be revealed during this process, while on the other hand in this particular situation the user has no standard means to communicate in an anonymous way (i.e., with the domain pseudonyms and signatures).

ContAv[false]: There is no way to transit from one set of pseudonyms to another set of pseudonyms. Schemes having this property have limited application scope, such as protecting identity of IoT artifacts (where there might be an agreement that a technical defect of the device causing the loss of keys should result in withdrawing the artifact from operation).

ContAv[true]: Service continuity might be provided in different ways as follows:

ContMeth[backup]: There is a backup mechanism for user’s private keys. Note that the backup helps when the device holding the keys malfunctions, but does not solve the problem of leaking the keys.

ContMeth[replacement]: There is a mechanism of replacing old (compromised) keys with fresh keys; however, it is possible to link new domain pseudonyms with the old ones. This cannot defend against deanonymization by an attacker who has got access to the old keys of a user, but prevents forging signatures with the signing date later than the replacement time.

4.6 *Taxonomy for Example Application Cases*

This section recalls the applications and requirements from Sect. 2 and formalizes them in terms of the presented functionalities.

4.6.1 Login Systems

Domain-specific login systems have very few specific requirements, mostly because they can be flexibly built around a great variety of solutions. In all cases, though there is the requirement for domain managers to prove that they are the rightful owners of the domain before users reveal their pseudonyms. One of the most convenient configurations of requirements might be the following:

Recommended: **Domain[Managed]**

As a server must be run by some authority, there is a party that may be responsible for the domain administration. Such an authority should reduce the burden put on other parts of the system, taking partial responsibility, for instance, for users' revocation.

Recommended: **JoinAuth[IDAuthority]**, **JoinScope[all]**, **JoinMech[key]**

In this scenario, the ID Authority issues all users their own keys; with the key a user can generate login data for any service, so overall costs are reduced significantly. At the same time, the ID Authority does not learn which services are used by a given person—fulfilling the legal requirement for personal data minimization. For the same reasons, the ID Authority should enroll users for all possible domains at once.

Required: **RevAv[true]**, **RevScope[all]**, **RevAuth[IDAuthority]**

Due to a broad application scope, the fact that some users may lose their cryptographic tokens has to be taken into account. In this case, users should be able to block their signing keys. Since the ID Authority allows a user to get a pseudonymous identity in all domains, consequently a similar solution should apply to revocation.

Recommended: **RevData[time]** or **RevData[health_certificate]**

Due to privacy protection rules, the best solution would be to apply **RevData[time]** or **RevData[health_certificate]**. The solutions such as **RevData[blacklist]** do not seem to be appropriate, as they lead to linking pseudonyms of users whose signing keys have been stolen. Simply one can observe which pseudonyms have appeared on the blacklists at the same time.

Recommended: **DeAnonAuth[IDAuthority+DomainAuthority]**,
DeAnonAuth[user]

The ID Authority should not have possibility to deanonymize the users on its own, as it may lead to global surveillance by a single entity. At the same time, a user should be given an option to prove their rights to their accounts.

Required: DeAnonLink[domain-ID]

Typically, deanonymization is required in selected domains only. Global deanonymization would lead to violation of privacy protection rules.

Required: ContAv[true] ContMeth[replacement]

Access to the account and to the data should be continued even if the keys expire, are lost or get compromised. This follows from the principles of personal data protection, where the right to access own data is one of the fundamental principles.

4.6.2 Record Authentication in Reputation Systems

A platform that offers a reputation system may serve as the ID Authority. Each entity under evaluation corresponds to a separate domain.

Recommended: Domain[Virtual.Created] or Domain[Virtual.Ad-hoc]

There is no need to have a Domain Authority for each domain (sometimes it would be hardly possible to create one). Therefore, virtual domains are preferred. It is an open question whether the list of evaluation entities is a closed or an open one. In the latter case, nothing needs to be done to start evaluation of a given entity. In the former case, a kind of registration for each evaluated entity is required.

Required: JoinAuth[IDAuthority]

The party running the reputation system might be responsible for admitting the evaluators. Alternatively, one can rely upon the anonymous identity system offered by a third party, e.g., a state authority issuing electronic identity documents.

Recommended: JoinScope[all] or JoinScope[domain]

Depending on the situation, a user may get the right to submit an evaluation report on any entity (e.g., in case of evaluating movies, books, video games, ...) or only the entities where he gets explicitly such a right (e.g., in case of evaluating university courses by students enrolled to these courses).

JoinMech Requirements are strongly related to the system design and economic or physical possibilities.

Recommended: RevScope[all], RevData[time]

Definitely, if a user gets revoked, their opinions should be invalidated in all domains. On the other hand, revoking should not deanonymize the user by linking opinions in different domains. Therefore, using time-limited keys seems to be the right choice.

Another advantage of using time-limited keys is a rough but undeniable indication of the signature creation time. It seems to be a useful property as very old reviews do not affect much of the reputation score as the quality may improve or drop over some period of time.

Recommended: ContAv[false]

In case of reputation systems, the lack of continuity is not a problem as long as a user cannot receive new identities frequently, and thereby issue multiple biased opinions for the same entity. On the other hand, preserving continuity requires considerable resources and additional logistic burden.

Required: DeAnonAuth[IDAuthority], DeAnonLink[domain-domain], DeAnonProof[none]

The ID Authority should be able to control and prevent users' misbehavior. However, removing only obviously deceitful reviews may not be enough.

4.6.3 Anonymization in a Filing System

Application of domain signatures for anonymization of database entries requires somewhat non-typical properties of the scheme. One of the most important issues is that the domain pseudonym of a user can be derived not only by the user but also by the Domain Authority of this domain. Thus, anonymization is not to protect against the party running the database, but against database users that may misuse data retrieved by setting queries to the database.

Required: Domain[Managed.Ad-hoc]

The scheme must involve some secret keys of the Domain Authority as otherwise anybody would be able to derive the domain pseudonym of a user. Also, for the sake of security it is better to assume that the Domain Authority generates the domain parameters itself.

Recommended: JoinAuth[IDAuthority], JoinScope[all], JoinMech[certificate]

The easy way to create a working system in a cost-efficient way is to provide an electronic ID document for each user with the keys for creation of domain pseudonyms and signatures. As the users do not need to be anonymous for the Domain Authority, which also derives the domain pseudonyms, the easiest way would be to provide a certificate for the main public key of the user.

Recommended: RevAv[true], RevScope[all], RevAuth[IDAuthority], RevData[blacklist]

As domain signatures are used to authenticate the requests of the data subject, it is necessary to provide a framework for revoking the signing keys. As the users are admitted to the system by the ID Authority, it should also bear the burden of revocation. The easiest way of revoking users would be to create a blacklist containing their main public keys.

Required: DeAnonAuth[DomainAuthority], DeAnonLink[domain-ID],
Recommended: DeAnonProof[interactive]

A Domain Authority should have the possibility to convert the pseudonyms to real identities. For the sake of law enforcement, it might be necessary to prove that the anonymized entries correspond to real identities and an interactive zero-knowledge proof should be appropriate to serve this purpose.

Recommended: ContAv[false]

As the user is not anonymous against the Domain Authority, it is easy to arrange replacement of the user's keys and pseudonyms.

4.6.4 Privacy-Preserving Self-organization

A self-organizing system of autonomous vehicles must prevent tracking but on the same time it must enable deanonymization for the sake of law enforcement and civil suits in case of damages. Moreover, due to particular limitations of vehicle-to-vehicle communication the size of messages is quite limited.

Required: Domain[Virtual.Ad-hoc], JoinAuth[IDAuthority]

The requirement concerning domain management is stated directly in the problem description (Sect. 2.4): the domain is created on demand and it represents a (*time, location*) pair. No Domain Authority is present, which results directly in the second requirement.

Required: JoinScope[all]

Recommended: JoinMech[key] or JoinMech[certificate]

A user of the system may visit a potentially unlimited number of ad hoc domains. Allowing a user to join only a limited and predefined number of domains exclude almost all practical applications.

A vehicle has to verify that other participants are legitimate members of the system, and hence the joining procedure (executed during OBU personalization) has to leave some means to create such a proof. In principle, the domain pseudonyms and signatures have to be used in an offline setting, so solutions such as health certificate are not applicable. Many solutions are excluded due to lack of domain authorities. Solutions based on possession of certain keys and/or randomizable certificates might be applicable, provided that computation time and message size are small enough.

Required: DeAnonAuth[DeanonymizationAuthority]

Recommended: DeAnonAuth[IDAuthority]

In certain situations (misbehavior, damage events, ...), it is necessary to deanonymize a user. It is recommended that the deanonymization task is delegated to another entity in order to minimize the capabilities of an IDAuthority. However, this may be relaxed to DeAnonAuth[IDAuthority], if no such strong privacy guarantee is needed.

Required: DeAnonLink[domain-ID] or DeAnonLink[domain-domain]

In case of misbehavior or damage, it should be necessary to find out the real identity of the responsible vehicle. So, the first case applies. The second kind of deanonymization may help to deal with the problems like simultaneous usage of cloned OBUs.

Note that in this case further fine tuning of deanonymization requirements might be necessary. For instance, it might be necessary to trace a stolen vehicle, but at the same time it should not come together with revealing past routes of this vehicle.

Required: DeAnonProof[signature]

The requirement comes directly from point 4 in Sect. 2.4 as the revealed link might be needed, for instance, during court proceedings or actions related to system management.

Required: RevAv[true]**Recommended: RevScope[all], RevData[time].**

The revocation occurs naturally when the IDAuthority refreshes its signing key, starting a new epoch. Malicious or broken OBUs are not recertified, thus getting revoked for all locations at once. Note that the means of revocation such as blacklists are not applicable, as the decision to entrust a signature must be made very quickly in an offline setting. Apart from that it is infeasible to create the blacklists since the domains involved are created ad hoc.

Recommended: ContAv[false]

If an OBU is compromised or out of order, one can simply replace it with a new valid OBU. As one of the dimensions defining the domain is time, there is no problem of Sybil attacks.

4.6.5 Direct Anonymous Attestation**Required: Domain[Virtual.Ad-hoc], JoinAuth[IDAuthority], JoinScope[all]**

As each attestation should be unlinkable from the other ones, it can be treated as a separate ad hoc domain. Obviously, no domain authority can be involved and admitting to a domain is a sole responsibility of the issuer of TPMs.

Recommended: JoinMech[key] or JoinMech[certificate]

The mechanism of joining should be based on cryptographic material stored securely in a TPM.

Recommended: DeAnonAuth[nobody]

There is no clear need for deanonymization, and therefore one can skip this functionality.

Required: RevAv[true], RevScope[all]

Recommended: RevData[time].

Due to the scale of the system, a pragmatic method would be to provide only time-limited authentication. Periodic refreshing of the cryptographic material on a TPM should not be a major issue as the TPM- equipped devices are intended to work online.

Recommended: ContAv[false]

If a TPM becomes compromised or breaks down, it must not be used anymore.

5 Security Models

For each concrete scheme, it is necessary to determine the corresponding security model describing its properties in terms of formal security games. A formal proof stating that a scheme fulfills such a game is an evidence of fulfilling properties described by the model. Of course, the model may disregard certain features corresponding to real-world attacks.

It should be obvious after Sects. 2 and 4 that it is not straightforward to create a single security model for all schemes under the same umbrella name “domain signature”. However, there are certain properties that occur with slight variations in each of these schemes. A brief description of those properties is provided below.

5.1 Unforgeability

The scope of unforgeability property is slightly broader than it is for standard signature schemes. The reason is that an adversary may not only attempt to create a new signature corresponding to a particular domain–pseudonym pair but also try to change a signature from one domain into a signature from another domain, or corresponding to another pseudonym. Consider a domain signature scheme $\mathcal{S}$ with the following data:

- a domain signature s that verifies positively for
 - message m ,
 - domain dom , and
 - pseudonym dnym ,
- as well as
 - any number of private keys, each of them yielding in dom a pseudonym different from dnym ,

- any set of domain signatures with the corresponding pseudonyms in domains different from dom , and
- any set of signatures corresponding to dnym in dom , created by the owner of dnym under a message different from m .

Scheme $\mathcal{S}$ is then said to satisfy the unforgeability property if one can conclude that there is a user A who went through the Join procedure so that

- the pseudonym of A in dom is dnym ,
- the party that created s has access to A 's signing key obtained during Join procedure, and
- nobody except A can use that signing key.

5.2 *Seclusiveness*

A domain signature scheme has to be secure against Sybil attacks. Therefore, it is necessary to ensure that there is no other way to create a valid pseudonym (and maybe a corresponding signature) than to go through the Join procedure and create the pseudonym with the key resulting from the execution of Join. That is, if dnym is a valid pseudonym for a domain dom , then

- there is a user A that has executed successfully the joining procedure enabling to become a user of domain dom , and
- dnym is the pseudonym of A for domain dom .

It is assumed that all actors of the scheme except for the ID Authority may collude to break this property. For this purpose, they are using all information available to them. In particular, a group of users may attempt to create a new identity dnym , using their own private keys for creating corresponding domain signatures.

5.3 *Unlinkability*

There are two approaches to define unlinkability. The first one is based on left-or-right games in a scenario where the adversary is given all information except for pseudonyms of two users in two domains and has to determine which signatures belong to the same person. Namely

1. take two domains dom_1 and dom_2 ,
2. take the following pairs of pseudonyms: $(\text{dnym}_1^1, \text{dnym}_1^2)$ for dom_1 and $(\text{dnym}_2^1, \text{dnym}_2^2)$ for dom_2 , where first pseudonyms in each pair belong to one user and second belong to a different user, and
3. permute the pseudonyms in each pair at random.

The aim of the adversary is to determine which pseudonyms correspond to the same user (linking), i.e., whether dnym_1^1 and dnym_2^1 correspond to the same user.

The second definition introduces two environment types related to a scheme $\mathcal{S}$ given below:

- consider two sets of users R , S , and a distinguished user u ,
- keys of the users from S are generated according to $\mathcal{S}$,
- each user in R gets a separate key for each domain, chosen independently at random from the set of keys allowed within $\mathcal{S}$,
- the situation of u depends on the environment type as follows:

type 1: u gets a single key according to $\mathcal{S}$,

type 2: u gets a separate key for each domain, just as the members of R .

Then, the adversary is given an environment E of the first or the second type, secrets of all the users except for u and can ask u for the pseudonym and signatures in any domain. The scheme $\mathcal{S}$ fulfills the unlinkability property, if the adversary cannot determine the type of E with a non-negligible advantage.

Although the above definition concerns a single user u , it shows that one can gradually replace the keys of honest users (i.e., not controlled by the adversary) so that, finally, each honest user holds a set of independent keys, one key per domain.

Note that in this definition all side information available in the real world might be taken into account, including an a priori known probability distribution of the links between pseudonyms. Thereby, the second definition simply says: the situation is not worse than in the case that for each domain the user gets a random key chosen independently of all other keys. Obviously, the last situation is maximum that one can get with a cryptographic scheme generating pseudonyms and signatures corresponding to them.

6 Algorithms

This section describes a few established Domain Signature schemes. Appropriate taxonomy summaries are provided. The constructions are mostly modular, and thus can be extended or tweaked to provide additional functionalities, or better suit the requirements.

6.1 Solutions Based on Whitelists

This section presents a simple domain signature scheme where the simplicity is achieved at the price that a separate whitelist has to be created for each domain. Nevertheless, such a scheme fits perfectly some scenarios—For example, evaluation of courses by university students [17] or database entries anonymization.

Algorithm 1 Setup of a scheme based on whitelists

Setup:

1. Choose a cyclic group $\mathbb{G}$ of a prime order p , and a generator $g \in \mathbb{G}$.
2. Output $\mathbb{G}, g$ as system parameters.

Join-Issue:

1. User A chooses $x < p$ at random, $y = g^x$.
2. A presents y to ID Authority.
3. ID Authority verifies identity of A and stores (A, y) in its database.

CreateDomain: (Creating domain parameter dPK for domain dom)

1. ID Authority chooses r_1 at random, computes $\text{dPK}' = g^{r_1}$.
2. ID Authority stores (dom, r_1) in its database, and presents dPK' to the authority of dom.
3. The Domain Authority of dom chooses r_2 at random, computes $\text{dPK} = (\text{dPK}')^{r_2}$.
4. The Domain Authority of dom stores r_2 securely and publishes dPK.

Algorithm 2 Operational part of a scheme based on whitelistsJoinDomain: For a domain dom with $\text{dPK} = g^{r_1 r_2}$:

1. ID Authority creates a (sorted) list L consisting of entries in the form y^{r_1} , where y is the public key of the user entitled to be active in dom.
2. ID Authority hands L over to the Domain Authority of dom.
3. For each entry $z \in L$, the Domain Authority of dom computes z^{r_2} and puts the sorted results on its whitelist.

Sign: A user holding the secret key x creates a Schnorr signature corresponding to x and the public key dPK^x .

In this scheme, domain signatures are just signatures based on discrete logarithm problem with respect to the generator dPK—the domain parameter of the domain that the signature refers to. The JoinDomain procedure is executed periodically in order to reflect the changes in the set of entitled users. Note that each entry of the whitelist for dom is a public key dPK^x , where x is the private key to be active in dom.

Deanonymization of a pseudonym dnym is a process reverse to its creation for the whitelist: the Domain Authority computes $\text{dnym}' = \text{dnym}^{r_2^{-1}}$, presents the result to the ID Authority where the public key of the user is recovered as $(\text{dnym}')^{r_1^{-1}}$.

6.1.1 Taxonomy Summary**Domain[Virtual.Created|Managed.Mutually-created]****JoinAuth[IDAuthority+DomainAuthority]****JoinScope[domain]**

JoinMech[whitelist]

It is easy to extend the scheme so that more than two parties must be involved in whitelist creation. If anonymity against the ID Authority is not required, then this authority can create the whitelist itself. For the applications like described in Sect. 2.3, domain authorities can create whitelists themselves.

One has to note that it is possible to run multiple “*ID Authorities*” and *Domain Authorities*, as soon as the public keys of the users are known.

RevAv[true]**RevData[whitelist]****RevScope[domain]****RevAuth[IDAuthority+DomainAuthority]****DeAnonLink[domain-ID]**

Note that no proof for deanonymization link is given directly according to the description from Algorithm 2; however, it is straightforward to create an appropriate zero-knowledge proof for correctness of the link.

ContAv[true]**ContMeth[replacement]**

It is relatively easy to respond to the cases such as key compromise by simply replacing the key, as the whitelists need to be updated frequently.

6.2 Pseudonymous Signatures (BSI)

German Federal Office for Information Security (BSI) has published a specification for *Pseudonymous Signatures* scheme [5] as a part of their eIDAS implementation. The scheme is proposed as an alternative for *Restricted Identification* protocol for domain- (or sector-, as in their original terminology) specific identification.

Due to inherent properties of the scheme, under certain circumstances, there might exist a *trusted third party* able to link users’ pseudonyms across domains.

Issuing a key for a user requires a trusted and secure ID Authority, as all users share a sort of a shared secret value. This in turn requires storing the shared secrets in secure hardware, since extraction of the secrets reveals the system keys of the ID Authority allowing to create new identities out of thin air.

Algorithm 3 Pseudonymous signature scheme setup

Setup:

1. Choose a cyclic group $\mathbb{G}$ of a prime order p , and a generator $g \in \mathbb{G}$.
2. Define a cryptographic hash function $\mathcal{H}$ that maps into $\mathbb{Z}_p$.
3. Output public parameters $(\mathbb{G}, g, \mathcal{H})$.
4. Choose $z \xleftarrow{R} \mathbb{Z}_p$ at random and put $g_1 \leftarrow g, g_2 \leftarrow g^z$.
5. Choose $x \xleftarrow{R} \mathbb{Z}_p$ at random and compute public key $\text{gPK} \leftarrow g_1^x$.
6. Output parameters (g_1, g_2, gPK) .

The above setup is periodically repeated starting from point (5) - gPK is called the group key (for a *group* of users, not to be confused with a *group* in the algebraic sense).

Join-Issue:

1. For each user i the ID Authority chooses $x_{i,2} \xleftarrow{R} \mathbb{Z}_p$ at random and computes $x_{i,1} \leftarrow x - z \cdot x_{i,2}$.
 2. The ID Authority embeds $x_{i,1}, x_{i,2}$ in the user's device and forgets them.
-

Note that if Join-Issue is not performed in a secure way and the user's keys $x_{i,1}, x_{i,2}$ are leaked outside, then having two such pairs allows for recomputing z and consequently the group secret key x , which allows for creating rogue identities.

The domain parameter $\text{dPK} \in \mathbb{G}$, which is an input to NymGen and Sign procedures is either assigned to the domain by a certain authority or created as the hash value of the domain identifier.

Algorithm 4 Pseudonymous signature domain creation

CreateDomain:

- option 1: $\text{dPK} \leftarrow \mathcal{H}_{\mathbb{G}}(\text{dom})$, where dom is the official domain identifier and $\mathcal{H}_{\mathbb{G}}$ maps into group $\mathbb{G}$
- option 2: just like for whitelists approach (see Algorithm 1)
-

The pseudonym generation follows the same idea as in Sect. 6.1 and is presented in Algorithm 5.

Algorithm 5 Pseudonymous signature pseudonym generation

NymGen: For domain dom and its parameters $\text{dPK} \in \mathbb{G}$ the user holding private keys $x_{i,1}, x_{i,2}$ creates pseudonyms as the pair $\text{dnym}_{\text{dom},i} = (\text{dnym}_{\text{dom},i,1}, \text{dnym}_{\text{dom},i,2})$, where

$$\text{dnym}_{\text{dom},i,1} \leftarrow \text{dPK}^{x_{i,1}},$$

$$\text{dnym}_{\text{dom},i,2} \leftarrow \text{dPK}^{x_{i,2}}.$$

Note that knowledge of the discrete logarithm α between two domain public keys $\text{dPK}_{\text{dom1}}^\alpha = \text{dPK}_{\text{dom2}}$ enables efficient linking of users' pseudonyms across these domains due to the following equalities:

$$(\text{dnym}_{\text{dom1},i,j})^\alpha = (\text{dPK}_{\text{dom1}}^{x_{i,1,j}})^\alpha = \text{dPK}_{\text{dom2}}^{x_{i,1,j}} = \text{dnym}_{\text{dom2},i,j}.$$

The signing process follows the idea of Okamoto–Schnorr signature of knowledge which proves the knowledge of private exponents $x_{i,1}, x_{i,2}$ and correctness of the exponent in $\text{dnym}_{\text{dom},i}$. In order to sign a message m with regards to a pseudonym $\text{dnym}_{\text{dom},i}$ for a domain specification $\text{dPK} \in \mathbb{G}$, user i performs the following signature of knowledge:

$$\pi \leftarrow \text{SoK}\{\alpha, \beta : \text{dnym}_{\text{dom},i,1} = \text{dPK}^\alpha \wedge \text{dnym}_{\text{dom},i,2} = \text{dPK}^\beta \wedge \text{gPK} = g_1^\alpha g_2^\beta\}(m).$$

The signature under m is simply the proof π .

Algorithm 6 Pseudonymous signature generation and verification

Sign: The following procedure yields a signature under m for domain parameter dPK , pseudonym $(\text{dnym}_1, \text{dnym}_2)$ and private key x_1, x_2 :

1. choose $k_1, k_2 \xleftarrow{R} \mathbb{Z}_p$ at random,
2. $Q \leftarrow g_1^{k_1} \cdot g_2^{k_2}$,
3. $A_1 \leftarrow \text{dPK}^{k_1}, A_2 \leftarrow \text{dPK}^{k_2}$,
4. $c \leftarrow \mathcal{H}(Q, \text{dnym}_1, A_1, \text{dnym}_2, A_2, \text{dPK}, m)$,
5. $s_1 \leftarrow k_1 - c \cdot x_1 \bmod p$ and $s_2 \leftarrow k_2 - c \cdot x_2 \bmod p$.

Output signature $\sigma(m) = (c, s_1, s_2)$.

Verify: Signature (c, s_1, s_2) for a message m and domain pseudonyms $(\text{dnym}_1, \text{dnym}_2)$ is verified as follows:

1. $Q' \leftarrow \text{gPK}^c \cdot g_1^{s_1} \cdot g_2^{s_2}$,
 2. $A'_1 \leftarrow \text{dPK}^{s_1} \cdot \text{dnym}_1^c$,
 3. $A'_2 \leftarrow \text{dPK}^{s_2} \cdot \text{dnym}_2^c$,
 4. output valid iff $c = \mathcal{H}(Q', \text{dnym}_1, A'_1, \text{dnym}_2, A'_2, \text{dPK}, m)$.
-

Validity of verification follows from the equations:

$$\begin{aligned} Q' &= \text{gPK}^c \cdot g_1^{s_1} \cdot g_2^{s_2} = g_1^{xc} \cdot g_1^{k_1-c \cdot x_1} \cdot g_2^{k_2-c \cdot x_2} = Q \cdot (g_1^{x-x_1-x_2 \cdot z})^c = Q \cdot 1^c = Q, \\ A'_1 &= \text{dPK}^{s_1} \cdot \text{dnym}_1^c = \text{dPK}^{k_1-c \cdot x_1} \cdot (\text{dPK}^{x_1})^c = \text{dPK}^{k_1} = A_1, \\ A'_2 &= \text{dPK}^{s_2} \cdot \text{dnym}_2^c = \text{dPK}^{k_2-c \cdot x_2} \cdot (\text{dPK}^{x_2})^c = \text{dPK}^{k_2} = A_2. \end{aligned}$$

Deanonymization is possible if the second option for generating dPK is used. In this case, the procedure follows the same steps as described in Sect. 6.1.

6.2.1 Taxonomy Summary

Domain[Virtual.Ad-hoc]

For option 1 deanonymization is infeasible.

Domain[Managed.Mutually-created]

For option 2 that supports deanonymization.

JoinAuth[IDAuthority]

JoinScope[all]

JoinMech[key]

The main mechanism of the scheme is that a user gets a pair of keys x_1, x_2 such that $x = x_1 + x_2 \cdot z$, where x and z are private system keys.

RevAv

As the designers aim to avoid any use of certificates, revocation is possible in multiple ways as follows:

- The group key gPK is revoked, thereby all group members are revoked at once, without revealing the culprit's identity:

RevAv[true], RevScope[all], RevAuth[IDAuthority], RevData[blacklist].

- Section 7.5 describes common solutions based on the way dPKs are generated.

DeAnonAuth

There are a few options available for deanonymization if option 2 for generating dPK is applied as given below:

- Users can be deanonymized in the same way the blacklists are created. Consequently, it implies:

DeAnonAuth[IDAuthority+DomainAuthority], DeAnonLink[domain-ID].

- It is possible to translate a pseudonym in one domain to a pseudonym in another domain by the authorities of these domains cooperating with the ID Authority, so that the ID Authority does not learn which pseudonym is translated (for details see Sect. 7). This corresponds to:

DeAnonAuth[IDAuthority+DomainAuthority],

DeAnonLink[domain-domain].

- Section 7.5 describes common solutions based on the way dPKs are generated.

DeAnonProof[interactive|signature]

In either case, revealing the link might be performed either as an interactive proof or as a signature of knowledge.

6.3 Schemes Based on SDH Assumption

This section and the following ones describe domain signature schemes utilizing bilinear maps. These schemes summarize main ideas contained, with certain variations, in papers [4, 15, 16, 22]. The first approach, presented in this section, is based on the strong Diffie–Hellman (SDH) Assumption [3]:

Definition 1 (*q-SDH Assumption*) Assume that $\mathbb{G}_1, \mathbb{G}_2$ are groups of a prime order p .

Given $g_1, g_1^z, g_1^{z^2}, \dots, g_1^{z^q}, g_2, g_2^z$ for a random choice over $(g_1, g_2) \in \mathbb{G}_1 \times \mathbb{G}_2$, and $z \in \mathbb{Z}_p$, it is infeasible to derive a pair $(m, g_1^{\frac{1}{z+m}}) \in \mathbb{Z}_p \times \mathbb{G}_1$.

The approach presented in this section is based on the following design. First, a user and the ID Authority compute the user's secret key in a two-party protocol. The resulting secret key is an element that cannot be computed without using the system keys of the ID Authority, and therefore contains implicitly a kind of a “special certificate” witnessing that it has been created in cooperation with the ID Authority. Due to the SDH Assumption no coalition of malicious users can create a new valid key and thereby forge a new identity. Consequently, the seclusiveness problem is addressed on the cryptographic level and the dependence on tamper-resistant hardware is eliminated. This is a substantial progress in comparison to Pseudonymous Signatures from Sect. 6.2.

Domain unlinkability is achieved due to the fact that pseudonyms are computed using distinct group generators in each domain. However, the design of the schemes has to be very careful, since bilinear maps might be used to break unlinkability, if wrong groups are used (in particular, type-1 mapping must not be used).

Pseudonym uniqueness is guaranteed by the fact that the pseudonym generation procedure is fully deterministic and depends only on the domain parameters and the user's secret key that cannot be changed by the user.

Finally, signatures are based on noninteractive signatures of knowledge obtained by transforming a Σ -protocol using the Fiat–Shamir transform.

Algorithm 7 describes the parameter generation process. The scheme is based on prime order groups with bilinear maps of type 2 or 3 (that is, there is no efficiently computable isomorphism from $\mathbb{G}_1$ to $\mathbb{G}_2$).

The Join-Issue procedure is described in Algorithm 8. User i obtains a tuple $(u_i, x_i, A_i) \in \mathbb{Z}_p^2 \times \mathbb{G}_1$, where

$$A_i = (g_1 \cdot h^{u_i})^{1/(z+x_i)}.$$

Execution of the procedure does not reveal u_i to the ID Authority, so that it cannot forge signatures of i . On the other hand, the procedure must not reveal the ID Authority's secret key z .

Algorithm 9 describes the pseudonym generation procedure for the SDH approach. As mentioned earlier, they have to be deterministic and involve only the domain parameters and (a part of) the user secret key. The pseudonym is generated using the pair (x_i, u_i) of the secret key. The remaining element A_i is used as the “special certificate” on these values. The selection of the domain parameters dPK may enable additional properties in terms of user revocation or deanonymization.

Algorithm 7 SDH specific setup

Setup:

1. Choose groups $\mathbb{G}_1$ and $\mathbb{G}_2$ of prime order p and a bilinear map $e : \mathbb{G}_1 \times \mathbb{G}_2 \rightarrow \mathbb{G}_T$ which maps into a target group $\mathbb{G}_T$.
2. Choose generators $g_1 \xleftarrow{R} \mathbb{G}_1$ and $g_2 \xleftarrow{R} \mathbb{G}_2$ at random.
3. Choose a cryptographic hash function $\mathcal{H}$ that maps into $\mathbb{G}_1$.
4. Choose $s \xleftarrow{R} \{0, 1\}^*$ at random and compute $h \leftarrow \mathcal{H}(s)$, i.e., map the random element into $\mathbb{G}_1$.
5. The ID Authority chooses its secret key $z \xleftarrow{R} \mathbb{Z}_p$ and computes its public key $Z \leftarrow g_2^z$.
6. Global parameters are $(g_1, g_2, p, h, s, Z, e, \mathcal{H})$.

(Note that anyone can check that $h = \mathcal{H}(s)$ and thereby can assume that nobody knows the discrete logarithm of h .)

Algorithm 8 Issuing protocol for the SDH approachJoin-Issue: This is a two-party protocol between the ID Authority $\mathcal{A}$ and a user i :

1. i chooses $u' \xleftarrow{R} \mathbb{Z}_p$ at random, sets $U' \leftarrow h^{u'}$, presents U' to $\mathcal{A}$ and runs the following zero-knowledge proof of knowledge:

$$ZKPoK\{\alpha : U' = h^\alpha\}$$

2. $\mathcal{A}$ chooses $u'' \xleftarrow{R} \mathbb{Z}_p$ at random, sets $U_i \leftarrow U' \cdot h^{u''}$.
3. $\mathcal{A}$ chooses the user revocation token as $\text{uRT}_i \leftarrow (x_i, U_i)$, where $x_i \xleftarrow{R} \mathbb{Z}_p$ is chosen at random.
4. $\mathcal{A}$ computes $A_i \leftarrow (g_1 \cdot U_i)^{1/(z+x_i)}$ and presents the tuple (u'', x_i, A_i) to i .
5. i computes $u_i \leftarrow u' + u''$ and sets their secret key to (u_i, x_i, A_i) .

Algorithm 9 SDH pseudonym generationNymGen: With domain parameter $\text{dPK} \in \mathbb{G}_1$ for a domain dom , the user i computes their pseudonym as $\text{dnym} \leftarrow g_1^{x_i} \cdot \text{dPK}^{u_i}$.

Note that type 1 pairings must not be used here (a pairing is of type 1 if there are efficiently computable isomorphisms from $\mathbb{G}_1$ to $\mathbb{G}_2$ and from $\mathbb{G}_2$ to $\mathbb{G}_1$). Given pseudonyms $\text{dnym}_1, \text{dnym}_2, \text{dnym}_3$ corresponding to the domain parameters $\text{dPK}_1, \text{dPK}_2, \text{dPK}_3$, one can check whether

$$e(\text{dnym}_1/\text{dnym}_2, \phi(\text{dPK}_2/\text{dPK}_3)) \stackrel{?}{=} e(\text{dnym}_2/\text{dnym}_3, \phi(\text{dPK}_1/\text{dPK}_2)).$$

The signing procedure is described in Algorithm 10. In short, the signer computes a signature of knowledge of three elements of their secret key, which need to fulfill two constraints. The first constraint is that the pseudonym is created from (x_i, u_i) . The second constraint is that the user has the “special certificate” A_i on these elements,

such that A_i and (x_i, u_i) verify correctly with the ID Authority's public key Z . The final signature consists of a signature of knowledge.

Algorithm 10 SDH signature generation

Sign: A signature under a message m with regards to a pseudonym dnym for a domain parameter dPK is essentially the following signature of knowledge (the Camenisch-Stadler notation is slightly abused here, as the value z is known neither to the verifier nor to the signer.)

$$\sigma \leftarrow \text{SoK}\{(\alpha, \beta, \gamma) : \text{dnym} = g_1^\alpha \cdot \text{dPK}^\beta \wedge \gamma^{\alpha+z} \cdot h^{-\beta} = g_1\}(m)$$

The signature on m is simply σ .

For example, the following steps are executed by the user i holding the key (u_i, x_i, A_i) :

1. Choose $(r, t_u, t_x, t_r, t_b, t_d) \xleftarrow{R} \mathbb{Z}_p^6$ at random.
2. Compute $R \leftarrow A_i \cdot h^r$.
3. Compute

$$\begin{aligned} T_1 &\leftarrow g_1^{t_x} \cdot \text{dPK}^{t_u}, \\ T_2 &\leftarrow \text{dnym}^{t_r} \cdot g_1^{-t_b} \cdot \text{dPK}^{-t_d}, \text{ and} \\ T_3 &\leftarrow e(A_i, g_2)^{t_x} \cdot e(h, g_2)^{r \cdot t_x - t_u - t_b} \cdot e(h, Z)^{-t_r}. \end{aligned}$$

4. Compute challenge $c \leftarrow \mathcal{H}(\text{dPK}, R, T_1, T_2, T_3, m)$ for the message m .
5. Compute

$$\begin{aligned} s_u &\leftarrow t_u + c \cdot u_i \bmod p & s_x &\leftarrow t_x + c \cdot x_i \bmod p \\ s_r &\leftarrow t_r + c \cdot r \bmod p & s_b &\leftarrow t_b + c \cdot r \cdot x_i \bmod p \\ s_d &\leftarrow t_d + c \cdot r \cdot u_i \bmod p. \end{aligned}$$

6. Output signature $\sigma = (R, c, s_u, s_x, s_r, s_b, s_d)$.
-

Verification of the signature presented above is performed as follows:

1. Reconstruct the values T_i :

$$\begin{aligned} T'_1 &\leftarrow g_1^{s_x} \cdot \text{dPK}^{s_u} \cdot \text{dnym}^{-c}, \\ T'_2 &\leftarrow \text{dnym}^{s_r} \cdot g_1^{-s_b} \cdot \text{dPK}^{-s_d}, \\ T'_3 &\leftarrow e(R, g_2)^{s_x} \cdot e(h, g_2)^{-s_u - s_b} \cdot e(h, Z)^{-s_r} \cdot [e(g_1, g_2) \cdot e(R, Z)^{-1}]^{-c}, \end{aligned}$$

2. Check whether $c = \mathcal{H}(\text{dPK}, R, T'_1, T'_2, T'_3, m)$.

The signature of knowledge reveals no information about the secret key elements used to prove the statement. It is easy to see that in the construction the only useful information to link user's activities across domains are the pseudonyms.

6.3.1 Revocation

If domain parameter dPK is created according to the formula $\text{dPK} = h^{r_1 r_2}$, where r_1 is held by the ID Authority and r_2 by the Domain Authority, then deanonymization can be achieved as follows:

A domain pseudonym can be easily derived from the revocation token as

$$\text{dnym} \leftarrow g_1^{x_i} (U_i)^{r_1 r_2}.$$

On the other hand, there seems to be no direct way to recover the revocation token from a domain pseudonym dnym. (Of course there is a tedious way: compute pseudonyms of all users in this domain and check in which cases the pseudonyms match.) From the practical point of view this might be a serious problem.

One can create an alternative revocation token (X_i, U'_i) , where $X'_i \leftarrow g_1^{x_i}$ and $U'_i = g_2^{u_i}$. Then, the test takes the following form:

$$e(\text{dnym}, g_2) \stackrel{?}{=} e(X'_i, g_2) \cdot e(\text{dPK}, U'_i).$$

6.3.2 Taxonomy Summary for the SDH Approach

Domain[Virtual.Ad-hoc]

For option 1, deanonymization is infeasible.

Domain[Managed.Mutually-created]

For option 2 that supports deanonymization.

JoinAuth[IDAuthority]

JoinScope[all]

JoinMech[key]

RevAv

Similarly to the Pseudonymous Signature scheme, the availability of revocation depends on the use case. See Sect. 7.5 for details on available options.

DeAnonAuth

Just like the revocation, the deanonymization is tightly bound to specific use cases. See Sect. 7 for details on available options.

ContAv[false]

For protocols without any extensions, no continuity mechanisms are envisioned. Section 8 discusses some extensions solving this issue.

6.4 Schemes Based on LRSW Assumption

The approach presented in this section, is based on the LRSW Assumption [21]. It follows similar patterns as the SDH-based solution, but at the same time utilizes

more standard structure. Notably, the structure of pseudonyms is perpendicular to cases presented in other constructions, which allows for similar deanonymization and revocation techniques.

Definition 2 (*LRSW Assumption*) Let $\mathbb{G}$ be a cyclic group with a generator g .

The LRSW Assumption states that given $X = g^x$, $Y = g^y$ it is infeasible to compute a tuple (m, a, a^y, a^{x+my}) for $a \neq 1, m \neq 0$.

The parameter generation process for the LRSW approach is presented in Algorithm 11. (As for the SDH approach, the type 1 pairing must not be used here.)

Algorithm 11 LRSW specific setup

Setup:

1. Choose groups $\mathbb{G}_1$ and $\mathbb{G}_2$ of a prime order p and a bilinear map $e : \mathbb{G}_1 \times \mathbb{G}_2 \rightarrow \mathbb{G}_T$ which maps into a target group $\mathbb{G}_T$.
 2. Choose generators $g_1 \xleftarrow{R} \mathbb{G}_1$ and $g_2 \xleftarrow{R} \mathbb{G}_2$ at random.
 3. Choose a cryptographic hash function $\mathcal{H}$ that maps into $\mathbb{G}_1$.
 4. Return $(\mathbb{G}_1, \mathbb{G}_2, g_1, g_2, e, \mathcal{H})$.
 5. The ID Authority generates a secret keys pair $(x, y) \xleftarrow{R} \mathbb{Z}_p^2$ at random and computes the public keys as $(X, Y) \leftarrow (g_1^x, g_2^y)$.
 6. Global parameters are $(g_1, g_2, p, X, Y, e, \mathcal{H})$.
-

Algorithm 12 describes the issuing procedure for the LRSW approach. In this case, the user generates a pair $(u_i, U_i) \in \mathbb{Z}_p \times \mathbb{G}_1$, where $U_i = g_1^{u_i}$. Another option is that these values are generated by the user and the ID Authority in a two-party protocol. Next, the ID Authority signs u_i using the CL-signature scheme. Luckily, due to specific properties of the CL-signature scheme, the ID Authority can create such a signature knowing only U_i . Thereby, the ID Authority does not learn u_i , and therefore gets no opportunity to forge signatures of the user i .

Algorithm 13 describes the pseudonym generation procedure. The pseudonym is simply derived from u_i for which the user has a CL-signature (A_i, B_i, C_i, D_i) created by the ID Authority. The way the domain parameters dPK are generated impacts the available revocation and deanonymization scenarios, in the same way as in Sect. 6.2.

Creating signatures is described in Algorithm 14. The user first randomizes the CL-signature obtaining $(\tilde{A}, \tilde{B}, \tilde{C}, \tilde{D})$. Then, they create a signature of knowledge of u_i which has been used to generate the pseudonym dnm and which is the message signed by the randomized CL-signature. Finally, the signature consists of the randomized CL-signature and the signature of knowledge.

For the example signing procedure presented in Algorithm 14, the verification procedure looks as follows:

1. Check that $\tilde{A} \neq 1, \tilde{B} \neq 1$, and

$$e(\tilde{A}, Y) = e(\tilde{B}, g_2), \quad e(\tilde{C}, g_2) = e(\tilde{A} \cdot \tilde{D}, X).$$

Algorithm 12 Issuing protocol for the LRSW approach

Join-Issue: At the end of the protocol:

- The ID Authority sets the user revocation token as $\text{uRT}_i \leftarrow U_i$, where $U_i = g_1^{u_i}$.
- The user obtains their secret key $(u_i, A_i, B_i, C_i, D_i)$, where $A_i \neq 1$, $B_i \neq 1$, $e(A_i, Y) = e(B_i, g_2)$, $e(C_i, g_2) = e(A_i \cdot D_i, X)$ and $D_i = B_i^{u_i}$.

For this purpose the following steps are executed:

1. The user chooses $u' \xleftarrow{R} \mathbb{Z}_p$ at random, computes $U' = g_1^{u'}$ and presents U' to the ID Authority and runs the following zero-knowledge proof of knowledge:

$$ZK\text{PoK}\{\alpha : U' = h^\alpha\}$$

2. The ID Authority chooses $(r, u'') \xleftarrow{R} \mathbb{Z}_p^2$ at random.
3. The ID Authority sets $A_i \leftarrow g_1^r$, computes $B_i \leftarrow g_1^{r^y}$, $C_i \leftarrow g_1^{r^x} \cdot (U' \cdot g_1^{u''})^{r^{xy}}$ and $D_i \leftarrow (U' \cdot g_1^{u''})^{r^y}$.
4. The ID Authority sets the user revocation token as $\text{uRT}_i \leftarrow U_i = U' \cdot g_1^{u''}$, and then presents the certificate (A_i, B_i, C_i, D_i) and the value u'' to the user.
5. The user computes $u_i \leftarrow u' + u'' \bmod p$ and sets their secret key to $(u_i, A_i, B_i, C_i, D_i)$.

Algorithm 13 LRSW pseudonym generation

NymGen: With domain parameter $\text{dPK} \in \mathbb{G}_1$, the user i computes their pseudonym as

$$\text{dnym} \leftarrow \text{dPK}^{u_i}.$$

Algorithm 14 LRSW signature generation

Sign: In order to sign a message m with regards to a pseudonym dnym for a domain parameter $\text{dPK} \in \mathbb{G}_1$, the user first randomizes their certificate (A_i, B_i, C_i, D_i) by choosing $r \xleftarrow{R} \mathbb{Z}_p$ and computing $(\tilde{A}, \tilde{B}, \tilde{C}, \tilde{D}) \leftarrow (A_i^r, B_i^r, C_i^r, D_i^r)$.

Then he computes the following signature of knowledge:

$$\pi \leftarrow \text{SoK}\{\alpha : \text{dnym} = \text{dPK}^\alpha \wedge \tilde{D} = \tilde{B}^\alpha\}(m).$$

The signature under m is $\sigma = (\tilde{A}, \tilde{B}, \tilde{C}, \tilde{D}, \pi)$.

For example, the following steps can be executed:

1. Choose $t \xleftarrow{R} \mathbb{Z}_p$ at random.
2. Compute $T_1 \leftarrow \text{dPK}^t$ and $T_2 \leftarrow \tilde{B}^t$.
3. Compute challenge $c \leftarrow \mathcal{H}(\text{dPK}, T_1, T_2, m)$ binding the signature to the message m .
4. Compute Schnorr-like signature $s \leftarrow t + c \cdot u_i$.
5. Output $(\tilde{A}, \tilde{B}, \tilde{C}, \tilde{D}, c, s)$.

2. Reconstruct T_1 and T_2 by computing

$$T_1' \leftarrow \text{dPK}^s \cdot \text{dnym}^{-c}, \quad T_2' \leftarrow \tilde{B}^s \cdot \tilde{D}^{-c}.$$

3. Check that $c = \mathcal{H}(\text{dPK}, T'_1, T'_2, m)$.

The signature of knowledge reveals no information about the secret key elements used to prove the statement. The information revealed to an adversary by the signature is slightly more valuable than in the SDH case, since it additionally includes the randomized CL-signature. However, CL-signatures are unlinkable in the sense that it is infeasible to tell whether two randomized CL-signatures concern the same message, under the DDH assumption, unless the signed message is known.

6.4.1 Taxonomy Summary for the LRSW Approach

Domain[Virtual.Ad-hoc]

For option 1, deanonymization is infeasible.

Domain[Managed.Mutually-created]

For option 2 that supports deanonymization.

JoinAuth[IDAuthority]

JoinScope[all]

JoinMech[key]

RevAv

Similarly to the Pseudonymous Signature scheme, the availability of revocation depends on the use case. See Sect. 7.5 for details on available options.

DeAnonAuth

Just like the revocation, the deanonymization is tightly bound to specific use cases. See Sect. 7 for details on available options.

ContAv[false]

For protocols without any extensions, no continuity mechanisms are envisioned. Section 8 discusses some extensions solving this issue.

6.5 Certificate-Based Approach

Rather than embedding the information about the signer's status and their pseudonym in the signature itself, another way of proving the signer's membership in a domain is to use specific certificates. They are attributed to domain pseudonyms and not particular signatures and are derived solely by the signer from the data obtained during the execution of Join-Issue. This solution allows much simpler signature schemes at the cost of calculating a certificate once per domain.

An example of such a scheme based on the LRSW assumption can be found in [24]. The aim of the scheme is not to provide secure pseudonymous signatures, but a framework of certificates that users can generate on their own, carrying the trust put into them by a central CA.

An additional feature of the scheme is that it allows extending the certificates with additional fields. However, for simplicity, in the following example only a single ran-

domizer value for information-theoretic security of the certificates is used. Note that the information-theoretic security approach allows for smaller security requirements put on the pairing-friendly domain parameters, as their compromise would at best allow creation of rogue certificates and can be circumvented by relatively short key life cycle. On the other hand, should solving hard problems in those groups become feasible in the future, the lack of information-theoretic security in certificates might allow a post-factum linkage of pseudonyms.

Algorithm 15 LRSW certificate specific setup

Setup:

1. Run $(\mathbb{G}_1, \mathbb{G}_2, g_1, g_2, e, \mathcal{H}) \leftarrow \text{CommonDSSetup}(\lambda)$.
 2. The ID Authority generates a secret key tuple $(x, y, z) \in \mathbb{Z}_p^3$ at random and computes the public key as $(X, Y, Z) = (g_2^x, g_2^y, g_2^z)$.
 3. The global parameters are $(g_1, g_2, p, X, Y, Z, e, \mathcal{H})$.
-

Generation of certificates is similar to the generation in case of the aforementioned LRSW-based signatures, with the exception of an additional parameter.

Algorithm 16 LRSW certificate specific issue

Join-Issue: This is an two-party secure computation protocol between the ID Authority and a user i , at the end of which:

- the ID Authority sets the user revocation token as $\text{uRT}_i \leftarrow U_i$, where $U_i = g_1^{u_i}$,
- the user i holds a secret key $(u_i, r_i, A_{0,i}, A_{1,i}, B_{0,i}, B_{1,i}, C_i)$, where

$$\begin{aligned}
 &A_{\cdot,i} \neq 1, B_{\cdot,i} \neq 1, \\
 &e(A_{0,i}, Y) = e(B_{0,i}, G_2), \\
 &e(A_{1,i}, Y) = e(B_{1,i}, G_2), \\
 &e(A_{0,i}, Z) = e(A_{1,i}, G_2), \\
 &e(C_i, G_2) = e(A_{0,i} B_{0,i}^{u_i} B_{1,i}^{r_i}, X).
 \end{aligned}$$

Note that in this case $A_{1,i} = A_{0,i}^z$, $B_{0,i} = A_{0,i}^y$, $B_{1,i} = A_{0,i}^{zy}$, $C_i = A_{0,i}^{x+xyu_i+xyzr_i}$.

The generation of certificates is moved to the NymGen procedure, as it is sufficient to execute it only once per domain as described by Algorithm 17.

Having such a certificate, in order to sign a message, it is sufficient to prove the knowledge of the private key u_i via a signature of knowledge, e.g., a Schnorr signature as described by Algorithm 18.

6.5.1 Taxonomy Summary

Domain[Virtual.Ad-hoc| Managed.Ad-hoc]

Possible with no deanonymization.

Algorithm 17 LRSW certificate generation

NymGen: With domain parameter $\text{dPK} \in \mathbb{G}_1$ as input, user i computes their pseudonym as $\text{dnym} \leftarrow \text{dPK}^{u_i}$ and their domain certificate $\text{Cert} = (\text{dnym}, \sigma)$:

1. compute

$$(\tilde{A}_{0,i}, \tilde{A}_{1,i}, \tilde{B}_{0,i}, \tilde{B}_{1,i}, \tilde{C}_i) \leftarrow (A_{0,i}^r, A_{1,i}^r, B_{0,i}^r, B_{1,i}^r, C_i^{rr'})$$

for a random (or pseudo-random) r and r' .

2. create a noninteractive zero-knowledge proof π :

$$\pi \leftarrow \text{NIZK}\{\alpha, \beta, \rho : \text{dnym} = \text{dPK}^\alpha \wedge e(\tilde{C}_i, G_2) = e(\tilde{A}_{0,i}^\rho \tilde{B}_{0,i}^{\alpha\rho} \tilde{B}_{1,i}^{\beta\rho}, X)\}.$$

3. output $\sigma = (\tilde{A}_{0,i}, \tilde{A}_{1,i}, \tilde{B}_{0,i}, \tilde{B}_{1,i}, \tilde{C}_i, \pi)$.

Algorithm 18 Message signing with an LRSW certificate

Sign: In order to sign a message m with regards to a pseudonym dnym for a domain specification $\text{dPK} \in \mathbb{G}_1$ and a certificate $\text{Cert} = (\text{dnym}, \sigma)$ the user computes a signature of knowledge:

$$\varsigma \leftarrow \text{SoK}\{\alpha : \text{dnym} = \text{dPK}^\alpha\}(m).$$

ς is the signature on m .

Domain[Virtual.Created| Managed.Mutually-created]

Required for deanonymization.

JoinAuth[IDAuthority]**JoinScope[all]****JoinMech[certificate]****RevAv**

Revocation is possible in a few ways:

- Certificates might have relatively short lifetime periods and be automatically revoked upon epoch change.

RevAv[true], RevScope[all], RevAuth[IDAuthority], RevData[time]

- Similarly to the Pseudonymous Signature scheme, additional revocation methods may be available, depending on the use case. See Sect. 7.5 for details on available options.

DeAnonAuth

Just like the revocation, the deanonymization is tightly bound to the specific use cases. See Sect. 7 for details on available options.

ContAv[false]

For the protocols without any extensions, no continuity mechanisms are envisioned. Section 8 discusses some extensions solving this issue.

6.6 Schemes Based on Pointcheval–Sanders Signatures

6.6.1 Pointcheval–Sanders Signatures

Pointcheval and Sanders [23] proposed a signature scheme with properties very close to the LRSW signatures, but with significantly reduced size and with a few interesting features presented below. The scheme is based on a type-3 pairing, i.e., $e : \mathbb{G}_1 \times \mathbb{G}_2 \rightarrow \mathbb{G}_T$, where there is no efficiently computable isomorphism from $\mathbb{G}_1$ to $\mathbb{G}_2$ and vice versa. One version of the scheme allows to run an interactive signing protocol in which a user sends to the signatory a Pedersen commitment of a message and a proof of opening, and obtains a valid signature on the message. Algorithm 19 recalls details of the scheme.

Algorithm 19 Pointcheval–Sanders interactive blind signature

Setup:

1. Choose groups $\mathbb{G}_1$ and $\mathbb{G}_2$ of a prime order p and a type-3 pairing function $e : \mathbb{G}_1 \times \mathbb{G}_2 \rightarrow \mathbb{G}_T$.
2. Choose $g \xleftarrow{R} \mathbb{G}_1$ and $\tilde{g} \xleftarrow{R} \mathbb{G}_2$ at random.
3. The signer chooses $x, y \xleftarrow{R} \mathbb{Z}_p$ at random and computes $(X, Y) \leftarrow (g^x, g^y)$, $(\tilde{X}, \tilde{Y}) \leftarrow (\tilde{g}^x, \tilde{g}^y)$.

$\text{sk}_S = (g, \tilde{g}, x, y)$ is the private signing key.

$\text{pk}_S = (g, Y, \tilde{g}, \tilde{X}, \tilde{Y})$ is the public key.

Sign: For a message u

1. The user selects $t \xleftarrow{R} \mathbb{Z}_p$ and sends a commitment on u of the form $C = \tilde{g}^t \cdot Y^u$ alongside with a proof of knowledge of the opening to the signer.
2. The signer aborts if the proof of knowledge is incorrect.
3. The signer selects $k \xleftarrow{R} \mathbb{Z}_p$ and sends back (σ_1, σ'_2) where $\sigma_1 \leftarrow g^k$, $\sigma'_2 \leftarrow (XC)^k$.
4. The user computes the signature for u in the following way: $\sigma \leftarrow (\sigma_1, \sigma'_2/\sigma_1^t)$

The signature has the form $(g^k, (XY^u)^k)$.

Verify: A signature (σ_1, σ_2) is accepted for u , if $\sigma_1 \neq 1$ and $e(\sigma_1, \tilde{X}\tilde{Y}^u) = e(\sigma_2, \tilde{g})$.

Notably, one can present a proof of possession of the PS signature without revealing the signed message u , but by presenting h^u . Algorithm 20 contains details of this Algorithm InteractiveProofPS. In the domain signature application that follows below, the element h^u will be the user's pseudonym.

A noninteractive version of InteractiveProofPS obtained via Fiat–Shamir transformation for nonce n will be denoted by $\text{ProvePS}(\text{pk}_S, \sigma, u, h, M, n)$. If π is the output of $\text{ProvePS}(\text{pk}_S, \sigma, u, h, M, n)$, then the corresponding verification procedure will be denoted by $\text{VerifyProofPS}(\text{pk}_S, \pi, h, M, n)$.

Algorithm 20 Proof of possession of Pointcheval–Sanders signature

InteractiveProofPS: For a signature (σ_1, σ_2) of u , $M = h^u$ held by the user, and the public key $\text{pk}_S = (g, Y, \tilde{g}, \tilde{X}, \tilde{Y})$:

1. The user:

a. Chooses $(r_1, r_2, r, t) \xleftarrow{R} \mathbb{Z}_p^4$ at random, and randomizes the signature:

$$\sigma' \leftarrow (\sigma_1^r, (\sigma_1^t \cdot \sigma_2)^r).$$

b. Computes

$$A \leftarrow e(\sigma'_1, \tilde{Y})^u, \quad B \leftarrow e(\sigma'_1, \tilde{g})^t, \quad T_1 \leftarrow e(\sigma'_1, \tilde{Y})^{r_1}, \quad T_2 \leftarrow e(\sigma'_1, \tilde{g})^{r_2}, \quad T_3 = h^{r_1}.$$

c. Sends $(\sigma', A, B, T_1, T_2, T_3)$ to the verifier.

2. The verifier aborts if

$$e(\sigma'_1, \tilde{X}) \cdot A \cdot B \neq e(\sigma'_2, \tilde{g}).$$

Otherwise, they choose a challenge $c \xleftarrow{R} \mathbb{Z}_p$ and send it to the user.

3. The user computes

$$s_1 \leftarrow r_1 + c \cdot u, \quad s_2 \leftarrow r_2 + c \cdot t,$$

and sends (s_1, s_2) to the verifier.

4. The verifier accepts the proof if

$$e(\sigma'_1, \tilde{Y})^{s_1} = T_1 \cdot A^c, \quad e(\sigma'_1, \tilde{g})^{s_2} = T_2 \cdot B^c \quad \text{and} \quad h^{s_1} = T_3 \cdot M^c.$$

Pointcheval–Sanders signatures (PS signatures) are a good starting point for constructing domain signature schemes. Indeed,

- a randomizable certificate σ for the user's private key u can be created via a blind PS signature of the ID Authority,
- the user may create their pseudonym $\text{dnym} \leftarrow h^u$, where h is derived from domain parameters dPK ,
- the user may create their domain signature under a message m as $\text{ProvePS}(\text{pk}_S, \sigma, u, h, \text{dnym}, m)$.

The main point is that $\text{ProvePS}(\text{pk}_S, \sigma, u, h, \text{dnym}, m)$ does not need σ to be revealed, and thereby one can avoid immediate linking of pseudonyms in different domains.

In [13], Hanzlik et al. use PS signatures this way, and moreover the construction enables *two-dimensional* deanonymization framework used in self-organization systems. For this purpose, PS signatures are combined with Cramer–Shoup encryption scheme.

6.6.2 Cramer–Shoup Encryption Scheme [10]

Details of Cramer–Shoup encryption scheme are recalled in Algorithm 21. One remarkable property of this scheme is that one can create a ciphertext of h_1^u and a

proof of knowledge of u such that $M = h_2^u$. This function is denoted as

$$(C, \pi) \leftarrow \text{ProveCS}(\text{pk}, h_1, u, h_2, M, n),$$

where n is a nonce. $\text{VerifyProofCS}(\text{pk}, (C, \pi), h_1, h_2, M, n)$ stands for the corresponding verification procedure.

Another essential property is the ability to create a proof of correct decryption $\pi \leftarrow \text{ProveDecrCS}(\text{sk}, \text{pk}, C)$. The corresponding verification procedure is denoted by $\text{VerifyDecrCS}(\text{pk}, C, h_1^u, \pi)$, where h_1^u is the plaintext.

Algorithm 21 Cramer–Shoup encryption scheme

KeyGen:

1. Let $\mathbb{G}$ be a cyclic group of a prime order p , and g_1, g_2 be generators of $\mathbb{G}$.
2. Select $x_1, x_2, y_1, y_2, z \xleftarrow{R} \mathbb{Z}_p$ at random.
3. Compute $c \leftarrow g_1^{x_1} g_2^{x_2}$, $d \leftarrow g_1^{y_1} g_2^{y_2}$, $h \leftarrow g_1^z$.

$\text{sk} = (x_1, x_2, y_1, y_2, z)$ is the private key.

$\text{pk} = (\mathbb{G}, p, g_1, g_2, c, d, h)$ is the public key.

Enc(pk, m):

1. Choose $k \xleftarrow{R} \mathbb{Z}_p$ at random.
2. Compute $u_1 \leftarrow g_1^k$, $u_2 \leftarrow g_2^k$, $e \leftarrow h^k m$, $\alpha \leftarrow \mathcal{H}(u_1, u_2, e)$, $v \leftarrow c^k d^{k\alpha}$.
3. Return (u_1, u_2, e, v) as the ciphertext of m .

Dec($\text{sk}, (u_1, u_2, e, v)$):

1. Compute $\alpha \leftarrow \mathcal{H}(u_1, u_2, e)$.
 2. Abort if $u_1^{x_1} u_2^{x_2} (u_1^{y_1} u_2^{y_2})^\alpha \neq v$.
 3. Compute $m \leftarrow e/u_1^z$.
 4. Return m as the plaintext.
-

Algorithm 22 ProveCS and VerifyProofCS for Cramer–Shoup ciphertexts

ProveCS: Given $\text{pk}, h_1, u, h_2, M = h_2^u, n$:

1. Compute a ciphertext $C = (u_1, u_2, e, v)$ of h_1^u according to the description from Algorithm 21, retain k used during derivation of C .
2. Choose $r_1, r_2 \xleftarrow{R} \mathbb{Z}_p$ at random.
3. Compute

$$T_1 \leftarrow h^{r_1} h_1^{r_2}, \quad T_2 \leftarrow h^{r_2}, \quad c \leftarrow \mathcal{H}(T_1, T_2, n).$$
4. Compute

$$s_1 \leftarrow r_1 + c \cdot k \bmod p, \quad s_2 \leftarrow r_2 + c \cdot u \bmod p.$$
5. Return (C, π) where $\pi = (s_1, s_2, c)$.

VerifyProofCS: Given $\text{pk}, C, \pi = (s_1, s_2, c), h_1, h_2, M, n$:

1. Compute $\hat{T}_1 = h^{s_1} h_1^{s_2} e^{-c}$ and $\hat{T}_2 = h^{s_2} M^{-c}$.
2. Accept iff $c = \mathcal{H}(\hat{T}_1, \hat{T}_2, n)$.

Algorithm 23 ProveDecrCS and VerifyDecrCS for Cramer–Shoup decryption

ProveDecrCS: Given $\text{sk} = (x_1, x_2, y_1, y_2, z), \text{pk} = (\mathbb{G}, p, g_1, g_2, c, d, h), C = (u_1, u_2, e, v)$:

1. Choose $r \xleftarrow{R} \mathbb{Z}_p$, compute $T_1 \leftarrow u_1^r$ and $T_2 \leftarrow g_1^r$.
2. Compute challenge $c \leftarrow \mathcal{H}(T_1, T_2)$ and $s \leftarrow r + c \cdot z \bmod p$.
3. Output a proof $\pi = (c, s)$.

VerifyDecrCS: Given $\text{pk}, C = (u_1, u_2, e, v)$, the plaintext $\mu = h_1^m$, and $\pi = (c, s)$:

1. Compute $\hat{T}_1 \leftarrow u_1^s \cdot (e \cdot \mu^{-1})^{-c}$ and $\hat{T}_2 \leftarrow g_1^s \cdot h^{-c}$.
2. Accept iff $c = \mathcal{H}(\hat{T}_1, \hat{T}_2)$.

6.6.3 Two-Dimensional Domain Signatures

The system introduces two additional authorities in order to provide deanonymization methods to the system: tracing authority (TA) capable of linking user pseudonyms in one of the dimensions and opening authority (OA) that can extract user's identity from the pseudonymous signature. In this setup, unlinkability is limited to the cases excluding the possession of the keys of either of the authorities. Moreover, the concept of dimensional-unlinkability is defined. It states that the signatures created with pseudonyms in domains that differ in both dimensions are still unlinkable without the knowledge of the OA's key. Both TA and OA authorities possess Cramer–Shoup key pairs created in the group of the first argument in PS signatures pairing function used for domain signatures. Algorithm 24 presents details of the scheme.

The most interesting feature of this scheme is revocation mechanisms. We postpone discussion on them to Sect. 7.

Taxonomy of this scheme is analogous to that of the LRSW approach. The only substantial difference lies in deanonymization and revocation procedures, due to the use of certificates.

Algorithm 24 The scheme from [13]

Setup:

1. Choose collision-resistant and independent hash functions $\mathcal{H} : \{0, 1\}^* \rightarrow \mathbb{Z}_p$, $\mathcal{H}_1 : \{0, 1\}^* \rightarrow \mathbb{G}_1$ and $\mathcal{H}_2 : \{0, 1\}^* \rightarrow \mathbb{G}_1$.
2. Generate parameters for PS signatures $(p, \mathbb{G}_1, \mathbb{G}_2, \mathbb{G}_T, e)$.
3. Generate PS key pair $(\text{sk}_{\text{IA}}, \text{pk}_{\text{IA}})$ for ID Authority, as in Algorithm 19
4. Generate Cramer–Shoup key pairs in $\mathbb{G}_1$:
 - $(\text{sk}_{\text{TA}}, \text{pk}_{\text{TA}})$ for Tracing Authority,
 - $(\text{sk}_{\text{OA}}, \text{pk}_{\text{OA}})$ for Opening Authority.
5. Choose $\hat{h} \xleftarrow{R} \mathbb{G}_1$.

The system parameters are $(p, \mathbb{G}_1, \mathbb{G}_2, \mathbb{G}_T, e, \text{pk}_{\text{IA}}, \text{pk}_{\text{TA}}, \text{pk}_{\text{OA}}, \hat{h})$.

Join:

1. A user chooses $t, u \xleftarrow{R} \mathbb{Z}_p$ at random, computes $C \leftarrow g^t Y^u$, $\text{ID} \leftarrow \hat{h}^u$, where g and Y come from pk_{IA} , and sends (C, ID) to the ID Authority.
2. An interactive zero-knowledge protocol is executed between the user and the ID Authority. The user proves that they know t, u such that $C = g^t Y^u$ and $\text{ID} = \hat{h}^u$.
3. The ID Authority creates a blind PS signature σ' of u committed with C (according to Algorithm 19) and sends it to the user. The ID is stored in the database run by the OA.
4. The user gets a signature σ by unblinding σ' .

The pair (u, σ) becomes the user's secret key.

NymGen:

1. For a two-dimensional domain $\text{dom} = (\text{dom}_1, \text{dom}_2)$, the domain parameter dPK equals $\mathcal{H}_1(\text{dom}_1) \cdot \mathcal{H}_2(\text{dom}_2)$.
2. The pseudonym of a user with a secret key (u, σ) is computed as $\text{dnym} \leftarrow \text{dPK}^u$.

Sign: The user's signature under m created with the secret key (u, σ) is a tuple $(C_1, \pi_1, C_2, \pi_2, \pi_3)$, where

1. $(C_1, \pi_1) = \text{ProveCS}(\text{pk}_{\text{TA}}, \mathcal{H}_2(\text{dom}_2 || \text{tracing}), u, \text{dPK}, \text{dnym}, m)$,
2. $(C_2, \pi_2) = \text{ProveCS}(\text{pk}_{\text{OA}}, \hat{h}, u, \text{dPK}, \text{dnym}, m)$,
3. $\pi_3 = \text{ProvePS}(\text{pk}_{\text{IA}}, \sigma, u, \text{dPK}, \text{dnym}, m)$.

Return $\zeta = (C_1, \pi_1, C_2, \pi_2, \pi_3)$ and the pseudonym dnym .

Verify: For signature $\zeta = (C_1, \pi_1, C_2, \pi_2, \pi_3)$, pseudonym dnym , domain $(\text{dom}_1, \text{dom}_2)$, and a message m :

1. Recompute the value $\text{dPK} \leftarrow \mathcal{H}_1(\text{dom}_1) \cdot \mathcal{H}_2(\text{dom}_2)$.
2. Accept iff the following procedures accept:
 - VerifyProofCS($\text{pk}_{\text{TA}}, C_1, \pi_1, \mathcal{H}_2(\text{dom}_2 || \text{tracing})$), $\text{dPK}, \text{dnym}, m$),
 - VerifyProofCS($\text{pk}_{\text{OA}}, C_2, \pi_2, \hat{h}, \text{dPK}, \text{dnym}, m$),
 - VerifyProofPS($\text{pk}_{\text{IA}}, \pi_3, \text{dPK}, \text{dnym}, m$).

7 Deanonymization and Revocation

While unlinkability is one of the basic properties in domain signature systems, deanonymization might be one of the key functionalities to be deployed. For instance, apart from the cases such as reaction to users' misbehavior, it might be necessary to transfer user's data between domains (e.g., transferring medical data or merging services). Since anonymity is the sole reason why the domain signature systems are designed, the ability to deanonymize must be strictly controlled. This is mostly achieved with either independent deanonymization authority or splitting the responsibility among many parties that must collaborate in order to perform deanonymization.

7.1 Deanonymization for Hash-Based dPK

In case of virtual ad hoc domains, domain parameter dPK is in most cases selected as an image of a hash function on a known value (e.g., the domain name or identifier). In such cases, the discrete logarithm of dPK in relation to a standard generator g is unknown. On the other hand, the domain pseudonym of a user holding a key u is computed as $\text{dnym} \leftarrow \text{dPK}^u$. In this case, unless some additional trapdoors are used (see later in this section) it is infeasible to decide whether dnym corresponds to g^u (a “main public key” of this user) or whether two pseudonyms $\text{dnym}_1, \text{dnym}_2$ in different domains correspond to one and the same user. Simply, answering this question would mean solving a version of the Diffie–Hellman problem.

7.2 Deanonymization for dPK with Known Discrete Logarithm

In the previous sections, another method of creating domain parameter dPK is concerned: $\text{dPK} = g^{r_1 r_2}$, where r_1 and r_2 are random values selected by the ID Authority and a Domain Authority, respectively, and g is a common system parameter. Pseudonyms are computed again as $\text{dnym} = \text{dPK}^u$, where x is user's secret key. Alternatively, computation of dPK may involve cooperation of more parties: $\text{dPK} = g^{\prod_{i \leq k} r_i}$.

In this case, the ID Authority in cooperation with the Domain Authority can compute a unique and user-specific value g^u by simply calculating $\text{dnym}^{r_1^{-1} r_2^{-1}}$. Of course, dnym must be the pseudonym in the domain represented by this Domain Authority. Reverse direction is also possible: given $U = g^u$, the ID Authority can compute U^{r_1} and give it to the Domain Authority, which in turn computes $(U^{r_1})^{r_2}$.

The situation gets more complicated for pseudonym generation such as in case of SDH approach—see Sect. 6.3, Algorithm 9.

7.3 Two-Dimensional Domain Signatures

This section focuses on a relatively sophisticated architecture of deanonymization developed with the two-dimensional domain signatures presented in Sect. 6.6. The scheme introduces two special authorities, tracing authority (TA) and opening authority (OA).

7.3.1 Deanonymization by Tracing Authority

TA is capable of linking two signatures of the same user in domains $(\text{dom}_1, \text{dom}_2)$, where the second component is fixed. In [13], the respective components are location and time at which vehicles run the protocol. Thereby, TA can detect that the same vehicle appears in different locations at the same time—witnessing that an on-board unit has been cloned.

Recall that according to this scheme the signatures have the form $\sigma = (C_1, \pi_1, C_2, \pi_2, \pi_3)$, where (C_1, π_1) is the output of

$$\text{ProveCS}(\text{pk}_{\text{TA}}, \mathcal{H}_2(\text{dom}_2 || \text{tracing}), u, (\mathcal{H}_1(\text{dom}_1) \cdot \mathcal{H}_2(\text{dom}_2)), \text{dnym}, m) .$$

Thereby, C_1 is a ciphertext of a tracing pseudonym

$$(\mathcal{H}_2(\text{dom}_2 || \text{tracing}))^u$$

with the proof of knowledge of u such that

$$\text{dnym} = (\mathcal{H}_1(\text{dom}_1) \cdot \mathcal{H}_2(\text{dom}_2))^u .$$

TA holds the private key sk_{TA} enabling to decrypt the ciphertext C_1 , and therefore can derive $(\mathcal{H}_2(\text{dom}_2 || \text{tracing}))^u$. As this tracing pseudonym depends only on dom_2 , the two pseudonyms of the same user with the same dom_2 component are linkable by TA.

7.3.2 Deanonymization by Opening Authority

The OA decrypts the component C_2 of the signature with its private key and obtains $\hat{h}^u$. Recall that $\text{ID} = \hat{h}^u$ is the user's identifier stored in the OA's database. A more tricky part is that the OA can prove that the decryption is correct. For this purpose, OA executes the protocol ProveDecrCS . Its output can be verified by a third party by executing VerifyDecrCS .

7.4 Pseudonym Conversion Between Domains

In all cases discussed so far a user can prove that their pseudonyms in different domains belong to them. Standard zero-knowledge proofs can be applied. However, for certain application areas it is not enough. In protocols focused on privacy-preserving databases that are presented below, each database corresponds to a domain and users' identities are replaced by domain pseudonyms, while this approach supports “privacy-by-design”, in certain situations one should be able to connect entries from one database to the entries concerning the same user in another database in order to perform tasks specific to the service type. This should be possible without involving the user—for instance, while merging two databases one cannot expect that all users of the databases will participate in this process.

A system of pseudonyms making such operations possible has been proposed by Camenisch and Lehmann in [6]. The main idea is presented below. In order to achieve domain–domain linkage, the scheme includes a special authority called Converter that somewhat extends the role of ID Authority. It is a deanonymizing authority that is capable of converting a pseudonym from one domain to another in a way that prevents it from learning which pseudonym is converted and what is the conversion result. The only knowledge gained are the domains between which the conversion occurs.

7.4.1 ElGamal Homomorphic Encryption

The conversion mechanism uses homomorphic properties of ElGamal encryption scheme. In homomorphic encryption schemes, there exist an efficient operation $\odot$ such that having two ciphertexts $c_1 \leftarrow \text{Enc}(\text{pk}, m_1)$ and $c_2 \leftarrow \text{Enc}(\text{pk}, m_2)$, one can generate a ciphertext $c_1 \odot c_2$ such that $\text{Dec}(\text{sk}, c_1 \odot c_2) = m_1 \cdot m_2$.

Algorithm 25 ElGamal encryption scheme

Setup: Let $\mathbb{G}$ be a cyclic group of order p such that DDH problem is considered to be hard in $\mathbb{G}$.
Let g be a generator of the group.

EncKGen: Select private key $\text{esk} \xleftarrow{R} \mathbb{Z}_p$ at random and compute public key $\text{epk} \leftarrow g^{\text{esk}}$.

Enc (epk, m): Select $r \xleftarrow{R} \mathbb{Z}_p$ at random and output $c = (c_1, c_2) \leftarrow (\text{epk}^r, g^r \cdot m)$.

Dec (esk, c): Compute $m \leftarrow c_2 \cdot c_1^{-1/\text{esk}}$.

Camenisch and Lehmann extend ElGamal with additional value $c_0 = \text{epk}'^r$ in the ciphertext, where epk' is another ElGamal public key. While this additional result is ignored in decryption, it allows to perform simulations needed for zero-knowledge proofs in the system protocols.

7.4.2 Dual-Mode Signature Scheme

Another building block is a dual-mode signature scheme, instantiated with AGOT+. Comparing to standard signature schemes, it is extended with two additional functions as follows:

- $\text{EncSign}_{\text{DM}}$ that, given a private signing key, a public encryption key, and a ciphertext, outputs a “partially encrypted” signature of the ciphertext,
- $\text{DecSign}_{\text{DM}}$ that, given a “partially encrypted” signature, a secret decryption key, and a public verification key outputs a signature of the plain message corresponding to the signed ciphertext.

Details of a technical realization of such a scheme are given in Algorithm 26.

7.4.3 Conversion Scheme Setup and Pseudonym Generation

The Converter possesses encryption key pair $(\text{epk}_{\mathcal{X}}, \text{esk}_{\mathcal{X}})$, a random secret value $x_{\mathcal{X}}$ and the corresponding public value $y_{\mathcal{X}} = g^{x_{\mathcal{X}}}$, where $g \in \mathbb{G}$ is the same as in the ElGamal parameters. Additionally, it holds a dual-mode signing key pair $(\text{spk}_{\mathcal{X},A}, \text{ssk}_{\mathcal{X},A})$ and a secret exponent $x_{\mathcal{X},A}$ corresponding to the public value $y_{\mathcal{X},A} = g^{x_{\mathcal{X},A}}$ for each domain dom_A .

Algorithm 26 AGOT + signature scheme

Setup: Choose two groups $\mathbb{G}$ and $\tilde{\mathbb{G}}$ of a prime order p , with generators, respectively, g and $\tilde{g}$, a type-3 pairing function $e : \mathbb{G} \times \tilde{\mathbb{G}} \rightarrow \mathbb{G}_T$ and an additional random element $x \xleftarrow{R} \mathbb{G}$.

SignKGen_{DM}: Select a private key $\text{ssk} \xleftarrow{R} \mathbb{Z}_p$ at random and compute the public key $\text{spk} = \tilde{g}^{\text{ssk}}$.

Sign_{DM}(ssk, m): Select $u \xleftarrow{R} \mathbb{Z}_p$ at random and output signature

$$\sigma = (r, s, t, w) \leftarrow (\tilde{g}^u, (m^{\text{ssk}} \cdot x)^{1/u}, (s^{\text{ssk}} \cdot g)^{1/u}, g^{1/u}),$$

where w is a randomization token that is not being verified.

Verify_{DM}(spk, σ , m): Accept the signature if all of the following statements are true:

- $m, s, t \in G$ and $r \in \tilde{\mathbb{G}}$,
- $e(s, r) = e(m, \text{spk}) \cdot e(x, \tilde{g})$,
- $e(t, r) = e(s, \text{spk}) \cdot e(g, \tilde{g})$.

EncSign_{DM}(ssk, epk, $M \leftarrow \text{Enc}(\text{epk}, m)$): Select $u \xleftarrow{R} \mathbb{Z}_p$ at random and output a partially “encrypted” signature

$$\bar{\sigma} = (r, S, T, w) = (\tilde{g}^u, (M^{\text{ssk}} \odot \text{Enc}(\text{epk}, x))^{1/u}, (S^{\text{ssk}} \odot \text{Enc}(\text{epk}, g))^{1/u}, g^{1/u}).$$

DecSign_{DM}(esk, $\bar{\sigma}$): Output $\sigma = (r, s, t, w) = (r, \text{Dec}(\text{esk}, S), \text{Dec}(\text{esk}, T), w)$.

Each domain dom_A has a key to a random permutation function k_A , encryption key pair $(\text{epk}_A, \text{esk}_A)$, and a signing key pair $(\text{spk}_A, \text{ssk}_A)$ —in this case, any secure signature scheme can be used.

For the sake of readability, a description of zero-knowledge proofs that have to be created and verified during the protocol execution is omitted here. These zero-knowledge proofs have to guarantee that each entity involved in the protocol is behaving according to the protocol. The details can be found in [6].

Pseudonym generation is a protocol run between the Converter and the Domain Authority. When the pseudonym for the user identified with $u_i \in \mathbb{Z}_p$ in domain dom_A has to be generated, the following procedure is executed:

1. The Converter generates its pseudonym contribution with a keyed pseudorandom function

$$\text{xnym}_{i,A} \leftarrow \text{PRF}(x_{\mathcal{X}}, u_i)^{x_{\mathcal{X},A}}.$$

It generates a signature of created value

$$\sigma_{\text{dnym}} \leftarrow \text{Sign}_{\text{DM}}(\text{ssk}_{\mathcal{X},A}, \text{xnym}_{i,A})$$

and sends $\text{xnym}_{i,A}$, σ_{dnym} and NIZK proofs of correctness of pseudonym generation to the Domain Authority of dom_A .

2. The Domain Authority verifies the proofs and σ_{dnym} . If verification is successful, it computes the pseudonym

$$\text{dnym}_{i,A} \leftarrow \text{PRP}(k_A, \text{xnym}_{i,A}),$$

where PRP is a keyed pseudorandom permutation. It saves σ_{dnym} alongside the received signature.

For the current discussion, the most important values are $\text{xnym}_{i,A}$ and σ_{dnym} , and how the former can be blindly transformed into $\text{xnym}_{i,B}$ for $A \neq B$.

7.4.4 Conversion Protocols

The conversion is a two-step procedure. The first stage called Convert is run between the Converter and the Domain Authority of dom_A that requests a conversion of a pseudonym from its database to a pseudonym of the same user in the domain dom_B as given below:

1. The Domain Authority reverts PRP function in order to obtain $\text{xnym}_{i,A}$. Then, it computes

$$c \leftarrow \text{Enc}(\text{epk}_{\mathcal{X}}, \text{Enc}(\text{epk}_B, \text{xnym}_{i,A}))$$

and signs the ciphertext together with a unique session and query identifiers

$$\sigma_c \leftarrow \text{Sign}(\text{ssk}_A, (\text{sid}, \text{qid}, c)).$$

It sends c, sid, qid, σ_c and the proof of knowledge of σ_{dnym} on $\text{xnym}_{i,A}$ under key $\text{spk}_{\mathcal{X},A}$ to the Converter. It also points out dom_B in the request.

2. Converter verifies the proofs and σ_c . If the verification passes, the conversion request is accepted.

The second stage, Proceed, is run between the Converter and the Domain Authority of dom_B that learns which of the pseudonym in its database corresponds to the pseudonym chosen by dom_A for conversion. The Domain Authority of dom_B learns neither $\text{dnym}_{i,A}$ nor $\text{xnym}_{i,A}$ as given below:

1. The Converter computes

$$c' \leftarrow \text{Dec}(\text{esk}_{\mathcal{X}}, c) \text{ and } c'' \leftarrow (c' \odot \text{Enc}(\text{epk}_B, 1))^{x_{\mathcal{X},B}/x_{\mathcal{X},A}}$$

and signs the encrypted pseudonym for dom_B

$$\bar{\sigma}_{\text{dnym}} \leftarrow \text{EncSign}_{\text{DM}}(\text{ssk}_{\mathcal{X},B}, \text{epk}_B, c'').$$

It sends $sid, qid, c, c'', \sigma_c, \bar{\sigma}_{\text{dnym}}$ together with the proofs of correct computation of these values, the identifier of dom_A and dom_A proofs to the Domain Authority of dom_B .

2. The Domain Authority of dom_B verifies all received proofs and σ_c . Then, it computes

$$\text{xnym}_{i,B} = \text{Dec}(\text{esk}_B, c'') \text{ and } \sigma_{\text{dnym}} = \text{DecSign}_{\text{DM}}(\text{esk}_B, \text{spk}_{\mathcal{X},B}, \bar{\sigma}_{\text{dnym}}).$$

It derives the pseudonym $\text{dnym}_{i,B} = \text{PRP}(k_B, \text{xnym}_{i,B})$ and stores it together with σ_{dnym} .

7.5 Revocation

7.5.1 Deanonymization Threats Related to Revocation

Revocation in domain signature schemes is a complex issue. The first step is deanonymization—its direct result is a blacklist of revoked pseudonyms in each domain. Subsequently, one has to make a decision how to make this information available for the verifiers of domain signatures.

The simplest way is to update a domain blacklist or a whitelist for every domain concerned. However, this approach provides substantial linking information: the pseudonyms revoked at the same time correspond to the same users. If the number of users revoked simultaneously is small, then loss of anonymity is quite substantial. This might be acceptable, if revocation is a consequence of a user's misbehavior; however, in many cases, revocation occurs when the user is a victim of misbehavior

and public deanonymization of their pseudonyms is an additional nuisance or even security threat.

The problem can be mitigated a little, if the data carrying the revocation information is redesigned. Instead of presenting the pseudonyms explicitly, it is enough to provide a data enabling to answer membership queries as follows:

blinded pseudonyms: Instead of a pseudonym dnym , the list contains $\mathcal{H}(\text{dnym}, R)$, where $\mathcal{H}$ is a cryptographic hash function and R is a nonce chosen independently at random for each version of the list.

Bloom filters: A Bloom filter is a bit array A of size n , where all bits are equal to 0, except for positions set to 1 in the following way: for each dnym to be inserted to the list one computes

$$i_j \leftarrow \mathcal{H}(\text{dnym}, j, R) \bmod n \quad \text{for } j \leq k \quad (1)$$

and set $A[i_j] = 1$ for each $j \leq k$. A pseudonym dnym is declared as contained in the list, if the array A contains 1's on all positions determined according to formula (1). Note that for every dnym inserted to the filter, the answer to a query will be always correct, while there is a chance (depending on the value of k , size of the filter and the number of elements inserted) of a false positive answer for a dnym not inserted to the filter.

accumulators: In general, one can adopt any cryptographic accumulator data structure.

These solutions provide only a limited protection, as given two pseudonyms, one can test whether they became invalid at the same time. Cf. Sect. 9.1 for a broader description of less obvious attacks based on whitelists and blacklists.

7.5.2 Epoch-Based Approach

A notable approach to revocation issues has been proposed in [9] for anonymous attestation schemes. The idea is generic and may also be applied for domain pseudonymous signature schemes. In short, for each epoch, users simply update their credentials but keep the same secret key for computing domain pseudonyms. It is easy to see that the construction paradigm shown in Sects. 6.3–6.6 may easily adopt this revocation mechanism. To be more specific, in each epoch, the ID Authority runs a new SDH or LRSW specific setup yielding epoch-specific public keys. Then, each user simply runs the Join-Issue procedure with the same secret key, thus the value U_i should be the same. Should a user with U_i be revoked, or U_i has never appeared on the list of legitimate users, the ID Authority simply aborts the Join-Issue procedure. Now, note that if a user is revoked, they simply cannot issue a correct signature in the current time epoch, since they are not enrolled into the group of valid users. Similarly, in schemes based on PS signatures (Sect. 6.6), the user may periodically refresh their blind signatures σ .

7.5.3 Health Certificates

A more general approach is to use a kind of *health certificates*. A sketch of an example procedure for getting one for a scheme, where $\text{dnym} = \text{dPK}^u$, with user's secret u and domain parameter dPK is presented below (assuming that all computations are in a group of prime order p):

1. The user chooses $\mu \xleftarrow{R} \mathbb{Z}_p$ at random, computes $\text{dPK}' \leftarrow \text{dPK}^\mu$ and $\text{dnym}' \leftarrow (\text{dPK}')^u$.
2. The user creates a (noninteractive) proof π of equality of discrete logarithms for the pairs $(\text{dPK}', \text{dnym}')$ and (g, g^u) , where g^u is the main public key of the user.
3. The user presents $(\pi, \text{dPK}', \text{dnym}', g^u)$ to the ID Authority.
4. If π verifies positively, then the ID Authority issues a randomizable signature ρ for $(\text{dPK}', \text{dnym}')$ and creation time.
5. The user obtains ρ , randomizes ρ , and creates a certificate of health $(\rho, \text{dPK}, \text{dnym}, \mu)$.

Alternatively, in order to protect against the ID Authority one can use a blind PS signature (see Algorithm 20).

The aforementioned revocation methods work perfectly for execution environments which are constantly connected to the Internet. This includes trusted execution environments which run on personal computers, smartphones, tablets, etc., since the credentials may be updated in the background. For smart cards such a method could be invoked periodically.

On the downside, in this method, the ID Authority gets some idea about intensity of activities of a given user. However, for commercial systems this might be an advantage and a good base for “pay-per-use” plans.

8 Continuity

This section describes a few ways of achieving continuity of service in case when the keys of a user get lost or compromised.

8.1 Two-Component Keys

One of the solutions is to split the secret (and public) keys of the users into two parts—one responsible for users' pseudonyms and one responsible for signatures' security. In such a scenario, the part responsible for pseudonyms can be stored in an encrypted form by the ID Authority and only loaded to the signing device during the enrollment phase. The other part can be safely generated in a secure hardware and never leave it in the plaintext form.

There is a number of schemes that can be augmented using this technique, notably the Pseudonymous Signatures (cf. Sect. 6.2), LRSW, and Pointcheval–Sanders-based solutions (cf. Sects. 6.4 and 6.6) as well as the certificate-based versions thereof (cf. Sect. 6.5). Below some details of such extensions for the LRSW approach and for Pseudonymous Signatures are given.

Algorithm 27 LRSW certificate generation with continuity

NymGen: Given a domain parameter $dPK \in \mathbb{G}_1$, i -th user computes their pseudonym as $dnym_D \leftarrow dPK^{u_i}$, the domain-specific public key $pk_D \leftarrow dPK^{r_i}$ and their domain certificate $Cert = (dnym_D, pk_D, \sigma)$ as:

$$(\tilde{A}_{0,i}, \tilde{A}_{1,i}, \tilde{B}_{0,i}, \tilde{B}_{1,i}, \tilde{C}_i) = (A_{0,i}^r, A_{1,i}^r, B_{0,i}^r, B_{1,i}^r, C_i^{rr'})$$

for random (or pseudo-random) r and r' ,

$$\begin{aligned} \pi &\leftarrow NIZK\{\alpha, \beta, \rho : dnym_D = dPK^\alpha \\ &\quad \wedge pk_D = dPK^\beta \\ &\quad \wedge e(\tilde{C}_i, G_2) = e(\tilde{A}_{0,i}^\rho \tilde{B}_{0,i}^{\alpha\rho} \tilde{B}_{1,i}^{\beta\rho}, X)\}. \end{aligned}$$

and $\sigma = (\tilde{A}_{0,i}, \tilde{A}_{1,i}, \tilde{B}_{0,i}, \tilde{B}_{1,i}, \tilde{C}_i, \pi)$.

8.1.1 LRSW

Consider the following augmentation of the certificate-based approach for the LRSW scheme (cf. Sect. 6.5 and [24]). In the *domain certificate* generation phase, two values are actually certified, a domain pseudonym $dnym_D$ and a domain-specific public key pk_D – see Algorithm 27.

In order to strengthen the scheme or tune it for specific use cases, different elements might be used as generators for $dnym_D$ and pk_D . Notably, the techniques used for revocation in Sect. 7.5 may be used to revoke only the pk_D part and not the $dnym_D$.

8.1.2 Pseudonymous Signature

Continuity can be easily introduced in the Pseudonymous Signature framework presented in Sect. 6.2. The basic idea is that instead of two elements satisfying a certain linear equality, there are three elements, where one of them will be fixed for a given user.

To summarize the changes:

Setup: An additional secret $r \xleftarrow{R} \mathbb{Z}_p$ is chosen at random by the ID Authority and $g_3 \leftarrow g^r$ is added to the system parameters,

Join-Issue: For user i , the following steps are executed:

1. The ID Authority chooses $x_{i,3}$ at random and stores it in a secure database for rekeying purposes.
2. The ID Authority chooses $x_{i,2} \xleftarrow{R} \mathbb{Z}_p$ at random and computes $x_{i,1} \leftarrow (x - x_{i,3} - z \cdot x_{i,2})/r \bmod p$.
3. The ID Authority embeds $x_{i,1}, x_{i,2}, x_{i,3}$ in the user's device and forgets $x_{i,1}, x_{i,2}$.

ReKey: For user i , the ID Authority

1. retrieves $x_{i,3}$ from its database,
2. follows steps 2 and 3 from Join-Issue.

NymGen: Additionally, third part of the pseudonym is generated according to the formula $\text{dnym}_{i,3}^{\text{dom}} \leftarrow \text{dPK}^{x_{i,3}}$.

Sign: Only a slight modification is needed. The following steps are executed:

1. choose $k_1, k_2, k_3 \xleftarrow{R} \mathbb{Z}_p$ at random,
2. $Q \leftarrow g^{k_1} \cdot g_2^{k_2} \cdot g^{k_3}$,
3. $A_1 \leftarrow \text{dPK}^{k_1}, A_2 \leftarrow \text{dPK}^{k_2}, A_3 \leftarrow \text{dPK}^{k_3}$,
4. $c \leftarrow \mathcal{H}(Q, \text{dnym}_1, A_1, \text{dnym}_2, A_2, \text{dnym}_3, A_3, \text{dPK}, m)$, and
5. $s_1 \leftarrow k_1 - c \cdot x_1 \bmod p, s_2 \leftarrow k_2 - c \cdot x_2 \bmod p$
 , and $s_3 \leftarrow k_3 - c \cdot x_3 \bmod p$.

$\sigma(m) = (c, s_1, s_2, s_3)$ is the resulting signature.

Verify: Verification is similar as in case of the unmodified procedure.

Numerous variations of the scheme are possible. For instance, it can be easily merged with the method described in Sect. 9.1.3 and aiming to prevent the ID Authority from learning the signing keys of the users.

8.2 Transition to a New Key

8.2.1 Certified Link Between Powers of x and x'

Having access to both secret keys x and x' , a certified link between γ^x and $\delta^{x'}$ can be created as follows:

1. The ID Authority blindly issues an LRSW [7] or PS [23] signature σ under messages x, x' .
2. To certify a link $\gamma^x \rightarrow \delta^{x'}$, the user randomizes σ into σ' , proves knowledge of x, x' and proves that the signature σ' validates the same values.

The main downside of this solution is that the user has to actively use both x and x' , which may be infeasible in some scenarios, where backing up x and/or transferring it to a new device is impossible. The upside is that γ and δ do not have to be the same value and do not even have to come from the same group, as long as their orders are equal. The same observation applies to the signature groups (i.e., the link groups do not have to be pairing-friendly).

8.2.2 Transition Tokens

Even if continuity is not supported directly by a domain signature scheme, it is still possible to create a system of transition tokens enabling to request linking of a new pseudonym with the old one. The following steps have to be executed by the user prior to the transition:

1. choose a secret z at random,
2. for a domain with the domain parameter dPK create a domain-specific token $z_{\text{dPK}} \leftarrow \mathcal{H}(\text{dPK}, z)$,
3. create a domain signature σ for dPK and message $\mathcal{H}(z_{\text{dPK}})$,
4. send σ to the Domain Authority of dPK, and
5. export and store z in a safe place.

Should the necessity of transition arise, the user recovers z , computes z_{dPK} , and presents it to the Domain Authority together with a new pseudonym generated and signed with the new private key.

The token z can be additionally protected. For instance, it can be exported as a ciphertext that can be decrypted once the ID Authority signs a certain message (see [14] for a scheme allowing this). Thereby, the possibility to decrypt can be conditioned by a successful verification of the user's request and issuing the new private key by the ID Authority.

9 Trust and Subversion Resilience

From a practitioner's point of view, the security of a scheme in the sense of a classical formal security model might be insufficient. This follows from the fact that in most cases it is assumed that the parties involved in the scheme (except for an external adversary) are trustworthy, just as the software implementing the scheme has no hidden features or bugs. In reality, this might be the weakest point of the system enabling an effective attack despite *formal provable security* of the scheme. The problem to be addressed is that the implementation may contain deviations from the ideal protocol specifications such that

- some component or components contain trapdoors,

- protocol executions are consistent with general specification when the affected components are treated as a black box, and
- the existence of a trapdoor is not observable, except for the adversary.

Note that the adversary is not necessarily colocated with the subverted software. The most obvious case is that a party modifies its own software or leaks its secrets to compromise the system. One mean of prevention is to implement the software in a tamper-resistant black box device. Yet, still the black box provider might be an attacker as well, embedding hidden features in their hardware and gaining access to it at later time.

The scope of the attack may vary from getting access to private keys to merely breaking unlinkability property. The following sections concentrate on the latter issue, as it is more specific to domain signature schemes.

9.1 Trapdoors Breaking Unlinkability

9.1.1 Whitelists

List Refreshing Attack

The protocol described in Sect. 6.1 requires that the ID Authority is honest and does not attempt to link the users between different domains. However, the following attack is possible against domains with domain parameters $\text{dPK}_1 = g^{r_1 r_2}$ and $\text{dPK}_2 = g^{\rho_1 \rho_2}$, where the exponents r_1 and ρ_1 are chosen by the ID Authority, while r_2 and ρ_2 are chosen by the authorities of domains dom_1 and dom_2 , respectively. Assume that the ID Authority aims to check whether the pseudonyms dnym_1 from dom_1 and dnym_2 from dom_2 correspond to the same user, i.e., $\text{dnym}_1 = g^{r_1 r_2 x}$ and $\text{dnym}_2 = g^{\rho_1 \rho_2 x}$ for some unknown x .

The steps executed by the ID Authority are as follows:

1. choose $\mu_1, \mu_2 \xleftarrow{R} \mathbb{Z}_p$ at random,
2. send $\text{dnym}_2^{\mu_1/\rho_1}$ to the Domain Authority of dom_1 for inclusion on the whitelist,
3. send $\text{dnym}_1^{\mu_2/r_1}$ to the Domain Authority of dom_2 for inclusion on the whitelist,
4. check whether the new whitelists of dom_1 and dom_2 contain, respectively, pseudonyms dnym_a and dnym_b such that

$$\text{dnym}_a^{\mu_2} = \text{dnym}_b^{\mu_1}.$$

Note that if $\text{dnym}_1 = g^{r_1 r_2 x}$ and $\text{dnym}_2 = g^{\rho_1 \rho_2 x}$, then on the first whitelist the following element will appear:

$$\text{dnym}_2^{r_2 \mu_1 / \rho_1} = g^{\rho_1 \rho_2 x r_2 \mu_1 / \rho_1} = g^{r_2 \rho_2 x \mu_1}$$

while the second whitelist contains the element

$$\text{dnym}_1^{\rho_2 \mu_2 / r_1} = g^{r_1 r_2 x \rho_2 \mu_2 / r_1} = g^{r_2 \rho_2 x \mu_2}.$$

Raising the first element to the power of μ_2 and the second to the power of μ_1 , identical results are obtained.

Shadow User Attack

For each user U , the ID Authority creates a shadow user U' . Namely, if U holds a public key pk , then U' gets the public key $\text{pk}' \leftarrow \text{pk}^{r_U}$, where $r_U = \mathcal{H}(K, U)$ and K is a secret key of the ID Authority (existence of this key must be hidden). (Of course, as the private key of U should not be available to the ID Authority, so the private key corresponding to pk' should be unknown to the ID Authority as well.)

Then, the ID Authority can locate the pseudonym of U on the whitelist for dom by finding a pair of pseudonyms $\text{dnym}_1, \text{dnym}_2$ such that $\text{dnym}_2 = \text{dnym}_1^{r_U}$. In this case, dnym_1 is the pseudonym of U .

Countermeasures

The simplest countermeasure would be to allow creating only a single whitelist for a given domain and to control the number of entries on the list. This mitigates the above attacks, but at the same time dramatically reduces the application range.

The second approach (used by Restricted Identification protocol implemented on German personal identity documents) is to create a pseudonym of a user holding a public key $\text{pk} = g^x$ according to the formula

$$\text{dnym} \leftarrow \mathcal{H}(\text{dPK}^x)$$

(by the user) and equivalently

$$\text{dnym} \leftarrow \mathcal{H}((\text{pk}^{r_1})^{r_2})$$

(by the ID Authority and the Domain Authority), where $\mathcal{H}$ is a cryptographically strong hash function. A major disadvantage of this approach is that learning the identity of the owner of a given pseudonym, in case of revocation or a controlled deanonymization, is tedious: it is necessary to recompute the whole set of pseudonyms and check which path leads to the pseudonym of a rogue domain member.

The third approach would be to include a zero-knowledge proof for each entry on the list given to the Domain Authority. It should prove that each entry corresponds to a

user holding the corresponding private key. A simple way—but requiring cooperation with the user—is the following:

- ID Authority presents its public domain parameter $dPK' = g^{r_1}$ for domain dom to the users,
- user holding public key $pk = g^x$ and entitled to join dom presents to the Domain Authority their signature corresponding to pseudonym dPK'^x ,
- ID Authority recomputes the pseudonym as pk^{r_1} , checks the domain signature, and puts both the pseudonym and the signature on the list L presented to the Domain Authority of dom , and
- Domain Authority checks each signature on the list L and rejects L if there are any faulty entries.

Selective Intra-domain Linking

Another example of an attack is a selective possibility to link pseudonyms in different domains. Namely, assume that the ID Authority aims to enable a third-party controlling the Domain Authorities of dom_1 and dom_2 to link the pseudonyms on their whitelists. For this purpose, the kleptographic trick of Adam Young and Moti Yung [28] can be applied in the following way:

1. Adversary in control of domains dom_1 and dom_2 (e.g., security agency of country B) chooses u at random, sets $U = g^u$ and presents U to the ID Authority in country A .
2. dPK_1 and dPK_2 for dom_1 and dom_2 , respectively, are derived as follows:
 - ID Authority chooses r_1 at random and sets $dPK'_1 = g^{r_1}$ for domain dom_1 . For domain dom_2 , it sets $dPK'_2 = g^{r_1 \cdot k'}$ where $k' = \mathcal{H}(U^{r_1})$.
 - Authorities of dom_1 and dom_2 choose r_2 and r'_2 so that $\rho = r'_2/r_2$ and is known to the adversary. Finally, $dPK_1 \leftarrow (dPK'_1)^{r_2}$ and $dPK_2 \leftarrow (dPK'_2)^{r'_2}$.

Note that the adversary can convert a pseudonym $dnym$ of a user in domain dom_1 to the pseudonym of the same user in dom_2 by computing $dnym^{k' \cdot \rho}$, where $k' \leftarrow \mathcal{H}((dPK'_1)^u)$. At the same time, the adversary cannot convert the pseudonyms to users' main public keys. Also, neither the ID Authority can link the pseudonyms in domains dom_1 and dom_2 (as ρ is a random element) nor the domain authorities of dom_1 and dom_2 can do it (as k' is hidden from them). Moreover, there is no easy way to check that the ID Authority is not colluding in this way with an adversary.

9.1.2 Pseudonymous Signatures

In case of the Pseudonymous Signature scheme presented in Sect. 6.2, it is relatively easy to install a trapdoor as the private keys of a user are created by the ID Authority.

The main point of the attack is the fact that the key is composed of two random values x_1, x_2 satisfying the linear equality

$$x = x_{i,1} + z \cdot x_{i,2} \bmod p,$$

where one of the keys is chosen at random and x is fixed for a group of users. The trick is to introduce another linear equality based on a pseudorandom coefficient personalized for each user [20] as given below:

$$u_i = x_{i,1} + s_i \cdot x_{i,2} \bmod p.$$

The values u_i and s_i are assigned to a given user and computed in a pseudorandom way as given below:

$$u_i \leftarrow \text{PRNG}(i, S, 1), \quad s_i \leftarrow \text{PRNG}(i, S, 2),$$

where S is a secret of the ID Authority and PRNG is a secret generator based on a strong Pseudorandom Number Generator returning elements of $\mathbb{Z}_p$. In this case, the ID Authority can selectively deanonymize users. Namely, in order to deanonymize user i against a Domain Authority of dom with public key dPK, the ID Authority presents $U_{\text{dom},i} = \text{dPK}^{u_i}$ and s_i together with the identity data of i . The Domain Authority can check whether a pair of identifiers $\text{dnym}_{i,1}, \text{dnym}_{i,2}$ belongs to i by checking whether

$$U_{\text{dom},i} = \text{dnym}_{i,1} \cdot \text{dnym}_{i,2}^{s_i}. \quad (2)$$

Note that the Domain Authority cannot use this data for deanonymization in a different domain. Indeed, while s_i can be used in any domain, the second parameter $U_{\text{dom},i}$ is domain specific. While the Domain Authority can derive a candidate for $U_{\text{dom},i}$ based on equality (2), it is infeasible to check that it has the form dPK^{u_i} even if these values are available for i in different domains, say $\text{dPK}_1^{u_i}, \text{dPK}_2^{u_i}, \dots$

Another attack presented in [20] entails creation of a *shadow eID*—an extra eID document that can be used to recover pseudonym of a given user i in any domain without the user's private key and without the possibility to prove that such an attack is taking place. For this purpose, an eID with *shadow keys* $x'_{i,1}, x'_{i,2}$ is prepared. They fulfill the following equalities:

$$\begin{cases} x_{i,1} = \rho_i \cdot (x'_{i,1})^2 \bmod p, \\ x = x'_{i,1} + z \cdot x'_{i,2} \bmod p. \end{cases}$$

The secret ρ_i is not installed in the eID, instead it is given to the attacker holding the shadow eID. Therefore, any inspection of the keys stored in the eID cannot indicate the attack—for any pair of users there is some ρ for which the equation $x_{i,1} = \rho \cdot (x'_{i,1})^2 \bmod p$ is satisfied. Now, the attacker willing to find the pseudonym $\text{dnym}_{i,1}$ of the user i

- computes its own pseudonym in this domain: $\text{dnym}'_{i,1} \leftarrow \text{dPK}^{x'_{i,1}}$,
- feeds $\text{dnym}'_{i,1}$ to their own eID as domain parameter of some domain, and requests a pseudonym; the result $\text{dnym}''_{i,1}$ equals

$$(\text{dnym}'_{i,1})^{x'_{i,1}} = \text{dPK}^{(x'_{i,1})^2},$$

- computes $\text{dnym}_{i,1} \leftarrow (\text{dnym}''_{i,1})^{\rho_i}$.

9.1.3 Countermeasures

One can defend against the above attacks (and possibly against other attacks of this kind) by letting users randomize their secret keys [20]. The way to achieve this is to provide two pairs of keys on the eID. The user has to activate the eID by choosing a linear combination of them. Namely, the user gets pairs $(x'_{i,1}, x'_{i,2})$ and $(x''_{i,1}, x''_{i,2})$ (stored in the secure memory of the device) and the corresponding public keys $P'_1 = g^{x'_{i,1}}$, $P'_2 = g^{x'_{i,2}}$ and $P''_1 = g^{x''_{i,1}}$, $P''_2 = g^{x''_{i,2}}$. Then, he chooses $\alpha \xleftarrow{R} \mathbb{Z}_p$ and sends it to the eID. Consequently, the device installs the following private keys:

$$\begin{aligned} x_{i,1} &\leftarrow \alpha \cdot x'_{i,1} + (1 - \alpha) \cdot x''_{i,1} \pmod{p}, \\ x_{i,2} &\leftarrow \alpha \cdot x'_{i,2} + (1 - \alpha) \cdot x''_{i,2} \pmod{p}. \end{aligned}$$

Obviously, a pair $(x_{i,1}, x_{i,2})$ fulfills Eq. (2) in Sect. 9.1.2. On the other hand, the pairs of private keys form a one-dimensional linear space. Therefore, by taking a linear combination of two elements one can get any element of this linear space. Moreover, the user can check that the eID is not cheating: one can ask for pseudonyms corresponding to a fake $\text{dPK} = g^r$ for r chosen at random. Then, the pseudonyms $\text{dnym}_{i,1}$, $\text{dnym}_{i,2}$ returned by the eID should fulfill the equations given as

$$\text{dnym}_{i,1} = ((P'_1)^\alpha \cdot (P''_1)^{1-\alpha})^r, \quad \text{dnym}_{i,2} = ((P'_2)^\alpha \cdot (P''_2)^{1-\alpha})^r.$$

On the other hand, activation of the eID must be coupled with registration of the public keys $g^{x_{i,1}}$, $g^{x_{i,2}}$; otherwise, no deanonymization would be possible.

9.1.4 SDH and LRSW

The list refreshing and shadow user attacks may apply in particular to the schemes based on SDH and LRSW assumptions supporting blacklist creation (and in any serious application blacklist creation is a must). There are slight differences, but the impact of the attack is the same as follows:

- Tested pseudonyms, dnym_1 and dnym_2 , are not taken from whitelists (since they do not exist). The pseudonyms appear as a result of users' activities within domains

dom_1 and dom_2 and the ID Authority may get access to these pseudonyms. Note that there is no particular reason to hide pseudonyms as in principle they do not concern identifiable persons.

- Unlike for whitelists, there should be no limitation to creating updated blacklists, as information on revoked pseudonyms must be available without unnecessary delay.
- A fake pseudonym placed on a blacklist by the attacker should not arise any suspicion, as it is often the case that pseudonyms related to lost devices are never used after blacklisting (e.g., a stolen card is likely to be quickly disposed off to get rid of evidence).

Note that the protection by hashing in this case may not work because usually certain algebraic properties of domain pseudonyms are used during verification.

9.2 *Leakage and Hidden Fingerprinting*

A typical security model for signatures silently assumes that the signing procedure is run on a trusted device, where all computations are kept away from the adversary. However, this assumption is very strong, and may not reflect the reality, especially due to unintentional programming errors, or even worse—to malicious implementations deliberately introduced at the production stage. Last but not least, generation of the random values used during the signing process might be imperfect so that the resulting values contain certain fingerprints of the device. Unlike in the case of regular signatures, this immediately would be a security issue: the domain signatures become linkable because of these random elements. In the worst case, modifications of the ephemeral secrets set by pseudorandom generators may lead to extracting long-term secret keys used for signing. This problem has already been analyzed in the context of identification schemes: leakage of bits of private keys [1], ephemeral reset attacks [2, 8], ephemeral leakage and setup for Schnorr and Okamoto identification schemes [18, 19], and anonymous credential systems [11].

Note that the number of bits required to link signatures created by the same device is considerably smaller than in case of leaking the private signing key. Therefore, it is much easier to mount an attack via a narrow leakage channel. A natural countermeasure against leaking the key is to increase its bit length, thus considerably thwarting a narrow-channel attack. For fingerprinting of a device such approach does not work, since the attack succeeds once a link is discovered even if only a part of the fingerprint becomes available.

9.2.1 *Leakage Mechanism*

In order to provide a fingerprint of a device, it suffices to create a certain imbalance observable by an adversary. Assume that a mechanism in a device intends to leak

its identifier id consisting of, say, 32 bits. (Note that for the mere purpose of linking signatures the device can choose this identifier at random.) Again the kleptographic mechanisms can be used [28]: the device holds an element U such that the adversary knows u such that $U = g^u$. Then, during creation of domain signatures the following additional steps are performed:

- When the signing process requires calculation of g^k for a randomly chosen k , the device computes additionally $t \leftarrow U^k$.
- Device computes $F(t)$, where F is a mapping into $\{0, 1\}^6$. Then, g^k is regarded as a *false witness*, if

$$F(t) = (a_0 a_1 \dots a_5) \quad \text{and} \quad id[a_0 a_1 \dots a_4] \neq a_5.$$

Otherwise, it is called a *valid witness*.

- Depending on the strategy, the device behaves differently in case of valid and false witnesses. Many strategies are possible, for example:
 - The device may drop the false witness and try again to choose k . In order to avoid observable long delays, the number of attempts to compute k should be limited.
If there is a large number of signatures issued, it suffices to recalculate k only from time to time, but frequently enough so that the tendency to point to the valid bit values are still statistically observable for the adversary.
 - The device may create a faulty signature or report a fault while computing a signature next after issuing a signature containing a true witness.

Of course, apart from the above mechanism, the full range of attacks may apply, including:

resetting the PRNG: The adversary can reset the pseudorandom generator to its initial state, and thus set the ephemeral to the same unknown initial value denoted by k_{init} .

learning the state of PRNG: The adversary can learn the generator state and thus learn all ephemeral values created since this moment.

setting PRNG state: The adversary can set pseudorandom generator to a chosen state and thus can set the ephemeral values.

Then, of course, the private keys become exposed for all domain signature schemes that incorporate Schnorr signature mechanism. For instance, for the reset attack, if two signatures are obtained for the same randomness in case of Pseudonymous Signature (Algorithm 6), then the secrets $(x_{i,1}, x_{i,2})$ can be computed as

$$x_{i,1} \leftarrow (s_1 - s'_1)/(c - c') \bmod p, \quad x_{i,2} \leftarrow (s_2 - s'_2)/(c - c') \bmod p.$$

For the SDH scheme from Algorithm 10, the secrets (u_i, x_i) can be computed as

$$u_i \leftarrow (s_u - s'_u)/(c - c') \bmod p, \quad x_i \leftarrow (s_x - s'_x)/(c - c') \bmod p.$$

Note that the secret value A_i is not revealed in this way; however, the same R could be used in subsequent forgery attacks.

9.2.2 Countermeasures

The simplest protection mechanism might be to eliminate all pseudorandom values and create a fully deterministic domain signature scheme. However, no scheme presented so far follows this strategy. Moreover, one has to ensure that the device cannot add any value of nonzero entropy to the message to be signed (such as, for instance, signature creation time). Indeed, these values can be used to create a fingerprint or to leak key bits in the way described above.

Threat Model

For the rest of this section, we assume that the signing device communicates only with a computer (PC) of the user. We do not assume that PC is secure; however, we do assume that either PC or the signing device can be attacked by an adversary, but not both at the same time. In this scenario, PC can monitor the activities of the device and serve as a semi-trusted watchdog trying either to detect an attack or to dismantle any hidden channel between the device and the adversary.

Verifiable Semi-deterministic Randomness

According to this approach [12], the user holds a special secret u and an additional public value $U = g^u$. U has to be installed in the device by the user. Then, the Schnorr signatures for the domain signature scheme are created according to the following modified procedure: Whenever an ephemeral k is to be used, it is computed in a special way as given below:

- Device first selects k_1 at random, then it derives $k_2 \leftarrow \mathcal{H}(U^{k_1}, i)$, increments the signature counter $i \leftarrow i + 1$, and computes a signature parameter $r_1 \leftarrow g^{k_1}$, $r \leftarrow g^{k_1 k_2}$.
- In the following steps of the signature creation, the value $k = k_1 \cdot k_2 \bmod p$ is used.
- Apart from r (which can be given implicitly), the output of the device contains also control data r_1, i . User can verify if the signature was properly created by checking: $k_2 \leftarrow \mathcal{H}(r_1^u, i)$, and $r \stackrel{?}{=} r_1^{k_2}$.

This approach may prevent a full-scale leakage of the signing keys, provided that the adversary (or malicious hardware of the device) can neither stop the counter updates (the counter can be implemented fully in hardware) nor guess the value U uploaded by the user [12]. However, it does not protect against a narrow-channel leakage used for placing footprints observable by the adversary.

Multiparty Computation

Another idea is to deploy a signing device composed of two independent parts (coming from different sources) and collectively creating a signature. For instance, the Pseudonymous Signature scheme from Algorithm 6 might be modified in the following way:

1. First device U , holding a partial signing key $(x_{1,u}, x_{2,u})$, computes

$$\begin{aligned} Q_u &\leftarrow g^{k_{1,u}} \cdot g_2^{k_{2,u}}, & A_{1,u} &\leftarrow \text{dPK}^{k_{1,u}}, & A_{2,u} &\leftarrow \text{dPK}^{k_{2,u}}, \\ I_{1,u} &\leftarrow \text{dPK}^{x_{1,u}}, & I_{2,u} &\leftarrow \text{dPK}^{x_{2,u}} \end{aligned}$$

and sends $Q_u, A_{1,u}, A_{2,u}, I_{1,u}, I_{2,u}$ to PC.

2. Analogously, the second device T holding a partial signing key $(x_{1,t}, x_{2,t})$ computes

$$\begin{aligned} Q_t &\leftarrow g^{k_{1,t}} \cdot g_2^{k_{2,t}}, & A_{1,t} &\leftarrow \text{dPK}^{k_{1,t}}, & A_{2,t} &\leftarrow \text{dPK}^{k_{2,t}}, \\ I_{1,t} &\leftarrow \text{dPK}^{x_{1,t}}, & I_{2,t} &\leftarrow \text{dPK}^{x_{2,t}} \end{aligned}$$

and sends $Q_t, A_{1,t}, A_{2,t}, I_{1,t}, I_{2,t}$ to PC.

3. The PC computes

$$\begin{aligned} Q &\leftarrow Q_u \cdot Q_t, & A_1 &\leftarrow A_{1,u} \cdot A_{1,t}, & A_2 &\leftarrow A_{2,u} \cdot A_{2,t}, \\ I_1 &\leftarrow I_{1,u} \cdot I_{1,t}, & I_2 &\leftarrow I_{2,u} \cdot I_{2,t} \end{aligned}$$

and sends them to the devices U and T .

4. Both devices compute $c \leftarrow \mathcal{H}(Q, I_1, A_1, I_2, A_2, \text{dPK}, m)$.
5. Device T computes

$$s_{1,t} \leftarrow k_{1,t} + x_{1,t}c \bmod p, \quad s_{2,t} \leftarrow k_{2,t} + x_{2,t}c \bmod p$$

and sends $c, s_{1,t}, s_{2,t}$ to the PC.

6. Analogously, device U computes

$$s_{1,u} \leftarrow k_{1,u} + x_{1,u}c \bmod p, \quad s_{2,u} \leftarrow k_{2,u} + x_{2,u}c \bmod p$$

and sends $c, s_{1,u}, s_{2,u}$ to the PC.

7. PC completes the signature creation by computing

$$s_1 \leftarrow s_{1,t} + s_{1,u} \bmod p, \quad s_2 \leftarrow s_{2,t} + s_{2,u} \bmod p.$$

The resulting signature (c, s_1, s_2) is verifiable with the domain pseudonyms I_1, I_2 .

In the above scheme each device may attempt to create a hidden channel to the adversary; however, the values of one device are blinded by the values of the other device.

Modification of Random Parameters

In the following example, PC provides updates to the random values chosen by the device and thereby destroys the hidden channels that may be created by a malicious device. The example is again based on the Pseudonymous Signature scheme as given below:

1. PC chooses values k'_1, k'_2 in a way (to some degree) unpredictable for the device. It computes

$$A'_1 \leftarrow \text{dPK}^{k'_1}, \quad A'_2 \leftarrow \text{dPK}^{k'_2}, \quad Q' \leftarrow g^{k'_1} g^{k'_2}$$

and sends a commitment to (A'_1, A'_2, Q') to the device.

2. Device computes

$$A''_1 \leftarrow \text{dPK}^{k_1}, \quad A''_2 \leftarrow \text{dPK}^{k_2}, \quad Q'' \leftarrow g^{k_1} g^{k_2}$$

for randomly chosen k_1, k_2 and sends A''_1, A''_2, Q'' to the PC.

3. PC reveals (A'_1, A'_2, Q') to the device.
4. Device computes

$$\begin{aligned} Q &\leftarrow Q' \cdot Q'', \quad A_1 \leftarrow A'_1 \cdot A''_1, \quad A_2 \leftarrow A'_2 \cdot A''_2, \\ c &\leftarrow \mathcal{H}(Q, I_1, A_1, I_2, A_2, \text{dPK}, m) \\ s''_1 &\leftarrow k_1 + x_1 \cdot c \bmod p, \quad s''_2 \leftarrow k_2 + x_2 \cdot c \bmod p \end{aligned}$$

and sends c, s''_1, s''_2 to the PC.

5. PC finalizes the signature by computing

$$s_1 \leftarrow k'_1 + s''_1 \bmod p, \quad s_2 \leftarrow k'_2 + s''_2 \bmod p.$$

6. PC verifies the resulting signature (c, s_1, s_2) . Additionally, it checks that the values A_1, A_2, Q reconstructed during the verification procedure satisfy the equalities

$$Q = Q' \cdot Q'', \quad A_1 = A'_1 \cdot A''_1, \quad A_2 = A'_2 \cdot A''_2.$$

Note that in the above solution the device has to determine the values k''_1, k''_2 before it learns the offsets k'_1 and k'_2 . Therefore, it has no chance to choose them so that $k''_1 + k'_1, k''_2 + k'_2$ have any chosen property or belong to a certain range. Consequently, it is impossible to encode any information in A_1, A_2, Q as the rest of the computation is deterministic. The only plausible method would be to abandon the

computation, as described above in the paragraph on leakage mechanisms. However, such a behavior would be immediately observed by PC and consequently the device should be regarded as malicious.

Note that PC has to choose its values k'_1, k'_2 before starting interaction with the device. Moreover, it must know k'_1, k'_2 , as otherwise it would not be able to finalize the signature and compute correct s_1, s_2 . Therefore, it is easy to see that any attack of PC against the device could be converted to an attack against the original scheme.

Acknowledgements This research was supported by the National Science Centre (Poland) under grant OPUS no 2014/15/B/ST6/02837.

References

1. Alwen, J., Dodis, Y., & Wichs, D. (2009). Leakage-resilient public-key cryptography in the bounded-retrieval model. In S. Halevi (ed.), *Advances in Cryptology - CRYPTO 2009: 29th Annual International Cryptology Conference, Santa Barbara, CA, USA, 16–20 August 2009. Proceedings* (pp. 36–54). Berlin: Springer. https://doi.org/10.1007/978-3-642-03356-8_3.
2. Bellare, M., Fischlin, M., Goldwasser, S., & Micali, S. (2001). Identification protocols secure against reset attacks. In B. Pfitzmann (ed.), *Advances in Cryptology — EUROCRYPT 2001: International Conference on the Theory and Application of Cryptographic Techniques Innsbruck, Austria, 6–10 May 2001, Proceedings* (pp. 495–511). Berlin: Springer. https://doi.org/10.1007/3-540-44987-6_30.
3. Boneh, D., & Boyen, X. (2008). Short signatures without random oracles and the SDH assumption in bilinear groups. *Journal of Cryptology*, 21(2), 149–177. <https://doi.org/10.1007/s00145-007-9005-7>.
4. Bringer, J., Chabanne, H., Lescuyer, R., & Patey, A. (2014). Efficient and strongly secure dynamic domain-specific pseudonymous signatures for ID documents. *IACR Cryptology ePrint Archive*, 2014, 67. <http://eprint.iacr.org/2014/067>.
5. BSI: Technical guideline TR-03110 v2.21 – advanced security mechanisms for machine readable travel documents and eIDAS token (2016). <https://www.bsi.bund.de/EN/Publications/TechnicalGuidelines/TR03110/BSITR03110.html>.
6. Camenisch, J., & Lehmann, A. (2017). Privacy for distributed databases via (un) linkable pseudonyms. *IACR Cryptology ePrint Archive*, 2017, 22.
7. Camenisch, J., & Lysyanskaya, A. (2004). Signature schemes and anonymous credentials from bilinear maps. In *Annual International Cryptology Conference* (pp. 56–72). Berlin: Springer.
8. Canetti, R., Goldreich, O., Goldwasser, S., & Micali, S. (2000). Resettable zero-knowledge (extended abstract). In *Proceedings of the Thirty-Second Annual ACM Symposium on Theory of Computing, STOC'00* (pp. 235–244). New York: ACM. <https://doi.org/10.1145/335305.335334>.
9. Chen, L., & Li, J. (2010). Revocation of direct anonymous attestation. In L. Chen & M. Yung (eds.), *Trusted Systems: Second International Conference, INTRUST 2010, Beijing, China, 13–15 December 2010, Revised Selected Papers* (pp. 128–147). Berlin: Springer. https://doi.org/10.1007/978-3-642-25283-9_9.
10. Cramer, R., & Shoup, V. (1998). A practical public key cryptosystem provably secure against adaptive chosen ciphertext attack. In H. Krawczyk (ed.), *Advances in Cryptology - CRYPTO'98, 18th Annual International Cryptology Conference, Santa Barbara, California, USA, 23–27 August 1998, Proceedings* (Vol. 1462, pp. 13–25). Lecture Notes in Computer Science. Berlin: Springer. <https://doi.org/10.1007/BFb0055717>.
11. Dolev, S., & Lodha, S. (eds.), *Cyber Security Cryptography and Machine Learning - First International Conference, CSCML 2017, Beer-Sheva, Israel, 29–30 June 2017, Proceedings*

- (Vol. 10332). Lecture Notes in Computer Science. Berlin: Springer. <https://doi.org/10.1007/978-3-319-60080-2>.
12. Hanzlik, L., Kluczniak, K., & Kutyłowski, M. (2016). Controlled randomness - a defense against backdoors in cryptographic devices. In R.C. Phan & M. Yung (eds.), *Paradigms in Cryptology - Mycrypt 2016. Malicious and Exploratory Cryptology - Second International Conference, Mycrypt 2016, Kuala Lumpur, Malaysia, 1–2 December 2016*, Revised Selected Papers (Vol. 10311, pp. 215–232). Lecture Notes in Computer Science. Berlin: Springer. https://doi.org/10.1007/978-3-319-61273-7_11.
 13. Hanzlik, L., Kluczniak, K., Kutyłowski, M., & Dolev, S. (2016). Local self-organization with strong privacy protection. In *Trustcom/BigDataSE/ISPA, 2016 IEEE* (pp. 775–782). IEEE.
 14. Klonowski, M., Kutyłowski, M., Lauks, A., & Zagórski, F. (2005). Conditional digital signatures. In S.K. Katsikas, J. Lopez, & G. Pernul (eds.), *Trust, Privacy and Security in Digital Business: Second International Conference, TrustBus 2005, Copenhagen, Denmark, 22–26 August 2005, Proceedings* (Vol. 3592, pp. 206–215). Lecture Notes in Computer Science. Berlin: Springer. https://doi.org/10.1007/11537878_21.
 15. Kluczniak, K. (2015). Anonymous authentication using electronic identity documents. Ph.D thesis. Institute of Computer Science, Polish Academy of Sciences.
 16. Kluczniak, K., Hanzlik, L., & Kutyłowski, M. (2016). A formal concept of domain pseudonymous signatures. In F. Bao, L. Chen, R.H. Deng, & G. Wang (eds.), *Information Security Practice and Experience - 12th International Conference, ISPEC 2016, Zhangjiajie, China, 16–18 November 2016, Proceedings* (Vol. 10060, pp. 238–254). Lecture Notes in Computer Science. https://doi.org/10.1007/978-3-319-49151-6_17.
 17. Kluczniak, K., Wang, J., Chen, X., & Kutyłowski, M. (2016). Multi-device anonymous authentication. In J. Chen, V. Piuri, C. Su, & M. Yung (eds.), *Network and System Security - 10th International Conference, NSS 2016, Taipei, Taiwan, 28–30 September 2016, Proceedings* (Vol. 9955, pp. 21–36). Lecture Notes in Computer Science. Berlin: Springer. https://doi.org/10.1007/978-3-319-46298-1_2.
 18. Krzywiecki, Ł. (2016). Schnorr-like identification scheme resistant to malicious subliminal setting of ephemeral secret. In I. Bica & R. Reyhanitabar (eds.), *Innovative Security Solutions for Information Technology and Communications - 9th International Conference, SECITC 2016, Bucharest, Romania, 9–10 June 2016*, Revised Selected Papers (Vol. 10006, pp. 137–148). Lecture Notes in Computer Science. https://doi.org/10.1007/978-3-319-47238-6_10.
 19. Krzywiecki, Ł., & Kutyłowski, M. (2017). Security of Okamoto identification scheme: A defense against ephemeral key leakage and setup. In C. Wang & M. Kantarcioglu (eds.), *Proceedings of the Fifth ACM International Workshop on Security in Cloud Computing, SCC@AsiaCCS 2017, Abu Dhabi, United Arab Emirates, 2 April 2017* (pp. 43–50). ACM. <https://doi.org/10.1145/3055259.3055267>.
 20. Kutyłowski, M., Hanzlik, L., & Kluczniak, K. (2016). Pseudonymous signature on eIDAS token - implementation based privacy threats. In J.K. Liu & R. Steinfeld (eds.), *Information Security and Privacy - 21st Australasian Conference, ACISP 2016, Melbourne, VIC, Australia, 4–6 July 2016, Proceedings, Part II* (vol. 9723, pp. 467–477). Lecture Notes in Computer Science. Berlin: Springer. https://doi.org/10.1007/978-3-319-40367-0_31.
 21. Lysyanskaya, A., Rivest, R.L., Sahai, A., & Wolf, S. (1999). Pseudonym systems. In H.M. Heys & C.M. Adams (eds.), *Selected Areas in Cryptography, 6th Annual International Workshop, SAC'99, Kingston, Ontario, Canada, 9–10 August 1999, Proceedings* (Vol. 1758, pp. 184–199). Lecture Notes in Computer Science. Berlin: Springer. https://doi.org/10.1007/3-540-46513-8_14.
 22. Patey, A. (2014). Techniques cryptographiques pour l'authentification et l'identification biométriques respectant la vie privée (Cryptographic techniques for privacy-preserving biometric authentication and identification). Ph.D. thesis. TELECOM ParisTech.
 23. Pointcheval, D., & Sanders, O. (2016) Short randomizable signatures. In *Cryptographers Track at the RSA Conference* (pp. 111–126). Berlin: Springer.
 24. Slowik, M., & Wszola, M. (2017). An efficient verification of CL-LRSW signatures and a pseudonym certificate system. In *Proceedings of the 4th ACM International Workshop on*

- ASIA Public-Key Cryptography, APKC'17* (pp. 13–23). New York: ACM. <https://doi.org/10.1145/3055504.3055506>.
25. The European Parliament and the Council of the European Union: Regulation (EU) No 910/2014 of the European Parliament and of the Council of 23 July 2014 on electronic identification and trust services for electronic transactions in the internal market and repealing Directive 1999/93/EC (2014). http://eur-lex.europa.eu/legal-content/EN/TXT/?uri=uriserv:OJ.L_.2014.257.01.0073.01.ENG.
 26. The European Parliament and the Council of the European Union: Regulation (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/ec (General Data Protection Regulation) (2016). *Official Journal of the European Union*, 119(1).
 27. Thomas, K., Li, F., Zand, A., Barrett, J., Ranieri, J., Invernizzi, L., et al. (2017). Data breaches, phishing, or malware?: Understanding the risks of stolen credentials. In *Proceedings of the 2017 ACM SIGSAC Conference on Computer and Communications Security* (pp. 1421–1434). Providence: ACM.
 28. Young, A.L., & Yung, M. (2004). *Malicious cryptography - exposing cryptovirology*. New York: Wiley.